

HCIA-Security V3.0

Comprehensive Exam Preparation Guide

Master Question Bank with In-Depth Conceptual Rationale

Complete 1,050-Question Examination Syllabus

Target Certification:	Huawei Certified ICT Associate – Security (Exam H12-711)
Curriculum Alignment:	HCIA-Security V3.0 (11 Comprehensive Chapters)
Total Question Volume:	1,050 Fully Annotated Questions
Part 1 (Single Choice):	420 Questions (Q1 – Q420)
Part 2 (Multiple Choice):	320 Questions (Q421 – Q740)
Part 3 (True / False):	310 Questions (Q741 – Q1050)
Feature Highlight:	Complete Conceptual Explanation for Every Single Question
Quick Reference:	Unified Master Answer Key Matrix

Curriculum Coverage: Network Security Concepts · Network Basics · Common Network Threats · Firewall Architecture & State Inspection · Security Policies & NAT · Dual-System Hot Standby (VRRP & VGMP) · AAA & User Authentication · Intrusion Prevention (IPS) · Cryptography Foundations · PKI Certificates · VPN Technologies (IPsec, IKEv1/v2, L2TP, SSL VPN)

Contents

HCIA-Security V3.0 Exam Blueprint & Question Distribution	3
I Single-Answer Questions (Q1 – Q420)	4
1 Chapter 1: Network Security Concepts and Specifications	4
2 Chapter 2: Network Basics	14
3 Chapter 3: Common Network Security Threats and Threat Prevention	26
4 Chapter 4: Firewall Security Policies	37
5 Chapter 5: Firewall NAT Technologies	49
6 Chapter 6: Firewall Hot Standby Technologies	62
7 Chapter 7: Firewall IPS	73
8 Chapter 8: Firewall User Management Technologies	85
9 Chapter 9: Fundamentals of Encryption and Decryption Technologies	97
10 Chapter 10: PKI Certificate System	107
11 Chapter 11: Encryption Technology Applications (IPsec & SSL VPN)	117
II Multiple-Answer Questions (Q421 – Q740)	130
12 Chapter 1: Network Security Concepts and Specifications	130
13 Chapter 2: Network Basics	138
14 Chapter 3: Common Network Security Threats and Threat Prevention	148
15 Chapter 4: Firewall Security Policies	156
16 Chapter 5: Firewall NAT Technologies	165
17 Chapter 6: Firewall Hot Standby Technologies	174
18 Chapter 7: Firewall IPS	183
19 Chapter 8: Firewall User Management Technologies	191
20 Chapter 9: Fundamentals of Encryption and Decryption Technologies	199
21 Chapter 10: PKI Certificate System	206
22 Chapter 11: Encryption Technology Applications (IPsec & SSL VPN)	214
III True / False Questions (Q741 – Q1050)	224
23 Chapter 1: Network Security Concepts and Specifications	224
24 Chapter 2: Network Basics	230
25 Chapter 3: Common Network Security Threats and Threat Prevention	238

26 Chapter 4: Firewall Security Policies	244
27 Chapter 5: Firewall NAT Technologies	251
28 Chapter 6: Firewall Hot Standby Technologies	259
29 Chapter 7: Firewall IPS	265
30 Chapter 8: Firewall User Management Technologies	272
31 Chapter 9: Fundamentals of Encryption and Decryption Technologies	279
32 Chapter 10: PKI Certificate System	285
33 Chapter 11: Encryption Technology Applications (IPsec & SSL VPN)	291
IV Complete Answer Key & Quick Reference	299

HCIA-Security V3.0 Exam Blueprint & Question Distribution

The Huawei Certified ICT Associate in Security (**HCIA-Security V3.0**, Exam Code: **H12-711**) validates that engineers possess foundational knowledge of enterprise network security architectures, Huawei firewall technologies, AAA user authentication, intrusion prevention, cryptographic principles, and VPN deployment. The examination consists of Single-Choice, Multiple-Choice, and True/False questions with a passing threshold of 600 out of 1000 points.

This comprehensive question bank comprises **1,050 fully annotated questions** systematically organized into three distinct parts, spanning all 11 curriculum modules:

Ch.	Chapter Curriculum Topic	Single (Pt 1)	Multi (Pt 2)	T/F (Pt 3)	Total Questions
1	Network Security Concepts and Specifications	36	26	26	88
2	Network Basics	44	34	32	110
3	Common Network Security Threats and Threat Prevention	36	28	26	90
4	Firewall Overview and Working Principles	40	30	30	100
5	Firewall Security Policy and NAT Technology	42	32	30	104
6	Firewall High Availability (VRRP & VGMP)	38	30	28	96
7	User Management and AAA Technology	38	30	28	96
8	Intrusion Prevention System (IPS) and Defense	38	28	28	94
9	Cryptography Foundations and Encryption Technology	34	26	25	85
10	PKI Certificate System and Applications	34	26	25	85
11	Encryption Technology Applications (IPsec & SSL VPN)	40	30	32	102
–	Total Questions Across Curriculum	420	320	310	1050

Structure of Each Question Entry:

- **Question Card:** Features the unique question number (QID), category accent color, specific syllabus topic tag, question stem, and standardized options (A, B, C, D).
- **Explanation Box:** Immediately follows each question card with the verified correct answer in the header, followed by an in-depth conceptual explanation elucidating *why* the correct option is right, why distractors are incorrect, and the core Huawei HCIA-Security principle at work.
- **Quick Answer Key:** Appendix at the end of the volume featuring compact reference matrices for rapid self-assessment and mock exam scoring.

PART I

Single-Answer Questions (Q1 – Q420)

1 Chapter 1: Network Security Concepts and Specifications

Question 1

Topic: CIA - Confidentiality

Type: Single Choice

Which security attribute ensures that sensitive information is not disclosed to unauthorized entities or eavesdropped during transmission?

- A. Integrity
- B. Confidentiality
- C. Availability
- D. Non-repudiation

Correct Answer: B

Concept & Rationale: Confidentiality ensures that information can be accessed and viewed only by authorized personnel. Cryptographic encryption is the primary mechanism to enforce confidentiality across untrusted networks.

Question 2

Topic: CIA - Integrity

Type: Single Choice

Which security property guarantees that transmitted data has not been altered, deleted, or forged in transit?

- A. Availability
- B. Integrity
- C. Confidentiality
- D. Authenticity

Correct Answer: B

Concept & Rationale: Integrity guarantees that data has not been tampered with or modified during transit or storage. Cryptographic hash functions (such as SHA-256) and message authentication codes are primary mechanisms to verify integrity.

Question 3

Topic: CIA - Availability

Type: Single Choice

An enterprise web service is taken down by a volumetric SYN flood attack, preventing legitimate clients from accessing their accounts. Which principle of the CIA triad has been violated?

- A. Confidentiality
- B. Integrity
- C. Availability
- D. Controllability

Correct Answer: C

Concept & Rationale: Availability ensures that authorized users have prompt and reliable access to information assets and network services. DoS/DDoS attacks specifically target availability by exhausting network bandwidth or server compute resources.

Question 4

Topic: Security Era - 1940s

Type: Single Choice

In the evolution of information security, what was the primary characteristic of the 'Communication Security' era during the 1940s?

- A. Focus on cyberspace sovereignty and IoT devices
- B. Protection was primarily confined to physical security and cipher-based transmission (mainly stream ciphers)
- C. Emphasis on multi-dimensional active defense and SIEM orchestration
- D. Standardization of enterprise security architectures such as ISO 27001

Correct Answer: B

Concept & Rationale: During the 1940s Communication Security era, communication technologies were underdeveloped. Information security focused on physical security and point-to-point cipher transmission (primarily stream ciphers) to protect confidential military and diplomatic telegrams.

Question 5

Topic: Security Era - 1990s

Type: Single Choice

During the 1990s Information Assurance period, which two new security principles were emphasized alongside the traditional CIA triad?

- A. Simplicity and Scalability
- B. Controllability and Non-repudiation
- C. Virtualization and Micro-segmentation
- D. Resilience and Fault-tolerance

Correct Answer: B

Concept & Rationale: In the 1990s Information Assurance era, as the Internet expanded rapidly, Controllability (ability to monitor and control information systems) and Non-repudiation (inability to deny transmitted actions/data) joined the CIA triad to form the five core security principles.

Question 6

Topic: Non-repudiation Mechanism

Type: Single Choice

Which cryptographic technology is primarily utilized to provide non-repudiation in electronic transactions?

- A. Symmetric block ciphers like AES-256
- B. Pre-shared keys (PSK)
- C. Digital signatures using asymmetric private keys
- D. Stream ciphers like RC4

Correct Answer: C

Concept & Rationale: Non-repudiation prevents a sender from denying having sent a message. It is achieved through digital signatures, where only the sender possesses the unique private key required to generate the signature.

Question 7

Topic: ISO Standards - ISO 27001

Type: Single Choice

Which of the following standards specifies requirements for establishing, implementing, maintaining, and continually improving an Information Security Management System (ISMS) and is used for organizational certification?

- A. ISO/IEC 27002
- B. ISO/IEC 27001
- C. ISO/IEC 27005
- D. RFC 1918

Correct Answer: B

Concept & Rationale: ISO/IEC 27001 provides the formal normative specification for an enterprise Information Security Management System (ISMS) and serves as the certification benchmark. ISO 27002 provides guidance and codes of practice for implementing security controls.

Question 8

Topic: ISO Standards - ISO 27002

Type: Single Choice

What is the primary role of ISO/IEC 27002 within the ISO 27000 series?

- A. A formal audit standard against which an enterprise receives an accredited certificate
- B. A code of practice containing reference control objectives and actionable security controls
- C. A hardware encryption standard for high-speed fiber communications
- D. A regulatory framework for national critical infrastructure penal sanctions

Correct Answer: B

Concept & Rationale: ISO/IEC 27002 provides a comprehensive code of practice and implementation guidelines for information security controls, helping organizations select and implement controls defined in Annex A of ISO 27001.

Question 9

Topic: Classified Protection - Levels Count

Type: Single Choice

Under Cybersecurity Classified Protection 2.0 (China's National Standard MLPS 2.0), how many security protection levels are defined?

- A. Three levels
- B. Four levels
- C. Five levels
- D. Seven levels

Correct Answer: C

Concept & Rationale: Classified Protection 2.0 defines five security levels: Level 1 (User Autonomy), Level 2 (System Audit), Level 3 (Supervised Protection), Level 4 (Mandatory Protection), and Level 5 (Special Control Protection).

Question 10

Topic: Classified Protection - Level 3 Impact

Type: Single Choice

In Classified Protection 2.0, Level 3 protection applies to information systems whose compromise would cause which severity of impact?

- A. Slight harm to legitimate rights of citizens, but no harm to social order or public interest
- B. Serious harm to social order and public interest, or harm to national security
- C. Extremely serious harm to national security directly causing collapse of state governance
- D. General harm to enterprise profitability without any public impact

Correct Answer: B

Concept & Rationale: Level 3 (Supervised Protection) applies to critical networks where security incidents cause serious harm to social order and public interests, or significant harm to national security. Most government and financial online systems require Level 3 compliance.

Question 11

Topic: TCSEC - Highest Division

Type: Single Choice

In the Trusted Computer System Evaluation Criteria (TCSEC, Orange Book), which division represents the highest level of security evaluation?

- A. Division D
- B. Division C
- C. Division B
- D. Division A

Correct Answer: D

Concept & Rationale: TCSEC categorizes systems into four divisions: D (Minimal protection), C (Discretionary protection: C1, C2), B (Mandatory protection: B1, B2, B3), and A (Verified protection: A1), where Division A is the highest verified security level.

Question 12

Topic: TCSEC - Class C2

Type: Single Choice

Which TCSEC division and class introduced individual user identification and auditing requirements (Discretionary Access Control)?

- A. Class D
- B. Class C2
- C. Class B2
- D. Class A1

Correct Answer: B

Concept & Rationale: Class C2 (Controlled Access Protection) enforces individual login accountability, discretionary access control (DAC), and comprehensive audit trail logging, making it the historical baseline for commercial operating systems.

Question 13

Topic: APT Characteristics

Type: Single Choice

Which of the following is a prominent characteristic of an Advanced Persistent Threat (APT)?

- A. Uncoordinated, short-duration high-volume automated ping sweeps
- B. Highly organized, stealthy, customized, and persistent attack targeting high-value assets over an extended period
- C. Purely accidental misconfigurations caused by novice network operators
- D. Public Wi-Fi packet sniffing without target selection

Correct Answer: B

Concept & Rationale: An APT is characterized by advanced attack techniques, persistent reconnaissance, stealthy lateral movement, and evasion of conventional defenses, sustained over long durations to extract intellectual property or sabotage operations.

Question 14

Topic: Zero Trust Philosophy

Type: Single Choice

What is the foundational philosophy of the Zero Trust security model?

- A. Trust internal network traffic by default; inspect only perimeter traffic
- B. Never trust, always verify; inspect and authenticate every request regardless of network location
- C. Rely solely on hardware border firewalls to defend the trusted core
- D. Grant unrestricted administrative privileges once user identity is validated at login

Correct Answer: B

Concept & Rationale: Zero Trust operates under the tenet 'Never Trust, Always Verify'. It assumes breaches are inevitable, eliminating implicit trust based on network locality and requiring continuous verification of identity, device, and context.

Question 15

Topic: SDP Connectivity

Type: Single Choice

In a Software-Defined Perimeter (SDP) framework, how is network connectivity established?

- A. Servers broadcast their IP and open ports publicly to allow direct client discovery
- B. The infrastructure remains invisible ('dark') until an SDP controller validates user and device identity
- C. Static security policies are permanently mapped to physical switch ports
- D. All communications bypass encryption to accelerate line-rate throughput

Correct Answer: B

Concept & Rationale: SDP follows a 'Need-to-Know' paradigm where protected servers and services remain invisible behind Gateways. Connectivity is dynamically granted only after the centralized SDP Controller verifies client identity and device posture.

Question 16

Topic: Cybersecurity Legislation

Type: Single Choice

What is the primary objective of national cybersecurity laws and data security regulations?

- A. To eliminate the need for enterprise firewalls and antivirus software
- B. To safeguard cyberspace sovereignty, national security, public interest, and lawful citizen data rights
- C. To mandate that all enterprise networks use unencrypted communication protocols
- D. To replace internal enterprise security audits with foreign third-party certification

Correct Answer: B

Concept & Rationale: National cybersecurity regulations establish statutory obligations for network operators to protect critical infrastructure, maintain operational continuity, prevent cybercrimes, and protect citizens' personal privacy.

Question 17

Topic: Social Engineering - Phishing

Type: Single Choice

An attacker posing as an IT support engineer contacts an employee to obtain their domain credentials under the guise of an urgent security upgrade. What attack type is this?

- A. Port scanning
- B. Smurf attack
- C. Social engineering / Phishing
- D. Buffer overflow

Correct Answer: C

Concept & Rationale: Social engineering exploits human psychology rather than software vulnerabilities. Attackers use impersonation, pretexts, urgency, or deception to trick authorized personnel into disclosing credentials or sensitive data.

Question 18**Topic:** Defense in Depth**Type:** Single Choice

What is the fundamental benefit of implementing a 'Defense-in-Depth' architecture?

- A. It guarantees 100% immunity against zero-day malware without software updates
- B. If a single defensive mechanism fails, multiple subsequent layers continue to protect critical assets
- C. It eliminates the need for user authentication and authorization
- D. It consolidates all security functions onto a single border router

Correct Answer: B

Concept & Rationale: Defense-in-Depth deploys multiple overlapping security controls across physical, perimeter, network, host, application, and data tiers, ensuring that compromise of any single layer does not compromise the entire enterprise.

Question 19**Topic:** PDCA Cycle**Type:** Single Choice

Which sequence correctly describes the continuous improvement lifecycle for enterprise security management?

- A. Execute -> Terminate -> Delete -> Ignore
- B. Plan -> Do -> Check -> Act (PDCA)
- C. Attack -> Defend -> Forget -> Re-install
- D. Inspect -> Block -> Allow -> Reset

Correct Answer: B

Concept & Rationale: The PDCA (Plan-Do-Check-Act) Deming cycle is the standard management framework adopted by ISO 27001 for establishing, maintaining, and continually optimizing organizational information security policies.

Question 20**Topic:** Classified Protection - Tech Domains**Type:** Single Choice

Which of the following is NOT one of the four general technical requirement domains in Classified Protection 2.0?

- A. Physical and Environmental Security
- B. Network and Communication Security
- C. Equipment and Computing Security
- D. Marketing and Public Relations Security

Correct Answer: D

Concept & Rationale: The four core technical requirement areas in Classified Protection 2.0 are: Physical and Environmental Security, Network and Communication Security, Equipment and Computing Security, and Application and Data Security.

Question 21

Topic: Classified Protection - Management Domains

Type: Single Choice

Which of the following belongs to the general security management requirements in Classified Protection 2.0?

- A. Security Management System, Organization, Personnel, Construction, and Operation
- B. Hardware BIOS Flashing and CPU Overclocking
- C. External Advertising and Social Media Marketing
- D. Quarterly Revenue Reporting and Tax Filing

Correct Answer: A

Concept & Rationale: The five management requirement domains under Classified Protection 2.0 comprise: Security Management System, Security Management Organization, Security Management Personnel, Security Construction Management, and Security Operation Management.

Question 22

Topic: Security Intelligence Center

Type: Single Choice

What is the primary function of a Security Intelligence Center (such as Huawei Cloud Security Intelligence)?

- A. To remotely format local enterprise hard drives during high load
- B. To aggregate global threat feeds, analyze zero-day exploits, and distribute real-time signature updates
- C. To replace local enterprise network switches with software emulators
- D. To permanently assign public IPv4 addresses to unauthorized mobile devices

Correct Answer: B

Concept & Rationale: Security Intelligence Centers analyze global telemetry, malware binaries, and emerging exploits using big data analytics and AI, producing up-to-date threat feeds, IPS/AV signatures, and malicious IP/domain blacklists.

Question 23

Topic: Cyberspace Characteristics

Type: Single Choice

Why is cyberspace considered an artificial, man-made operational domain compared to land, sea, air, and space?

- A. It exists purely as a natural physical phenomenon without hardware
- B. It is built upon physical microelectronics, logical network protocols, and software created by human engineering
- C. It operates entirely without electrical power or telecommunication links
- D. It is governed solely by international maritime law

Correct Answer: B

Concept & Rationale: Cyberspace is an engineered domain consisting of physical network infrastructure, logical software architectures, and cognitive human interaction, making it inherently dynamic and constantly evolving.

Question 24

Topic: Controllability Definition

Type: Single Choice

Under the five-pillar information security framework, what does 'Controllability' refer to?

- A. Ensuring network bandwidth is throttled to 56 kbps at all times
- B. Controlling information dissemination and maintaining administrative authority over information systems
- C. Preventing any user from ever accessing external web servers
- D. Eliminating all logging and auditing mechanisms on border firewalls

Correct Answer: B

Concept & Rationale: Controllability ensures that security administrators can monitor, audit, and regulate the lifecycle, flow, content, and system access of information assets, preventing unauthorized operations and policy violations.

Question 25**Topic:** Ransomware Mechanism**Type:** Single Choice

What is the primary economic extortion technique utilized by modern ransomware families?

- A. Flooding target routers with ICMP echo requests until bandwidth saturation occurs
- B. Silently modifying website HTML source code to display jokes without data loss
- C. Encrypting critical organizational files with strong ciphers and demanding cryptocurrency for the private key
- D. Stealing physical server chassis from locked enterprise datacenter racks

Correct Answer: C

Concept & Rationale: Ransomware uses high-grade symmetric and asymmetric cryptographic algorithms (e.g., AES-256 + RSA-2048) to encrypt user data in place, coercing victims into paying ransoms to obtain the decryption key.

Question 26**Topic:** Vulnerability vs Exploit**Type:** Single Choice

What is the technical distinction between a 'Vulnerability' and an 'Exploit'?

- A. A vulnerability is malicious software code, whereas an exploit is a security standard
- B. A vulnerability is a defect/weakness in software or hardware; an exploit is code or technique used to take advantage of it
- C. A vulnerability only affects physical cables, while an exploit only affects web browsers
- D. There is no distinction; both terms are exact synonyms in network engineering

Correct Answer: B

Concept & Rationale: A vulnerability is a flaw, bug, or design weakness present in software, protocols, or firmware. An exploit is a crafted payload, tool, or sequence of commands specifically constructed to take advantage of that vulnerability.

Question 27**Topic:** Residual Risk**Type:** Single Choice

What is 'Residual Risk' in enterprise risk management?

- A. The initial risk measured before any security countermeasures are considered
- B. The remaining risk that persists after appropriate security controls have been implemented
- C. The risk that only affects obsolete hardware discarded in storage rooms
- D. Risk that has been 100% eliminated through cyber insurance

Correct Answer: B

Concept & Rationale: Residual risk is the remaining risk level after security controls, safeguards, and mitigation policies have been deployed. An organization must determine whether residual risk falls within its acceptable risk appetite.

Question 28

Topic: Security Awareness

Type: Single Choice

Why is regular security awareness training considered a critical component of enterprise security?

- A. It completely replaces the need for technical controls like firewalls and IPS
- B. Human errors and social engineering remain major attack vectors; user awareness mitigates phishing and policy violations
- C. It guarantees that network equipment will never experience hardware power outages
- D. It allows regular employees to rewrite firewall kernel code without supervision

Correct Answer: B

Concept & Rationale: Humans are frequently the weakest link in the security perimeter. Attackers leverage phishing and social engineering to bypass perimeter defenses; continuous training develops vigilance and adherence to security protocols.

Question 29

Topic: Asset Classification

Type: Single Choice

What is the first fundamental step in conducting an enterprise information security risk assessment?

- A. Purchasing the most expensive firewall available on the market
- B. Identifying and classifying organizational information assets based on business value and sensitivity
- C. Disabling all incoming and outgoing Internet traffic across all branch offices
- D. Assigning equal public administrative access to all internal and external users

Correct Answer: B

Concept & Rationale: Before risks can be assessed or mitigated, an organization must identify and catalog its critical assets (hardware, software, data, personnel) and categorize them according to confidentiality, integrity, and availability impact.

Question 30

Topic: Cyberspace Sovereignty

Type: Single Choice

How does the concept of national cyberspace sovereignty apply to digital communications?

- A. Nation-states have independent jurisdiction over network infrastructure, data, and cyber activities within their sovereign territory
- B. No government has the authority to regulate or protect domestic telecommunication systems
- C. All data packets traversing global fiber optics are owned exclusively by international software vendors
- D. Cyber activities are strictly exempt from domestic legal compliance

Correct Answer: A

Concept & Rationale: Cyberspace sovereignty reflects a state's independent jurisdiction and authority over its sovereign territory's cyber infrastructure, facilities, data governance, and legal accountability in cyberspace.

Question 31

Topic: Risk Transfer

Type: Single Choice

An enterprise decides to purchase cyber insurance to compensate for potential financial losses from data breaches. Which risk treatment strategy is being applied?

- A. Risk Avoidance
- B. Risk Mitigation
- C. Risk Transfer
- D. Risk Acceptance

Correct Answer: C

Concept & Rationale: Risk Transfer involves shifting financial liability or risk consequences to an external third party, commonly accomplished through cyber insurance policies or contractual outsourcing.

Question 32

Topic: Risk Acceptance

Type: Single Choice

When an organization formally decides to take no further action regarding an identified low-impact vulnerability because the cost of fixing it exceeds potential loss, this strategy is called:

- A. Risk Avoidance
- B. Risk Acceptance
- C. Risk Transfer
- D. Risk Exploitation

Correct Answer: B

Concept & Rationale: Risk Acceptance occurs when management formally acknowledges an identified risk and decides not to deploy countermeasures because the risk falls within acceptable tolerance or mitigation costs exceed the value of the asset.

Question 33

Topic: Defense in Depth - IAM

Type: Single Choice

In a multi-tier defense architecture, which security mechanism operates at the identity and access management layer?

- A. Fiber optic intrusion detection sensor
- B. Multi-Factor Authentication (MFA) and Least Privilege RBAC
- C. BGP Route Reflector filtering
- D. Shielded twisted pair copper grounding

Correct Answer: B

Concept & Rationale: Identity and Access Management (IAM) controls operate at the logical user tier, employing Multi-Factor Authentication (MFA), role-based access control (RBAC), and least privilege to enforce access boundaries.

Question 34

Topic: ISMS Purpose

Type: Single Choice

What is the core purpose of establishing an ISMS according to ISO 27001?

- A. To build a systematic, ongoing management framework that identifies, manages, and minimizes security risks to corporate data
- B. To replace all human employees with automated AI bots
- C. To mandate the exclusive use of proprietary networking hardware
- D. To produce marketing materials for social media advertising

Correct Answer: A

Concept & Rationale: An ISMS is a systematic framework comprising policies, processes, procedures, organizational structures, and software/hardware controls designed to manage and protect an organization's sensitive information assets.

Question 35**Topic:** TCSEC B1 Mandatory Access Control**Type:** Single Choice

What significant capability was introduced at the TCSEC Division B (specifically B1) level compared to Division C?

- A. Elimination of all password authentication mechanisms
- B. Mandatory Access Control (MAC) based on security labels and sensitivity levels
- C. Unrestricted file sharing across all military networks without classification
- D. Use of wireless Ethernet transmission without authentication

Correct Answer: B

Concept & Rationale: TCSEC Division B introduced Mandatory Access Control (MAC), where data objects and subjects carry formal security labels (e.g., Unclassified, Confidential, Secret, Top Secret), enforcing the Bell-LaPadula mathematical security model.

Question 36**Topic:** Physical Security Priority**Type:** Single Choice

Why does Classified Protection 2.0 list 'Physical and Environmental Security' as a mandatory technical domain?

- A. Because physical access to server hardware bypasses logical controls, allowing direct storage extraction or hardware compromise
- B. Because physical cables are immune to eavesdropping and environmental fire hazards
- C. Because physical security replaces the necessity of IP routing protocols
- D. Because server racks cannot operate unless painted in certified colors

Correct Answer: A

Concept & Rationale: Physical security is the bedrock of information assurance. If an adversary gains physical access to a server or network switch, logical controls (passwords, firewalls) can be circumvented via local console access, hardware implants, or direct drive extraction.

2 Chapter 2: Network Basics

Question 37**Topic:** OSI Model Layers**Type:** Single Choice

How many layers are defined in the Open Systems Interconnection (OSI) reference model?

- A. 4 layers
- B. 5 layers
- C. 7 layers
- D. 8 layers

Correct Answer: C

Concept & Rationale: The OSI reference model standardizes network communication into 7 distinct layers: Physical, Data Link, Network, Transport, Session, Presentation, and Application.

Question 38

Topic: OSI Layer 3 PDU

Type: Single Choice

What is the Protocol Data Unit (PDU) termed at Layer 3 (Network Layer) of the OSI model?

- A. Bit
- B. Frame
- C. Packet
- D. Segment

Correct Answer: C

Concept & Rationale: PDUs across OSI layers: Layer 1 = Bit; Layer 2 = Frame; Layer 3 = Packet; Layer 4 = Segment; Layers 5-7 = Data.

Question 39

Topic: OSI vs TCP/IP Mapping

Type: Single Choice

Which OSI layers are consolidated into the single Application layer in the 4-layer TCP/IP model?

- A. Physical and Data Link layers
- B. Data Link and Network layers
- C. Session, Presentation, and Application layers
- D. Transport and Session layers

Correct Answer: C

Concept & Rationale: The TCP/IP model merges the functions of OSI Layer 5 (Session), Layer 6 (Presentation), and Layer 7 (Application) into a single Application Layer.

Question 40

Topic: Ethernet Frame MAC Length

Type: Single Choice

In a standard Ethernet II frame, what is the length in bytes of the Destination MAC address field?

- A. 4 bytes
- B. 6 bytes
- C. 8 bytes
- D. 16 bytes

Correct Answer: B

Concept & Rationale: An Ethernet MAC address is 48 bits (6 bytes) long. An Ethernet II frame header contains a 6-byte Destination MAC followed by a 6-byte Source MAC and a 2-byte Type field.

Question 41

Topic: Ethernet EtherType IPv4

Type: Single Choice

What is the hexadecimal EtherType value indicating that the payload of an Ethernet II frame is an IPv4 packet?

- A. 0x0806
- B. 0x0800
- C. 0x86DD
- D. 0x8100

Correct Answer: B

Concept & Rationale: Standard EtherType values: 0x0800 indicates IPv4; 0x0806 indicates ARP; 0x86DD indicates IPv6; 0x8100 indicates an IEEE 802.1Q tagged frame.

Question 42

Topic: Ethernet EtherType ARP

Type: Single Choice

Which EtherType value indicates an Address Resolution Protocol (ARP) frame?

- A. 0x0800
- B. 0x0806
- C. 0x86DD
- D. 0x8847

Correct Answer: B**Concept & Rationale:** EtherType 0x0806 is assigned specifically to the Address Resolution Protocol (ARP).

Question 43

Topic: Ethernet MTU

Type: Single Choice

What is the standard default Maximum Transmission Unit (MTU) size for an Ethernet interface payload?

- A. 576 bytes
- B. 1480 bytes
- C. 1500 bytes
- D. 9000 bytes

Correct Answer: C**Concept & Rationale:** The standard default MTU for Ethernet is 1500 bytes. This defines the maximum size of the Layer 3 packet (IP header + payload) that can be encapsulated into an Ethernet frame without fragmentation.

Question 44

Topic: IPv4 Header Minimum Size

Type: Single Choice

What is the minimum length of an IPv4 packet header when no optional fields are present?

- A. 16 bytes
- B. 20 bytes
- C. 32 bytes
- D. 40 bytes

Correct Answer: B**Concept & Rationale:** The standard base IPv4 header with no options contains 5 rows of 32 bits (4 bytes) each, resulting in a minimum length of 20 bytes.

Question 45

Topic: IPv4 Header IHL Field

Type: Single Choice

In an IPv4 header, the Internet Header Length (IHL) field has a value of 5. How many total bytes does the IP header contain?

- A. 5 bytes
- B. 10 bytes
- C. 20 bytes
- D. 25 bytes

Correct Answer: C**Concept & Rationale:** The IHL field specifies the IP header length in 32-bit (4-byte) words. Therefore, an IHL of 5 represents $5 * 4 = 20$ bytes.

Question 46

Topic: IPv4 Header TTL Purpose

Type: Single Choice

What is the primary function of the Time to Live (TTL) field in an IPv4 header?

- A. To record the exact timestamp when the packet was created
- B. To prevent packets from circulating endlessly in routing loops
- C. To calculate the round-trip latency between source and destination hosts
- D. To negotiate the maximum TCP sliding window buffer size

Correct Answer: B

Concept & Rationale: The TTL field is decremented by 1 at each router hop. When TTL reaches 0, the packet is discarded and an ICMP Time Exceeded (Type 11) message is generated, preventing persistent routing loops.

Question 47

Topic: IPv4 Header Protocol TCP

Type: Single Choice

In the IPv4 header, what protocol value in the 'Protocol' field designates TCP?

- A. 1
- B. 6
- C. 17
- D. 47

Correct Answer: B

Concept & Rationale: Common IP Protocol numbers: 1 = ICMP; 6 = TCP; 17 = UDP; 47 = GRE; 50 = ESP; 51 = AH; 89 = OSPF.

Question 48

Topic: IPv4 Header Protocol UDP

Type: Single Choice

Which value in the IPv4 Protocol field identifies the payload as a User Datagram Protocol (UDP) segment?

- A. 6
- B. 17
- C. 1
- D. 88

Correct Answer: B

Concept & Rationale: Protocol number 17 designates UDP, while 6 designates TCP and 1 designates ICMP.

Question 49

Topic: IPv4 Header DF Flag

Type: Single Choice

Which flag in the IPv4 header instructs intermediate routers NOT to fragment the packet?

- A. MF (More Fragments)
- B. DF (Don't Fragment)
- C. URG (Urgent)
- D. SYN (Synchronize)

Correct Answer: B

Concept & Rationale: The DF (Don't Fragment) flag, when set to 1, instructs routers to drop the packet and send an ICMP Destination Unreachable (Fragmentation Needed, Type 3 Code 4) message if the packet exceeds the outgoing link's MTU.

Question 50

Topic: IPv4 RFC 1918 Private Ranges

Type: Single Choice

Which of the following IPv4 address blocks is designated as a private address space under RFC 1918?

- A. 100.64.0.0/10
- B. 172.16.0.0/12
- C. 192.0.2.0/24
- D. 169.254.0.0/16

Correct Answer: B

Concept & Rationale: RFC 1918 defines three private IPv4 address blocks: 10.0.0.0/8 (10.0.0.0 - 10.255.255.255), 172.16.0.0/12 (172.16.0.0 - 172.31.255.255), and 192.168.0.0/16 (192.168.0.0 - 192.168.255.255).

Question 51

Topic: IPv4 Class C Private Range

Type: Single Choice

What is the valid RFC 1918 private IPv4 range for Class C addresses?

- A. 10.0.0.0 - 10.255.255.255
- B. 172.16.0.0 - 172.31.255.255
- C. 192.168.0.0 - 192.168.255.255
- D. 192.168.1.0 - 192.168.1.255

Correct Answer: C

Concept & Rationale: The Class C private address space defined in RFC 1918 is 192.168.0.0/16, spanning from 192.168.0.0 to 192.168.255.255.

Question 52

Topic: IPv4 Loopback Address

Type: Single Choice

Which IPv4 address block is reserved by IANA for host internal loopback testing?

- A. 0.0.0.0/8
- B. 127.0.0.0/8
- C. 169.254.0.0/16
- D. 224.0.0.0/4

Correct Answer: B

Concept & Rationale: The entire 127.0.0.0/8 block is reserved for loopback operations. Traffic sent to 127.0.0.1 is looped back internally within the host IP stack without reaching physical media.

Question 53

Topic: Subnetting Usable Hosts /27

Type: Single Choice

How many usable host IP addresses are available in an IPv4 subnet with a /27 prefix (mask 255.255.255.224)?

- A. 14
- B. 30
- C. 32
- D. 62

Correct Answer: B

Concept & Rationale: A /27 subnet has $32 - 27 = 5$ host bits. Total addresses = $2^5 = 32$. Subtracting the network address and directed broadcast address yields $32 - 2 = 30$ usable host IP addresses.

Question 54

Topic: Subnetting Broadcast Address

Type: Single Choice

What is the directed broadcast address for the subnet 192.168.1.64/26?

- A. 192.168.1.64
- B. 192.168.1.127
- C. 192.168.1.128
- D. 192.168.1.255

Correct Answer: B

Concept & Rationale: A /26 subnet has block size $256 - 192 = 64$. Subnet range: 192.168.1.64 to 192.168.1.127. The first address (.64) is network ID, and the last (.127) is the directed broadcast address.

Question 55

Topic: ARP Request Mode

Type: Single Choice

How is an initial ARP Request frame transmitted across a local broadcast domain to resolve a target IP address?

- A. Unicast to the default gateway
- B. Broadcast (Destination MAC FF:FF:FF:FF:FF:FF)
- C. Multicast to 224.0.0.1
- D. Anycast across all router ports

Correct Answer: B

Concept & Rationale: Because the sending host does not know the destination MAC address, it broadcasts the ARP Request with Destination MAC FF:FF:FF:FF:FF:FF so all hosts on the local link process it.

Question 56

Topic: ARP Reply Mode

Type: Single Choice

How does the target host respond to an ARP Request?

- A. It broadcasts the ARP Reply to all hosts
- B. It transmits a unicast ARP Reply directly to the requester's MAC address
- C. It transmits an ICMP Echo Reply
- D. It registers its MAC address with the DNS server

Correct Answer: B

Concept & Rationale: The target host learned the requester's MAC and IP addresses from the ARP Request header. Thus, it responds with a unicast ARP Reply directly addressed to the requester.

Question 57

Topic: Gratuitous ARP Function

Type: Single Choice

What is a primary purpose of transmitting a Gratuitous ARP packet?

- A. To query the DNS root server for top-level domains
- B. To detect duplicate IP address conflicts and update neighbors' ARP mapping caches
- C. To authenticate user credentials against a RADIUS server
- D. To establish an encrypted IPsec tunnel across the WAN

Correct Answer: B

Concept & Rationale: A host broadcasts a Gratuitous ARP (where source IP and target IP are its own address) upon interface activation to check if another device is already using that IP address (conflict detection) and to update MAC-to-IP tables on switches and neighbors.

Question 58

Topic: Proxy ARP Function

Type: Single Choice

What is the function of Proxy ARP on a router or firewall interface?

- A. To encrypt all ARP queries using AES-128
- B. To respond with its own MAC address to an ARP request on behalf of a target host located on another subnet
- C. To permanently block all ARP traffic entering the interface
- D. To translate IPv4 addresses to IPv6 addresses

Correct Answer: B

Concept & Rationale: Proxy ARP allows a router or firewall to reply with its own MAC address to an ARP Request sent by a local host seeking a destination host on a different subnet/network, enabling communication without configuring default gateways on legacy hosts.

Question 59

Topic: ICMP Protocol Layer

Type: Single Choice

At which OSI layer does the Internet Control Message Protocol (ICMP) logically operate, and how is it encapsulated?

- A. Layer 2, encapsulated directly inside Ethernet frames
- B. Layer 3, encapsulated directly inside IPv4 packets (Protocol 1)
- C. Layer 4, encapsulated inside TCP segments
- D. Layer 7, encapsulated inside HTTP requests

Correct Answer: B

Concept & Rationale: ICMP is an integral part of the Network Layer (Layer 3). Its messages are encapsulated directly within IP datagrams with the IP header Protocol field set to 1.

Question 60

Topic: ICMP Ping Echo Request

Type: Single Choice

What are the ICMP Type and Code values for an ICMP Echo Request (Ping request)?

- A. Type 0, Code 0
- B. Type 8, Code 0
- C. Type 3, Code 1
- D. Type 11, Code 0

Correct Answer: B

Concept & Rationale: An ICMP Echo Request utilizes Type 8, Code 0. The responding device replies with an ICMP Echo Reply using Type 0, Code 0.

Question 61

Topic: ICMP Destination Unreachable

Type: Single Choice

Which ICMP Type indicates that a destination network, host, port, or protocol is unreachable?

- A. Type 0
- B. Type 3
- C. Type 8
- D. Type 11

Correct Answer: B

Concept & Rationale: ICMP Type 3 represents 'Destination Unreachable'. Specific codes include Code 0 (Network Unreachable), Code 1 (Host Unreachable), Code 3 (Port Unreachable), and Code 4 (Fragmentation Needed and DF set).

Question 62

Topic: ICMP Traceroute Type

Type: Single Choice

Which ICMP message is generated by intermediate routers when their TTL counter reaches zero, enabling the 'tracert' / 'traceroute' command?

- A. Type 0 Echo Reply
- B. Type 3 Destination Unreachable
- C. Type 11 Time Exceeded
- D. Type 5 Redirect

Correct Answer: C

Concept & Rationale: Traceroute transmits packets with incrementing TTL values starting at 1. When a router decrements TTL to 0, it drops the packet and sends an ICMP Type 11 (Time Exceeded) message back to the source, revealing that hop's IP address.

Question 63

Topic: TCP Characteristics

Type: Single Choice

Which of the following is a key operational characteristic of Transmission Control Protocol (TCP)?

- A. Connectionless, best-effort delivery without acknowledgments
- B. Connection-oriented, reliable byte-stream service with error recovery and flow control
- C. Stateless broadcast transmission across local networks
- D. Fixed 8-byte header size with no options

Correct Answer: B

Concept & Rationale: TCP (RFC 793) is a connection-oriented, reliable transport protocol that provides sequencing, acknowledgments, sliding-window flow control, congestion avoidance, and retransmission of lost segments.

Question 64

Topic: TCP Handshake Flags

Type: Single Choice

What is the correct sequence of TCP flag exchanges during connection establishment?

- A. ACK -> SYN -> FIN
- B. SYN -> SYN-ACK -> ACK
- C. SYN -> ACK-FIN -> RST
- D. RST -> SYN -> ACK

Correct Answer: B

Concept & Rationale: The TCP 3-way handshake begins with the client sending a SYN segment, the server responding with SYN-ACK, and the client confirming with an ACK segment, transitioning the connection to the ESTABLISHED state.

Question 65

Topic: TCP Termination Segments

Type: Single Choice

How many segments are typically exchanged to gracefully close a bidirectional TCP connection?

- A. 2 segments
- B. 3 segments
- C. 4 segments (FIN -> ACK -> FIN -> ACK)
- D. 6 segments

Correct Answer: C

Concept & Rationale: Because TCP is full-duplex, each direction of data transfer closes independently. Host A sends FIN, Host B sends ACK (closing A->B); then Host B sends FIN, and Host A sends ACK (closing B->A), totaling 4 segments.

Question 66

Topic: TCP TIME_WAIT Rationale

Type: Single Choice

What is the primary reason the TCP active close endpoint remains in the TIME_WAIT state for 2 MSL (Maximum Segment Lifetime)?

- A. To immediately renegotiate encryption keys for the next connection
- B. To ensure the final ACK is received by the peer and allow old duplicate segments to expire in the network
- C. To allow the server to recharge its hardware interface buffers
- D. To force the client to restart its operating system

Correct Answer: B

Concept & Rationale: The 2 MSL TIME_WAIT state ensures that if the final ACK is lost, the retransmitted FIN can be acknowledged. It also guarantees that all delayed segments from the closed connection expire and cannot corrupt future connections using the same socket pair.

Question 67

Topic: TCP RST Flag

Type: Single Choice

What is the function of the RST (Reset) flag in a TCP header?

- A. To request dynamic routing table updates from adjacent firewalls
- B. To abort an abnormal connection immediately and reject invalid connection attempts
- C. To initiate the graceful 3-way handshake
- D. To indicate that urgent out-of-band data is present

Correct Answer: B

Concept & Rationale: The RST flag resets an invalid connection, aborts an active session due to errors, or rejects an incoming SYN directed to an inactive/closed port.

Question 68

Topic: UDP Header Length

Type: Single Choice

What is the fixed header size of a standard User Datagram Protocol (UDP) segment?

- A. 8 bytes
- B. 16 bytes
- C. 20 bytes
- D. 32 bytes

Correct Answer: A

Concept & Rationale: A UDP header contains exactly four 16-bit fields: Source Port (2 bytes), Destination Port (2 bytes), Length (2 bytes), and Checksum (2 bytes), totaling 8 bytes.

Question 69

Topic: UDP Real-Time Media

Type: Single Choice

Why is UDP preferred over TCP for real-time voice and video streaming (e.g., VoIP, video conferencing)?

- A. UDP provides stronger encryption algorithms than TCP
- B. UDP has low latency and no retransmission delays, prioritizing timely delivery over perfect reliability
- C. UDP guarantees 100% loss-free packet delivery across congested links
- D. UDP automatically modifies router forwarding tables to prevent jitter

Correct Answer: B

Concept & Rationale: Real-time media applications prioritize low latency and predictable jitter. Retransmitting dropped audio/video frames via TCP causes noticeable lag and freezes; dropping occasional packets is preferable.

Question 70

Topic: DNS Query Transport

Type: Single Choice

Which transport protocol and port number are predominantly used by standard DNS client queries?

- A. TCP port 25
- B. UDP port 53
- C. TCP port 80
- D. UDP port 67

Correct Answer: B

Concept & Rationale: Standard DNS queries and responses utilize UDP port 53 for speed. DNS uses TCP port 53 for responses exceeding 512 bytes (or EDNS0 limits) and for zone transfers between DNS servers.

Question 71

Topic: DNS Record Type A

Type: Single Choice

Which DNS resource record type maps a fully qualified domain name (FQDN) to an IPv4 address?

- A. AAAA record
- B. A record
- C. CNAME record
- D. PTR record

Correct Answer: B

Concept & Rationale: An 'A' record maps a hostname to an IPv4 address. 'AAAA' maps to IPv6; 'CNAME' maps an alias to a canonical name; 'PTR' provides reverse resolution from IP to domain name.

Question 72

Topic: HTTP HTTPS Default Ports

Type: Single Choice

What are the default standard TCP ports for unencrypted HTTP and encrypted HTTPS, respectively?

- A. HTTP: 21, HTTPS: 22
- B. HTTP: 80, HTTPS: 443
- C. HTTP: 8080, HTTPS: 8443
- D. HTTP: 25, HTTPS: 587

Correct Answer: B

Concept & Rationale: Standard HTTP communicates over cleartext TCP port 80, whereas HTTPS encrypts HTTP traffic inside TLS/SSL over TCP port 443.

Question 73

Topic: FTP Control and Data Ports

Type: Single Choice

In traditional Active Mode File Transfer Protocol (FTP), which port is used for control commands and which for data transfer?

- A. Port 21 for Control; Port 20 for Data
- B. Port 22 for Control; Port 21 for Data
- C. Port 80 for Control; Port 443 for Data
- D. Port 69 for Control; Port 68 for Data

Correct Answer: A

Concept & Rationale: FTP separates control commands from data transfer. Port 21 is the command/control port, while the FTP server initiates data connections from port 20 in Active FTP mode.

Question 74

Topic: FTP Active Mode NAT Problem

Type: Single Choice

Why does Active FTP fail when the FTP client is located behind a standard NAT router/firewall?

- A. The client refuses to communicate with servers running Linux
- B. The FTP server initiates an inbound connection from port 20 to the client's high port, which the client firewall blocks
- C. Active FTP requires uncompressed video streaming bandwidth
- D. NAT devices are physically prohibited from handling TCP port 21

Correct Answer: B

Concept & Rationale: In Active FTP, the client sends a PORT command specifying its internal IP and high port, then listens. The server initiates an incoming connection from port 20 to that port. A stateful firewall or NAT device at the client border blocks this unsolicited incoming connection unless an FTP ALG/ASPF is active.

Question 75

Topic: FTP Passive Mode Solution

Type: Single Choice

How does Passive FTP (PASV) resolve client-side firewall and NAT traversal issues?

- A. The server initiates the data connection directly to port 80
- B. The server opens a random high port and the client initiates the outbound data connection to that port
- C. Passive FTP disables encryption and authentication entirely
- D. The client and server communicate exclusively over ICMP echo packets

Correct Answer: B

Concept & Rationale: In Passive FTP, the client sends the PASV command. The server opens a random unprivileged high port and returns the IP and port to the client. The client then initiates the outbound data connection, which client firewalls permit as outbound traffic.

Question 76

Topic: SSH vs Telnet Security

Type: Single Choice

Why is SSH (TCP port 22) universally recommended over Telnet (TCP port 23) for device management?

- A. Telnet is restricted to connecting only to printers
- B. Telnet transmits usernames, passwords, and commands in cleartext, vulnerable to packet sniffing; SSH encrypts all session data
- C. Telnet requires hardware dongles for terminal emulation
- D. SSH uses connectionless UDP broadcast frames to reach remote routers

Correct Answer: B

Concept & Rationale: Telnet transmits all data, including administrative credentials, in unencrypted plaintext across the network. Anyone intercepting traffic with a packet sniffer can read passwords. SSH encrypts the entire channel and authenticates server and client.

Question 77

Topic: DHCP DORA Sequence

Type: Single Choice

What is the correct sequence of the four DHCP broadcast/unicast messages exchanged during dynamic host IP address allocation?

- A. Discover -> Offer -> Request -> Acknowledge (DORA)
- B. Request -> Offer -> Discover -> Acknowledge
- C. Dial -> Open -> Ready -> Accept
- D. Detect -> Order -> Receive -> Authenticate

Correct Answer: A

Concept & Rationale: The four-step DHCP process is DORA: 1. DHCP Discover (client broadcasts looking for a server); 2. DHCP Offer (server proposes IP configuration); 3. DHCP Request (client formally requests the offered IP); 4. DHCP ACK (server confirms lease).

Question 78

Topic: DHCP UDP Ports

Type: Single Choice

Which UDP ports are utilized by DHCP servers and DHCP clients, respectively?

- A. Server: UDP 67, Client: UDP 68
- B. Server: UDP 68, Client: UDP 67
- C. Server: UDP 53, Client: UDP 53
- D. Server: UDP 161, Client: UDP 162

Correct Answer: A

Concept & Rationale: DHCP server listens on UDP port 67, and DHCP client listens on UDP port 68.

Question 79

Topic: DHCP Relay Agent Role

Type: Single Choice

When DHCP clients and the DHCP server reside in different IP subnets, which device feature must be configured on the local router/switch interface?

- A. DNS Dynamic Update
- B. DHCP Relay Agent
- C. ARP Proxy
- D. NAT ALG

Correct Answer: B

Concept & Rationale: Because initial DHCP Discover messages are Layer 2 broadcasts (255.255.255.255), routers drop them by default. A DHCP Relay agent intercepts these broadcasts and forwards them as unicast packets across routers to the centralized DHCP server.

Question 80**Topic:** VLAN 802.1Q Header Size**Type:** Single Choice

What is the size in bytes of the IEEE 802.1Q VLAN tag inserted into an Ethernet frame?

- A. 2 bytes
- B. 4 bytes
- C. 6 bytes
- D. 8 bytes

Correct Answer: B

Concept & Rationale: An 802.1Q tag is 4 bytes (32 bits) long, comprising a 2-byte Tag Protocol Identifier (TPID = 0x8100) and a 2-byte Tag Control Information (TCI, which contains 3-bit Priority, 1-bit CFI/DEI, and 12-bit VLAN ID).

3 Chapter 3: Common Network Security Threats and Threat Prevention

Question 81**Topic:** Malware Classification - Virus**Type:** Single Choice

Which type of malicious software attaches its code to legitimate executable files and requires user interaction (such as launching the infected program) to replicate?

- A. Worm
- B. Computer Virus
- C. Trojan Horse
- D. Spyware

Correct Answer: B

Concept & Rationale: A computer virus requires a host program or file and relies on human execution of the infected host to spread to other files or systems.

Question 82**Topic:** Malware Classification - Worm**Type:** Single Choice

Which malware family is characterized as a self-replicating standalone program that autonomously propagates across computer networks by exploiting operating system vulnerabilities without requiring host files?

- A. Computer Virus
- B. Computer Worm
- C. Logic Bomb
- D. Rootkit

Correct Answer: B

Concept & Rationale: A worm is an independent standalone program that replicates automatically over network connections by exploiting software flaws, propagating rapidly without human intervention or host files (e.g., Code Red, SQL Slammer).

Question 83

Topic: Malware Classification - Trojan Horse

Type: Single Choice

A program masquerading as a legitimate system optimization utility that secretly opens an unauthorized remote access backdoor for an external attacker is classified as a:

- A. Trojan Horse
- B. Worm
- C. Macro Virus
- D. Boot Sector Virus

Correct Answer: A

Concept & Rationale: A Trojan horse disguises itself as useful, legitimate software while concealing malicious functionality, such as opening backdoors or exfiltrating data. Unlike viruses and worms, Trojans do not self-replicate.

Question 84

Topic: Ransomware Encryption Method

Type: Single Choice

Modern ransomware families commonly employ which cryptographic approach to lock a victim's files before demanding cryptocurrency?

- A. Rot13 substitution cipher
- B. Hybrid encryption using strong symmetric ciphers (e.g., AES-256) for file encryption and asymmetric ciphers (e.g., RSA-2048) to protect the key
- C. One-way MD5 hashing of user documents
- D. Cleartext base64 obfuscation without keys

Correct Answer: B

Concept & Rationale: Ransomware employs hybrid encryption: high-speed symmetric algorithms (AES) encrypt local files, and an asymmetric public key encrypts the AES key, ensuring that only the attacker possessing the private key can decrypt the data.

Question 85

Topic: Rootkit Capability

Type: Single Choice

What is the primary distinguishing feature of a Rootkit in malware operations?

- A. Displaying continuous pop-up advertisements in web browsers
- B. Subverting operating system kernel APIs to hide malicious processes, files, registry keys, and network connections from detection
- C. Overheating the computer power supply unit through electrical resonance
- D. Reformatting hard drives immediately upon insertion of a USB drive

Correct Answer: B

Concept & Rationale: Rootkits operate at deep operating system layers (kernel/hypervisor), hooking system calls and data structures to conceal their presence, active processes, files, and backdoors from antivirus tools and administrators.

Question 86

Topic: Botnet Command and Control

Type: Single Choice

In a botnet architecture, how does the botmaster coordinate and transmit commands to thousands of compromised zombie devices?

- A. By sending physical letters to each device owner
- B. Via Command and Control (C2) communication channels using protocols such as IRC, HTTP/HTTPS, DNS, or P2P
- C. Through manual console logins at each individual workstation
- D. Using standard broadcast television frequencies

Correct Answer: B

Concept & Rationale: Botnets rely on centralized or distributed Command and Control (C2) servers communicating over standard protocols (HTTP/HTTPS, IRC, DNS tunneling, P2P) to issue synchronized instructions to zombies for DDoS attacks or spam campaigns.

Question 87

Topic: Reconnaissance - Ping Sweep

Type: Single Choice

What is the primary objective of an attacker conducting an ICMP ping sweep across an enterprise IP subnet?

- A. To crack the administrator's domain password
- B. To identify live, responsive host IP addresses across the target network range
- C. To exhaust the firewall's physical flash storage
- D. To modify the DNS records on the authoritative nameserver

Correct Answer: B

Concept & Rationale: A ping sweep transmits ICMP Echo Requests across a range of sequential IP addresses to map out which IP addresses correspond to active, online systems based on receiving ICMP Echo Replies.

Question 88

Topic: Port Scanning - TCP SYN Scan

Type: Single Choice

Why is a TCP SYN scan (half-open scan) frequently referred to as a 'stealth scan' compared to a full TCP Connect scan?

- A. It operates entirely without transmitting any IP packets
- B. It terminates the handshake with an RST segment after receiving SYN-ACK, avoiding the creation of an established connection in server application logs
- C. It encrypts the TCP header using quantum cryptography
- D. It forces the destination server to power down before logging occurs

Correct Answer: B

Concept & Rationale: In a SYN scan, the scanner sends a SYN. If the target responds with SYN-ACK (indicating an open port), the scanner immediately responds with an RST rather than completing the 3-way handshake, avoiding session establishment and logging by legacy application daemons.

Question 89

Topic: Port Scanning - TCP Connect Scan

Type: Single Choice

Which of the following describes the operation of a TCP Connect scan on a target port?

- A. It relies on specialized kernel drivers to send malformed TCP packets
- B. It completes the entire TCP 3-way handshake (SYN, SYN-ACK, ACK) using standard operating system socket system calls
- C. It transmits only ICMP Echo packets to high UDP ports
- D. It leaves target ports permanently frozen in the LISTEN state

Correct Answer: B

Concept & Rationale: A TCP Connect scan uses standard operating system network APIs (`connect()`) to complete the full 3-way handshake. Because an established connection is formed, it is easily detected and recorded in server application access logs.

Question 90

Topic: Port Scanning - UDP Scan

Type: Single Choice

How does an attacker determine that a target UDP port is closed during a UDP port scan?

- A. The target returns a TCP RST segment
- B. The target replies with an ICMP Port Unreachable message (Type 3, Code 3)
- C. The target sends an ARP Reply frame with an all-zero MAC address
- D. The target transmits a DHCP NAK packet

Correct Answer: B

Concept & Rationale: According to RFC 792, if a host receives a UDP datagram addressed to a closed port, it responds with an ICMP Type 3, Code 3 (Destination Unreachable: Port Unreachable) error message.

Question 91

Topic: Sniffing - Promiscuous Mode

Type: Single Choice

What occurs when a network interface card (NIC) is configured into 'promiscuous mode'?

- A. The NIC refuses to transmit any outbound packets
- B. The NIC captures and passes all received frames to the OS, regardless of destination MAC address
- C. The NIC automatically encrypts all Ethernet traffic using AES-GCM
- D. The NIC disables its physical transceiver to save power

Correct Answer: B

Concept & Rationale: Normally, a NIC discards frames whose destination MAC does not match its own MAC, broadcast, or joined multicast groups. In promiscuous mode, the NIC captures and forwards every frame on the physical wire to packet analysis software.

Question 92

Topic: Sniffing - MAC Flooding Attack

Type: Single Choice

What is the operational goal of an attacker executing a MAC flooding (CAM table overflow) attack against a Layer 2 switch?

- A. To crack the switch's console enable password
- B. To exhaust the switch's MAC address table memory, forcing the switch to flood unknown unicast frames out all ports like a hub
- C. To permanently burn the switch's ASIC microchips
- D. To force all connected PCs to reboot into safe mode

Correct Answer: B

Concept & Rationale: Switches forward frames based on MAC tables. By flooding the switch with thousands of bogus source MACs, the CAM table fills up completely. When the table overflows, the switch defaults to broadcast flooding for all incoming unicast frames, allowing the attacker to sniff traffic from other ports.

Question 93**Topic:** ARP Spoofing Mechanism**Type:** Single Choice

In an ARP spoofing (cache poisoning) attack, what deceptive information does the attacker broadcast or unicast to victim hosts?

- A. The attacker claims that all DNS queries should be sent over Telnet
- B. The attacker associates its own MAC address with the IP address of the default gateway
- C. The attacker changes the physical serial number of the target router
- D. The attacker advertises an invalid BGP autonomous system number

Correct Answer: B

Concept & Rationale: In ARP cache poisoning, the attacker transmits gratuitous or forged ARP replies informing victims that the default gateway's IP address maps to the attacker's MAC address, diverting outbound traffic through the attacker's machine for Man-in-the-Middle interception.

Question 94**Topic:** DHCP Starvation Attack**Type:** Single Choice

What is the primary mechanism of a DHCP Starvation attack?

- A. Flooding the DHCP server with malformed ICMP ping packets
- B. Broadcasting thousands of DHCP requests with spoofed, randomized MAC addresses to exhaust the available IP address pool
- C. Modifying the physical lease file on the DHCP server hard drive
- D. Encrypting the server's network card firmware using ransomware

Correct Answer: B

Concept & Rationale: A DHCP Starvation attack floods the DHCP server with continuous DHCP Discover/Request messages, each using a distinct randomized MAC address. The server assigns all available pool leases to bogus MACs, denying IP addresses to legitimate incoming clients.

Question 95**Topic:** Rogue DHCP Server Attack**Type:** Single Choice

What threat does an unauthorized 'Rogue DHCP Server' introduce into a corporate LAN segment?

- A. It causes physical short circuits across Ethernet cables
- B. It assigns malicious default gateway and rogue DNS server IP addresses to unsuspecting clients, facilitating MitM and phishing
- C. It permanently disables all wireless antennas within 500 meters
- D. It deletes all files stored on domain controllers

Correct Answer: B

Concept & Rationale: A rogue DHCP server responds faster than the legitimate server, configuring clients with the attacker's IP as the default gateway and rogue DNS servers, enabling seamless traffic interception, credential harvesting, and website spoofing.

Question 96

Topic: DoS - SYN Flood Mechanism

Type: Single Choice

How does a classic TCP SYN Flood attack cause a Denial of Service on a target web server?

- A. By overwriting the server's master boot record (MBR)
- B. By sending massive volumes of SYN packets with unreachable/spoofed source IPs, filling the server's half-open connection backlog queue (SYN_RECEIVED)
- C. By executing unauthorized SQL DROP TABLE commands against backend databases
- D. By physically disabling the server's network interface card

Correct Answer: B

Concept & Rationale: The attacker sends a deluge of TCP SYN segments with spoofed source IPs. The server allocates a Transmission Control Block (TCB) in memory and enters SYN_RECEIVED, awaiting final ACKs that never arrive, quickly exhausting the connection backlog queue.

Question 97

Topic: SYN Flood Defense - SYN Cookie

Type: Single Choice

How does the 'SYN Cookie' defense mechanism mitigate TCP SYN flood attacks on servers and firewalls?

- A. It blocks all incoming TCP traffic permanently
- B. It encodes connection parameters into the Initial Sequence Number (ISN) of the SYN-ACK without allocating server memory until the client returns a valid ACK
- C. It requires every web client to enter a CAPTCHA before sending a SYN
- D. It converts TCP packets into unacknowledged UDP datagrams

Correct Answer: B

Concept & Rationale: SYN Cookies eliminate memory allocation during the SYN_RECEIVED state. The server encodes socket state and cryptographic hashes into the SYN-ACK sequence number; connection memory is allocated only when the client returns a valid final ACK containing the cookie value.

Question 98

Topic: DoS - Land Attack

Type: Single Choice

What is the unique characteristic of a 'Land Attack' packet?

- A. The packet length exceeds 65535 bytes
- B. The Source IP address and Port are identical to the Destination IP address and Port
- C. The packet contains completely unencrypted credit card numbers
- D. The packet has the URG and FIN flags set simultaneously

Correct Answer: B

Concept & Rationale: In a Land Attack, the attacker crafts a TCP SYN packet where the Source IP and Port match the victim's own IP address and Port. Vulnerable operating systems attempt to process the connection with themselves, entering infinite loops and crashing.

Question 99

Topic: DoS - Smurf Attack

Type: Single Choice

Which protocol and addressing combination is exploited in a classic Smurf DDoS attack?

- A. TCP SYN packets sent to a unicast web server
- B. ICMP Echo Requests sent to an IP directed broadcast address with the victim's spoofed IP as the source address
- C. DNS queries sent over cleartext Telnet sessions
- D. BGP route advertisements containing private AS numbers

Correct Answer: B

Concept & Rationale: In a Smurf attack, the attacker broadcasts ICMP Echo Requests to intermediate amplifying networks with the victim's IP spoofed as the source address. Hundreds of responsive hosts reply simultaneously to the victim, saturating its inbound bandwidth.

Question 100**Topic:** DoS - Fraggle Attack**Type:** Single Choice

How does a Fraggle attack differ fundamentally from a Smurf attack?

- A. Fraggle uses UDP Echo packets (port 7) instead of ICMP Echo packets
- B. Fraggle targets only wireless Bluetooth devices
- C. Fraggle encrypts the packet payload using RSA-4096
- D. Fraggle requires physical access to the victim's motherboard

Correct Answer: A

Concept & Rationale: Fraggle is the UDP counterpart to the Smurf attack. It sends UDP Echo datagrams (typically to port 7) to broadcast addresses with the victim's spoofed source IP, prompting hosts to send UDP replies that overwhelm the victim.

Question 101**Topic:** DoS - Ping of Death**Type:** Single Choice

What structural anomaly in a network packet constitutes a 'Ping of Death' attack?

- A. An ICMP packet carrying an audio recording of a siren
- B. An IP packet that, when reassembled from fragments, exceeds the maximum legal IPv4 packet size of 65,535 bytes
- C. A packet transmitted without an Ethernet preamble
- D. A TCP packet where all header fields are filled with zeros

Correct Answer: B

Concept & Rationale: The maximum size of an IPv4 packet including header is 65,535 bytes. A Ping of Death transmits fragmented ICMP packets whose total reassembled size exceeds 65,535 bytes, causing buffer overflows and crashes in vulnerable network stacks.

Question 102**Topic:** DoS - Teardrop Attack**Type:** Single Choice

What mechanism causes system crashes in a 'Teardrop' fragmentation attack?

- A. Flooding the router with million-hop TTL packets
- B. Transmitting packet fragments with overlapping, conflicting fragment offsets, corrupting OS kernel memory buffers during reassembly
- C. Overheating server CPUs by requesting complex mathematical square roots
- D. Injecting malicious SQL syntax into Ethernet frame headers

Correct Answer: B

Concept & Rationale: Teardrop exploits IP fragmentation reassembly flaws. The attacker crafts overlapping, contradictory Fragment Offset and Length fields. When the target operating system attempts to reassemble the malformed fragments into a contiguous buffer, a memory fault or kernel panic occurs.

Question 103

Topic: Application Layer DoS - CC Attack

Type: Single Choice

What is a Challenge Collapsar (CC) attack, and at which OSI layer does it primarily operate?

- A. A physical fiber disconnection attack at Layer 1
- B. An Application Layer (Layer 7) HTTP/HTTPS flood that repeatedly requests computationally expensive web pages or database queries
- C. A Layer 2 MAC address exhaustion attack on core switches
- D. A hardware BIOS flashing attack on border routers

Correct Answer: B

Concept & Rationale: A CC attack targets Layer 7 (Application Layer). The attacker uses proxy networks or botnets to issue floods of legitimate-looking HTTP GET/POST requests for resource-intensive web pages, exhausting web server CPUs, memory pools, and database connection limits.

Question 104

Topic: DoS - Slowloris Attack

Type: Single Choice

How does a Slowloris attack exhaust web server resources without generating massive volumetric bandwidth?

- A. By sending single 100-gigabyte video files to port 80
- B. By opening multiple HTTP connections and sending incomplete HTTP headers at slow, periodic intervals, holding server threads open until the maximum concurrent pool is exhausted
- C. By flooding the web server with high-frequency ICMP echo requests
- D. By manipulating the server's BGP routing table

Correct Answer: B

Concept & Rationale: Slowloris is a low-and-slow Layer 7 DoS attack. It opens numerous TCP connections to a web server and transmits partial HTTP headers periodically just before the keep-alive timeout expires, keeping server worker threads indefinitely occupied until no new clients can connect.

Question 105

Topic: NTP Amplification Attack

Type: Single Choice

Why are Network Time Protocol (NTP) servers frequently exploited in volumetric amplification DDoS attacks?

- A. NTP uses 4096-bit asymmetric encryption
- B. Vulnerable NTP servers supporting the legacy 'monlist' command return lists of the last 600 clients, producing amplification factors exceeding 500x
- C. NTP operates exclusively over high-latency satellite links
- D. NTP packets automatically delete victim routing tables

Correct Answer: B

Concept & Rationale: The NTP 'monlist' command sends a tiny UDP request that triggers a response containing up to 600 recent client IP addresses. By spoofing the victim's IP, the attacker generates an enormous asymmetric amplification flood directing hundreds of times more traffic onto the victim.

Question 106

Topic: DNS Amplification Factor

Type: Single Choice

How does an attacker maximize the bandwidth amplification factor in a DNS reflection attack?

- A. By requesting standard 1-byte ICMP replies
- B. By querying open DNS resolvers for large 'ANY' or 'TXT' resource records with EDNS0 support, spoofing the victim's source IP
- C. By establishing encrypted SSH tunnels to all DNS servers simultaneously
- D. By disabling TCP checksum calculation on client computers

Correct Answer: B

Concept & Rationale: In a DNS amplification attack, an attacker sends small UDP queries (e.g. requesting the 'ANY' record for a domain signed with DNSSEC) to open recursive resolvers. The resulting responses are tens of times larger than the requests, overwhelming the spoofed victim's link.

Question 107

Topic: IP Spoofing Purpose

Type: Single Choice

What is the primary technical objective of an attacker when utilizing IP address spoofing in DDoS attacks?

- A. To ensure the attacker receives all reply data packets for analysis
- B. To conceal the attacker's true geographical identity and redirect victim response traffic to an innocent third party or unroutable sinkhole
- C. To accelerate Ethernet switching speeds across local subnets
- D. To legally comply with national cybersecurity regulations

Correct Answer: B

Concept & Rationale: IP spoofing hides the real origin of the attack traffic and causes target systems to send replies to the spoofed victim (in reflection attacks) or drop them into black holes, rendering source-based blocking ineffective without deep packet inspection.

Question 108

Topic: Defense-in-Depth Tiers

Type: Single Choice

Which of the following security architectures exemplifies the Defense-in-Depth principle for an enterprise data center?

- A. Relying exclusively on a single hardware firewall with default permit rules
- B. Deploying border firewalls, perimeter IPS, internal DMZ segmentation, host-level antivirus/EDR, and data-at-rest encryption
- C. Configuring all server IP addresses into the public Untrust security zone
- D. Disabling all user authentication mechanisms to reduce network latency

Correct Answer: B

Concept & Rationale: Defense-in-Depth creates multiple concentric rings of protection across the perimeter, network segments, host operating systems, applications, and storage, ensuring that if one boundary is breached, subsequent layers continue defense.

Question 109

Topic: Anti-DDoS Scrubbing Center

Type: Single Choice

What is the operational function of an Anti-DDoS Traffic Scrubbing Center during a volumetric attack?

- A. To format all hard drives on the victim server
- B. To divert incoming traffic using BGP routing, clean the traffic by stripping malicious flood packets, and reinject legitimate traffic back to the enterprise
- C. To physically replace all fiber optic cables leading into the data center
- D. To shut down the entire Internet connection to prevent electrical overheating

Correct Answer: B

Concept & Rationale: When a DDoS attack is detected, traffic destined for the victim is diverted via BGP or DNS to a specialized scrubbing center. High-performance cleaning engines filter out flood packets (SYN, UDP, HTTP floods) and reinject clean legitimate traffic back to the target host.

Question 110

Topic: Malware - Logic Bomb

Type: Single Choice

What distinguishes a 'Logic Bomb' from other standard malware varieties?

- A. It relies exclusively on audio microphones to detect targets
- B. It remains dormant in a system until triggered by a specific predefined event, date, or logical condition, upon which it executes its destructive payload
- C. It spreads autonomously across all reachable subnets within 10 milliseconds
- D. It only infects computers running Unix operating systems

Correct Answer: B

Concept & Rationale: A logic bomb is malicious code deliberately inserted into a software system that remains dormant until triggered by a specific condition (e.g., a specific date/time, a user being deleted from payroll, or a failed command execution).

Question 111

Topic: Social Engineering - Watering Hole

Type: Single Choice

What is a 'Watering Hole' attack strategy?

- A. Flooding an enterprise drinking water cooler with electrical interference
- B. Compromising legitimate third-party websites frequently visited by employees of a target organization to deliver drive-by malware downloads
- C. Sending broadcast emails asking employees to drink more water
- D. Sniffing unencrypted VoIP packets across WAN links

Correct Answer: B

Concept & Rationale: In a Watering Hole attack, adversaries profile target organizations to identify industry websites frequently visited by their employees. The attackers compromise that third-party website, injecting malicious scripts to infect visitors from the target company via drive-by downloads.

Question 112

Topic: Man-in-the-Middle (MitM) Definition

Type: Single Choice

In a Man-in-the-Middle (MitM) attack, what position does the attacker establish?

- A. The attacker sits behind the destination database server without network access
- B. The attacker intercepts, relays, and potentially alters communication between two legitimate parties without either party being aware of the intrusion
- C. The attacker only monitors environmental temperatures inside the server rack
- D. The attacker acts as an accredited Certificate Authority

Correct Answer: B

Concept & Rationale: An MitM attacker inserts themselves into the active communication path between two endpoints (via ARP poisoning, rogue Wi-Fi, or DNS spoofing), reading, modifying, or injecting data into the conversation transparently.

Question 113

Topic: Buffer Overflow Vulnerability

Type: Single Choice

What causes a traditional Buffer Overflow vulnerability in software applications?

- A. The CPU clock frequency drops below operating specifications
- B. An application writes more data to a memory buffer than the buffer is allocated to hold, overwriting adjacent memory spaces such as the return address pointer
- C. The Ethernet cable length exceeds 100 meters without a repeater
- D. The database table contains more than 10,000 text rows

Correct Answer: B

Concept & Rationale: A buffer overflow occurs when a program writes input data beyond the boundary of an allocated stack or heap memory buffer without proper bounds checking, corrupting adjacent control data (such as the instruction pointer) to hijack execution flow.

Question 114

Topic: SQL Injection Threat

Type: Single Choice

What is the core operational mechanism of a SQL Injection (SQLi) attack on a web application?

- A. Flooding the database port with malformed UDP datagrams
- B. Injecting malicious SQL commands through user input fields that the backend database executes as genuine database queries
- C. Physically disconnecting the SCSI storage cables from the database server
- D. Rewriting the DNS records for the database server's domain name

Correct Answer: B

Concept & Rationale: SQL Injection occurs when untrusted user input is concatenated directly into dynamic SQL query strings without sanitization or parameterized queries, allowing attackers to manipulate database commands to bypass authentication or extract entire tables.

Question 115**Topic:** Cross-Site Scripting (XSS)**Type:** Single Choice

What is the fundamental mechanism of a Cross-Site Scripting (XSS) attack?

- A. Executing unauthorized SQL statements on the backend database engine
- B. Injecting malicious client-side JavaScript into trusted web pages viewed by other users, stealing session cookies or redirecting users
- C. Flooding the border firewall with malformed ICMP echo packets
- D. Modifying the physical firmware of the web server's motherboard

Correct Answer: B

Concept & Rationale: XSS occurs when a web application includes unsanitized user input in its web output. When other users view the page, their browser executes the injected malicious script in the context of the trusted site, exposing session tokens and cookies.

Question 116**Topic:** Zero-Day Vulnerability Definition**Type:** Single Choice

What defines a 'Zero-Day Vulnerability' in cybersecurity practice?

- A. A vulnerability that requires exactly zero days of effort to patch completely
- B. A software security flaw that is unknown to the vendor or for which no official patch or fix has been publicly released
- C. A vulnerability that only impacts computers manufactured in the year 2000
- D. A flaw that can only be exploited during nighttime hours

Correct Answer: B

Concept & Rationale: A Zero-Day vulnerability is an undisclosed software or hardware security flaw unknown to the product vendor (giving them 'zero days' of defense notice) or for which no patch currently exists, making proactive behavioral defense vital.

4 Chapter 4: Firewall Security Policies

Question 117**Topic:** Security Zone - Local Priority**Type:** Single Choice

In Huawei USG series firewalls, what is the default fixed security priority of the Local security zone?

- A. 5
- B. 50
- C. 85
- D. 100

Correct Answer: D

Concept & Rationale: The Local zone represents the firewall device itself and has the highest fixed priority value of 100. All management traffic, routing protocol packets, and VPN tunnels terminate in the Local zone.

Question 118**Topic:** Security Zone - Trust Priority**Type:** Single Choice

What is the default security priority assigned to the predefined Trust zone on a Huawei firewall?

- A. 5
- B. 50
- C. 85
- D. 100

Correct Answer: C

Concept & Rationale: The predefined Trust zone has a priority of 85, representing the internal secure enterprise network.

Question 119**Topic:** Security Zone - DMZ Priority**Type:** Single Choice

What is the default security priority of the Demilitarized Zone (DMZ) in Huawei firewalls?

- A. 5
- B. 50
- C. 85
- D. 100

Correct Answer: B

Concept & Rationale: The DMZ zone has a fixed default priority of 50. It is designed to host public-facing enterprise servers (e.g., Web, Mail, FTP) that require controlled access from both internal and external networks.

Question 120**Topic:** Security Zone - Untrust Priority**Type:** Single Choice

What is the default security priority of the Untrust zone in Huawei firewalls?

- A. 5
- B. 50
- C. 85
- D. 100

Correct Answer: A

Concept & Rationale: The Untrust zone has the lowest default priority of 5, representing untrusted external networks such as the public Internet.

Question 121**Topic:** Traffic Direction - Outbound**Type:** Single Choice

When traffic flows from an internal network (Trust zone, priority 85) to the Internet (Untrust zone, priority 5), what is the direction of this traffic?

- A. Inbound
- B. Outbound
- C. Bidirectional
- D. Loopback

Correct Answer: B

Concept & Rationale: On Huawei firewalls, traffic traveling from a zone with a higher security priority to a zone with a lower security priority is defined as Outbound traffic.

Question 122

Topic: Traffic Direction - Inbound

Type: Single Choice

Traffic originating from the Internet (Untrust, priority 5) destined for an internal web server in the DMZ (priority 50) is classified as:

- A. Outbound traffic
- B. Inbound traffic
- C. Intra-zone traffic
- D. Pass-through traffic

Correct Answer: B

Concept & Rationale: Traffic traveling from a zone with a lower security priority to a zone with a higher security priority is defined as Inbound traffic.

Question 123

Topic: Intra-zone Default Action

Type: Single Choice

By default, what is the default forwarding behavior for traffic between two interfaces assigned to the SAME security zone (intra-zone traffic)?

- A. Permanently blocked and discarded
- B. Permitted without requiring inter-zone security policies
- C. Subject to mandatory deep packet antivirus scanning only
- D. Automatically mirrored to all physical switch ports

Correct Answer: B

Concept & Rationale: On Huawei firewalls, intra-zone traffic (traffic between interfaces within the identical security zone) is permitted by default, although administrators can configure intra-zone policies to restrict it if necessary.

Question 124

Topic: Inter-zone Default Action

Type: Single Choice

What is the default security behavior for inter-zone traffic (traffic between different security zones) when no matching security policy rule is found?

- A. It matches the predefined default policy and is denied (dropped)
- B. It is automatically forwarded using standard IP routing
- C. It is forwarded only after stripping all TCP options
- D. It triggers a broadcast ARP request across all interfaces

Correct Answer: A

Concept & Rationale: Huawei firewalls enforce an implicit 'deny-all' model for inter-zone traffic. If packets between different zones do not match any explicit permit policy, they match the predefined bottom 'default' policy and are silently discarded.

Question 125

Topic: Security Policy Matching Order

Type: Single Choice

In what order does a Huawei firewall evaluate security policy rules when a new connection arrives?

- A. Random order based on hash values
- B. Sequentially from top to bottom; the first rule that matches terminates policy evaluation
- C. Rules are evaluated from bottom to top, prioritizing the default rule
- D. Simultaneously across all rules, executing the rule with the highest ID number

Correct Answer: B

Concept & Rationale: Security policy rules are evaluated sequentially from top to bottom. The firewall checks matching criteria one by one, and upon encountering the first matching rule, it executes the specified action (permit/deny) and ceases further policy evaluation.

Question 126**Topic:** Default Policy Customization**Type:** Single Choice

Which of the following operations is permitted on the predefined 'default' security policy rule in a Huawei firewall?

- A. Deleting the rule completely
- B. Changing the default action from 'deny' to 'permit' (though not recommended for security)
- C. Moving the default rule to the top of the policy list
- D. Renaming the default rule to 'Corporate_Main_Rule'

Correct Answer: B

Concept & Rationale: The predefined 'default' rule cannot be deleted, moved, or renamed. However, its default action can be toggled between 'deny' and 'permit' (default is deny).

Question 127**Topic:** Session Table 5-Tuple**Type:** Single Choice

Which five parameters constitute the fundamental 5-tuple used to identify a network flow in a firewall session table?

- A. Source IP, Destination IP, Source Port, Destination Port, Transport Protocol
- B. Source MAC, Destination MAC, VLAN ID, TTL, Window Size
- C. Source IP, Destination IP, Security Zone, Application ID, User ID
- D. Egress Interface, Ingress Interface, Next Hop, DSCP, Packet Length

Correct Answer: A

Concept & Rationale: The fundamental 5-tuple of a session entry comprises: Source IP Address, Destination IP Address, Transport Layer Protocol, Source Port, and Destination Port.

Question 128**Topic:** Fast Forwarding Mechanism**Type:** Single Choice

How does a stateful inspection firewall process subsequent packets belonging to an already established permitted connection?

- A. It re-evaluates all security policy rules from top to bottom for every single packet
- B. It matches the session table directly, bypassing the security policy engine for fast-path forwarding
- C. It re-authenticates the user credentials against the RADIUS server
- D. It broadcasts the packets to all security zones simultaneously

Correct Answer: B

Concept & Rationale: Only the initial packet of a connection undergoes complete security policy matching. Once permitted, a session table entry is created. All subsequent forward and return packets match the session table directly, enabling line-rate fast-path forwarding.

Question 129

Topic: Session Table Aging Timer

Type: Single Choice

Why do firewall session table entries have associated aging timers?

- A. To periodically refresh the firewall's hardware MAC address
- B. To automatically purge inactive or terminated connections, freeing up system memory and resources
- C. To force users to re-enter their passwords every 60 seconds
- D. To synchronize the firewall clock with an external NTP server

Correct Answer: B

Concept & Rationale: If sessions remained in memory indefinitely, stale connections would exhaust the session table capacity, preventing new connections. Aging timers ensure that idle, closed, or aborted connections are reclaimed.

Question 130

Topic: TCP Established Aging Timer

Type: Single Choice

Compared to the aging timer for a TCP SYN packet, the aging timer for a TCP connection in the ESTABLISHED state is typically:

- A. Much shorter (e.g., 5 seconds)
- B. Much longer (e.g., several hours / 10,000 seconds by default)
- C. Exactly 0 seconds (disabled)
- D. Identical to the ICMP aging timer

Correct Answer: B

Concept & Rationale: Initial handshake states (like TCP SYN or FIN) have short timers (e.g., 20 seconds) to prevent SYN flood resource exhaustion. Once ESTABLISHED, long timers (default ~10,000s or 20 minutes on Huawei firewalls) allow idle business sessions to persist.

Question 131

Topic: ASPF Protocol Purpose

Type: Single Choice

What is the primary technical problem solved by Application Specific Packet Filter (ASPF) on a firewall?

- A. Encrypting HTTP web pages using 2048-bit RSA keys
- B. Dynamically opening pinholes for multi-channel protocols (like FTP) that negotiate dynamic data ports during control sessions
- C. Converting IPv4 packets into IPv6 format without translation
- D. Increasing the physical link speed of Ethernet interfaces

Correct Answer: B

Concept & Rationale: Multi-channel protocols (e.g., FTP active mode, SIP, H.323) negotiate secondary data connections using unpredictable dynamic ports. ASPF inspects control channel payloads and dynamically creates temporary Server-Map entries to allow the secondary channels without broadly opening static firewall ports.

Question 132

Topic: Server-Map Table Function

Type: Single Choice

How does a Server-Map table differ from a standard Session table on a Huawei firewall?

- A. A Server-Map table permanently stores historical network packets on the hard disk
- B. A Server-Map table dynamically generates temporary pass-through pinholes for anticipated secondary channels or static NAT server mappings
- C. A Server-Map table is used exclusively to record physical hardware serial numbers
- D. A Server-Map table replaces the need for an IP routing table

Correct Answer: B

Concept & Rationale: A Server-Map table is a specialized forwarding table that stores pre-allocated pinholes (e.g., dynamic pinholes generated by ASPF for FTP data channels, or static pinholes generated by NAT Server). When matching packets arrive, a standard session entry is formed, and the dynamic server-map entry expires.

Question 133

Topic: First Generation Firewall

Type: Single Choice

What is the defining operational characteristic of a first-generation Packet Filtering Firewall?

- A. Deep packet inspection of application layer payloads and user identities
- B. Stateless inspection of Layer 3 and Layer 4 headers against access control lists without tracking connection state
- C. Terminating TCP connections completely and acting as an application gateway proxy
- D. Using artificial intelligence to detect behavioral zero-day exploits

Correct Answer: B

Concept & Rationale: First-generation packet filters operate statelessly. They examine individual packets in isolation against rules based on 5-tuple headers, unable to correlate packets to ongoing connections or detect dynamic port negotiations.

Question 134

Topic: Second Generation Firewall

Type: Single Choice

What was a major operational drawback of second-generation Application Proxy Firewalls?

- A. They were incapable of inspecting application layer headers
- B. They suffered from high latency, significant compute resource consumption, and poor scalability for new protocols
- C. They allowed all external Internet users unrestricted access to internal subnets
- D. They could only be deployed on token ring network topologies

Correct Answer: B

Concept & Rationale: Application proxies terminate client connections and initiate new connections to servers, performing deep Layer 7 inspection. While secure, this introduced severe latency, high CPU overhead, and required dedicated proxy code for every supported application.

Question 135

Topic: Next-Generation Firewall (NGFW)

Type: Single Choice

What is a core capability that differentiates a Next-Generation Firewall (NGFW) from a traditional stateful firewall?

- A. The ability to forward packets based solely on destination MAC addresses
- B. Integrated application identification (independent of port), user awareness, and unified content security inspection (IPS/AV)
- C. Eliminating the need for IP routing and security zones
- D. Operating purely at the physical layer of the OSI model

Correct Answer: B

Concept & Rationale: An NGFW integrates Layer 7 application awareness (identifying applications regardless of port/protocol), user identity integration, and unified threat inspection (IPS, Antivirus, URL filtering) in a single-pass processing architecture.

Question 136

Topic: Security Zone Interface Mapping

Type: Single Choice

In Huawei firewall configuration, what is the relationship between physical/logical interfaces and security zones?

- A. A single interface can belong to multiple security zones simultaneously
- B. An interface can belong to only one security zone at any given time
- C. An interface must always belong to all four default security zones
- D. Security zones can only be applied to wireless loopback interfaces

Correct Answer: B

Concept & Rationale: In Huawei USG firewalls, each interface (physical interface, VLANIF, sub-interface, or tunnel interface) can be assigned to only ONE security zone at a time.

Question 137

Topic: Security Policy Matching Criteria

Type: Single Choice

Which of the following is NOT a standard matching criterion supported in a Huawei NGFW security policy rule?

- A. Source and Destination Security Zones
- B. Source and Destination IP Addresses / Subnets / Address Sets
- C. Physical room temperature of the client workstation
- D. Application identification and Time Range (Schedule)

Correct Answer: C

Concept & Rationale: Firewall security policies match network parameters: source/destination zones, IP addresses, services/ports, user identities, application IDs, and schedules. Physical environmental conditions of endpoints are not network policy criteria.

Question 138

Topic: Security Policy Action - Deny

Type: Single Choice

When a security policy rule's action is configured as 'Deny', what does the firewall do with matching traffic?

- A. It forwards the packet to the DMZ zone for manual review
- B. It discards the packet (and optionally returns a TCP RST or ICMP unreachable if configured)
- C. It converts the packet into an unencrypted HTTP request
- D. It permanently disables the ingress physical switch port

Correct Answer: B

Concept & Rationale: When a rule action is 'Deny', matching packets are discarded by the firewall. Depending on configuration, the firewall may silently drop the packet or generate an active reset (TCP RST) or ICMP unreachable notification.

Question 139

Topic: Custom Security Zone Priority Range

Type: Single Choice

What is the valid priority range for creating custom user-defined security zones on a Huawei firewall?

- A. 0 to 255
- B. 1 to 100 (excluding priorities already assigned to active zones)
- C. 100 to 1000
- D. Only priorities 10, 20, 30, and 40

Correct Answer: B

Concept & Rationale: Custom security zones can be configured with priority values between 1 and 100. By default, priorities cannot overlap with existing zones (e.g., default priorities 5, 50, 85, 100 are already reserved).

Question 140

Topic: Security Policy Rule Optimization

Type: Single Choice

Why is it best practice to place specific, high-frequency rules near the top of the security policy list?

- A. To prevent the firewall's flash storage from fragmenting
- B. Because top-down matching stops upon the first match; placing high-volume rules early minimizes CPU processing and matching latency
- C. Because lower rules are permanently ignored after 5:00 PM
- D. To automatically encrypt all low-priority traffic

Correct Answer: B

Concept & Rationale: Since firewalls evaluate rules sequentially, placing rules for frequent traffic near the top reduces the number of rule comparisons the CPU must perform before finding a match, optimizing forwarding throughput.

Question 141

Topic: Session Table Inspection Command

Type: Single Choice

Which Huawei VRP CLI command displays the active session table on a USG series firewall?

- A. display current-configuration
- B. display firewall session-table
- C. display ip routing-table
- D. display mac-address

Correct Answer: B

Concept & Rationale: The command `display firewall session-table` displays active connection states, 5-tuples, zones, and timers currently tracked by the firewall.

Question 142

Topic: Session Table 'verbose' Keyword

Type: Single Choice

What additional information is displayed when executing `display firewall session table verbose` on a Huawei firewall?

- A. The physical MAC address of the firewall manufacturer
- B. Detailed session attributes including ingress/egress interfaces, zone IDs, application IDs, packet/byte counters, and NAT translation details
- C. The cleartext passwords of all domain administrators
- D. The internal CPU register assembly code

Correct Answer: B

Concept & Rationale: The `verbose` keyword expands the session display to show detailed flow parameters: application identification, NAT translations, input/output interface, TTL/aging timers, zone mappings, and packet/byte counters.

Question 143

Topic: Stateful Inspection Security Benefit

Type: Single Choice

Why is stateful inspection superior to simple packet filtering in defending against external network scans?

- A. Stateful inspection automatically doubles the link bandwidth
- B. It permits return traffic only if it matches an existing session initiated from the inside, blocking unsolicited external packets without broad inbound port openings
- C. It translates all external IP addresses into private addresses
- D. It replaces all external routers with optical splitters

Correct Answer: B

Concept & Rationale: Because stateful firewalls track connection states, return traffic for an internally initiated connection is automatically permitted via the session table. Inbound unsolicited connection attempts from the outside are dropped unless explicitly permitted by policy.

Question 144

Topic: FTP Control Session Port

Type: Single Choice

When an internal client accesses an external FTP server, the initial control session is established to which destination port?

- A. TCP port 20
- B. TCP port 21
- C. UDP port 69
- D. TCP port 22

Correct Answer: B

Concept & Rationale: FTP control commands (USER, PASS, PORT, PASV) are transmitted over TCP port 21. Data connections use port 20 (Active mode) or negotiated dynamic ports (Passive mode).

Question 145

Topic: Firewall Policy Schedule

Type: Single Choice

What is the function of associating a 'Time Range' (schedule) with a firewall security policy rule?

- A. To automatically change the firewall's system clock
- B. To activate the security policy rule only during specified dates, days of the week, or hours of the day
- C. To measure the round-trip latency of user packets
- D. To limit user connection durations to exactly 15 seconds

Correct Answer: B

Concept & Rationale: A Time Range schedule allows administrators to restrict the validity of a security rule to specific working hours, weekdays, or promotional periods, automatically deactivating the rule outside the designated window.

Question 146**Topic:** Address Object Set**Type:** Single Choice

What is the administrative benefit of defining an 'Address Set' object and referencing it within security policies?

- A. It allows multiple IP addresses or subnets to be managed collectively, simplifying policy rules and ongoing maintenance
- B. It eliminates the need for subnet masks across all enterprise servers
- C. It forces all referenced IP addresses to use identical MAC addresses
- D. It converts private IP addresses directly into public DNS domain names

Correct Answer: A

Concept & Rationale: Address Sets group multiple IP addresses, ranges, or subnets into a single logical object. When IP addresses change, updating the object automatically updates all associated security policies without modifying individual rules.

Question 147**Topic:** Service Object Group**Type:** Single Choice

What information is encapsulated within a custom 'Service Object' on a Huawei firewall?

- A. The physical location and room number of a server
- B. Transport protocol (TCP/UDP/ICMP) and source/destination port ranges
- C. The monthly billing cost of an enterprise application
- D. The firmware revision of connected switches

Correct Answer: B

Concept & Rationale: A Service Object defines network protocols and port parameters (e.g., protocol TCP, destination port 8080-8088), allowing custom enterprise applications to be referenced cleanly in security policies.

Question 148**Topic:** Application Identification (SA)**Type:** Single Choice

How does Huawei NGFW Service Awareness (SA) identify network applications regardless of the port number used?

- A. By reading the destination port number only
- B. Through deep packet inspection (DPI) analyzing application-layer packet payload signatures and behavioral features
- C. By contacting the software developer over the telephone
- D. By randomly assigning application names based on IP addresses

Correct Answer: B

Concept & Rationale: Huawei NGFW employs Deep Packet Inspection (DPI) and behavioral heuristics to inspect application-layer payloads and protocol handshakes, accurately identifying applications (e.g., BitTorrent, WeChat, Facebook) even when they run over non-standard ports or port 80/443.

Question 149

Topic: Security Policy Counter Feature

Type: Single Choice

Why would an administrator enable the 'traffic statistics' (counter) feature on a security policy rule?

- A. To calculate employee salaries based on bandwidth usage
- B. To verify if the policy rule is actually matching traffic and monitor the volume of permitted/denied packets and bytes
- C. To permanently store all transmitted files in the cloud
- D. To disable the rule automatically when traffic reaches 100 megabytes

Correct Answer: B

Concept & Rationale: Policy counters track the number of matching packets and bytes. This is crucial for verifying policy effectiveness, troubleshooting rule ordering issues, and identifying unused legacy rules for decommissioning.

Question 150

Topic: Management Access Control

Type: Single Choice

How does a firewall regulate administrative access (HTTPS, SSH, Ping) to its own physical interfaces?

- A. Management traffic to the firewall interface terminates in the Local zone and is controlled via interface access management or Local zone security policies
- B. Management access is permitted automatically on all interfaces without restriction
- C. Management traffic cannot be processed by firewalls
- D. By disabling all IP routing on management ports

Correct Answer: A

Concept & Rationale: Interface management services (Ping, SSH, HTTPS, NETCONF) are governed by interface access management settings and security policies between the originating zone (e.g., Trust) and the Local zone (priority 100).

Question 151

Topic: Intra-Zone Traffic Security Policy

Type: Single Choice

If an administrator desires to block communication between two departments whose interfaces reside in the same Trust zone, what must be done?

- A. The firewall hardware must be replaced with two physical firewalls
- B. An intra-zone security policy with the action 'Deny' must be configured, or intra-zone inter-interface filtering must be enabled
- C. Intra-zone traffic can never be blocked under any circumstances
- D. All departmental PCs must be powered off

Correct Answer: B

Concept & Rationale: Although intra-zone traffic is permitted by default, administrators can enforce security by creating explicit intra-zone security policies (Source Zone: Trust, Destination Zone: Trust) with 'Deny' actions or enabling intra-zone packet filtering.

Question 152

Topic: Stateful Firewall and Asymmetric Routing

Type: Single Choice

What issue arises when asymmetric routing causes outbound packets to traverse Firewall A but return packets to traverse Firewall B?

- A. Firewall B drops the return packets because it lacks an existing session table entry for the connection
- B. Firewall A immediately powers off its cooling fans
- C. The client's network interface card is permanently damaged
- D. The destination server sends duplicate SYN packets indefinitely

Correct Answer: A

Concept & Rationale: In asymmetric routing, Firewall B receives return packets without having seen the initial SYN packet that creates the session. Because stateful detection is enabled, Firewall B drops the unsolicited return packet as an invalid state transition unless session synchronization or stateful inspection exceptions are configured.

Question 153

Topic: Session Table Limit

Type: Single Choice

What happens when a firewall's session table reaches its maximum hardware capacity during a severe connection flood?

- A. The firewall begins formatting its hard drives
- B. New connection requests cannot be established and are discarded, resulting in denial of service for new users
- C. The firewall converts all TCP traffic into unencrypted UDP broadcasts
- D. Existing established sessions are immediately deleted

Correct Answer: B

Concept & Rationale: The session table has a finite maximum capacity dictated by available memory. When full, the firewall cannot allocate new session entries, causing all subsequent new connection requests to be dropped.

Question 154

Topic: Disabling Stateful Inspection

Type: Single Choice

If stateful inspection is globally disabled on a firewall interface, how does the firewall behave?

- A. It functions like a stateless packet filter, requiring explicit policy rules for both forward and return traffic flows
- B. It permanently blocks 100% of all IP traffic
- C. It automatically encrypts all traffic using IPsec
- D. It forwards all packets exclusively to the DMZ zone

Correct Answer: A

Concept & Rationale: When stateful inspection is disabled, the firewall stops creating session tables. It evaluates every single packet in isolation like a traditional stateless packet filter, requiring administrators to write explicit rules for both forward request and return response traffic.

Question 155**Topic:** Security Policy Profile Association**Type:** Single Choice

In Huawei NGFWs, which security features are attached to a permitted security policy rule as 'Security Profiles'?

- A. Antivirus, IPS, URL Filtering, File Filtering, Content Filtering, and Mail Filtering
- B. BGP, OSPF, RIP, and IS-IS routing tables
- C. DHCP Server address pool ranges and lease timers
- D. Interface physical duplex and speed settings

Correct Answer: A

Concept & Rationale: Security Profiles (IPS, Antivirus, URL Filtering, File/Content Filtering, Application Control) are bound to 'Permit' security policy rules to perform deep Layer 7 content inspection on traffic that passes basic 5-tuple filtering.

Question 156**Topic:** Policy Logging Best Practice**Type:** Single Choice

Why is it recommended to enable session logging only on specific critical policies rather than logging every single permitted packet in high-throughput environments?

- A. Because logging is prohibited by international networking RFCs
- B. To avoid exhausting firewall CPU, disk I/O, and log server storage caused by billions of routine session logs
- C. Because session logs contain unencrypted passwords
- D. To prevent the firewall from generating IP routing updates

Correct Answer: B

Concept & Rationale: Generating logs for every permitted connection in a multi-gigabit data center creates massive CPU overhead and storage exhaustion. Best practice is to log denied traffic, threat alerts, and critical business policies.

5 Chapter 5: Firewall NAT Technologies

Question 157**Topic:** NAT Purpose - Primary Driver**Type:** Single Choice

What was the primary initial driver for the invention and widespread adoption of Network Address Translation (NAT)?

- A. To increase the physical clock speed of network switches
- B. To mitigate the rapid exhaustion of the public IPv4 address space
- C. To eliminate the need for routing tables in wide area networks
- D. To encrypt all web traffic using SSL/TLS

Correct Answer: B

Concept & Rationale: The rapid depletion of the 32-bit IPv4 address space was the primary catalyst for NAT, enabling multiple private internal hosts to share one or a few public IP addresses for Internet access.

Question 158

Topic: NAT Classification - No-PAT

Type: Single Choice

In which type of Source NAT is only the private IP address translated to a public IP address from a pool, WITHOUT translating transport layer port numbers?

- A. NAPT
- B. NAT No-PAT
- C. Easy IP
- D. Smart NAT

Correct Answer: B

Concept & Rationale: NAT No-PAT (No Port Address Translation) performs 1-to-1 IP address translation without modifying source port numbers. The number of concurrent external connections is strictly limited to the number of public IPs in the address pool.

Question 159

Topic: NAT No-PAT Concurrency Limit

Type: Single Choice

If an enterprise configures a NAT No-PAT address pool containing 5 public IPv4 addresses, how many internal hosts can concurrently access the Internet simultaneously?

- A. 5 hosts
- B. 500 hosts
- C. 65,535 hosts
- D. Unlimited hosts

Correct Answer: A

Concept & Rationale: Because NAT No-PAT does not multiplex sessions using transport layer port numbers, each concurrent internal host requires a dedicated public IP address. Thus, 5 public IPs can support at most 5 concurrent hosts.

Question 160

Topic: NAT Classification - NAPT

Type: Single Choice

Which Source NAT technology translates both the private IP address and the source port number into a public IP address and a unique public port number?

- A. NAT No-PAT
- B. NAPT (Network Address Port Translation)
- C. NAT Server
- D. Static 1-to-1 NAT

Correct Answer: B

Concept & Rationale: NAPT translates both source IP addresses and source port numbers. By mapping internal sockets (IP:Port) to public sockets, thousands of internal hosts can simultaneously share a single public IP address.

Question 161

Topic: NAT Classification - Easy IP

Type: Single Choice

What is the defining characteristic of the Easy IP translation technology in Huawei firewalls?

- A. It requires a pre-allocated pool of at least 16 public IP addresses
- B. It directly utilizes the public IP address configured on the firewall's egress interface for translation, eliminating the need for an address pool
- C. It translates destination IP addresses exclusively for database servers
- D. It disables stateful session table creation

Correct Answer: B

Concept & Rationale: Easy IP is a specialized form of NAT that uses the public IP address dynamically or statically assigned to the firewall's egress interface. It requires no address pool configuration, making it ideal for PPPoE dial-up or DHCP WAN connections.

Question 162

Topic: Easy IP Ideal Deployment Scenario

Type: Single Choice

For which network environment is Easy IP predominantly recommended?

- A. Data centers hosting 500 public-facing web servers
- B. Small office / home office (SOHO) or enterprise branch locations with dynamic WAN IP addresses obtained via PPPoE or DHCP
- C. Internal corporate subnets communicating with isolated DMZ servers
- D. Core ISP backbones routing BGP full tables

Correct Answer: B

Concept & Rationale: Because SOHO and branch networks frequently obtain dynamic, changing public IP addresses from ISPs via DHCP or PPPoE, Easy IP automatically tracks the interface IP without requiring static address pool adjustments.

Question 163

Topic: Smart NAT Operational Behavior

Type: Single Choice

How does Smart NAT operate on a Huawei firewall when the public IP address pool is under heavy load?

- A. It drops all new incoming and outgoing packets immediately
- B. It initially performs 1-to-1 No-PAT translation; when pool addresses are exhausted, it uses a reserved public IP to perform NAT for remaining hosts
- C. It reboots the firewall into recovery mode
- D. It converts all TCP sessions into unencrypted UDP broadcasts

Correct Answer: B

Concept & Rationale: Smart NAT combines No-PAT and NAT. High-priority or initial users receive dedicated 1-to-1 No-PAT translations from the pool. When available IPs run out, a designated reserved IP in the pool performs NAT for all remaining hosts.

Question 164

Topic: NAT Server Primary Function

Type: Single Choice

What is the primary function of the 'NAT Server' feature on a Huawei firewall?

- A. To translate internal client source IPs when browsing external websites
- B. To statically map a public IP address and port to an internal server's private IP address and port, allowing Internet users to access intranet servers
- C. To provide automatic DHCP address leases to local PCs
- D. To act as an authoritative DNS root nameserver

Correct Answer: B

Concept & Rationale: NAT Server (Destination NAT with port mapping) publishes intranet servers to the Internet. It maps public IP:Port combinations to private server IP:Port combinations, enabling external users to reach internal web, mail, or FTP servers.

Question 165

Topic: NAT Server Table Generation

Type: Single Choice

Which forwarding table entry is automatically created when a 'NAT Server' rule is configured on a Huawei firewall?

- A. A dynamic ARP table entry
- B. A static Server-Map table entry
- C. A BGP routing table entry
- D. An OSPF link-state advertisement

Correct Answer: B

Concept & Rationale: Configuring a `nat server` rule automatically creates a permanent, static Server-Map table entry that stores the mapping between the public IP/port and private IP/port.

Question 166

Topic: Bidirectional NAT - Scenario 1

Type: Single Choice

Which NAT technique simultaneously translates BOTH the source IP address and destination IP address of the same packet?

- A. NAT No-PAT
- B. Easy IP
- C. Bidirectional NAT
- D. NAT ALG

Correct Answer: C

Concept & Rationale: Bidirectional NAT performs Source NAT and Destination NAT concurrently on a single packet flow. It is essential when internal hosts access internal servers using the server's public IP (NAT hairpinning) or to prevent asymmetric routing.

Question 167

Topic: NAT Hairpinning / Loopback Problem

Type: Single Choice

When an intranet client attempts to access an intranet server using the server's public IP address without Bidirectional NAT, why does the connection fail?

- A. The server replies directly to the client's private IP, causing the client to discard the response due to socket address mismatch
- B. The firewall physically powers off its egress interface
- C. The DNS server refuses to resolve domain names ending in .com
- D. The Ethernet frame size exceeds 9000 bytes

Correct Answer: A

Concept & Rationale: When Destination NAT translates the public IP to the server's private IP, the server receives a packet with the client's private source IP. The server replies directly via the local switch to the client's private IP. The client, expecting a reply from the public IP, drops the packet because the source socket does not match.

Question 168

Topic: NAT Hairpinning Solution with SNAT

Type: Single Choice

How does Bidirectional NAT resolve the NAT hairpinning problem for intranet clients accessing intranet servers via public IP?

- A. It translates the destination IP to the server's private IP AND translates the client's source IP to a firewall interface IP
- B. It forces all traffic to route across the public Internet to the ISP before returning
- C. It disables TCP checksum validation on the server
- D. It converts all HTTP requests to FTP downloads

Correct Answer: A

Concept & Rationale: By applying Destination NAT (public server IP -> private server IP) and Source NAT (client private IP -> firewall IP), the server replies back to the firewall. The firewall reverses both translations and sends the reply to the client from the expected public IP.

Question 169

Topic: NAT ALG - Multi-Channel Problem

Type: Single Choice

Why is standard NAT incapable of successfully translating multi-channel protocols like FTP active mode without an Application Level Gateway (ALG)?

- A. FTP packets are encrypted using 4096-bit RSA keys
- B. Standard NAT translates only IP/port headers; it cannot inspect or modify IP addresses and port numbers embedded inside the application-layer payload (e.g. PORT commands)
- C. FTP cannot operate over IPv4 networks
- D. Standard NAT automatically deletes all files being transferred

Correct Answer: B

Concept & Rationale: Standard NAT rewrites Layer 3 IP headers and Layer 4 TCP/UDP headers. In FTP active mode, the client transmits its private IP and data port as text inside the application-layer payload (PORT h1,h2,h3,h4,p1,p2). Without ALG, the server attempts to connect to the unreachable private IP.

Question 170

Topic: NAT ALG Operational Mechanism

Type: Single Choice

What actions does a NAT ALG perform when inspecting an FTP active mode control connection?

- A. It translates the private IP and port embedded inside the application payload to the public IP/port AND creates a dynamic Server-Map entry for the data connection
- B. It blocks the connection and alerts the domain administrator
- C. It converts the FTP transfer into an email attachment
- D. It forces the client to use Telnet instead

Correct Answer: A

Concept & Rationale: NAT ALG parses the application payload, rewrites the embedded IP/port string to the corresponding public IP/port, and generates a dynamic Server-Map entry to allow the server's incoming data connection through the firewall.

Question 171

Topic: NAT Blackhole Route Purpose

Type: Single Choice

What is the primary technical reason for configuring a NAT Blackhole Route (`ip route-static <pool-ip> 32 NULL0`) on a Huawei firewall?

- A. To prevent routing loops between the firewall and upstream ISP gateway when packets arrive for unused addresses in the NAT pool
- B. To permanently delete all infected malware files
- C. To prevent internal users from accessing social media websites
- D. To test the maximum bandwidth throughput of the firewall backplane

Correct Answer: A

Concept & Rationale: If public address pool IPs are not assigned to the firewall interface, an incoming packet destined to an idle pool IP is bounced between the upstream ISP router (which routes the pool to the firewall) and the firewall (which has a default route back to the ISP), creating an infinite routing loop. A blackhole route drops the packet immediately.

Question 172

Topic: NAT Address Pool Configuration Command

Type: Single Choice

Which Huawei VRP CLI command creates an address pool for Source NAT?

- A. `nat address-group <group-number> <start-ip> <end-ip>`
- B. `ip pool <name>`
- C. `dhcp server ip-pool`
- D. `firewall nat-pool create`

Correct Answer: A

Concept & Rationale: In Huawei firewalls, the command `nat address-group <group-id> <start-ip> <end-ip>` (or in newer USG models `nat address-group <name>`) defines the pool of public IPv4 addresses available for translation.

Question 173

Topic: NAT Policy Matching Sequence

Type: Single Choice

In what order are rules evaluated within a Huawei firewall's NAT Policy rulebase?

- A. Alphabetical order by rule name
- B. Top-to-bottom sequential matching; the first matching rule is executed and matching terminates
- C. Bottom-to-top reverse matching
- D. Random selection based on CPU load

Correct Answer: B

Concept & Rationale: Similar to security policies, NAT policies are evaluated sequentially from top to bottom. Once a packet matches a NAT rule's conditions, the translation action is executed and evaluation stops.

Question 174

Topic: NAT Policy Action - No-NAT

Type: Single Choice

What is the purpose of configuring a NAT policy rule with the action 'no-nat' on a Huawei firewall?

- A. To disable the firewall's routing engine
- B. To exempt specific traffic (such as branch-to-branch IPsec VPN traffic) from undergoing NAT translation
- C. To format the firewall's solid-state drive
- D. To force all traffic to be logged in cleartext

Correct Answer: B

Concept & Rationale: When an enterprise establishes an IPsec tunnel between branches, traffic between internal private subnets must not be translated to public IPs. A high-priority 'no-nat' rule exempts VPN traffic from standard Internet Source NAT.

Question 175

Topic: Destination NAT vs NAT Server

Type: Single Choice

How does general Destination NAT differ from NAT Server in Huawei firewall configuration?

- A. NAT Server statically maps specific public ports to specific private servers, whereas general Destination NAT translates destination IPs to a pool of addresses (often with port preservation or load balancing)
- B. Destination NAT only works for IPv6 packets
- C. NAT Server works only when the firewall is powered off
- D. There is no difference; they are exact synonyms

Correct Answer: A

Concept & Rationale: NAT Server provides 1-to-1 static port and IP mapping for publishing internal servers. General Destination NAT maps traffic destined for public IPs to an internal address pool, commonly utilized for server farm load balancing.

Question 176

Topic: Port Overloading in NAT

Type: Single Choice

Approximately how many concurrent translation sessions can theoretically be supported per public IPv4 address in NAT?

- A. Only 1 session
- B. Approximately 60,000 to 64,000 concurrent sessions (bounded by 16-bit transport port range)
- C. Exactly 256 sessions
- D. Unlimited sessions without memory usage

Correct Answer: B

Concept & Rationale: Transport layer source ports are 16-bit integers (ports 1024 to 65535, minus reserved ports), allowing roughly 60,000 concurrent translated flows per transport protocol per public IP address.

Question 177

Topic: NAT No-PAT Address Release

Type: Single Choice

In NAT No-PAT, when is a public IP address released back to the address pool for another internal host to use?

- A. Never; once assigned, it is permanently locked to that host MAC
- B. When all session table entries for that internal host expire or age out
- C. Every 60 seconds regardless of active traffic
- D. Only when the firewall is manually rebooted

Correct Answer: B

Concept & Rationale: In No-PAT, a public IP is allocated to an internal host and mapped in the Server-Map table. When all active connection sessions for that host terminate and the Server-Map aging timer expires, the public IP returns to the free pool.

Question 178

Topic: NAT Multipool Use Case

Type: Single Choice

Why would an enterprise deploy NAT Multipool configuration on a border firewall?

- A. To map different internal departments or user groups to distinct public IP address pools for traffic separation, auditing, and QoS
- B. To allow internal users to share identical MAC addresses
- C. To replace BGP routing across multiple ISPs
- D. To convert copper Ethernet interfaces into optical ports

Correct Answer: A

Concept & Rationale: NAT Multipool allows an enterprise to direct traffic from different departments, guest Wi-Fi networks, or business units to separate public IP address pools, enabling granular billing, ISP policy routing, and security isolation.

Question 179

Topic: NAT Session Table Display

Type: Single Choice

Which command displays the active NAT translation mappings and session details on a Huawei USG firewall?

- A. display firewall session table verbose
- B. display ip interface brief
- C. display version
- D. display device

Correct Answer: A

Concept & Rationale: Executing `display firewall session table verbose` displays detailed session records, including the original 5-tuple and the translated NAT 5-tuple (-> translation indicators).

Question 180

Topic: NAT Server Configuration Syntax

Type: Single Choice

In Huawei VRP CLI, which command correctly configures a static NAT Server rule publishing an internal web server?

- A. nat server protocol tcp global 203.0.113.10 80 inside 192.168.1.100 80
- B. firewall web publish 203.0.113.10 to 192.168.1.100
- C. ip route-static 203.0.113.10 32 192.168.1.100
- D. nat address-group 1 203.0.113.10 192.168.1.100

Correct Answer: A

Concept & Rationale: The standard Huawei VRP command syntax is: `nat server [zone <zone>] protocol tcp global <public-ip> <public-port> inside <private-ip> <private-port>`.

Question 181

Topic: NAT ALG Enabled Protocols by Default

Type: Single Choice

On many Huawei firewalls, for which protocol is NAT ALG typically enabled by default due to its widespread operational necessity?

- A. FTP
- B. BGP
- C. RIP
- D. OSPF

Correct Answer: A

Concept & Rationale: FTP is the classic multi-channel protocol with ubiquitous enterprise usage; firewalls commonly have FTP ALG enabled by default (`firewall detect ftp`).

Question 182

Topic: Source IP vs Destination IP Translation

Type: Single Choice

When an internal host (192.168.1.10) browses an external website (93.184.216.34) through Source NAT (public IP 203.0.113.5), what does the packet header look like as it leaves the firewall's egress interface?

- A. Source IP: 192.168.1.10, Destination IP: 203.0.113.5
- B. Source IP: 203.0.113.5, Destination IP: 93.184.216.34
- C. Source IP: 93.184.216.34, Destination IP: 192.168.1.10
- D. Source IP: 203.0.113.5, Destination IP: 192.168.1.10

Correct Answer: B

Concept & Rationale: Source NAT replaces the private source IP (192.168.1.10) with the public IP (203.0.113.5). The destination IP remains the external web server's IP (93.184.216.34).

Question 183

Topic: Destination NAT Packet Header

Type: Single Choice

When an external client (198.51.100.25) accesses an internal web server published via NAT Server (public IP 203.0.113.10 -> private IP 192.168.1.100), what does the packet header look like after leaving the firewall towards the server?

- A. Source IP: 198.51.100.25, Destination IP: 192.168.1.100
- B. Source IP: 203.0.113.10, Destination IP: 192.168.1.100
- C. Source IP: 192.168.1.100, Destination IP: 198.51.100.25
- D. Source IP: 198.51.100.25, Destination IP: 203.0.113.10

Correct Answer: A

Concept & Rationale: NAT Server performs Destination NAT: the destination IP is translated from the public address (203.0.113.10) to the internal private address (192.168.1.100). The original client source IP (198.51.100.25) is preserved.

Question 184

Topic: Bidirectional NAT Header Translation

Type: Single Choice

In Bidirectional NAT, after translation by the firewall, what happens to both Source and Destination IP fields?

- A. Neither field is modified
- B. Both the Source IP and Destination IP addresses are rewritten to new values
- C. Only the TCP checksum is recalculated without IP changes
- D. The packet is converted to an unroutable broadcast frame

Correct Answer: B

Concept & Rationale: In Bidirectional NAT, the firewall translates the Source IP (e.g., from client private IP to firewall interface IP) AND translates the Destination IP (from public server IP to private server IP) simultaneously.

Question 185

Topic: Server-Map Entry for NAT No-PAT

Type: Single Choice

Why does NAT No-PAT generate a Server-Map entry upon the first packet translation?

- A. To track the 1-to-1 mapping between the private host IP and assigned public pool IP, ensuring subsequent inbound or outbound packets from that host use the same public IP
- B. To permanently disable all firewall security policies for that host
- C. To record the user's keystrokes for forensic logging
- D. To translate the host's operating system language

Correct Answer: A

Concept & Rationale: NAT No-PAT creates a dynamic Server-Map entry binding the host's private IP to the allocated public IP. This ensures all concurrent flows from that host share the identical public IP and permits incoming sessions if configured.

Question 186

Topic: NAT Policy vs Security Policy Processing Order

Type: Single Choice

On a Huawei firewall processing an OUTBOUND packet from Trust to Untrust with Source NAT, what is the correct processing order between Security Policy and NAT Policy?

- A. The packet is translated by NAT Policy first, and then matches Security Policy based on the translated public IP
- B. The packet matches Security Policy first based on its original private IP; if permitted, it is then processed by NAT Policy for source translation
- C. Security Policy and NAT Policy are evaluated by separate physical processors at the same time
- D. NAT Policy is evaluated only after the packet reaches the destination web server

Correct Answer: B

Concept & Rationale: On outbound flows, the firewall first checks Security Policy against the original private source IP and destination IP. If traffic is permitted, the packet enters the NAT pipeline where Source NAT translates the source IP address.

Question 187

Topic: Inbound Traffic Policy Processing Order

Type: Single Choice

When an external Internet user accesses an internal server published via NAT Server, what is the processing order between Destination NAT and Security Policy?

- A. Security Policy is evaluated using the public IP; destination translation never occurs
- B. Destination NAT translation occurs first (or server-map matches), and the Security Policy is evaluated using the translated private IP address
- C. Security Policy is bypassed completely for all inbound traffic
- D. The packet is held in storage for 24 hours before inspection

Correct Answer: B

Concept & Rationale: For inbound traffic targeting a NAT Server, destination translation (Server-Map matching) occurs before security policy evaluation. Therefore, the security policy rule permitting inbound traffic must specify the internal private IP address of the server as the destination!

Question 188

Topic: NAT Table Capacity Impact

Type: Single Choice

What impact does running heavy NAT translation have on a firewall's hardware resources?

- A. It has zero impact because translation is done on the client NIC
- B. It consumes CPU cycles for port allocation/checksum recalculation and memory for maintaining stateful session and NAT mapping tables
- C. It permanently damages the optical fiber transceivers
- D. It reduces the physical storage capacity of the hard drive

Correct Answer: B

Concept & Rationale: NAT requires tracking port states, rewriting IP/TCP/UDP headers, recalculating checksums, and managing session memory, imposing higher compute and memory overhead than stateless routing.

Question 189

Topic: NAT IPsec Incompatibility (AH)

Type: Single Choice

Why is the IPsec Authentication Header (AH) protocol fundamentally incompatible with NAT?

- A. AH uses 56-bit DES encryption
- B. AH calculates its cryptographic integrity check value (ICV) over the entire IP packet including the outer IP header; NAT alters IP addresses, causing AH integrity verification to fail
- C. AH operates only over dial-up telephone lines
- D. AH packets cannot be routed across Ethernet switches

Correct Answer: B

Concept & Rationale: AH provides data integrity by hashing the entire packet, including IP source and destination addresses. When NAT translates an IP address, the receiver's computed hash fails to match the transmitted ICV, causing the packet to be dropped.

Question 190

Topic: NAT Traversal (NAT-T) Solution

Type: Single Choice

How does NAT Traversal (NAT-T) resolve the problem of passing IPsec ESP traffic through a NAT router/firewall?

- A. By converting the entire packet into cleartext HTTP
- B. By encapsulating the IPsec ESP packet inside a UDP header using port 4500, allowing NAT devices to translate ports normally
- C. By disabling encryption on the IPsec tunnel
- D. By forcing the NAT router to adopt an IPv6 address

Correct Answer: B

Concept & Rationale: Because standard ESP lacks transport layer ports, NAT devices cannot translate multiple ESP streams. NAT-T encapsulates ESP packets inside UDP datagrams using port 4500, enabling standard NAT port translation and preserving encryption integrity.

Question 191

Topic: NAT Address Group Mode - No-PAT Keyword

Type: Single Choice

In Huawei VRP CLI, which keyword is appended to the address group configuration to enforce 1-to-1 translation without port multiplexing?

- A. pat
- B. no-pat
- C. easy-ip
- D. smart

Correct Answer: B

Concept & Rationale: In Huawei firewall configuration, the keyword **no-pat** (e.g., `section 0 203.0.113.10 203.0.113.20 no-pat`) specifies that the address pool operates in No-PAT mode.

Question 192

Topic: NAT Server 'no-reverse' Keyword

Type: Single Choice

What is the effect of configuring the **no-reverse** keyword in a Huawei **nat server** declaration?

- A. It prevents the firewall from generating a reverse Server-Map entry, ensuring internal server outbound connections do not automatically use this public IP
- B. It disables the server's network adapter
- C. It blocks all inbound traffic to the server
- D. It reverses the polarity of the Ethernet cable

Correct Answer: A

Concept & Rationale: By default, **nat server** creates forward and reverse mappings. When the internal server initiates outbound connections, it is translated to the public server IP. The **no-reverse** keyword disables reverse translation, allowing outbound server traffic to match general Internet NAT policies.

Question 193

Topic: Dynamic NAT vs Static NAT

Type: Single Choice

What is the primary operational difference between Static NAT and Dynamic NAT?

- A. Static NAT establishes a permanent, fixed 1-to-1 mapping between a private IP and public IP, whereas Dynamic NAT assigns public IPs dynamically from a pool on a first-come, first-served basis
- B. Static NAT only works during daytime hours
- C. Dynamic NAT requires unshielded twisted pair copper cabling
- D. Static NAT disables firewall routing capabilities

Correct Answer: A

Concept & Rationale: Static NAT maps a specific private IP to a specific public IP permanently. Dynamic NAT draws public IPs dynamically from an address pool when active traffic arrives, releasing them when connections expire.

Question 194

Topic: NAT Loopback Prevention

Type: Single Choice

Why is Bidirectional NAT commonly configured on the DMZ interface for internal users accessing intranet servers?

- A. To ensure the internal server sends return packets back through the firewall rather than directly across the local switch to the client
- B. To force all traffic to be logged by the ISP
- C. To accelerate DNS resolution speed
- D. To convert TCP packets into SCTP format

Correct Answer: A

Concept & Rationale: Translating the client's source IP to a firewall interface IP forces the server to return packets to the firewall. The firewall untranslates both source and destination IPs, ensuring the client receives return packets matching its original public destination IP.

Question 195

Topic: Twice NAT Concept

Type: Single Choice

In industry terminology, what is 'Twice NAT' another name for?

- A. Applying NAT twice in series across two separate firewalls
- B. Bidirectional NAT (translating both source and destination addresses on the same device simultaneously)
- C. Translating only the TCP sequence numbers
- D. Formatting the firewall configuration twice

Correct Answer: B

Concept & Rationale: Twice NAT is standard industry terminology for Bidirectional NAT, where an appliance rewrites both the source and destination IP addresses of a single packet flow.

Question 196

Topic: Display NAT Address Group Command

Type: Single Choice

Which command is used on a Huawei firewall to verify configured NAT address groups and their utilization?

- A. display nat address-group
- B. display ip pool
- C. display current-nat
- D. display memory nat

Correct Answer: A

Concept & Rationale: The command `display nat address-group` displays configured NAT address pools, start/end IP addresses, assigned modes (PAT or No-PAT), and current IP allocation status.

Question 197

Topic: NAT ALG Supported Multi-Media Protocol

Type: Single Choice

Which of the following multimedia signaling protocols requires NAT ALG on firewalls to negotiate audio/video RTP streaming channels across NAT boundaries?

- A. SIP (Session Initiation Protocol)
- B. SNMP
- C. NTP
- D. Syslog

Correct Answer: A

Concept & Rationale: SIP embeds private IP addresses and dynamic RTP media ports inside its Session Description Protocol (SDP) payload. A SIP ALG translates these embedded addresses and creates Server-Map pinholes for the voice/video media streams.

Question 198

Topic: Address Pool Overlap Warning

Type: Single Choice

What happens if an administrator configures a NAT address pool with an IP range that overlaps with the IP assigned to an active interface on the firewall?

- A. The firewall will produce a configuration error or warning because overlapping IP assignments cause ARP and routing conflicts
- B. The firewall automatically doubles the interface speed to compensate
- C. All firewall interfaces are permanently disabled
- D. The firewall converts into a wireless access point

Correct Answer: A

Concept & Rationale: Public address pool IPs must not conflict with interface IPs unless Easy IP is explicitly configured. Overlapping addresses cause IP conflicts and ARP broadcast anomalies.

6 Chapter 6: Firewall Hot Standby Technologies

Question 199

Topic: HA Uptime Standard

Type: Single Choice

In enterprise high availability (HA) network design, what availability percentage is commonly known as 'five nines' availability?

- A. 99.000%
- B. 99.900%
- C. 99.999%
- D. 99.9999%

Correct Answer: C

Concept & Rationale: 'Five nines' refers to 99.999% system availability, allowing at most approximately 5.26 minutes of unscheduled downtime per year across enterprise services.

Question 200

Topic: VRRP RFC Standard

Type: Single Choice

Virtual Router Redundancy Protocol (VRRP) is standard protocol defined by which standards body?

- A. IEEE 802.3
- B. IETF (RFC 3768 / RFC 5798)
- C. ITU-T X.509
- D. ISO 27001

Correct Answer: B

Concept & Rationale: VRRP is an open industry standard protocol defined by the Internet Engineering Task Force (IETF) in RFC 3768 (VRRPv2) and RFC 5798 (VRRPv3) to provide gateway redundancy.

Question 201

Topic: VRRP Virtual MAC Format

Type: Single Choice

What is the standard format of a VRRP Virtual MAC address for an IPv4 VRRP group with VRID 1?

- A. 00-E0-FC-00-00-01
- B. 00-00-5E-00-01-01
- C. FF-FF-FF-FF-FF-01
- D. 01-00-5E-00-01-01

Correct Answer: B

Concept & Rationale: The standard VRRP IPv4 Virtual MAC format is 00-00-5E-00-01-XX, where the last byte XX represents the VRID in hexadecimal. For VRID 1, the Virtual MAC is 00-00-5E-00-01-01.

Question 202

Topic: VRRP Default Priority

Type: Single Choice

What is the default priority value assigned to a router participating in a standard VRRP group?

- A. 1
- B. 50
- C. 100
- D. 255

Correct Answer: C

Concept & Rationale: The default VRRP priority is 100. Configurable priorities range from 1 to 254. Priority 255 is automatically reserved for the router that owns the actual physical IP address matching the Virtual IP.

Question 203

Topic: VRRP Advertisement Interval

Type: Single Choice

By default, at what interval does the VRRP Master router broadcast VRRP Advertisement packets?

- A. 100 milliseconds
- B. 1 second
- C. 5 seconds
- D. 30 seconds

Correct Answer: B

Concept & Rationale: The default VRRP advertisement interval is 1 second. If the Backup router fails to receive advertisements for three consecutive intervals ($3 * \text{Advertisement_Interval} + \text{Skew_Time}$), it transitions to Master.

Question 204

Topic: VRRP Multicast Destination

Type: Single Choice

What is the standard IPv4 multicast address used by the VRRP Master to send advertisement packets to backup routers?

- A. 224.0.0.1
- B. 224.0.0.2
- C. 224.0.0.18
- D. 224.0.1.1

Correct Answer: C

Concept & Rationale: VRRP protocol advertisements are encapsulated in IP packets (Protocol 112) and transmitted to the dedicated multicast address 224.0.0.18.

Question 205

Topic: Standard VRRP Limitation on Firewalls

Type: Single Choice

What is the primary technical limitation of deploying standard standalone VRRP on multi-interface stateful firewalls?

- A. VRRP cannot run over Ethernet interfaces
- B. VRRP groups on uplink and downlink interfaces operate independently; a failure on the uplink does not trigger a failover on the downlink, creating a routing black hole
- C. VRRP disables all NAT translation features on firewalls
- D. VRRP requires physical serial cables between routers

Correct Answer: B

Concept & Rationale: Standard VRRP operates per-interface independently. If Firewall A's external uplink fails, its internal interface remains VRRP Master. Internal traffic still flows to Firewall A, where it is blackholed because Firewall A has lost its upstream path.

Question 206

Topic: VGMP Definition

Type: Single Choice

What is the VRRP Group Management Protocol (VGMP) on Huawei firewalls?

- A. An open IETF protocol used to configure wireless access points
- B. A Huawei proprietary protocol that manages all VRRP groups on a firewall as a unified entity to coordinate synchronized state switchovers
- C. A protocol used exclusively to update antivirus signature databases
- D. A routing protocol replacing OSPF in data centers

Correct Answer: B

Concept & Rationale: VGMP is a Huawei proprietary protocol that groups all VRRP interfaces (uplink, downlink, DMZ) under a centralized management group, ensuring that when one interface fails, all VRRP groups switch states together.

Question 207

Topic: VGMP Management Groups

Type: Single Choice

In Huawei firewall hot standby, what are the two predefined VGMP management groups?

- A. Active Group and Standby Group
- B. Master Group and Slave Group
- C. Primary Group and Secondary Group
- D. Trust Group and Untrust Group

Correct Answer: A

Concept & Rationale: VGMP provides two management groups: the Active Group (default state is Active) and the Standby Group (default state is Standby).

Question 208

Topic: VGMP Default Priority

Type: Single Choice

What is the default initial priority of both the Active and Standby VGMP management groups on Huawei firewalls?

- A. 100
- B. 1000
- C. 45000
- D. 65000

Correct Answer: D

Concept & Rationale: By default, the initial priority of both the Active VGMP group and the Standby VGMP group is 65000.

Question 209

Topic: VGMP Priority Adjustment on Failure

Type: Single Choice

When a monitored interface on the active firewall goes DOWN, how does VGMP adjust its group priority by default?

- A. It resets the priority to 0
- B. It decrements the VGMP priority (typically by 2) for each failed monitored interface
- C. It doubles the VGMP priority to compensate
- D. It leaves the priority unchanged and reboots the firewall

Correct Answer: B

Concept & Rationale: When an interface tracked by VGMP fails, VGMP reduces its priority value (default reduction is 2). This causes the active firewall's priority (e.g. 64998) to drop below the standby firewall's priority (65000), triggering an immediate switchover.

Question 210

Topic: VGMP Unified Switchover

Type: Single Choice

What occurs across all VRRP groups on a firewall when its VGMP management group transitions from Active to Standby?

- A. All associated VRRP groups switch from Master to Backup simultaneously
- B. All internal network switches lose power
- C. Only the failed interface switches, while others remain unchanged
- D. The firewall formats its configuration disk

Correct Answer: A

Concept & Rationale: Because VGMP centrally controls all member VRRP groups, when the VGMP group changes state, every associated VRRP group (internal, external, DMZ) transitions simultaneously, preventing asymmetric routing black holes.

Question 211

Topic: HRP Definition

Type: Single Choice

What is the primary role of the Huawei Redundancy Protocol (HRP)?

- A. To assign IP addresses to DHCP clients across the WAN
- B. To synchronize configuration commands, session tables, and status information between active and standby firewalls over heartbeat interfaces
- C. To provide public key digital certificate verification
- D. To calculate shortest path trees for OSPF routing

Correct Answer: B

Concept & Rationale: HRP is a Huawei proprietary protocol running over heartbeat links that synchronizes configuration commands (**hrp enable**), dynamic session tables, Server-Map entries, and IPsec SA states between clustered firewalls.

Question 212

Topic: HRP Heartbeat Transport Protocol

Type: Single Choice

Which transport protocol and port number are utilized by HRP heartbeat packets?

- A. TCP port 80
- B. UDP port 18514
- C. TCP port 443
- D. UDP port 500

Correct Answer: B

Concept & Rationale: HRP encapsulates heartbeat packets and synchronization data inside UDP datagrams using destination port 18514.

Question 213

Topic: HRP Synchronized Data Types

Type: Single Choice

Which of the following dynamic state tables is synchronized in real-time by HRP to prevent active TCP sessions from dropping during a failover?

- A. The BGP routing information base (RIB)
- B. The firewall Session Table
- C. The switch STP topology change table
- D. The CPU instruction cache

Correct Answer: B

Concept & Rationale: Real-time session table synchronization by HRP ensures that the backup firewall maintains an identical copy of active connection states. When a failover occurs, established TCP connections continue without interruption.

Question 214

Topic: HRP Backup Modes - Real-Time Backup

Type: Single Choice

When does HRP 'Real-Time Backup' execute data synchronization?

- A. Once every 24 hours at midnight
- B. Immediately as each new session table entry or configuration command is created or modified
- C. Only when the administrator manually enters a synchronization command
- D. Only when an interface physically fails

Correct Answer: B

Concept & Rationale: Real-time backup continuously replicates state changes: as soon as a new session is established or a security policy is modified, HRP immediately transmits the update to the standby peer.

Question 215

Topic: HRP Backup Modes - Batch Backup

Type: Single Choice

Under which circumstance is HRP 'Batch Backup' primarily triggered?

- A. During an active DDoS attack
- B. When the standby firewall boots up, re-establishes heartbeat connectivity, or an administrator manually triggers `hrp sync config`
- C. When a user types a wrong password three times
- D. Whenever an ICMP ping packet is received

Correct Answer: B

Concept & Rationale: Batch backup bulk-synchronizes all configuration commands and existing session tables. It executes upon initial peer connection establishment, manual administrator command (`hrp sync`), or after a reboot.

Question 216

Topic: Quick Session Backup Purpose

Type: Single Choice

Why is 'Quick Session Backup' specifically implemented in Load-Balancing (Active/Active) hot standby mode?

- A. To immediately replicate sessions before return packets arrive in asymmetric routing topologies, preventing session drop on the peer firewall
- B. To permanently disable stateful packet inspection
- C. To reduce CPU clock speeds during business hours
- D. To convert TCP packets into UDP broadcasts

Correct Answer: A

Concept & Rationale: In Active/Active mode, asymmetric routing can cause outbound traffic to traverse FW1 while return traffic reaches FW2. Quick session backup instantly pushes the session from FW1 to FW2 upon creation so FW2 can forward the return packet without dropping it.

Question 217

Topic: Hot Standby Mode - Active/Standby

Type: Single Choice

In Active/Standby (1+1 Redundancy) mode, how is network traffic handled under normal operating conditions?

- A. Both firewalls forward 50% of the traffic simultaneously
- B. The Active firewall processes all service traffic, while the Standby firewall remains idle ready to take over upon failure
- C. The Standby firewall processes only voice traffic
- D. Traffic bypasses both firewalls completely

Correct Answer: B

Concept & Rationale: In Active/Standby mode, one firewall (the active unit) handles all network forwarding, policy enforcement, and NAT. The standby firewall does not forward traffic; it synchronizes states and monitors the active unit.

Question 218

Topic: Hot Standby Mode - Load Balancing

Type: Single Choice

In Load-Balancing (Active/Active) mode, how are VRRP groups typically deployed across the two firewalls?

- A. Both firewalls are configured as Backup for all VRRP groups
- B. Firewall A is configured as Master for VRRP Group 1 and Backup for Group 2; Firewall B is configured as Master for Group 2 and Backup for Group 1
- C. Neither firewall is assigned a virtual IP address
- D. VRRP is completely disabled on both firewalls

Correct Answer: B

Concept & Rationale: In Active/Active mode, services are divided between two VRRP groups. FW1 is Master for Group 1 (gateway for Subnet A), and FW2 is Master for Group 2 (gateway for Subnet B). Both forward traffic concurrently, providing mutual backup.

Question 219

Topic: Heartbeat Interface Type

Type: Single Choice

What type of interface is recommended for connecting the HRP heartbeat link between two clustered firewalls?

- A. A dedicated point-to-point Layer 3 physical interface or dedicated Eth-Trunk
- B. A public Internet WAN interface routed through an external ISP
- C. An unmanaged consumer Wi-Fi connection
- D. An optical interface connected to an analog television tuner

Correct Answer: A

Concept & Rationale: Best practice mandates dedicated point-to-point physical links (or aggregated Eth-Trunk links) directly connecting the two firewalls for heartbeat traffic, preventing heartbeat loss from intermediate switch failures.

Question 220

Topic: HRP Enable Command

Type: Single Choice

Which command is executed in Huawei VRP system view to enable the Huawei Redundancy Protocol?

- A. `hrp enable`
- B. `vrp start`
- C. `firewall cluster on`
- D. `ha mode active`

Correct Answer: A

Concept & Rationale: The command `hrp enable` activates the HRP process and begins heartbeat transmission and state synchronization.

Question 221

Topic: HRP Track Interface Command

Type: Single Choice

Which command configures a firewall interface to be monitored by VGMP so that its failure decrements the VGMP priority?

- A. `hrp track interface <interface-name>`
- B. `interface monitor enable`
- C. `vrp track link`
- D. `ha watch port`

Correct Answer: A

Concept & Rationale: In Huawei firewalls, executing `hrp track interface <interface-type> <interface-number>` registers the specified interface with VGMP for health tracking.

Question 222

Topic: HRP Command Synchronization Prompt

Type: Single Choice

When HRP configuration synchronization is active, what prefix typically appears before the CLI command prompt on the secondary firewall?

- HRP_Active
- HRP_Standby
- Master_Node
- Sync_Disabled

Correct Answer: B

Concept & Rationale: On the standby firewall, the CLI prompt is typically modified to HRP_S or HRP_Standby to indicate that local configuration is locked and synchronized from the active unit (HRP_A / HRP_Active).

Question 223

Topic: Standby Configuration Lockout

Type: Single Choice

Why does HRP lock out direct configuration changes on the Standby firewall by default?

- A. To prevent conflicting configuration discrepancies between the clustered firewalls
- B. Because the standby firewall's flash memory is physically removed
- C. Because the standby firewall runs a different operating system
- D. To allow unauthorized guest users to reconfigure security rules

Correct Answer: A

Concept & Rationale: To guarantee consistent policy enforcement, configurations should only be performed on the Active firewall, which automatically replicates them to the Standby firewall. Modifying the Standby directly causes split-brain configuration mismatches.

Question 224

Topic: HRP Manual Synchronization Command

Type: Single Choice

Which CLI command forces an immediate manual batch synchronization of configuration from the active firewall to the standby peer?

- A. hrp sync config
- B. copy running startup
- C. save cluster
- D. vrrp update now

Correct Answer: A

Concept & Rationale: Executing `hrp sync config` on the active firewall forces an immediate batch synchronization of all configuration parameters to the standby unit.

Question 225

Topic: Preemption Mode Function

Type: Single Choice

What is the function of the 'Preemption Mode' setting in firewall hot standby?

- A. It causes the firewall to randomly reboot during network congestion
- B. When a failed primary firewall recovers, it automatically reclaims the Active role after a configurable preemption delay
- C. It permanently shuts down the secondary firewall
- D. It prevents any user from accessing web services

Correct Answer: B

Concept & Rationale: Preemption mode allows the primary firewall (with higher default priority) to reclaim the Active role once it recovers from a failure. A preemption delay is configured to allow routing protocols and interfaces to stabilize before reclaiming traffic.

Question 226

Topic: Preemption Delay Rationale

Type: Single Choice

Why is it critical to configure a 'Preemption Delay' (e.g. 60 seconds) rather than allowing immediate preemption upon primary firewall recovery?

- A. To let the primary firewall's cooling fans accelerate
- B. To allow routing protocols (OSPF/BGP), physical interfaces, and session tables to fully converge before traffic is switched back, preventing packet loss
- C. To give the administrator time to cancel the preemption manually
- D. Because the standby firewall requires 60 seconds to format its storage

Correct Answer: B

Concept & Rationale: If the primary firewall preempts immediately upon booting, routing tables and neighbor adjacencies may not have converged, resulting in blackholed traffic. A delay ensures complete network stabilization before traffic switchback.

Question 227

Topic: Split-Brain Scenario

Type: Single Choice

What occurs in a 'Split-Brain' condition when the heartbeat connection between two firewalls is completely severed while both units remain powered on?

- A. Both firewalls perceive the peer as dead; both transition to the Active state, causing IP/MAC conflicts on virtual IP addresses
- B. Both firewalls automatically enter sleep mode
- C. The firewalls merge into a single physical unit
- D. All network packets are converted into frame relay

Correct Answer: A

Concept & Rationale: When heartbeat connectivity is lost, each firewall assumes the peer has failed. Both promote themselves to Active/Master, claiming the same virtual IP and virtual MAC addresses, resulting in ARP thrashing, IP conflicts, and widespread network paralysis.

Question 228

Topic: Display HRP State Command

Type: Single Choice

Which command is used to check the operational status of HRP, the active/standby role, and heartbeat link health?

- A. display hrp state
- B. display vrrp brief
- C. display ha status
- D. display cluster info

Correct Answer: A

Concept & Rationale: The command `display hrp state` outputs the current HRP operational state (e.g., Active or Standby), local and peer VGMP priorities, heartbeat link status, and synchronization counters.

Question 229

Topic: Multi-Heartbeat Link Redundancy

Type: Single Choice

Why is it recommended to configure multiple redundant heartbeat interfaces or an Eth-Trunk heartbeat between firewalls?

- A. To increase the speed of user web browsing
- B. To prevent a single cable failure from triggering a devastating Split-Brain condition
- C. To allow the firewalls to mine cryptocurrency in idle periods
- D. To eliminate the need for VRRP virtual IP addresses

Correct Answer: B

Concept & Rationale: Heartbeat redundancy (via dual physical links or link aggregation) ensures that the failure of a single cable or SFP module does not sever heartbeat communications, protecting the cluster against split-brain failures.

Question 230

Topic: HRP Heartbeat Interface Negotiation

Type: Single Choice

How does HRP determine which firewall is Active when both firewalls are powered on simultaneously with equal initial VGMP priorities (65000)?

- A. They flip a random coin electronically
- B. They compare configured roles (e.g., `hrp standby config` or preemption settings) or use tie-breaking rules such as lower heartbeat IP or MAC address
- C. The firewall with larger physical dimensions becomes Active
- D. Both firewalls remain permanently disabled until manual intervention

Correct Answer: B

Concept & Rationale: If priorities are equal, configured roles (`hrp standby config`), preemption rules, or tie-breakers (such as IP address comparison) dictate which firewall assumes the Active role.

Question 231

Topic: HRP Server-Map Synchronization

Type: Single Choice

Why must Server-Map tables be synchronized via HRP in addition to session tables?

- A. Because Server-Map entries store user desktop wallpaper preferences
- B. To ensure that dynamic pinholes for multi-channel protocols (e.g. FTP data) and static NAT Server mappings are immediately available on the peer during failover
- C. Because Server-Map entries contain the firewall serial numbers
- D. To convert public IP addresses into private IP addresses

Correct Answer: B

Concept & Rationale: Synchronizing Server-Map entries ensures that active multi-channel data transfers (FTP, SIP) and NAT Server mappings seamlessly continue without requiring renegotiation when a failover occurs.

Question 232

Topic: IPsec SA Synchronization via HRP

Type: Single Choice

How does HRP synchronization of IPsec Security Associations (SAs) benefit remote branch VPN connections during firewall failover?

- A. It requires remote branch routers to re-enter their pre-shared keys
- B. The backup firewall assumes the existing IPsec SAs, allowing encrypted VPN tunnels to continue forwarding data without renegotiating IKE Phase 1 or Phase 2
- C. It changes the encryption algorithm from AES to DES
- D. It permanently disables the IPsec tunnel

Correct Answer: B

Concept & Rationale: Replicating IPsec SAs allows the standby firewall to decrypt and encrypt ongoing IPsec traffic immediately upon taking over, avoiding tunnel renegotiation dropped packets and IKE re-authentication delays.

Question 233

Topic: VRRP Tracking Upper Link Command

Type: Single Choice

In standard VRRP, how does an interface track another interface's status?

- A. `vrrp vrid <id> track interface <interface-name> [reduced <value>]`
- B. `interface track enable`
- C. `vrrp follow port`
- D. `track link status`

Correct Answer: A

Concept & Rationale: In VRRP, the command `vrrp vrid <id> track interface <interface> [reduced <value>]` dynamically decrements VRRP priority if the tracked interface goes down.

Question 234

Topic: Firewall Load-Balancing Route Asymmetry

Type: Single Choice

In Load-Balancing mode with two firewalls, why does symmetric routing engineering matter?

- A. To prevent firewalls from overheating
- B. Because stateful firewalls require session synchronization to handle return traffic if forward and return packets take different firewall paths
- C. Because Ethernet switches cannot learn two MAC addresses simultaneously
- D. Because routing protocols cannot run on standby firewalls

Correct Answer: B

Concept & Rationale: Asymmetric traffic paths cause return packets to reach a firewall that did not see the initial SYN. Without quick session synchronization, the firewall drops the return packet as an invalid state transition.

Question 235

Topic: HRP Packet Authentication

Type: Single Choice

Can HRP heartbeat communication be authenticated using a shared secret key?

- A. No, HRP packets are always unauthenticated cleartext
- B. Yes, a shared key can be configured using `hrp key <password>` to verify heartbeat packet authenticity and prevent spoofing
- C. HRP can only be authenticated using physical iris scanners
- D. Authentication is handled automatically by the ISP router

Correct Answer: B

Concept & Rationale: Administrators can configure an HRP authentication key (`hrp key <key>`) to cryptographically authenticate heartbeat packets exchanged between the firewalls, preventing unauthorized injection of forged VGMP packets.

Question 236

Topic: VGMP Priority Deduction Customization

Type: Single Choice

Can the priority deduction value applied by VGMP when an interface fails be customized?

- A. No, it is permanently hardcoded to 100
- B. Yes, administrators can specify custom priority reduction values when tracking interfaces or IP links
- C. VGMP priority can only be modified by rebooting
- D. Priority reduction is prohibited by RFC standards

Correct Answer: B

Concept & Rationale: Administrators can customize the priority deduction value (e.g. `hrp track interface GigabitEthernet 0/0/1 reduced 50`) to tailor failover sensitivity across multi-interface topologies.

7 Chapter 7: Firewall IPS

Question 237

Topic: IDS vs IPS Deployment Mode

Type: Single Choice

What is the fundamental difference in physical network deployment between an Intrusion Detection System (IDS) and an Intrusion Prevention System (IPS)?

- A. IDS is deployed inline, whereas IPS is deployed out-of-path
- B. IDS is deployed out-of-path (via port mirroring/TAP), whereas IPS is deployed in-line directly in the traffic forwarding path
- C. IDS operates only over wireless networks, whereas IPS operates only over copper cabling
- D. There is no difference in deployment; both are deployed exclusively on client desktops

Correct Answer: B

Concept & Rationale: An IDS is deployed out-of-path (out-of-band) using switch port mirroring (SPAN) or physical TAPs to passively inspect copies of traffic. An IPS is deployed in-line directly in the live forwarding path to inspect and actively block malicious traffic in real time.

Question 238

Topic: IPS Active Mitigation Capability

Type: Single Choice

Why can an inline IPS actively block an exploit packet before it reaches the victim, whereas an out-of-path IDS cannot?

- A. The IPS has faster electrical cables than the IDS
- B. Because the IPS sits directly in the transmission path, it can drop malicious packets or reset connections immediately before forwarding; the IDS receives only a passive mirrored copy after the packet has already traveled to the victim
- C. The IDS is prohibited by international standards from sending alert emails
- D. The IPS converts all TCP packets into unencrypted UDP broadcasts

Correct Answer: B

Concept & Rationale: Because an inline IPS sits directly in the data flow, it inspects packets before forwarding them and can immediately drop malicious packets or inject TCP resets. An out-of-path IDS receives only a mirrored copy; the original packet has already reached the target host.

Question 239**Topic:** Signature-Based Detection**Type:** Single Choice

What is the primary operational mechanism of signature-based intrusion detection in an IPS?

- A. Comparing network traffic payloads and headers against a database of known attack patterns and vulnerability characteristics
- B. Measuring ambient server room temperature fluctuations
- C. Randomly dropping 10% of all incoming packets to deter attackers
- D. Converting all web traffic into binary morse code

Correct Answer: A

Concept & Rationale: Signature-based detection compares packet payloads, protocol fields, and behavioral sequences against a curated database of known vulnerability exploits and attack signatures, offering high detection accuracy and low false-positive rates for known threats.

Question 240**Topic:** Signature-Based Detection Weakness**Type:** Single Choice

What is the principal operational limitation of signature-based intrusion detection?

- A. It consumes excessive electrical power
- B. It is fundamentally incapable of detecting novel, previously unknown zero-day attacks for which no signature has been created
- C. It can only inspect packets transmitted over dial-up modems
- D. It permanently disables all firewall routing capabilities

Correct Answer: B

Concept & Rationale: Signature detection relies on prior knowledge. When a completely new exploit or zero-day vulnerability emerges, no signature exists in the database, allowing the attack to bypass signature inspection undetected until a vendor signature update is released.

Question 241**Topic:** Anomaly-Based Detection Strength**Type:** Single Choice

What is the major technical advantage of anomaly-based intrusion detection over signature-based detection?

- A. It requires zero CPU or memory resources on the firewall
- B. It can detect novel, unknown zero-day attacks and abnormal behavioral deviations by comparing real-time traffic against an established baseline of normal network activity
- C. It guarantees a 0% false-positive rate under all network conditions
- D. It eliminates the need for user passwords across the enterprise

Correct Answer: B

Concept & Rationale: Anomaly detection constructs a mathematical profile of normal baseline behavior (bandwidth, protocol distribution, connection rates). Statistically significant deviations trigger alerts, enabling the detection of previously unseen zero-day attacks and stealthy worms.

Question 242

Topic: Anomaly-Based Detection Challenge

Type: Single Choice

What is the primary operational drawback associated with anomaly-based detection mechanisms?

- A. It can only inspect ICMP echo packets
- B. It tends to produce higher false-positive rates because legitimate but unusual business traffic spikes may be flagged as attacks
- C. It requires physical hardware replacement every 30 days
- D. It is incompatible with standard Ethernet frames

Correct Answer: B

Concept & Rationale: Defining 'normal' network behavior is difficult in dynamic enterprise environments. Legitimate events (e.g., sudden software rollouts, marketing campaigns, large backups) can deviate from the baseline, generating false-positive alarms.

Question 243

Topic: Huawei IPS Predefined Signatures

Type: Single Choice

What are 'Predefined Signatures' in a Huawei USG series firewall IPS?

- A. Signatures that must be written manually by the enterprise network administrator in C++
- B. Built-in threat signatures created, tested, and regularly updated by Huawei security research teams via online intelligence updates
- C. Signatures stored exclusively on local USB flash drives
- D. Signatures that expire after exactly 60 seconds of use

Correct Answer: B

Concept & Rationale: Predefined signatures are vendor-provided signatures shipped with the firewall firmware and continually updated via Huawei Security Intelligence Center online feeds to protect against emerging CVEs and exploits.

Question 244

Topic: Huawei IPS User-Defined Signatures

Type: Single Choice

Under what circumstances would an enterprise administrator create 'User-Defined Signatures' on an IPS?

- A. To protect proprietary internal enterprise applications or address custom threats not covered by predefined vendor signatures
- B. Because predefined signatures cannot be used on firewalls
- C. To format the firewall's internal solid-state storage
- D. To disable all IP routing on the border router

Correct Answer: A

Concept & Rationale: User-defined signatures allow security teams to create custom snort-like rules or regular expressions tailored to proprietary enterprise software, localized malware variants, or immediate hotfixes before official vendor signatures are published.

Question 245

Topic: IPS Action - Block

Type: Single Choice

When a Huawei IPS signature detects an active remote code execution attack and its configured action is 'Block', what does the firewall do?

- A. It logs the event but forwards the packet to the destination server
- B. It discards the malicious packet and can optionally reset the TCP connection or blacklist the attacking source IP
- C. It encrypts the packet and sends it to the cloud
- D. It permanently disables the firewall's cooling fan

Correct Answer: B

Concept & Rationale: The 'Block' action terminates the threat by dropping the malicious packet, terminating the TCP session (via TCP RST), and optionally placing the attacking source IP into a temporary blacklist to prevent subsequent connection attempts.

Question 246

Topic: IPS Action - Alert

Type: Single Choice

When an IPS signature's action is configured as 'Alert', how is matching traffic handled?

- A. The packet is dropped and deleted immediately
- B. The firewall generates a security event log/alarm, but allows the packet to pass through to the destination
- C. The firewall automatically reboots into safe mode
- D. The packet is converted into a DNS query

Correct Answer: B

Concept & Rationale: The 'Alert' action produces an audit log entry or security alarm while permitting the traffic to proceed without interruption, commonly used during initial IPS deployment tuning to evaluate potential false positives.

Question 247

Topic: Antivirus Detection - Flow-Based

Type: Single Choice

What is the primary technical advantage of the Flow-Based (Stream-Based) antivirus scanning method utilized in Huawei USG firewalls?

- A. It can inspect files larger than 100 gigabytes without using memory
- B. It inspects data streams in real time on the fly as packets transit the firewall without caching entire files in memory, delivering high throughput and low latency
- C. It completely replaces the need for endpoint antivirus software
- D. It does not require virus signature database updates

Correct Answer: B

Concept & Rationale: Flow-based antivirus scans packet streams in real time using specialized hardware and pattern matching algorithms without buffering complete multi-megabyte files in RAM, enabling multi-gigabit line-rate throughput.

Question 248

Topic: Antivirus Detection - File-Based

Type: Single Choice

What is a characteristic disadvantage of traditional File-Based antivirus inspection compared to Flow-Based inspection?

- A. File-based inspection cannot detect known viruses
- B. The firewall must buffer and reassemble the entire file in memory before scanning, resulting in higher memory consumption, increased latency, and potential buffer exhaustion on large files
- C. File-based inspection operates only on wireless access points
- D. File-based inspection is prohibited by national cybersecurity standards

Correct Answer: B

Concept & Rationale: File-based scanning reconstructs the entire file in RAM before scanning. For multi-gigabit gateways handling millions of concurrent flows, buffering complete files introduces substantial latency and can overwhelm firewall memory buffers.

Question 249

Topic: Antivirus Supported Protocols

Type: Single Choice

Which of the following application layer protocols is commonly supported for malware inspection by Huawei firewall Antivirus engines?

- A. HTTP, FTP, SMTP, POP3, IMAP, and SMB
- B. BGP, OSPF, and RIP routing updates
- C. Ethernet CRC checksum frames
- D. Physical Layer optical laser pulses

Correct Answer: A

Concept & Rationale: Huawei NGFW Antivirus inspects prominent file transfer and communication protocols: Web (HTTP), File transfer (FTP, SMB), and Email (SMTP, POP3, IMAP).

Question 250

Topic: Antivirus Action - Declare

Type: Single Choice

In Huawei firewall antivirus configuration, what does the 'Declare' action signify for email protocols?

- A. Deleting the recipient's entire mailbox
- B. Permitting the email attachment to pass through while inserting a warning notification or modifying the email subject header to alert the recipient
- C. Sending a physical letter to the sender's postal address
- D. Disabling all incoming email for 30 days

Correct Answer: B

Concept & Rationale: The 'Declare' action allows an infected email to be delivered but modifies the message (e.g., adding a warning banner to the subject or body, or stripping the infected attachment) to inform the user of the threat.

Question 251

Topic: URL Filtering Purpose

Type: Single Choice

What is the primary operational objective of implementing URL Filtering on an enterprise firewall?

- A. To accelerate DNS caching speed across local servers
- B. To regulate, monitor, and restrict employee web browsing to specific categories of websites (e.g., blocking adult, gambling, or phishing sites)
- C. To replace web servers with firewall hardware
- D. To force all web browsers to use the same font size

Correct Answer: B

Concept & Rationale: URL Filtering controls employee web access, preventing visits to malicious websites (phishing, malware distribution), non-work-related sites (gambling, gaming), or high-bandwidth consumption portals (video streaming).

Question 252

Topic: URL Filtering Category - Predefined

Type: Single Choice

What are Predefined URL Categories in Huawei USG firewalls?

- A. Categories that must be typed manually by the administrator one URL at a time
- B. A comprehensive, cloud-updated classification database (e.g., Finance, Education, Adult, Malicious) maintained by Huawei Security Intelligence
- C. Categories stored on read-only optical discs inside the firewall chassis
- D. Categories that only apply during nighttime hours

Correct Answer: B

Concept & Rationale: Predefined categories group millions of global URLs into structured classifications (Business, Social, Entertainment, Security Threats). The database is dynamically updated via cloud intelligence.

Question 253

Topic: URL Filtering - Whitelist Priority

Type: Single Choice

On a Huawei firewall configured with URL Filtering, what is the evaluation priority of the URL Whitelist compared to category rules and blacklists?

- A. Lowest priority; evaluated only if all other rules fail
- B. Highest priority; if a requested URL matches the Whitelist, it is permitted immediately without checking blacklists or category rules
- C. Equal priority; resolved by coin toss
- D. Whitelists are evaluated only on alternate days of the week

Correct Answer: B

Concept & Rationale: The Whitelist has the highest precedence in URL filtering. Any URL matching a whitelist entry is immediately permitted, bypassing category inspection and blacklists.

Question 254

Topic: URL Filtering - Blacklist Action

Type: Single Choice

When a user attempts to browse a website whose domain name matches the configured URL Blacklist, what is the default result?

- A. The request is permitted with high priority
- B. The connection is blocked immediately and a block notification page is presented to the user
- C. The user's computer monitor is turned off
- D. The web page is translated into Latin

Correct Answer: B

Concept & Rationale: The Blacklist has absolute blocking priority. Any request matching a blacklist pattern is blocked immediately, terminating the connection and displaying a customizable warning/block page.

Question 255

Topic: File Filtering Technology

Type: Single Choice

How does Huawei NGFW File Filtering accurately identify file types even if a malicious user renames an executable file from `malware.exe` to `document.txt`?

- A. By reading only the file extension characters in the file name
- B. By analyzing the true file type through file header magic numbers and binary structural signatures, independent of the file extension
- C. By contacting the user to ask for the genuine file type
- D. By converting all files into PDF documents

Correct Answer: B

Concept & Rationale: Attackers frequently rename malicious executables (`.exe`) to harmless extensions (`.txt`, `.jpg`). Huawei File Filtering inspects the binary file header magic bytes (e.g., MZ for PE executables, %PDF for PDFs) to identify the true file type.

Question 256

Topic: Content Filtering - Keyword Matching

Type: Single Choice

What is the primary function of Content Filtering on an enterprise firewall?

- A. To measure the physical length of network cables
- B. To scan application payloads (web pages, web posts, emails) for sensitive keywords (e.g., proprietary project names, confidential data) to prevent data leakage
- C. To format the hard drives of internal servers
- D. To change the color scheme of corporate websites

Correct Answer: B

Concept & Rationale: Content Filtering performs deep text analysis on transmitted data (HTTP posts, email text, search queries) to detect and block predefined sensitive keywords, preventing data exfiltration and policy violations.

Question 257

Topic: IPS Signature Severity Levels

Type: Single Choice

Which of the following represents a valid severity level for an IPS signature on a Huawei firewall?

- A. High, Medium, Low, and Informational
- B. Atomic, Molecular, Cellular, and Organism
- C. Alpha, Beta, Gamma, and Delta
- D. Gold, Silver, Bronze, and Platinum

Correct Answer: A

Concept & Rationale: Huawei IPS signatures are categorized by threat impact into four standardized severity ratings: High (critical exploits, RCE), Medium (privilege escalation), Low (information disclosure), and Informational (scanning, protocol anomaly).

Question 258

Topic: IPS Exception Signature Configuration

Type: Single Choice

Why would an administrator configure an 'Exception' within an IPS profile?

- A. To permanently disable the entire IPS engine
- B. To override the default action or severity of a specific signature (e.g., changing action from Block to Alert) without altering the global signature database
- C. To delete the firewall operating system
- D. To allow unauthorized users to log in as root

Correct Answer: B

Concept & Rationale: An Exception rule allows administrators to customize the behavior of individual signatures. If a specific signature triggers false positives on an internal business application, changing its action to Alert or Pass in the Exception list prevents business interruption.

Question 259

Topic: Protocol Anomaly Detection

Type: Single Choice

What does Protocol Anomaly Detection verify when inspecting network traffic?

- A. It checks whether the user is wearing an official uniform
- B. It verifies whether traffic strictly conforms to standardized RFC specifications (e.g., legal HTTP request lengths, valid header formatting, valid DNS transaction fields)
- C. It measures the electrical resistance of the network interface
- D. It counts the number of letters in the user's password

Correct Answer: B

Concept & Rationale: Protocol Anomaly Detection checks incoming packets against official RFC standards, flagging malformed headers, illegal field lengths, or unexpected command sequences that indicate fuzzing, exploit payloads, or protocol abuse.

Question 260

Topic: IPS Profile Association

Type: Single Choice

How is an IPS Profile activated to inspect live production traffic on a Huawei NGFW?

- A. By typing `ips start` in user view
- B. By binding the configured IPS Profile to a Security Policy rule whose action is 'Permit'
- C. By assigning the IPS Profile to an empty USB storage port
- D. By rebooting all connected desktop computers

Correct Answer: B

Concept & Rationale: In Huawei NGFWs, security inspection profiles (IPS, AV, URL filtering) are applied by associating them with a 'Permit' rule in the Security Policy. Traffic matching the policy is then passed through the assigned IPS engine.

Question 261

Topic: Antivirus Signature Database Update

Type: Single Choice

Why is it essential for an enterprise firewall to maintain regular, automated updates of its Antivirus signature database?

- A. Because thousands of new malware variants and ransomware strains emerge daily across the global Internet
- B. Because the firewall hardware automatically deletes all signatures every 24 hours
- C. To prevent Ethernet cables from corroding
- D. Because older signatures increase the weight of the firewall

Correct Answer: A

Concept & Rationale: Cyber threat actors continuously develop new malware variants, obfuscated packers, and zero-day trojans. Without daily or real-time signature updates, the antivirus engine cannot identify the latest malicious binaries.

Question 262

Topic: Mail Filtering - Spam Defense

Type: Single Choice

Which technique is commonly employed by Huawei firewall Mail Filtering engines to combat unsolicited commercial email (spam)?

- A. RBL (Real-time Blackhole List) server IP reputation querying and keyword filtering
- B. Disconnecting all incoming email servers permanently
- C. Converting all incoming emails into unencrypted audio files
- D. Requiring email senders to visit the company in person

Correct Answer: A

Concept & Rationale: Mail filtering uses Real-time Blackhole Lists (RBL), sender IP reputation databases, SPF/DKIM verification, and body keyword analysis to classify and block spam emails before delivery.

Question 263

Topic: URL Filtering Search Keyword Auditing

Type: Single Choice

How does a firewall inspect search engine queries (e.g. Google or Bing searches) when HTTPS inspection is enabled?

- A. By guessing the user's thoughts
- B. By decrypting the SSL session using SSL Decryption / SSL Proxy and inspecting the HTTP GET parameters for the search keyword string
- C. By modifying the DNS records of all search engine companies
- D. By physically monitoring the user's keyboard

Correct Answer: B

Concept & Rationale: Because modern search engines use HTTPS, inspection requires an SSL Decryption Policy (SSL Proxy). The firewall decrypts the TLS session, inspects the plaintext HTTP URI parameters (e.g. ?q=keyword), and applies content/URL policies before re-encrypting.

Question 264

Topic: False Positive Definition

Type: Single Choice

What is a 'False Positive' in the context of IPS security monitoring?

- A. An attack that is correctly detected and blocked by the IPS
- B. Legitimate, benign network traffic that is incorrectly flagged and blocked by the IPS as malicious
- C. An attack that passes through the IPS completely undetected
- D. A hardware power failure on the firewall chassis

Correct Answer: B

Concept & Rationale: A False Positive occurs when benign, legitimate network traffic is erroneously classified as an attack and blocked or alerted by the IPS, potentially disrupting normal business applications.

Question 265

Topic: False Negative Definition

Type: Single Choice

What is a 'False Negative' in IPS operational terminology?

- A. Benign traffic that is allowed to pass normally
- B. A real, malicious attack that the IPS fails to detect and allows to pass through to the target
- C. An attack that triggers an alarm on all enterprise monitors
- D. A software update that installs successfully

Correct Answer: B

Concept & Rationale: A False Negative occurs when a genuine malicious exploit slips through the IPS completely undetected, often due to missing signatures, evasion techniques, or zero-day vulnerabilities.

Question 266

Topic: Flow-Based AV Resource Advantage

Type: Single Choice

Why is Flow-Based antivirus particularly advantageous on border firewalls handling heavy user downloads?

- A. It requires zero megabytes of storage on user PCs
- B. It avoids holding multi-megabyte files in firewall RAM buffers, preserving system memory and ensuring consistent forwarding latency during large file transfers
- C. It allows the firewall to mine Bitcoin during quiet periods
- D. It doubles the physical speed of the fiber optic link

Correct Answer: B

Concept & Rationale: Flow-based scanning examines packet streams on the fly without holding whole files in memory, avoiding memory exhaustion and high latency when hundreds of concurrent users download large files.

Question 267

Topic: URL Category Action - Force Redirect

Type: Single Choice

What occurs when a URL Filtering rule action is set to 'Force Redirect'?

- A. The user is redirected to a different specified URL (such as a corporate policy reminder page or secondary proxy)
- B. The user's computer is rebooted into safe mode
- C. The user is disconnected from the local network permanently
- D. The web server is powered off

Correct Answer: A

Concept & Rationale: Force Redirect intercepts the user's HTTP request and returns an HTTP 302 redirect response pointing the browser to a designated warning page, compliance portal, or corporate intranet URL.

Question 268

Topic: File Filtering Direction

Type: Single Choice

In Huawei firewall configuration, can File Filtering rules be configured with directional granularity?

- A. No, File Filtering applies identically in all directions without distinction
- B. Yes, File Filtering can be configured specifically for Uploads (outbound data loss prevention) or Downloads (inbound malware prevention)
- C. File Filtering works only for internal server backups
- D. Direction is determined by the physical tilt of the firewall rack

Correct Answer: B

Concept & Rationale: File filtering can be applied directionally: inspecting Inbound downloads (blocking executable downloads or malicious PDFs) and Outbound uploads (preventing proprietary document exfiltration).

Question 269

Topic: IPS Signature Evasion - Fragmentation

Type: Single Choice

How do attackers attempt to evade simple signature matching using IP packet fragmentation?

- A. By splitting the malicious exploit string across multiple small IP fragments so that neither fragment alone contains the full recognizable signature pattern
- B. By setting the IP TTL to 255
- C. By using wireless transmission instead of copper
- D. By deleting the IP checksum

Correct Answer: A

Concept & Rationale: Attackers fragment packets so that exploit strings (e.g. /bin/sh) are split across separate fragment boundaries. To prevent evasion, modern NGFWs reassemble IP fragments before performing deep packet signature inspection.

Question 270

Topic: Firewall DPI Performance Engine

Type: Single Choice

What architectural design in Huawei NGFWs enables simultaneous execution of IPS, Antivirus, and URL Filtering without compounding latency?

- A. Single-pass parallel processing engine that inspects packet contents against multiple security signature engines simultaneously in a single scan
- B. Passing the packet through five separate physical hardware firewalls connected in series
- C. Disabling all IP routing while security engines are running
- D. Using mechanical relays to switch packets between hard drives

Correct Answer: A

Concept & Rationale: Huawei NGFW uses an integrated single-pass architecture. Packets are parsed once, and the data stream is evaluated in parallel against IPS, Antivirus, and URL filtering engines simultaneously, eliminating serial processing latency.

Question 271

Topic: IPS Bypass Mode on Overload

Type: Single Choice

What is the purpose of an 'IPS Bypass' or 'Fail-Open' mechanism during extreme hardware overload or failure?

- A. To ensure business network traffic continues to flow without interruption, trading security inspection for operational availability
- B. To permanently delete all firewall operating system files
- C. To force all employee computers to disconnect from the LAN
- D. To convert the firewall into an optical amplifier

Correct Answer: A

Concept & Rationale: If the firewall or inline IPS engine experiences severe hardware failure or unmanageable traffic saturation, a bypass switch (fail-open) allows packets to bypass the inspection engine, prioritizing business continuity over security inspection.

Question 272

Topic: URL Filtering Domain vs Path Matching

Type: Single Choice

How does URL filtering distinguish between domain matching and URL path matching?

- A. Domain matching evaluates only the host FQDN (e.g., `example.com`), whereas path matching evaluates the complete resource URI (e.g., `example.com/downloads/file.zip`)
- B. Domain matching works only for IPv6, and path matching works only for IPv4
- C. Domain matching works only over Telnet
- D. There is no difference; domain and path are identical

Correct Answer: A

Concept & Rationale: Domain filtering matches the server host name (e.g., `www.example.com`), while complete URL filtering inspects the protocol, host, port, directory path, and query parameters, allowing granular rules (e.g., allow `example.com`, block `example.com/games`).

Question 273

Topic: Antivirus File Extension Deception

Type: Single Choice

An attacker changes the file name of `trojan.exe` to `invoice.pdf` and sends it via email. How does Huawei NGFW Antivirus prevent infection?

- A. It relies on the recipient noticing the wrong icon
- B. It analyzes the internal file header and binary stream to recognize that the file is actually a Portable Executable (PE) binary, applying EXE inspection rules regardless of the PDF extension
- C. It deletes the email server
- D. It asks the sender to resend the email in cleartext

Correct Answer: B

Concept & Rationale: The AV engine performs true file type identification by reading internal file signatures (magic bytes) rather than trusting superficial file extensions, ensuring that masked executables are scanned with appropriate executable signatures.

Question 274**Topic:** Threat Log Viewing Command**Type:** Single Choice

Which command is used in Huawei VRP to view intrusion prevention threat log records?

- A. display security-policy rule
- B. display logbuffer
- C. display ip routing-table
- D. display version

Correct Answer: B

Concept & Rationale: The command `display logbuffer` (or viewing dedicated threat logs in the web GUI / eLog server) displays real-time security events, including IPS signature hits, blocked source IPs, and antivirus detections.

8 Chapter 8: Firewall User Management Technologies

Question 275**Topic:** AAA Framework - Three Pillars**Type:** Single Choice

In the network security AAA architecture, which of the following represents the core question addressed by 'Authentication'?

- A. What did you do on the network?
- B. Who are you (identity verification)?
- C. What resources are you permitted to access?
- D. How much bandwidth did you consume?

Correct Answer: B

Concept & Rationale: Authentication verifies the identity claimed by an entity (answering 'Who are you?'). Authorization determines access rights ('What can you do?'), and Accounting tracks resource consumption ('What did you do?').

Question 276**Topic:** AAA Framework - Authorization**Type:** Single Choice

Which component of AAA determines whether a validated user has permission to access a specific network segment or execute administrative commands?

- A. Authentication
- B. Authorization
- C. Accounting
- D. Auditing

Correct Answer: B

Concept & Rationale: Authorization grants or restricts permissions, service privileges, and resource access levels to an authenticated user based on policy.

Question 277

Topic: AAA Framework - Accounting

Type: Single Choice

Which component of AAA is responsible for logging user session start and stop times, duration, and transmitted byte volumes for billing and auditing?

- A. Authentication
- B. Authorization
- C. Accounting
- D. Attestation

Correct Answer: C

Concept & Rationale: Accounting collects session metrics, timestamps, and resource consumption data used for billing, capacity planning, and forensic auditing.

Question 278

Topic: User Categories - Local Users

Type: Single Choice

What defines a 'Local User' on a Huawei firewall?

- A. A user whose account credentials and privilege levels are configured and stored directly in the firewall's local database
- B. A user who connects to the firewall using an analog dial-up modem
- C. A user whose identity is validated by an external RADIUS server
- D. A guest user accessing the network without a password

Correct Answer: A

Concept & Rationale: Local users are configured and maintained in the local database of the firewall. They are ideal for local administrators or small branch deployments that lack external identity servers.

Question 279

Topic: User Categories - Server Users

Type: Single Choice

When a firewall acts as a Network Access Server (NAS) and queries an external RADIUS or LDAP server to authenticate users, these users are classified as:

- A. Local Users
- B. Server Users
- C. Anonymous Users
- D. Hardware Users

Correct Answer: B

Concept & Rationale: Server users reside on external centralized authentication servers (RADIUS, HWTACACS, LDAP, Active Directory). The firewall relays authentication queries to these servers.

Question 280

Topic: RADIUS Transport and Standard Ports

Type: Single Choice

Which transport protocol and standard default UDP ports are utilized by the RADIUS protocol for Authentication/Authorization and Accounting, respectively?

- A. TCP port 49 for all functions
- B. UDP port 1812 for Authentication/Authorization, and UDP port 1813 for Accounting
- C. TCP port 80 for Authentication, and TCP port 443 for Accounting
- D. UDP port 53 for Authentication, and UDP port 67 for Accounting

Correct Answer: B

Concept & Rationale: Standard RADIUS (RFC 2865 / RFC 2866) operates over UDP, using destination port 1812 for Authentication and Authorization, and port 1813 for Accounting (legacy RFCs used 1645 and 1646).

Question 281

Topic: RADIUS Packet Encryption Scope

Type: Single Choice

How does the RADIUS protocol protect sensitive user credentials during transmission between the NAS and the RADIUS server?

- A. It encrypts the entire packet body and all attributes using AES-256
- B. It encrypts ONLY the User-Password attribute using an MD5-based algorithm; the rest of the packet (including username) is transmitted in cleartext
- C. It does not encrypt any part of the packet; all data is cleartext
- D. It converts the packet into an encrypted SSL VPN tunnel

Correct Answer: B

Concept & Rationale: In standard RADIUS, only the User-Password attribute is encrypted (using an MD5 shared secret hash). The username, header, and other RADIUS attributes are sent in cleartext, making RADIUS vulnerable to username sniffing on untrusted networks.

Question 282

Topic: RADIUS Auth and Authz Coupling

Type: Single Choice

How does RADIUS handle Authentication and Authorization in its protocol message exchange?

- A. Authentication and Authorization are strictly separated into two independent TCP exchanges
- B. Authentication and Authorization are bundled together in the single **Access-Accept** response packet
- C. Authorization must always be performed before Authentication
- D. RADIUS does not support Authorization

Correct Answer: B

Concept & Rationale: RADIUS couples Authentication and Authorization together. When the server validates credentials and sends an **Access-Accept** message, it includes authorization attributes (such as user group, VLAN, or ACL assignments) in the same packet.

Question 283

Topic: HWTACACS Transport Protocol

Type: Single Choice

Which transport layer protocol and destination port are utilized by Huawei's HWTACACS protocol?

- A. UDP port 1812
- B. TCP port 49
- C. TCP port 389
- D. UDP port 18514

Correct Answer: B

Concept & Rationale: HWTACACS (based on TACACS+, RFC 1492) uses reliable TCP transport over destination port 49.

Question 284

Topic: HWTACACS Encryption Scope

Type: Single Choice

What is the primary security advantage of HWTACACS encryption compared to standard RADIUS?

- A. HWTACACS encrypts the entire packet body (payload) except the standard 12-byte header, protecting usernames and commands from eavesdropping
- B. HWTACACS uses unencrypted cleartext for maximum speed
- C. HWTACACS encrypts only the destination IP address
- D. HWTACACS uses physical quantum key encryption

Correct Answer: A

Concept & Rationale: Unlike RADIUS which encrypts only the password, HWTACACS encrypts the entire body of the packet following the 12-byte header. This conceals usernames, authorization commands, and accounting parameters from passive sniffing.

Question 285

Topic: HWTACACS Separation of AAA

Type: Single Choice

How does HWTACACS handle the relationship between Authentication, Authorization, and Accounting?

- A. It merges all three functions into a single packet
- B. It strictly separates Authentication, Authorization, and Accounting into distinct, independent client-server exchanges
- C. It supports Authentication only and eliminates Authorization completely
- D. It requires all three functions to be performed on separate physical days

Correct Answer: B

Concept & Rationale: A defining strength of HWTACACS is the strict separation of AAA functions. A network device can perform authentication against one server, authorize individual CLI commands against a second server, and log accounting records to a third.

Question 286

Topic: HWTACACS Primary Use Case

Type: Single Choice

For which network operational scenario is HWTACACS predominantly deployed in enterprise networks?

- A. Consumer public Wi-Fi guest portal logins
- B. Administrative device access and per-command authorization for routers, switches, and firewalls
- C. Dial-up residential Internet access billing
- D. Streaming video media delivery

Correct Answer: B

Concept & Rationale: Due to per-command authorization, reliable TCP delivery, and full payload encryption, HWTACACS is the enterprise standard for administrative access control (TACACS+) over network infrastructure devices.

Question 287

Topic: LDAP Directory Standard

Type: Single Choice

The Lightweight Directory Access Protocol (LDAP) is based on which international directory service architecture?

- A. ITU-T X.500 directory model
- B. IEEE 802.11 wireless standard
- C. ISO 27001 ISMS model
- D. IETF RFC 1918 addressing model

Correct Answer: A

Concept & Rationale: LDAP is a streamlined software protocol developed to provide lightweight network access to hierarchical directory information trees structured according to the ITU-T X.500 standard.

Question 288**Topic:** LDAP Transport Ports**Type:** Single Choice

What are the standard TCP port numbers used for unencrypted LDAP and encrypted LDAPS (LDAP over SSL/TLS), respectively?

- A. LDAP: TCP 80, LDAPS: TCP 443
- B. LDAP: TCP 389, LDAPS: TCP 636
- C. LDAP: TCP 23, LDAPS: TCP 22
- D. LDAP: TCP 1812, LDAPS: TCP 1813

Correct Answer: B

Concept & Rationale: Standard LDAP communicates over cleartext TCP port 389, whereas encrypted LDAPS secures directory communications over TCP port 636 using TLS/SSL.

Question 289**Topic:** LDAP Distinguished Name Components**Type:** Single Choice

In an LDAP directory tree, what do the abbreviations 'DC', 'OU', and 'CN' represent?

- A. Data Center, Operating Unit, Computer Node
- B. Domain Component, Organizational Unit, Common Name
- C. Domain Controller, Open User, Certified Network
- D. Dynamic Configuration, Optical Unit, Core Network

Correct Answer: B

Concept & Rationale: In LDAP Distinguished Names (DN), DC = Domain Component (e.g. `dc=example,dc=com`), OU = Organizational Unit (e.g. `ou=Engineering`), and CN = Common Name (e.g. `cn=Alice Smith`).

Question 290**Topic:** Active Directory Integration**Type:** Single Choice

How does a Huawei firewall integrate with Microsoft Active Directory (AD) for centralized user management?

- A. By acting as the primary domain controller and deleting existing domain accounts
- B. By querying the AD domain controller via LDAP/LDAPS to authenticate domain users and synchronize organizational unit (OU) user groups
- C. By formatting the AD server hard drives
- D. By replacing all Windows domain workstations with Linux terminals

Correct Answer: B

Concept & Rationale: Huawei firewalls integrate with Microsoft Active Directory using LDAP/LDAPS queries to validate user credentials and import/synchronize domain user groups, mapping enterprise domain structures directly into firewall policies.

Question 291**Topic:** User-Based Security Policy Advantage**Type:** Single Choice

What is the primary advantage of applying security policies to 'User/User Group' objects rather than static IP addresses?

- A. It reduces the physical power consumption of network switches
- B. Security policies dynamically follow the user regardless of which physical workstation or dynamic DHCP IP address they use
- C. It eliminates the need for user passwords
- D. It permanently disables all firewall session logging

Correct Answer: B

Concept & Rationale: In modern enterprise networks with DHCP, Wi-Fi roaming, and mobile devices, a user's IP changes frequently. User-based policies bind access rules to the user's identity, ensuring appropriate permissions apply consistently wherever the user connects.

Question 292**Topic:** Portal Authentication Definition**Type:** Single Choice

What is 'Portal Authentication' (Captive Portal) on a Huawei firewall?

- A. A physical door lock opened using an RFID badge
- B. A web-based authentication method where unauthenticated users attempting HTTP browsing are redirected to a captive web login page to enter credentials
- C. An administrative terminal session using Telnet
- D. A dynamic routing protocol used between autonomous systems

Correct Answer: B

Concept & Rationale: Portal authentication intercepts unauthenticated HTTP/HTTPS web requests from guest or employee devices and redirects them to a web captive portal, prompting users to authenticate before granting network access.

Question 293**Topic:** Single Sign-On (SSO) Goal**Type:** Single Choice

What is the primary operational objective of Single Sign-On (SSO) on an enterprise firewall?

- A. Requiring users to enter their credentials separately for every single website they visit
- B. Allowing users to authenticate once (e.g. at Windows domain workstation login) and have the firewall transparently identify them without prompted re-authentication
- C. Eliminating the need for firewalls on the network perimeter
- D. Forcing all employee computers to reboot every hour

Correct Answer: B

Concept & Rationale: SSO allows users to authenticate once against an enterprise identity provider (e.g. Active Directory). The firewall transparently learns the user's IP-to-username mapping, applying user-specific security policies without interrupting user workflow.

Question 294**Topic:** AD SSO Event Monitoring**Type:** Single Choice

How does Active Directory Single Sign-On (AD SSO) transparently map IP addresses to usernames without user intervention on Huawei firewalls?

- A. The firewall monitors or queries Windows Domain Controller security event logs (specifically Event ID 4624 successful logon events) to correlate workstation IP with domain username
- B. The firewall installs a keylogger on the user's keyboard
- C. The firewall captures cleartext Telnet sessions
- D. The firewall asks the user to send an email every morning

Correct Answer: A

Concept & Rationale: When a user logs into a Windows domain computer, the Domain Controller logs Event ID 4624 (Successful Logon) containing the user's account name and workstation IP. The firewall (or an SSO agent) monitors these security logs to dynamically build IP-to-user bindings.

Question 295**Topic:** RADIUS SSO Mechanism**Type:** Single Choice

How does RADIUS Single Sign-On (RADIUS SSO) operate in campus wireless networks?

- A. By transmitting user passwords over unencrypted broadcast radio
- B. The firewall intercepts (snoops) RADIUS Accounting-Request packets sent between wireless access controllers and the RADIUS server to learn IP-to-username bindings
- C. By disabling all wireless encryption on corporate access points
- D. By requiring users to manually configure firewall routing tables

Correct Answer: B

Concept & Rationale: When users authenticate to 802.1X enterprise Wi-Fi, the Wireless Access Controller sends RADIUS Accounting-Request packets (containing username and assigned IP) to the RADIUS server. The firewall snoops these accounting packets to seamlessly register user-to-IP mappings.

Question 296**Topic:** Local User Service Types**Type:** Single Choice

In Huawei VRP CLI, which command configures the allowed service types (e.g. SSH, HTTP, Telnet) for a local user account?

- A. `local-user <name> service-type { http | ssh | telnet | terminal }`
- B. `user-interface vty service enable`
- C. `firewall service user <name>`
- D. `aaa service start <name>`

Correct Answer: A

Concept & Rationale: In Huawei VRP AAA view, the command `local-user <name> service-type <types>` defines which access methods (HTTP web management, SSH, Telnet, or console terminal) the account can utilize.

Question 297

Topic: Local User Privilege Level Range

Type: Single Choice

What is the standard administrator privilege level range for local users on Huawei network devices?

- A. 0 to 3 (or 0 to 15 on extended VRP systems)
- B. 1 to 100
- C. 0 to 65535
- D. Only level 1 and level 2

Correct Answer: A

Concept & Rationale: Huawei VRP supports user privilege levels ranging from 0 (Visit), 1 (Monitor), 2 (Configuration), to 3 (Management), expandable up to level 15 for granular role-based access control.

Question 298

Topic: User Group Hierarchy

Type: Single Choice

How are User Groups structured on Huawei NGFWs to simplify security policy administration?

- A. All users must belong to exactly one flat group with no nesting
- B. User groups can be organized hierarchically into parent and child groups, mirroring enterprise organizational departments (e.g., Company -> R&D -> Software)
- C. User groups can only be assigned to physical switch ports
- D. User groups are limited to a maximum of 3 users per group

Correct Answer: B

Concept & Rationale: Huawei NGFW supports hierarchical user groups with multi-level parent/child inheritance. Policies applied to a parent group automatically apply to members of subordinate child groups, matching enterprise organizational trees.

Question 299

Topic: Guest User Management

Type: Single Choice

What capability is typically provided by Huawei firewall Guest User Management for temporary visitors?

- A. Granting permanent unrestricted access to confidential source code databases
- B. Self-service registration, SMS verification code login, administrator approval workflows, and automatic account expiration
- C. Disabling all firewall security rules for visitor IP addresses
- D. Permanently burning visitor MAC addresses into the motherboard ROM

Correct Answer: B

Concept & Rationale: Guest management provides self-service portal registration, one-time SMS verification codes, sponsor approval, and automatic expiration timers (e.g., access expires after 8 hours), securing visitor access.

Question 300

Topic: Security Policy with User Matching

Type: Single Choice

When a security policy rule is configured with both an IP Address condition AND a User condition, how does the firewall evaluate traffic?

- A. Both conditions must match (the traffic must originate from the specified IP AND belong to the specified authenticated user)
- B. The firewall ignores the user condition and checks only the IP address
- C. The firewall randomly selects one of the two conditions to evaluate
- D. The firewall drops the packet automatically as a configuration conflict

Correct Answer: A

Concept & Rationale: Security policy conditions are combined using logical AND. For the rule to match, the packet must satisfy all specified criteria: it must originate from the defined IP range AND be mapped to the specified authenticated user.

Question 301

Topic: IP-to-User Mapping Table Display

Type: Single Choice

Which Huawei VRP CLI command displays the active IP-to-user mapping table currently learned by the firewall?

- A. display user-manage online-user
- B. display ip routing-table
- C. display firewall session table
- D. display mac-address

Correct Answer: A

Concept & Rationale: The command `display user-manage online-user` outputs the current active online users, including their authenticated usernames, mapped IP addresses, authentication mode, and group memberships.

Question 302

Topic: Authentication Domain Concept

Type: Single Choice

What is an 'Authentication Domain' in Huawei firewall AAA configuration?

- A. A physical geographic territory where firewalls are sold
- B. An administrative container that binds authentication schemes, authorization schemes, accounting schemes, and server templates together for a category of users
- C. A DNS top-level domain ending in .org
- D. A hardware ASIC chip on the motherboard

Correct Answer: B

Concept & Rationale: An Authentication Domain is a logical AAA management entity. It links specific authentication schemes (local/RADIUS/LDAP), authorization rules, and accounting servers, allowing different user groups (e.g., staff vs guests) to use distinct AAA pipelines.

Question 303

Topic: Default Authentication Domain

Type: Single Choice

In Huawei firewall AAA architecture, which domain is utilized if a user logs in with a plain username without specifying a domain suffix (e.g., logging in as 'john' rather than 'john@corp')?

- A. The guest domain
- B. The default domain (default to 'default' or configured default domain)
- C. The connection is rejected immediately
- D. The local loopback domain

Correct Answer: B

Concept & Rationale: When credentials omit a domain suffix, the firewall automatically evaluates the login against the designated Default Domain (named `default` unless altered by administrators).

Question 304

Topic: Accounting Interim Update Interval

Type: Single Choice

Why do enterprise AAA deployments configure periodic 'Accounting Interim Updates' between the firewall and RADIUS accounting server?

- A. To prevent the RADIUS server from entering sleep mode
- B. To provide regular ongoing session health checks and volume updates, ensuring accurate billing and detecting abrupt connection drops
- C. To change the user's password every 10 minutes
- D. To test the maximum throughput of the firewall backplane

Correct Answer: B

Concept & Rationale: Interim accounting updates (sent periodically, e.g. every 15 minutes) inform the billing/auditing server that the session remains active and report cumulative data usage, preventing orphan sessions if a client disconnects without a formal stop message.

Question 305

Topic: Password Storage Security in VRP

Type: Single Choice

How should passwords for local user accounts be configured in Huawei VRP CLI to prevent cleartext exposure in configuration files?

- A. local-user <name> password plain <pwd>
- B. local-user <name> password cipher <pwd> (or using modern irreversible hashing like PBKDF2/SHA-256)
- C. local-user <name> password cleartext <pwd>
- D. Passwords cannot be stored in Huawei VRP

Correct Answer: B

Concept & Rationale: Configuring `password cipher` (or newer secure hash keywords) ensures that passwords are encrypted or irreversibly hashed in configuration files, preventing exposure during administrative reviews or configuration exports.

Question 306

Topic: Multi-Factor Authentication (MFA)

Type: Single Choice

How does Multi-Factor Authentication (MFA) enhance user authentication security on Huawei firewalls?

- A. By requiring users to type their password twice on the same screen
- B. By requiring two or more independent credential categories (e.g., something you know [password], something you have [token/SMS code], something you are [biometric])
- C. By doubling the CPU clock frequency during authentication
- D. By requiring authentication exclusively during daylight hours

Correct Answer: B

Concept & Rationale: MFA enforces defense-in-depth for user identity, requiring verification across distinct authentication factors (knowledge, possession, inherence), neutralizing threats from stolen or leaked passwords.

Question 307

Topic: Online User Aging Mechanism

Type: Single Choice

What happens to an IP-to-user mapping in the firewall's online user table when a user's idle timeout elapses?

- A. The user's workstation is automatically formatted
- B. The online user entry ages out and is cleared from the table, requiring the user to re-authenticate before accessing protected resources
- C. The firewall converts the user's account into a local administrator
- D. All firewall security policies are permanently disabled

Correct Answer: B

Concept & Rationale: To maintain accurate bindings and reclaim resources, an aging timer monitors traffic from mapped IPs. If no traffic is detected within the idle timeout window, the user is logged out and removed from the active table.

Question 308

Topic: LDAP Search Filter

Type: Single Choice

What is an LDAP Search Filter used for when the firewall queries an Active Directory server?

- A. To restrict the search query to specific object classes and attributes (e.g., `(&(objectClass=user)(sAMAccountName=%u))` to locate a specific user)
- B. To filter out high-frequency electrical interference from Ethernet cables
- C. To delete unauthorized email messages on the exchange server
- D. To calculate the subnet mask of the domain controller

Correct Answer: A

Concept & Rationale: LDAP search filters define precise criteria (using standardized RFC LDAP filter syntax) that instruct the directory server to return only matching user or group objects, optimizing query performance.

Question 309

Topic: HWTACACS Command Authorization

Type: Single Choice

How does HWTACACS command authorization operate during an administrator's CLI session?

- A. The administrator must reboot the switch after every command
- B. Each time the administrator enters a command at the CLI prompt, the firewall sends a separate authorization request to the HWTACACS server to verify if that user has permission to execute that specific command string
- C. The firewall executes all commands without checking permissions
- D. Commands are authorized only once at initial login

Correct Answer: B

Concept & Rationale: With per-command authorization enabled, the firewall intercepts each command entered by the administrator and sends an authorization query to the HWTACACS server in real time. The command executes only if the server returns **PASS**.

Question 310**Topic:** Local User Account Locking**Type:** Single Choice

What security feature protects local user accounts against online brute-force password guessing attacks on Huawei firewalls?

- A. Automatic account lockout after a configurable number of consecutive failed authentication attempts (e.g., locked for 10 minutes after 3 failures)
- B. Permanently destroying the firewall flash storage after 5 failures
- C. Converting failed passwords into valid root passwords
- D. Disabling power to the enterprise building

Correct Answer: A

Concept & Rationale: Account lockout policies automatically lock user accounts for a specified duration after consecutive failed login attempts, rendering automated brute-force credential attacks ineffective.

Question 311**Topic:** MAC-Address-Based Authentication**Type:** Single Choice

In environments with non-interactive devices (such as IP cameras, printers, and IoT sensors) that lack web browsers, which authentication mode is commonly used?

- A. Portal web browser authentication
- B. MAC Address Authentication (or 802.1X MAC bypass) where the device's physical MAC address serves as the authentication credential against a RADIUS server
- C. Requiring printers to type their passwords using touchscreens
- D. Disabling all network access for non-PC devices

Correct Answer: B

Concept & Rationale: Headless IoT devices (printers, cameras, badge readers) cannot complete interactive web portal logins. MAC Authentication (MAB) automatically authenticates devices by using their hardware MAC address as the username and password against a RADIUS server.

Question 312**Topic:** Display User Status Command**Type:** Single Choice

Which command is used in Huawei VRP to view the configuration and operational status of a specific local user account?

- A. `display local-user username <name>`
- B. `display current-user`
- C. `display password`
- D. `display interface`

Correct Answer: A

Concept & Rationale: The command `display local-user username <name>` outputs configuration parameters for the specified account, including privilege level, account state (active/locked), expiration time, and allowed service types.

9 Chapter 9: Fundamentals of Encryption and Decryption Technologies

Question 313

Topic: Kerckhoffs's Principle

Type: Single Choice

According to Kerckhoffs's Principle in modern cryptography, what should the security of a cryptosystem depend on?

- A. Keeping the mathematical algorithm secret from the public
- B. The secrecy of the key alone, assuming the algorithm is completely public knowledge
- C. The physical thickness of the computer chassis
- D. Changing the computer operating system every 30 days

Correct Answer: B

Concept & Rationale: Kerckhoffs's Principle states that the design of a cryptosystem must not require secrecy; the system must remain secure even if everything about the algorithm is known to the adversary, provided only the key is kept secret.

Question 314

Topic: Symmetric Encryption Definition

Type: Single Choice

What is the defining operational characteristic of a symmetric encryption algorithm?

- A. It uses completely different, mathematically unrelated keys for encryption and decryption
- B. The exact same secret key (or easily derived keys) is used for both encryption and decryption
- C. It can only encrypt data during nighttime hours
- D. It requires physical paper keys delivered by postal courier

Correct Answer: B

Concept & Rationale: In symmetric cryptography, both communicating parties share a single secret key ($K_e = K_d$) utilized for both encrypting plaintext into ciphertext and decrypting ciphertext back into plaintext.

Question 315

Topic: Symmetric Encryption Strength

Type: Single Choice

What is the primary operational advantage of symmetric encryption algorithms compared to asymmetric algorithms?

- A. They completely eliminate the need for key distribution
- B. High computational speed, low processing overhead, and high throughput, making them ideal for bulk data encryption
- C. They provide legal non-repudiation without digital signatures
- D. They do not require any computer memory

Correct Answer: B

Concept & Rationale: Symmetric ciphers use fast hardware-friendly bitwise operations, making them hundreds to thousands of times faster than asymmetric ciphers, perfectly suited for high-speed transmission of large data streams.

Question 316

Topic: Symmetric Key Scalability Problem

Type: Single Choice

If an enterprise network has N participating entities that all need to communicate securely with each other using unique symmetric keys, how many total keys must be generated and managed?

- A. N keys
- B. $2N$ keys
- C. $N(N-1)/2$ keys
- D. N^2 keys

Correct Answer: C

Concept & Rationale: Because every pair of participants requires a unique shared secret key, the total number of keys scales quadratically as $N(N-1)/2$, creating severe key distribution and storage challenges at scale.

Question 317

Topic: Stream vs Block Cipher

Type: Single Choice

How does a Block Cipher process plaintext compared to a Stream Cipher?

- A. A block cipher encrypts data bit-by-bit continuously
- B. A block cipher divides plaintext into fixed-size blocks (e.g. 64 or 128 bits) and encrypts each block as a discrete unit
- C. A block cipher does not use any keys
- D. A block cipher operates only on analog voice audio

Correct Answer: B

Concept & Rationale: Block ciphers divide plaintext into discrete blocks of fixed length (e.g., 64 bits for DES, 128 bits for AES) and apply rounds of substitution and permutation. Stream ciphers encrypt continuous streams bit-by-bit or byte-by-byte (e.g., RC4).

Question 318

Topic: DES Key Length

Type: Single Choice

What is the effective cryptographic key length of the standard Data Encryption Standard (DES) algorithm?

- A. 32 bits
- B. 56 bits
- C. 64 bits
- D. 128 bits

Correct Answer: B

Concept & Rationale: DES uses a 64-bit key, but 8 bits are parity bits used for error checking. Therefore, the effective cryptographic key strength is only 56 bits, which is insecure against modern brute-force computing.

Question 319

Topic: 3DES Operational Structure

Type: Single Choice

In Triple DES (3DES), what is the sequence of cryptographic operations applied to each 64-bit plaintext block using three keys (K_1 , K_2 , K_3)?

- A. Encrypt with K_1 -> Encrypt with K_2 -> Encrypt with K_3
- B. Encrypt with K_1 -> Decrypt with K_2 -> Encrypt with K_3 (EDE mode)
- C. Decrypt with K_1 -> Decrypt with K_2 -> Decrypt with K_3
- D. Hash with K_1 -> Sign with K_2 -> Encrypt with K_3

Correct Answer: B

Concept & Rationale: Standard 3DES uses Encrypt-Decrypt-Encrypt (EDE) processing: $C = E_{K1}(D_{K2}(E_{K3}(P)))$. This ensures backward compatibility with single DES when $K_1 = K_2 = K_3$.

Question 320

Topic: AES Block Size

Type: Single Choice

What is the fixed block size processed by the Advanced Encryption Standard (AES) algorithm?

- A. 56 bits
- B. 64 bits
- C. 128 bits
- D. 256 bits

Correct Answer: C

Concept & Rationale: Under the official FIPS 197 standard (Rijndael cipher), AES has a fixed block size of 128 bits, regardless of whether the key length is 128, 192, or 256 bits.

Question 321

Topic: AES Key Length Options

Type: Single Choice

Which three key lengths are officially supported by the standard AES algorithm?

- A. 56, 112, and 168 bits
- B. 64, 128, and 256 bits
- C. 128, 192, and 256 bits
- D. 256, 512, and 1024 bits

Correct Answer: C

Concept & Rationale: AES officially supports three cryptographic key lengths: 128 bits (10 transformation rounds), 192 bits (12 rounds), and 256 bits (14 rounds).

Question 322

Topic: Asymmetric Cryptography Concept

Type: Single Choice

What key pair structure is utilized in Asymmetric (Public-Key) cryptography?

- A. A single shared symmetric key
- B. Two mathematically related keys: a Public Key (distributed openly) and a Private Key (kept strictly secret by the owner)
- C. Three identical keys stored on three separate servers
- D. An unencrypted password sent in cleartext

Correct Answer: B

Concept & Rationale: Asymmetric cryptography uses key pairs. The Public Key is shared openly for encryption or signature verification; the Private Key is kept secret by the owner for decryption or signature generation.

Question 323

Topic: Asymmetric Key Count Scalability

Type: Single Choice

In a network with N participants using asymmetric public-key cryptography, how many total keys are required across the entire system?

- A. $N(N-1)/2$ keys
- B. $2N$ keys (one public key and one private key per user)
- C. N^2 keys
- D. Exactly 1 key

Correct Answer: B

Concept & Rationale: Because each participant generates one public key and one private key, a system of N users requires only $2N$ keys, completely solving the quadratic key-management scalability issue of symmetric ciphers.

Question 324

Topic: RSA Mathematical Foundation

Type: Single Choice

What underlying mathematical problem provides the cryptographic security of the RSA algorithm?

- A. The difficulty of solving linear algebraic equations
- B. The computational difficulty of factoring the product of two very large prime numbers
- C. The speed of calculating square roots of even numbers
- D. The physical distance between two fiber optic endpoints

Correct Answer: B

Concept & Rationale: RSA security relies on the prime factorization trapdoor problem: multiplying two large prime numbers (p and q) is computationally simple, but factoring their large composite product ($n = p \times q$) is computationally infeasible with classical algorithms.

Question 325

Topic: RSA Recommended Key Length

Type: Single Choice

What is the minimum key length generally recommended for secure enterprise RSA implementations today?

- A. 512 bits
- B. 768 bits
- C. 1024 bits
- D. 2048 bits or higher

Correct Answer: D

Concept & Rationale: RSA keys of 512 and 1024 bits are considered deprecated and vulnerable to factoring attacks. National and international standards mandate 2048-bit or 4096-bit RSA keys for secure enterprise deployments.

Question 326

Topic: Elliptic Curve Cryptography (ECC) Advantage

Type: Single Choice

What is the primary technical advantage of Elliptic Curve Cryptography (ECC) compared to traditional RSA?

- A. ECC can be decrypted without any keys
- B. ECC provides equivalent cryptographic strength with significantly shorter key lengths (e.g. 256-bit ECC provides security equivalent to 3072-bit RSA), reducing processing overhead and bandwidth
- C. ECC does not use any mathematical equations
- D. ECC can only be executed on supercomputers

Correct Answer: B

Concept & Rationale: Based on the discrete logarithm problem over elliptic curves, ECC delivers equivalent cryptographic security with much smaller key sizes (e.g., 256-bit ECC roughly equivalent to 3072-bit RSA), resulting in faster computations and lower bandwidth/memory footprints.

Question 327

Topic: Diffie-Hellman (DH) Function

Type: Single Choice

What is the primary operational capability provided by the Diffie-Hellman (DH) algorithm in network protocols like IPsec?

- A. Direct bulk file encryption of multi-gigabyte databases
- B. Allowing two parties to securely negotiate and establish a shared secret key over an insecure, public communication channel
- C. Creating digital signatures to provide legal non-repudiation
- D. Formatting hard drives remotely across the Internet

Correct Answer: B

Concept & Rationale: Diffie-Hellman is a key agreement/exchange protocol. It enables two communicating entities to derive a shared symmetric secret key across an untrusted network without transmitting the secret itself. DH cannot directly encrypt data or produce digital signatures.

Question 328

Topic: Diffie-Hellman MitM Vulnerability

Type: Single Choice

What critical vulnerability does basic unauthenticated Diffie-Hellman exhibit if an active attacker intercepts communications?

- A. It causes physical overheating of the network switch
- B. Vulnerability to Man-in-the-Middle (MitM) attacks where the attacker negotiates independent keys with both endpoints
- C. It forces both endpoints to reveal their private passwords
- D. It permanently disables the IP routing protocol

Correct Answer: B

Concept & Rationale: Standard DH does not authenticate peer identities. An active attacker can intercept the exchange, negotiate separate DH keys with each endpoint, and transparently decrypt, read, and re-encrypt all traffic in a classic Man-in-the-Middle attack. Authentication (via PSK or certificates) is required to secure DH.

Question 329

Topic: Cryptographic Hash Definition

Type: Single Choice

What is a One-Way Cryptographic Hash Function?

- A. An encryption algorithm that can be reversed using a secret key
- B. A mathematical algorithm that takes an arbitrary-length input and transforms it into a fixed-length digest, such that reversing the operation is computationally infeasible
- C. A protocol that accelerates physical optical signal propagation
- D. A software tool that formats USB flash drives

Correct Answer: B

Concept & Rationale: A one-way hash function maps variable-length input data to a fixed-size output digest. It is irreversible (pre-image resistant), meaning the original message cannot be reconstructed from the hash value alone.

Question 330

Topic: Hash Avalanche Effect

Type: Single Choice

What does the 'Avalanche Effect' signify in cryptographic hash functions?

- A. Changing even a single bit in the input message completely and unpredictably alters more than half of the bits in the output digest
- B. The hash algorithm runs twice as fast when processing large files
- C. The server chassis temperature drops below freezing
- D. The output digest length expands continuously as more data is processed

Correct Answer: A

Concept & Rationale: The avalanche effect ensures that minor modifications to input data (such as flipping a single bit) produce a drastically and unpredictably different digest, making it impossible to detect patterns or predict hash variations.

Question 331

Topic: MD5 Digest Length

Type: Single Choice

What is the fixed output digest length produced by the MD5 (Message Digest 5) algorithm?

- A. 64 bits
- B. 128 bits
- C. 160 bits
- D. 256 bits

Correct Answer: B

Concept & Rationale: MD5 produces a fixed 128-bit (16-byte) hash digest, commonly displayed as a 32-character hexadecimal string. MD5 is cryptographically broken due to demonstrated collision attacks.

Question 332

Topic: SHA-1 Digest Length

Type: Single Choice

What is the fixed output digest length produced by the SHA-1 algorithm?

- A. 128 bits
- B. 160 bits
- C. 256 bits
- D. 512 bits

Correct Answer: B

Concept & Rationale: SHA-1 produces a 160-bit (20-byte) hash digest, displayed as a 40-character hexadecimal string. SHA-1 is deprecated due to practical collision attacks.

Question 333

Topic: SHA-2 Family Members

Type: Single Choice

Which of the following hash algorithms belongs to the SHA-2 family and is universally deployed in modern network security protocols?

- A. MD5
- B. SHA-1
- C. SHA-256
- D. DES

Correct Answer: C

Concept & Rationale: The SHA-2 family (defined in FIPS 180-4) comprises SHA-224, SHA-256, SHA-384, and SHA-512. SHA-256 produces a 256-bit digest and is the modern benchmark for data integrity.

Question 334

Topic: Hash Pre-Image Resistance

Type: Single Choice

What does 'Pre-Image Resistance' (One-Way Property) mean for a cryptographic hash function H ?

- A. Given an input M , it is impossible to calculate $H(M)$
- B. Given a hash digest Y , it is computationally infeasible to find any original message M such that $H(M) = Y$
- C. Finding two messages with the same hash is instantaneous
- D. The hash algorithm can only process plaintext shorter than 10 bytes

Correct Answer: B

Concept & Rationale: Pre-image resistance (first pre-image resistance) ensures that given an output hash Y , it is computationally impossible to reverse-engineer any valid plaintext M that hashes to Y .

Question 335

Topic: Hash Collision Definition

Type: Single Choice

In cryptographic hashing, what is a 'Collision'?

- A. Two physical network cables touching each other
- B. Two completely different input messages that produce the exact same output hash digest ($H(M_1) = H(M_2)$ where $M_1 \neq M_2$)
- C. An IP address conflict between two workstations
- D. A corrupted Ethernet frame header

Correct Answer: B

Concept & Rationale: A hash collision occurs when two distinct input messages yield the identical hash digest. Secure cryptographic hash functions must be collision-resistant to prevent attackers from substituting forged messages.

Question 336

Topic: HMAC Definition

Type: Single Choice

What is a Hash-Based Message Authentication Code (HMAC)?

- A. An unencrypted text message sent across the Internet
- B. A cryptographic construction that combines a secret key with a hash function (e.g., HMAC-SHA256) to provide both data integrity and origin authentication
- C. A physical hardware token used to unlock server doors
- D. A method of formatting hard drives using hashes

Correct Answer: B

Concept & Rationale: HMAC incorporates a secret cryptographic key into the hashing process ($H((K \oplus \text{opad}) \parallel H((K \oplus \text{ipad}) \parallel M))$). Only entities possessing the shared secret can generate or verify the HMAC, confirming both integrity and origin authenticity.

Question 337

Topic: Digital Signature Signing Key

Type: Single Choice

When an entity creates a digital signature on a document, which key is used to generate the signature?

- A. The recipient's public key
- B. The sender's private key
- C. The sender's public key
- D. A shared symmetric pre-shared key

Correct Answer: B

Concept & Rationale: A digital signature is created when the sender encrypts a hash digest of the document using the sender's own PRIVATE key. Because only the sender possesses this private key, it uniquely authenticates the sender.

Question 338

Topic: Digital Signature Verification Key

Type: Single Choice

Which key does the recipient use to verify a sender's digital signature?

- A. The sender's private key
- B. The recipient's private key
- C. The sender's public key
- D. The ISP router's MAC address

Correct Answer: C

Concept & Rationale: The recipient verifies the signature by decrypting it using the sender's openly available PUBLIC key to retrieve the original digest, comparing it with a locally computed hash of the received message.

Question 339

Topic: Digital Signature Core Guarantees

Type: Single Choice

Which three fundamental security guarantees are simultaneously provided by a digital signature?

- A. Confidentiality, Physical Security, and Port Redundancy
- B. Authenticity (origin verification), Integrity (tamper detection), and Non-repudiation
- C. Bandwidth acceleration, Compression, and Low latency
- D. Anonymity, Deniability, and Plausible erasure

Correct Answer: B

Concept & Rationale: A digital signature mathematically guarantees: 1. Authenticity (proves who sent it); 2. Integrity (detects alterations); and 3. Non-repudiation (sender cannot deny having signed it).

Question 340

Topic: Digital Signature and Confidentiality

Type: Single Choice

Does digitally signing an email message automatically encrypt the message body to provide confidentiality?

- A. Yes, digital signatures always encrypt the entire message body
- B. No, a digital signature provides authenticity and integrity, but does not encrypt the message plaintext unless separate encryption is applied
- C. Yes, but only if the recipient uses Linux
- D. Yes, by converting the message into an uncompressed ZIP archive

Correct Answer: B

Concept & Rationale: A digital signature signs a hash digest; it does not encrypt the underlying plaintext message. The message can still be read by eavesdroppers unless an encryption cipher is layered with the signature.

Question 341

Topic: Hybrid Cryptosystem Architecture

Type: Single Choice

How does a 'Hybrid Cryptosystem' (such as TLS or IPsec) combine symmetric and asymmetric cryptography effectively?

- A. It uses asymmetric encryption to encrypt bulk user files and symmetric encryption to exchange keys
- B. It uses asymmetric cryptography (e.g. RSA or DH) to authenticate entities and securely negotiate a shared session key, which is then used by fast symmetric cryptography (e.g. AES) to encrypt bulk data
- C. It alternates between symmetric and asymmetric ciphers on every odd-numbered second
- D. It disables encryption entirely to maximize speed

Correct Answer: B

Concept & Rationale: Hybrid cryptosystems capture the best of both worlds: asymmetric ciphers solve key distribution and authentication, while high-throughput symmetric ciphers encrypt the actual high-volume data payloads.

Question 342

Topic: Message Digest Invertibility

Type: Single Choice

Can a 256-bit SHA-256 hash digest of a 10-megabyte video file be decrypted to recreate the original video file?

- A. Yes, using the sender's private RSA key
- B. No, hashing is a one-way mathematical reduction; the original data cannot be reconstructed from the digest
- C. Yes, if the firewall has at least 64 GB of RAM
- D. Yes, by reversing the MD5 algorithm

Correct Answer: B

Concept & Rationale: A hash is a fixed-length mathematical compression, not an encrypted file. Enormous amounts of original data are irreversibly discarded during hashing; a digest cannot be 'decrypted' into the original file.

Question 343

Topic: RC4 Cipher Type

Type: Single Choice

What type of cryptographic algorithm is RC4, and what is its current security status?

- A. A 128-bit block cipher that is widely recommended for banking
- B. A stream cipher that has been proven insecure due to statistical keystream biases and is deprecated across modern protocols
- C. An asymmetric public-key algorithm based on elliptic curves
- D. A one-way cryptographic hash function producing 512-bit digests

Correct Answer: B

Concept & Rationale: RC4 is a variable key-size stream cipher. Due to severe cryptographic vulnerabilities (keystream biases and plaintext recovery attacks), RC4 is prohibited by IETF RFCs and deprecated in modern TLS and VPNs.

Question 344**Topic:** Symmetric Key Exchange Challenge**Type:** Single Choice

What is the fundamental operational dilemma of pure symmetric cryptography in widespread communications?

- A. Symmetric algorithms are too slow to run on modern computers
- B. How to securely transmit the secret key to the remote party across an untrusted network before encrypted communication can begin
- C. Symmetric ciphers can only encrypt text written in English
- D. Symmetric keys cannot exceed 8 bits in length

Correct Answer: B

Concept & Rationale: The fundamental challenge of symmetric encryption is the 'Key Distribution Problem': both parties must share a secret key before communicating securely, but transmitting the key across an insecure channel risks interception.

Question 345**Topic:** AES Key Expansion**Type:** Single Choice

In AES encryption, what is the purpose of the Key Expansion (Key Schedule) algorithm?

- A. To increase the size of the ciphertext file on disk
- B. To generate a series of round keys from the initial cipher key for use in each round of transformation
- C. To translate the key into a public digital certificate
- D. To send the key to an external NTP server

Correct Answer: B

Concept & Rationale: AES takes the primary cipher key (128, 192, or 256 bits) and runs it through a key expansion routine to derive multiple 128-bit 'round keys' applied during each successive round of substitution and permutation.

Question 346**Topic:** Digital Signature Verification Failure**Type:** Single Choice

If an attacker intercepts a digitally signed message in transit and alters a single letter in the text before it reaches the recipient, what will happen during verification?

- A. The recipient's computer will catch fire
- B. The recipient's locally computed hash will not match the decrypted signature hash, and the signature verification will fail, detecting the tampering
- C. The signature will automatically fix the letter back to its original state
- D. The verification will succeed because signatures ignore text changes

Correct Answer: B

Concept & Rationale: Because of the avalanche effect, altering even one character produces a totally different hash digest. When the recipient computes the hash of the tampered text, it fails to match the digest decrypted from the signature, exposing the alteration.

10 Chapter 10: PKI Certificate System

Question 347**Topic:** PKI Fundamental Problem Solved**Type:** Single Choice

What fundamental security challenge does a Public Key Infrastructure (PKI) solve in public-key cryptography?

- A. Increasing the physical speed of Ethernet cables
- B. The authenticity and binding problem of public keys (preventing attackers from substituting fake public keys)
- C. Eliminating the need for asymmetric mathematics
- D. Translating IPv4 addresses to IPv6 format

Correct Answer: B

Concept & Rationale: Public-key cryptography requires verifying that a public key genuinely belongs to the claimed identity. Without PKI, an attacker can perform a Man-in-the-Middle attack by substituting a forged public key. PKI binds identities to public keys via trusted digital certificates.

Question 348**Topic:** Digital Certificate Definition**Type:** Single Choice

What is a Digital Certificate in the context of ITU-T X.509 PKI?

- A. A physical paper diploma issued by a university
- B. An electronic credential digitally signed by a trusted Certificate Authority (CA) that binds a subject identity to its public key
- C. An unencrypted password file stored on a USB drive
- D. A hardware microchip installed on an Ethernet switch

Correct Answer: B

Concept & Rationale: A digital certificate is a tamper-evident electronic document signed by a trusted CA. It securely binds an identity (the Subject) to its public key, containing validity dates, serial numbers, and usage constraints.

Question 349**Topic:** CA Core Role**Type:** Single Choice

What is the primary operational role of a Certificate Authority (CA) in a PKI system?

- A. To manufacture physical fiber optic cables
- B. To issue, sign, manage, and revoke digital certificates as an authoritative trusted third party
- C. To assign IP addresses to DHCP clients
- D. To perform high-speed packet routing between autonomous systems

Correct Answer: B

Concept & Rationale: The Certificate Authority (CA) is the central trusted authority in PKI. The CA verifies identities (or relies on an RA), signs certificates using its private key, manages certificate lifecycles, and publishes revocation information.

Question 350

Topic: RA Role

Type: Single Choice

What is the primary function of a Registration Authority (RA) in a PKI deployment?

- A. To physically route IP packets across the WAN
- B. To accept certificate requests, verify the applicant's real-world identity and credentials, and forward approved requests to the CA
- C. To sign root certificates using its private key
- D. To provide electrical power to the server room

Correct Answer: B

Concept & Rationale: The Registration Authority (RA) acts as the front-end identity verification officer for the CA. The RA validates the applicant's credentials, organizational standing, and domain ownership before requesting the CA to sign the certificate.

Question 351

Topic: CRL Definition

Type: Single Choice

What is a Certificate Revocation List (CRL)?

- A. A list of all users who have forgotten their passwords
- B. A digitally signed list published periodically by a CA that catalogs the serial numbers of revoked certificates that should no longer be trusted
- C. A routing table containing blackholed IP addresses
- D. A list of physical hardware MAC addresses

Correct Answer: B

Concept & Rationale: A CRL is a time-stamped, CA-signed list containing the serial numbers of certificates that have been revoked prior to their scheduled expiration date (e.g. due to private key compromise or organizational departure).

Question 352

Topic: X.509 Standard Version

Type: Single Choice

Which version of the ITU-T X.509 standard is universally used for digital certificates in modern network security and SSL/TLS?

- A. X.509 Version 1
- B. X.509 Version 2
- C. X.509 Version 3
- D. X.509 Version 4

Correct Answer: C

Concept & Rationale: X.509 Version 3 (RFC 5280) is the prevailing international standard for digital certificates, introducing flexible Extension fields (such as Key Usage, Subject Alternative Name, and Basic Constraints).

Question 353

Topic: X.509 Core Field - Serial Number

Type: Single Choice

What is the requirement for the 'Serial Number' field in an X.509 digital certificate?

- A. It must be identical for all certificates issued worldwide
- B. It must be a unique positive integer assigned by the issuing CA to distinguish each certificate it issues
- C. It must match the user's telephone number
- D. It must be written in cleartext ASCII English

Correct Answer: B

Concept & Rationale: Under RFC 5280, the certificate serial number must be a unique positive integer assigned by the issuing CA. No two distinct certificates issued by the same CA may share the same serial number.

Question 354**Topic:** X.509 Validity Period Fields**Type:** Single Choice

Which two time-stamped fields define the active lifespan of an X.509 digital certificate?

- A. Start Time and End Time
- B. Not Before and Not After
- C. Creation Date and Deletion Date
- D. Lease Acquired and Lease Expired

Correct Answer: B

Concept & Rationale: The Validity field in an X.509 certificate contains two timestamps: **Not Before** (the date/time when the certificate becomes valid) and **Not After** (the date/time when the certificate expires).

Question 355**Topic:** X.509 Subject Field**Type:** Single Choice

In an X.509 certificate, what entity does the 'Subject' field represent?

- A. The Certificate Authority that issued the certificate
- B. The specific identity (user, server, domain name, or organization) that owns the certificate and holds the corresponding private key
- C. The physical switch port to which the server is connected
- D. The protocol version of the operating system

Correct Answer: B

Concept & Rationale: The Subject field identifies the entity holding the private key corresponding to the public key certified in the document. The Issuer field identifies the CA that signed the certificate.

Question 356**Topic:** X.509 Subject Public Key Info**Type:** Single Choice

What information is encapsulated within the 'Subject Public Key Info' field of an X.509 certificate?

- A. The private key of the user in cleartext
- B. The public key algorithm identifier (e.g., RSA or ECC) and the actual public key bit string
- C. The password used to log in to the workstation
- D. The MAC address of the default gateway

Correct Answer: B

Concept & Rationale: Subject Public Key Info contains the algorithm identifier (e.g., `rsaEncryption` or `id-ecPublicKey`) along with the mathematical public key bits. Private keys are NEVER stored in a digital certificate!

Question 357

Topic: X.509 Extension - Basic Constraints

Type: Single Choice

In X.509 v3, what does the 'Basic Constraints' extension field indicate?

- A. The maximum bandwidth of the server interface
- B. Whether the certificate belongs to a Certificate Authority (`ca = TRUE`) and the maximum allowed depth of subordinate certification paths
- C. The operating system version of the client computer
- D. The physical dimensions of the server chassis

Correct Answer: B

Concept & Rationale: Basic Constraints defines whether the certificate subject is a CA (`ca=TRUE`), authorized to sign other certificates, or an end entity (`ca=FALSE`). It can also specify a `pathLenConstraint` limiting the intermediate CA chain depth.

Question 358

Topic: X.509 Extension - SAN

Type: Single Choice

Why is the Subject Alternative Name (SAN) extension essential for modern HTTPS web server certificates?

- A. It allows a single certificate to secure multiple distinct domain names, subdomains, and IP addresses
- B. It permanently disables all firewall security policies
- C. It stores the company's financial accounting records
- D. It converts RSA keys into AES keys

Correct Answer: A

Concept & Rationale: The SAN extension allows binding multiple hostnames (e.g. `example.com`, `www.example.com`, `mail.example.com`) and IP addresses to a single certificate, replacing legacy single-domain Common Name (CN) matching.

Question 359

Topic: X.509 Extension - Key Usage

Type: Single Choice

What is the purpose of the 'Key Usage' extension in an X.509 certificate?

- A. To count how many times the user logs in per day
- B. To restrict the specific cryptographic operations for which the certified key may be used (e.g., Digital Signature, Key Encipherment, CRL Sign)
- C. To measure the electrical power consumption of the processor
- D. To record the user's physical office room number

Correct Answer: B

Concept & Rationale: Key Usage defines permissible cryptographic purposes for the public key (e.g., `digitalSignature`, `keyEncipherment`, `keyCertSign`, `cRLSign`), preventing keys intended for signing from being misused for encryption.

Question 360

Topic: X.509 Extension - Extended Key Usage (EKU)

Type: Single Choice

Which of the following is a standard purpose specified under the Extended Key Usage (EKU) extension?

- A. Server Authentication (TLS Web Server)
- B. Client Authentication
- C. Code Signing
- D. All of the above

Correct Answer: D

Concept & Rationale: EKU defines specific application purposes: Server Authentication (OID 1.3.6.1.5.5.7.3.1), Client Authentication (OID 1.3.6.1.5.5.7.3.2), Code Signing (OID 1.3.6.1.5.5.7.3.3), and Email Protection (S/MIME).

Question 361

Topic: X.509 Extension - CDP

Type: Single Choice

What information is provided by the CRL Distribution Points (CDP) extension in an X.509 certificate?

- A. The home address of the user
- B. One or more URIs (HTTP or LDAP) where clients can download the latest Certificate Revocation List to verify revocation status
- C. The IP address of the primary DNS root server
- D. The credit card number of the certificate purchaser

Correct Answer: B

Concept & Rationale: The CDP extension provides URIs (typically HTTP URLs or LDAP paths) indicating where validation software can retrieve the current CRL published by the issuing CA.

Question 362

Topic: OCSP Protocol Purpose

Type: Single Choice

What is the Online Certificate Status Protocol (OCSP, RFC 6960)?

- A. An online banking protocol for wire transfers
- B. A lightweight, real-time query protocol allowing clients to check the revocation status of a specific certificate directly against an OCSP Responder
- C. A routing protocol used to establish BGP peering
- D. A protocol for synchronizing computer motherboard clocks

Correct Answer: B

Concept & Rationale: OCSP provides real-time certificate status checks. Instead of downloading large multi-megabyte CRL files, a client queries the OCSP responder with a certificate serial number, receiving an immediate signed status response: 'Good', 'Revoked', or 'Unknown'.

Question 363

Topic: OCSP vs CRL Advantage

Type: Single Choice

What is the primary operational advantage of OCSP over traditional CRLs?

- A. OCSP completely eliminates the need for Certificate Authorities
- B. OCSP provides immediate real-time revocation verification with minimal bandwidth consumption, avoiding large periodic CRL downloads
- C. OCSP works without any network connection
- D. OCSP automatically repairs revoked certificates

Correct Answer: B

Concept & Rationale: Traditional CRLs suffer from publication delays (a revoked key remains accepted until the next CRL is published) and heavy bandwidth overhead. OCSP queries provide real-time status with tiny request/response packets.

Question 364

Topic: OSCP Stapling Mechanism

Type: Single Choice

How does 'OCSP Stapling' (RFC 6066) optimize TLS connection establishment for web clients?

- A. The web server periodically queries the OSCP responder and attaches ('staples') the time-stamped, CA-signed OSCP response directly into the TLS handshake to the client
- B. The client physically staples a paper certificate to its computer monitor
- C. The client disables certificate validation entirely to accelerate connection speed
- D. The web server forces all clients to download the entire CRL database

Correct Answer: A

Concept & Rationale: In OSCP Stapling, the web server caches a signed OSCP response from the CA and includes it in the initial TLS handshake. This eliminates client latency from querying external OSCP responders and protects user privacy from tracking.

Question 365

Topic: Root CA Characteristics

Type: Single Choice

What is a defining characteristic of a 'Root CA' certificate in a hierarchical PKI?

- A. It is signed by an external commercial ISP
- B. It is self-signed (the Issuer field matches the Subject field) and serves as the ultimate trust anchor
- C. It must be renewed every 24 hours
- D. It contains the private keys of all subordinate users

Correct Answer: B

Concept & Rationale: A Root CA sits at the top of the trust tree. Its certificate is self-signed (**Issuer == Subject**) and signed with its own private key. Operating systems and browsers pre-install Root CA certificates as trusted anchors.

Question 366

Topic: Intermediate CA Role

Type: Single Choice

Why do enterprise PKI architectures deploy Intermediate (Subordinate) CAs rather than issuing end-entity certificates directly from the Root CA?

- A. Because Root CAs cannot issue certificates to web servers
- B. To protect the Root CA private key in an offline, physically secured vault, minimizing root compromise risk while the Intermediate CA handles daily operational issuance
- C. To convert public certificates into symmetric keys
- D. To comply with international maritime radio standards

Correct Answer: B

Concept & Rationale: Best practice keeps the Root CA offline in a secure, air-gapped safe. Intermediate CAs are issued to handle day-to-day certificate signing. If an intermediate CA is compromised, it can be revoked without invalidating the entire root trust anchor.

Question 367

Topic: Certificate Chain Verification

Type: Single Choice

How does a client validate a certificate chain presented by a web server (Server Cert -> Intermediate CA -> Root CA)?

- A. By verifying the digital signature on each certificate in the path using the issuing CA's public key up to a pre-installed trusted Root CA
- B. By sending the server's private key to the FBI for review
- C. By calculating the square root of the certificate serial number
- D. By converting the certificate into an uncompressed audio file

Correct Answer: A

Concept & Rationale: The client verifies each link in the hierarchical chain: Server Cert signature is verified with Intermediate CA's public key; Intermediate CA signature is verified with Root CA's public key; Root CA is confirmed present in the client's local trust store.

Question 368

Topic: Certificate Revocation Reasons

Type: Single Choice

Under which of the following circumstances MUST a digital certificate be immediately revoked by the CA?

- A. The private key corresponding to the certificate has been stolen or compromised
- B. The employee owning the certificate has resigned or been terminated from the enterprise
- C. The certified fully qualified domain name (FQDN) has been transferred to a different organization
- D. All of the above

Correct Answer: D

Concept & Rationale: Certificates must be revoked whenever private key compromise occurs, employee affiliation ends, domain ownership shifts, or operational parameters become untrusted.

Question 369

Topic: Self-Signed Certificate Insecurity

Type: Single Choice

Why does a web browser display an untrusted security warning when visiting a website using a self-signed certificate?

- A. The browser cannot calculate the AES encryption algorithm
- B. The self-signed certificate was not signed by a Certificate Authority pre-installed in the browser's trusted root store, meaning its identity cannot be verified against a trusted anchor
- C. Self-signed certificates cannot encrypt network data
- D. The website has physically disconnected its network card

Correct Answer: B

Concept & Rationale: Self-signed certificates are signed by their own private key, not by an established CA. Because the browser has no pre-existing trust anchor for that signer, it cannot verify the server's identity and warns of potential Man-in-the-Middle spoofing.

Question 370**Topic:** Certificate Signing Request (CSR)**Type:** Single Choice

What is a Certificate Signing Request (CSR) generated by an administrator when applying for a digital certificate?

- A. A request to purchase new server hardware
- B. A standardized file containing the applicant's public key, distinguished name (DN), and signature proving possession of the private key
- C. A file containing the applicant's secret private key in cleartext
- D. An administrative invoice submitted to the finance department

Correct Answer: B

Concept & Rationale: A CSR (standardized in PKCS#10) contains the applicant's public key and subject information, signed with the applicant's private key (proving possession of the key). The private key itself remains confidential on the local server.

Question 371**Topic:** PKCS#12 File Format**Type:** Single Choice

What is the standard purpose of the PKCS#12 (.p12 / .pfx) file format?

- A. A portable, password-encrypted archive format used to store and transfer an entity's private key along with its digital certificate and certificate chain
- B. A cleartext format used to display website logos
- C. An uncompressed video format used in security cameras
- D. A routing protocol configuration file

Correct Answer: A

Concept & Rationale: PKCS#12 defines an encrypted container format (protected by a symmetric password) designed to bundle private keys, user certificates, and intermediate CA certificates for secure backup and device import.

Question 372**Topic:** PEM File Format**Type:** Single Choice

What is the PEM (Privacy Enhanced Mail) certificate format commonly seen on Linux and Apache servers?

- A. A binary format that can only be opened with specialized hex editors
- B. A Base64-encoded ASCII text format delimited by header and footer lines (e.g., ---BEGIN CERTIFICATE---)
- C. An encrypted USB dongle
- D. A proprietary database format used by Microsoft Word

Correct Answer: B

Concept & Rationale: PEM is the most common certificate container format in open systems, encoding binary DER data into ASCII Base64 text framed by headers like ---BEGIN CERTIFICATE--- and ---END CERTIFICATE---.

Question 373

Topic: DER File Format

Type: Single Choice

What is the DER (Distinguished Encoding Rules) certificate format?

- A. A Base64 ASCII text format used in web emails
- B. A raw binary encoding format for X.509 certificates commonly used in Java and Windows environments
- C. A physical hardware device used to generate random numbers
- D. A script used to configure firewall security policies

Correct Answer: B

Concept & Rationale: DER is the binary representation of an X.509 certificate according to ASN.1 encoding rules, commonly identified by `.der` or `.cer` extensions in Windows and Java environments.

Question 374

Topic: Cross-Certification Concept

Type: Single Choice

What is 'Cross-Certification' in enterprise PKI architectures?

- A. Two independent CAs issue digital certificates to each other, establishing mutual trust between different organizations or PKI domains
- B. Crossing copper Ethernet cables to create a crossover link
- C. Encrypting data twice using different symmetric keys
- D. Re-installing the operating system on the primary CA server

Correct Answer: A

Concept & Rationale: Cross-certification allows two distinct PKI hierarchies (e.g. two merging enterprises or government agencies) to establish mutual trust without sharing a common Root CA by having each CA issue a cross-certificate to the other.

Question 375

Topic: CA Private Key Protection

Type: Single Choice

Which hardware technology is recommended as best practice for storing and protecting the private key of a high-assurance Root CA?

- A. A standard unencrypted desktop hard drive
- B. A dedicated tamper-resistant Hardware Security Module (HSM)
- C. A shared network folder accessible by all employees
- D. An unencrypted USB flash drive kept in an unlocked desk drawer

Correct Answer: B

Concept & Rationale: Hardware Security Modules (HSMs) provide physical tamper resistance, certified cryptographic boundaries (e.g. FIPS 140-2 Level 3), and ensure that private keys can never be exported in plaintext.

Question 376

Topic: Trust Anchor Definition

Type: Single Choice

In public key infrastructure, what is a 'Trust Anchor'?

- A. A heavy iron weight placed on server racks to prevent theft
- B. An authoritative entity (typically a self-signed Root CA certificate) that is trusted by default without requiring an external cryptographic signature
- C. A physical anchor attached to undersea fiber cables
- D. A domain controller with a static IP address

Correct Answer: B

Concept & Rationale: A Trust Anchor is the foundational root certificate explicitly trusted by an operating system, browser, or device. All certificate validation paths must terminate at an established trust anchor.

Question 377

Topic: AIA Extension Purpose

Type: Single Choice

What information does the Authority Information Access (AIA) extension provide to a certificate-validating client?

- A. The home phone number of the CA administrator
- B. URIs indicating where the client can retrieve the issuing CA's certificate and the location of the CA's OCSP responder service
- C. The internal IP address of the user's default gateway
- D. The physical room temperature of the data center

Correct Answer: B

Concept & Rationale: The AIA extension provides two critical endpoints: the HTTP URI to fetch the parent/issuing CA certificate (for building chains) and the OCSP responder URI (for real-time status verification).

Question 378

Topic: Expired Certificate Behavior

Type: Single Choice

What happens when a client software attempts to validate an X.509 certificate whose **Not After** date has passed?

- A. The client automatically updates the date on the certificate
- B. The certificate validation fails immediately with an expired certificate error, and the connection is flagged as untrusted
- C. The client ignores the date and permits the connection with full trust
- D. The computer turns off its network adapter

Correct Answer: B

Concept & Rationale: During path validation, the client checks current system time against **Not Before** and **Not After**. If current time exceeds **Not After**, the certificate is expired and validation fails, raising security warnings.

Question 379

Topic: Subject DN Component 'C'

Type: Single Choice

In an X.509 Distinguished Name (e.g. `C=CN, O=Huawei, CN=www.huawei.com`), what does the attribute 'C' represent?

- A. City
- B. Country (two-letter ISO code)
- C. Company
- D. Certificate

Correct Answer: B

Concept & Rationale: In X.500/X.509 Distinguished Name syntax, **C** represents the Country (standard two-letter ISO 3166 code, such as **CN**, **US**, **FR**). City is represented by **L** (Locality), and Company is **O** (Organization).

Question 380**Topic:** PKI Certificate Repository**Type:** Single Choice

What is the function of a Certificate Repository in PKI?

- A. A public directory (accessible via LDAP or HTTP) where valid end-entity certificates, CA certificates, and CRLs are stored for public retrieval
- B. A secure vault where private keys are openly published for download
- C. A scrap storage bin for discarded networking cables
- D. A database storing employee salaries

Correct Answer: A

Concept & Rationale: A Certificate Repository is a publicly accessible directory or web server that stores issued public certificates and published CRLs, enabling communicating parties to discover certificates and verify status.

11 Chapter 11: Encryption Technology Applications (IPsec & SSL VPN)

Question 381**Topic:** VPN Core Value**Type:** Single Choice

What is the primary motivation for an enterprise to deploy Virtual Private Network (VPN) technology across the public Internet instead of leasing dedicated physical leased lines?

- A. VPNs eliminate the need for routing protocols and IP addressing
- B. VPNs provide secure, encrypted virtual communication channels over low-cost public Internet infrastructure, drastically reducing connectivity costs and providing flexible scalability
- C. VPNs guarantee 100 Gbps physical throughput over standard telephone twisted-pair wires
- D. VPNs eliminate the need for enterprise firewalls and host endpoint protection

Correct Answer: B

Concept & Rationale: Leasing private telecommunication circuits (such as dedicated TDM/SDH or MPLS leased lines) is extremely expensive and rigid. VPN technology creates encrypted, authenticated virtual tunnels over public networks (like the Internet), providing high security at significantly reduced costs with rapid deployment flexibility.

Question 382**Topic:** VPN Classification by Topology**Type:** Single Choice

Which VPN deployment model is specifically designed for mobile employees, teleworkers, and roaming business travelers who need secure remote access into internal enterprise servers?

- A. Site-to-Site VPN
- B. Client-to-Site (Remote Access) VPN
- C. Layer 2 Carrier Backbone Interconnect
- D. Hub-and-Spoke Leased Ring

Correct Answer: B

Concept & Rationale: A Client-to-Site VPN (also known as Remote Access VPN or Client-Initiated VPN) enables roaming or telecommuting users to initiate dial-up or encrypted tunnel sessions from laptop/mobile endpoints to an enterprise VPN gateway.

Question 383

Topic: Site-to-Site VPN Scenario

Type: Single Choice

Which scenario represents a typical application of a Site-to-Site VPN?

- A. An executive accessing corporate email from an airport Wi-Fi using a smartphone
- B. Connecting the corporate headquarters network directly to a remote branch office LAN across the Internet
- C. A home user connecting to an online gaming server
- D. A customer browsing a public e-commerce web storefront

Correct Answer: B

Concept & Rationale: Site-to-Site VPN securely interconnects two fixed, static local area networks (LANs)—such as an enterprise headquarters and a branch office—via their edge VPN gateways across an untrusted WAN or Internet.

Question 384

Topic: VPN Tunneling Concept

Type: Single Choice

In VPN terminology, what is 'tunneling technology'?

- A. A physical excavation method used when installing underground fiber optic cables
- B. A technology that encapsulates packets of one network protocol (passenger protocol) inside the packets of another delivery protocol (encapsulating protocol) to traverse intermediate networks
- C. A protocol that compresses video files to reduce bandwidth usage
- D. A method of bypassing network firewalls without packet inspection

Correct Answer: B

Concept & Rationale: Tunneling encapsulates the original passenger packets (including original private IP headers and payloads) inside an encapsulating protocol header with outer routable IP headers, enabling private network traffic to transit across public intermediate transit networks.

Question 385

Topic: GRE Protocol Number

Type: Single Choice

In the IPv4 packet header, which Protocol field value uniquely identifies Generic Routing Encapsulation (GRE)?

- A. 50
- B. 51
- C. 47
- D. 6

Correct Answer: C

Concept & Rationale: IP protocol numbers: GRE is protocol 47; ESP is protocol 50; AH is protocol 51; TCP is protocol 6; UDP is protocol 17.

Question 386

Topic: GRE Primary Limitation

Type: Single Choice

What is the fundamental security limitation of standard Generic Routing Encapsulation (GRE) tunnels?

- A. GRE does not support tunneling multicast or dynamic routing protocols like OSPF
- B. GRE provides no native encryption or cryptographic data integrity authentication, transmitting passenger payloads in cleartext
- C. GRE is strictly limited to 10 hops across any IP network
- D. GRE requires an active web browser and SSL client installation

Correct Answer: B

Concept & Rationale: Standard GRE provides tunneling and supports heterogeneous protocols (including multicast and dynamic routing protocols like OSPF/RIP), but it provides zero cryptographic security: no data encryption and no data integrity verification. Therefore, GRE is frequently combined with IPsec (GRE over IPsec).

Question 387**Topic:** IPsec Architecture Definition**Type:** Single Choice

What is IPsec (IP Security)?

- A. A standalone hardware routing switch manufactured by Huawei
- B. An open, standardized framework developed by the IETF operating at the Network Layer (Layer 3) to provide confidentiality, integrity, and origin authentication for IP communications
- C. A proprietary application-layer software program running only on Windows desktops
- D. An asymmetric public key management standard defined by ITU-T

Correct Answer: B

Concept & Rationale: IPsec is an open suite of protocols defined by the IETF operating at Layer 3 (Network Layer) of the OSI model. It secures IP communications by providing data confidentiality (encryption), data integrity (tamper-proofing), data origin authentication, and anti-replay protection.

Question 388**Topic:** IPsec Protocol Suite Components**Type:** Single Choice

Which two core security encapsulation protocols form the foundation of the IPsec architecture?

- A. TCP and UDP
- B. AH (Authentication Header) and ESP (Encapsulating Security Payload)
- C. PAP and CHAP
- D. RIP and OSPF

Correct Answer: B

Concept & Rationale: The IPsec protocol suite is anchored by two primary security protocols: AH (Authentication Header, IP protocol 51) and ESP (Encapsulating Security Payload, IP protocol 50), coordinated by the Internet Key Exchange (IKE) protocol.

Question 389**Topic:** AH Security Capabilities**Type:** Single Choice

Which security services are provided by the Authentication Header (AH) protocol?

- A. Data encryption only
- B. Data origin authentication, data integrity verification, and anti-replay protection, but NO data confidentiality (no encryption)
- C. Full payload encryption and SSL certificate enrollment
- D. Port forwarding and web proxying

Correct Answer: B

Concept & Rationale: AH (IP protocol 51) provides strong data origin authentication, message integrity verification (via ICV hash), and anti-replay protection. Crucially, AH does NOT encrypt data; the packet payload remains completely visible in cleartext.

Question 390

Topic: AH and NAT Incompatibility

Type: Single Choice

Why is the AH protocol fundamentally incompatible with Network Address Translation (NAT)?

- A. AH packets exceed the standard Ethernet MTU limit of 1500 bytes
- B. AH calculates its Integrity Check Value (ICV) over the entire IP packet, including the outer IP header; modifying IP addresses/ports in NAT alters the header and causes the receiver's ICV verification to fail
- C. AH uses UDP port 4500 which is blocked by NAT devices
- D. AH only supports IPv6 addressing and cannot operate in IPv4 environments

Correct Answer: B

Concept & Rationale: AH calculates the ICV covering non-mutable fields of the IP header (such as source and destination IP addresses). When a NAT device rewrites the IP addresses, the outer header changes; the receiving IPsec peer recalculates the ICV, detects a mismatch, and drops the packet as tampered.

Question 391

Topic: ESP Security Capabilities

Type: Single Choice

Which security services does the Encapsulating Security Payload (ESP) protocol provide?

- A. Only packet compression without integrity verification
- B. Data confidentiality (encryption), data origin authentication, data integrity verification, and anti-replay protection
- C. Only Layer 2 VLAN tag encapsulation
- D. Dynamic routing updates across BGP peers without encryption

Correct Answer: B

Concept & Rationale: ESP (IP protocol 50) provides both data confidentiality (symmetric encryption of the payload) and optional data origin authentication, data integrity verification (ICV), and anti-replay protection. It is the most widely deployed IPsec security protocol.

Question 392

Topic: IPsec Transport Mode Scope

Type: Single Choice

In IPsec Transport Mode, what portion of the packet is protected by ESP?

- A. The entire IP packet including the original IP header
- B. Only the upper-layer payload (e.g., TCP/UDP segment), retaining the original IP header without adding a new outer IP header
- C. Only the Ethernet frame trailer and preamble
- D. The hardware MAC address table of the ingress switch

Correct Answer: B

Concept & Rationale: In Transport Mode, IPsec protects only the upper-layer transport payload. The original IP header remains intact and serves as the routing header; no new outer IP header is added. Transport mode is primarily used for host-to-host or end-to-end communication.

Question 393**Topic:** IPsec Tunnel Mode Scope**Type:** Single Choice

In IPsec Tunnel Mode, what happens to the original IP packet?

- A. The original IP header is discarded and replaced permanently by a MAC address
- B. The entire original IP packet (including original private IP header and payload) is protected and encapsulated inside a brand-new outer IP header
- C. The packet is stripped down to raw ASCII text without headers
- D. The packet is converted into an MPLS label stack

Correct Answer: B

Concept & Rationale: In Tunnel Mode, the entire original IP packet (original IP header + payload) is encapsulated as the security payload, and a brand-new outer IP header is prepended. The outer header routes the packet between the two VPN gateway endpoints, hiding private internal IP topologies.

Question 394**Topic:** Transport vs Tunnel Mode Application**Type:** Single Choice

Which statement correctly describes the primary deployment application of IPsec Tunnel Mode?

- A. Direct communication between two end-user PCs within the same VLAN
- B. Gateway-to-Gateway (Site-to-Site) VPN communication where private subnets behind edge firewalls communicate across an untrusted public WAN
- C. Managing a local Ethernet switch via console cable
- D. Assigning IP addresses to clients via DHCP

Correct Answer: B

Concept & Rationale: Tunnel Mode is universally used in Gateway-to-Gateway (Site-to-Site) deployments because the gateways encapsulate internal private enterprise packets inside public outer headers, allowing two isolated private LANs to communicate securely across the Internet.

Question 395**Topic:** IPsec Security Association (SA) Concept**Type:** Single Choice

What is an IPsec Security Association (SA)?

- A. A physical cable connecting two security gateways
- B. A unidirectional, logical agreement between two communicating endpoints specifying the security parameters (algorithms, keys, SPI, protocol) used to protect traffic
- C. A digital certificate issued by a root CA to an individual user
- D. A user account registered in the local firewall database

Correct Answer: B

Concept & Rationale: An IPsec SA is a unidirectional logical connection that defines the specific security attributes negotiated between peers, including the encryption algorithm, authentication algorithm, shared keys, lifetime, and Security Parameter Index (SPI).

Question 396

Topic: Bidirectional Communication SAs

Type: Single Choice

How many IPsec Security Associations (SAs) are required to support full-duplex, bidirectional communication between two IPsec peers using ESP?

- A. 1 SA
- B. 2 SAs (one inbound and one outbound)
- C. 4 SAs
- D. 8 SAs

Correct Answer: B

Concept & Rationale: Because an IPsec SA is strictly unidirectional (simplex), bidirectional communication between two endpoints requires at least two SAs: one outbound SA for encrypting transmitting traffic, and one inbound SA for decrypting received traffic.

Question 397

Topic: Security Parameter Index (SPI)

Type: Single Choice

What is the function of the Security Parameter Index (SPI) in the IPsec AH/ESP header?

- A. It indicates the physical interface speed in megabits per second
- B. It is a 32-bit value that uniquely identifies a specific Security Association (SA) at the receiving endpoint when combined with the destination IP address and security protocol
- C. It defines the maximum transmission unit (MTU) of the VPN link
- D. It counts the number of dropped packets during transmission

Correct Answer: B

Concept & Rationale: The SPI is a 32-bit field in AH/ESP headers. Together with the destination IP address and the security protocol (AH or ESP), the SPI forms a unique triplet that allows the receiver to locate the exact inbound SA and cryptographic keys from its SADDB (Security Association Database).

Question 398

Topic: IKE Role in IPsec

Type: Single Choice

What is the primary role of the Internet Key Exchange (IKE) protocol in an IPsec deployment?

- A. To route packets dynamically using the Bellman-Ford algorithm
- B. To automate identity authentication, securely exchange key material via Diffie-Hellman, and negotiate Security Associations (SAs) dynamically
- C. To translate private IPv4 addresses into public IPv4 addresses
- D. To act as a web server delivering HTML login pages

Correct Answer: B

Concept & Rationale: While IPsec SAs can theoretically be configured manually, manual key management is error-prone and unscalable. IKE automates peer identity authentication, uses Diffie-Hellman (DH) to derive symmetric session keys over an untrusted medium, and dynamically negotiates/refreshes SAs.

Question 399

Topic: IKE Protocol and Port

Type: Single Choice

Which transport layer protocol and default port does IKE use for negotiation messages?

- A. TCP port 80
- B. UDP port 500
- C. TCP port 443
- D. UDP port 1701

Correct Answer: B

Concept & Rationale: IKE uses UDP port 500 for standard Phase 1 and Phase 2 negotiations. (When NAT Traversal is detected, traffic switches to UDP port 4500).

Question 400

Topic: IKEv1 Phase 1 Purpose

Type: Single Choice

What is the objective of IKEv1 Phase 1 negotiation?

- A. To negotiate the IPsec SAs used directly for encrypting user data traffic
- B. To establish a secure, authenticated communication channel (the IKE SA / ISAKMP SA) to protect subsequent Phase 2 negotiations
- C. To allocate DHCP IP addresses to client endpoints
- D. To download antivirus signature database files

Correct Answer: B

Concept & Rationale: IKEv1 Phase 1 establishes an authenticated and encrypted management channel known as the IKE SA (or ISAKMP SA). This secure control channel is then used to safely negotiate the actual IPsec SAs in Phase 2.

Question 401

Topic: IKEv1 Phase 1 Modes

Type: Single Choice

Which two exchange modes can be configured for IKEv1 Phase 1 negotiation?

- A. Client Mode and Server Mode
- B. Main Mode and Aggressive Mode
- C. Tunnel Mode and Transport Mode
- D. Active Mode and Passive Mode

Correct Answer: B

Concept & Rationale: IKEv1 Phase 1 supports two operating modes: Main Mode (Identity Protection Exchange, consisting of 6 messages) and Aggressive Mode (consisting of 3 messages).

Question 402

Topic: IKEv1 Main Mode Message Count

Type: Single Choice

How many messages are exchanged between the initiator and responder in IKEv1 Phase 1 Main Mode?

- A. 2 messages
- B. 3 messages
- C. 4 messages
- D. 6 messages

Correct Answer: D

Concept & Rationale: IKEv1 Phase 1 Main Mode strictly requires 6 messages: Messages 1 & 2 negotiate security policies (proposals); Messages 3 & 4 perform Diffie-Hellman public value exchange and exchange nonces; Messages 5 & 6 perform encrypted identity authentication.

Question 403

Topic: IKEv1 Main Mode Identity Protection

Type: Single Choice

In IKEv1 Phase 1 Main Mode, which messages transmit the peer identity information, and in what state?

- A. Messages 1 and 2 in cleartext
- B. Messages 3 and 4 in cleartext
- C. Messages 5 and 6, encrypted using the negotiated IKE key material
- D. Messages 7 and 8 in cleartext

Correct Answer: C

Concept & Rationale: In Main Mode, peer identities (such as IP addresses or digital certificates) are transmitted in Messages 5 and 6, which are fully encrypted by the session keys derived during Messages 3 and 4. This provides identity protection against eavesdropping.

Question 404

Topic: IKEv1 Aggressive Mode Message Count

Type: Single Choice

How many messages are exchanged in IKEv1 Phase 1 Aggressive Mode?

- A. 3 messages
- B. 4 messages
- C. 6 messages
- D. 8 messages

Correct Answer: A

Concept & Rationale: Aggressive Mode trades identity privacy for speed, completing Phase 1 in only 3 messages: Message 1 sends proposals, DH public value, and ID; Message 2 responds with selected proposal, DH value, ID, and authentication; Message 3 confirms authentication.

Question 405

Topic: IKEv1 Aggressive Mode Trade-off

Type: Single Choice

What is the primary security drawback of IKEv1 Phase 1 Aggressive Mode compared to Main Mode?

- A. Aggressive Mode does not support Diffie-Hellman key exchange
- B. Peer identity information is transmitted in cleartext in the first two messages, making it vulnerable to eavesdropping and identity reconnaissance
- C. Aggressive Mode only supports 3DES encryption and cannot run AES
- D. Aggressive Mode cannot establish IPsec tunnels

Correct Answer: B

Concept & Rationale: In Aggressive Mode, peer identities (IDs) are sent in cleartext in Messages 1 and 2 before encryption keys are established. Attackers intercepting these packets can discover the identity and IP address of the participating peers.

Question 406**Topic:** IKEv1 Aggressive Mode Dynamic IP Scenario**Type:** Single Choice

Why is IKEv1 Aggressive Mode typically used when a branch office connects with a dynamically assigned IP address using pre-shared key (PSK) authentication?

- A. Because Main Mode cannot run on Huawei USG firewalls
- B. In Main Mode with PSK, the responder must lookup the PSK using the initiator's source IP address before Messages 5/6; with dynamic IP, the responder cannot determine which PSK to use, whereas Aggressive Mode transmits the Name ID in Message 1
- C. Because Aggressive Mode uses TCP instead of UDP
- D. Because Aggressive Mode bypasses firewall security policies automatically

Correct Answer: B

Concept & Rationale: In Main Mode with PSK, the responder must decrypt Message 5 using the PSK, so it must know the peer identity before decrypting. If the initiator has a dynamic IP, the responder cannot identify which PSK to load. In Aggressive Mode, the Name ID is sent in plaintext in Message 1, allowing the responder to locate the matching pre-shared key.

Question 407**Topic:** IKEv1 Phase 2 Mode Name**Type:** Single Choice

What is the exchange mode used in IKEv1 Phase 2 to negotiate IPsec SAs?

- A. Main Mode
- B. Aggressive Mode
- C. Quick Mode
- D. Passive Mode

Correct Answer: C

Concept & Rationale: IKEv1 Phase 2 uses Quick Mode (consisting of 3 encrypted messages) to negotiate the IPsec SAs (security parameters, proxy IDs/ACLs, lifetimes) and generate keys for ESP/AH data protection.

Question 408**Topic:** PFS in Quick Mode**Type:** Single Choice

What does Perfect Forward Secrecy (PFS) achieve when enabled in IKEv1 Phase 2 Quick Mode?

- A. It prevents the firewall from restarting
- B. It forces an additional independent Diffie-Hellman exchange during Phase 2 so that compromising the Phase 1 master key does not compromise Phase 2 IPsec data keys
- C. It converts ESP packets into cleartext GRE packets
- D. It permanently disables IKE rekeying

Correct Answer: B

Concept & Rationale: Without PFS, Phase 2 keys are derived directly from the Phase 1 keying material. If an attacker later compromises the Phase 1 master key, all past Phase 2 keys are compromised. PFS forces a new, independent DH key exchange in Quick Mode, guaranteeing that future or past session keys cannot be decrypted if the master key is compromised.

Question 409**Topic:** IKEv2 Message Count for Initial Negotiation**Type:** Single Choice

How many messages does IKEv2 require during its initial exchange to establish both the IKE SA and the initial IPsec Child SA?

- A. 2 messages
- B. 4 messages (two round trips: IKE_SA_INIT and IKE_AUTH)
- C. 6 messages
- D. 9 messages

Correct Answer: B

Concept & Rationale: IKEv2 drastically streamlines negotiation: it requires only 4 messages (two request-response pairs): IKE_SA_INIT (2 messages to negotiate IKE SA parameters and DH keys) and IKE_AUTH (2 encrypted messages to authenticate identities and establish the first Child SA).

Question 410**Topic:** IKEv2 CREATE_CHILD_SA Exchange**Type:** Single Choice

In IKEv2, which exchange is used to negotiate additional Child SAs or perform SA rekeying?

- A. IKE_SA_INIT
- B. IKE_AUTH
- C. CREATE_CHILD_SA
- D. INFORMATIONAL

Correct Answer: C

Concept & Rationale: In IKEv2, CREATE_CHILD_SA (a 2-message exchange) is used to create additional Child SAs (IPsec SAs) or to rekey existing IKE SAs or Child SAs without tearing down the connection.

Question 411**Topic:** NAT Traversal (NAT-T) Port**Type:** Single Choice

When an IPsec gateway detects the presence of a NAT device along the communication path during IKE negotiation, which UDP port is used to encapsulate ESP traffic in NAT-T?

- A. UDP port 500
- B. UDP port 4500
- C. TCP port 443
- D. UDP port 1701

Correct Answer: B

Concept & Rationale: When NAT is detected, IKE and subsequent ESP traffic transition from UDP 500 to UDP port 4500 (NAT Traversal / NAT-T). ESP packets are wrapped inside an outer UDP header, enabling them to traverse standard PAT/NAPT gateways.

Question 412**Topic:** Dead Peer Detection (DPD)**Type:** Single Choice

What is the purpose of the Dead Peer Detection (DPD) mechanism in IPsec VPNs?

- A. To prevent routing loops in OSPF networks
- B. To periodically check the liveness and responsiveness of the remote IPsec peer, allowing the gateway to quickly reclaim SA resources and re-establish tunnels if the peer fails
- C. To scan remote endpoints for malware infections
- D. To authenticate user passwords via LDAP

Correct Answer: B

Concept & Rationale: DPD uses keepalive messages (or sends periodic DPD inquiries) to detect whether the remote VPN peer is still active. If the peer crashes or the path breaks, DPD detects the outage, deletes stale SAs, and frees system resources.

Question 413**Topic:** L2TP Port and Protocol**Type:** Single Choice

Which transport protocol and destination port does the Layer 2 Tunneling Protocol (L2TP) use?

- A. TCP port 22
- B. UDP port 1701
- C. UDP port 500
- D. TCP port 443

Correct Answer: B

Concept & Rationale: L2TP encapsulates Layer 2 PPP frames into UDP packets using UDP port 1701. To ensure confidentiality, L2TP is almost universally paired with IPsec (L2TP over IPsec).

Question 414**Topic:** L2TP Architecture Components**Type:** Single Choice

What are the two primary structural endpoint roles in an L2TP VPN deployment?

- A. Master and Slave
- B. LAC (L2TP Access Concentrator) and LNS (L2TP Network Server)
- C. Root and Leaf
- D. Client and Proxy

Correct Answer: B

Concept & Rationale: An L2TP network consists of the LAC (L2TP Access Concentrator), which initiates or terminates calls from users, and the LNS (L2TP Network Server), which terminates the tunnel and authenticates users against internal directories.

Question 415**Topic:** SSL VPN Working Layer**Type:** Single Choice

At which layer of the network model does SSL/TLS VPN primarily operate, and what client requirement differentiates it from traditional IPsec VPNs?

- A. Data Link Layer, requiring specialized hardware transceivers
- B. Transport/Application Layer, allowing users to connect using a standard web browser without installing complex client software for basic services
- C. Physical Layer, requiring fiber optic modems
- D. Network Layer only, requiring kernel-level device drivers on every smartphone

Correct Answer: B

Concept & Rationale: SSL/TLS VPN operates at the Transport and Application layers (Layers 4-7). Its greatest advantage is clientless or light-client access: users can securely access corporate resources from any standard web browser over HTTPS (port 443) without pre-installing complex VPN software.

Question 416**Topic:** SSL VPN Service - Web Proxy**Type:** Single Choice

Which SSL VPN service allows mobile users to access internal enterprise HTTP/HTTPS web intranet servers directly through their web browser without any local agent installation?

- A. Port Forwarding
- B. Web Proxy (Web Browsing)
- C. File Sharing
- D. Network Extension

Correct Answer: B

Concept & Rationale: Web Proxy allows remote users to access internal intranet websites (HTTP/HTTPS) using a standard web browser. The SSL VPN gateway acts as a reverse proxy, translating external HTTPS browser requests into internal web requests.

Question 417**Topic:** SSL VPN Service - File Sharing**Type:** Single Choice

Which file access protocols does the Huawei USG SSL VPN File Sharing service support natively via the browser?

- A. NFS and SMB/CIFS
- B. BGP and OSPF
- C. TFTP and Telnet
- D. SNMP and NTP

Correct Answer: A

Concept & Rationale: The File Sharing service enables users to access enterprise file servers running SMB/CIFS (Windows file sharing) and NFS (UNIX/Linux file sharing) protocols directly through the SSL VPN web portal without installing network shares.

Question 418**Topic:** SSL VPN Service - Port Forwarding**Type:** Single Choice

What type of applications is the SSL VPN Port Forwarding service primarily designed to support?

- A. Dynamic routing protocols running on raw IP
- B. Static, TCP-based enterprise client-server applications (such as Telnet, SSH, RDP, VNC, and POP3/SMTP)
- C. UDP-based real-time broadcast audio streaming
- D. ICMP ping echo testing only

Correct Answer: B

Concept & Rationale: Port Forwarding is designed for static TCP-based services. A lightweight control (ActiveX or Java or local agent) listens on a local loopback port and tunnels application TCP connections through the secure SSL session to internal target servers.

Question 419**Topic:** SSL VPN Service - Network Extension**Type:** Single Choice

Which SSL VPN service provides full, transparent Layer 3 IP-level network access to internal resources, assigning the remote client a virtual IP address from a private address pool?

- A. Web Proxy
- B. Port Forwarding
- C. File Sharing
- D. Network Extension

Correct Answer: D

Concept & Rationale: Network Extension installs a virtual network adapter (virtual NIC) on the client PC. The virtual gateway assigns the client an intranet IP address from a designated IP pool, granting full Layer 3 access to corporate subnets as if the user were physically connected to the office LAN.

Question 420

Topic: SSL VPN Virtual Gateway Concept

Type: Single Choice

In Huawei USG firewalls, what is the role of an 'SSL VPN Virtual Gateway'?

- A. A physical backup firewall deployed in cold standby
- B. An independent, logically isolated virtual security instance with dedicated authentication policies, user databases, access permissions, and resource allocations
- C. An external DNS server managed by an ISP
- D. A hardware Ethernet switch module inside the chassis

Correct Answer: B

Concept & Rationale: A Virtual Gateway is an independent logical entity within the USG firewall. Multiple virtual gateways can be hosted on a single physical firewall to serve distinct corporate departments, subsidiaries, or external partners with customized domains, branding, authentication methods, and security policies.

PART II

Multiple-Answer Questions (Q421 – Q740)

12 Chapter 1: Network Security Concepts and Specifications

Question 421

Topic: CIA Triad Components

Type: Multiple Choice

Which of the following are the three fundamental pillars that constitute the classic CIA Triad in information security?

- A. Confidentiality
- B. Integrity
- C. Availability
- D. Centralization
- E. Scalability

Correct Answer: A, B, C

Concept & Rationale: The traditional Information Security Triad consists of Confidentiality (preventing unauthorized disclosure), Integrity (preventing unauthorized modification), and Availability (ensuring accessible services).

Question 422

Topic: 1990s Information Security Principles

Type: Multiple Choice

Which of the following principles were introduced during the 1990s Information Assurance era to expand upon the traditional CIA triad?

- A. Controllability
- B. Non-repudiation
- C. Anonymity
- D. Decentralization

Correct Answer: A, B

Concept & Rationale: The five pillars of the 1990s Information Assurance era are Confidentiality, Integrity, Availability, Controllability (supervising and regulating information), and Non-repudiation (preventing denial of actions).

Question 423**Topic:** Enterprise Information Assurance Aspects**Type:** Multiple Choice

From which of the following perspectives was an enterprise information assurance system constructed during the Information Assurance era?

- A. Services
- B. Security system
- C. Management
- D. Physical real estate

Correct Answer: A, B, C

Concept & Rationale: Enterprise information assurance systems were comprehensively established across three dimensions: Services (risk mitigation for diverse business traffic), Security Systems (technical controls and proactive defense), and Management (personnel and administrative policies).

Question 424**Topic:** Cybersecurity Objectives**Type:** Multiple Choice

Which of the following are primary objectives of modern cyberspace security?

- A. Safeguarding critical information infrastructure
- B. Ensuring personal data privacy and digital rights
- C. Protecting national security and economic stability in digital domains
- D. Permanently disabling Internet connectivity between enterprise branch offices

Correct Answer: A, B, C

Concept & Rationale: Cyberspace security aims to defend critical information infrastructure, safeguard digital privacy, prevent cyber attacks, and maintain national security and economic prosperity across the digital space.

Question 425**Topic:** ISO 27000 Series Family**Type:** Multiple Choice

Which of the following statements regarding the ISO 27000 family of information security standards are true?

- A. ISO/IEC 27001 specifies normative requirements for establishing and certifying an ISMS
- B. ISO/IEC 27002 provides a comprehensive code of practice and control guidelines
- C. ISO/IEC 27002 can be used directly by an enterprise to obtain accredited third-party certification
- D. The standards follow the Plan-Do-Check-Act (PDCA) continuous improvement framework

Correct Answer: A, B, D

Concept & Rationale: ISO 27001 is the formal certifiable specification for an ISMS, while ISO 27002 is an advisory code of practice (not directly certifiable). Both align with the PDCA continual improvement cycle.

Question 426**Topic:** Classified Protection 2.0 Levels**Type:** Multiple Choice

Which of the following are valid security protection levels defined in China's Cybersecurity Classified Protection 2.0?

- A. Level 1: User Autonomy Protection
- B. Level 2: System Audit Protection
- C. Level 3: Supervised Protection
- D. Level 4: Mandatory Protection
- E. Level 5: Special Control Protection

Correct Answer: A, B, C, D, E

Concept & Rationale: Classified Protection 2.0 formally establishes five levels: Level 1 (User Autonomy), Level 2 (System Audit), Level 3 (Supervised Protection), Level 4 (Mandatory Protection), and Level 5 (Special Control Protection).

Question 427

Topic: Classified Protection Technical Requirements

Type: Multiple Choice

Under Classified Protection 2.0, which of the following are designated as the general technical requirement categories?

- A. Physical and Environmental Security
- B. Network and Communication Security
- C. Equipment and Computing Security
- D. Application and Data Security
- E. Customer Service Feedback Tracking

Correct Answer: A, B, C, D

Concept & Rationale: The four technical domains in Classified Protection 2.0 are Physical and Environmental Security, Network and Communication Security, Equipment and Computing Security, and Application and Data Security.

Question 428

Topic: Classified Protection Management Requirements

Type: Multiple Choice

Which of the following domains are included under the general security management requirements of Classified Protection 2.0?

- A. Security Management System
- B. Security Management Organization
- C. Security Management Personnel
- D. Security Construction Management
- E. Security Operation Management

Correct Answer: A, B, C, D, E

Concept & Rationale: All five domains represent the official security management requirements in Classified Protection 2.0: System, Organization, Personnel, Construction, and Operation Management.

Question 429

Topic: TCSEC Divisions

Type: Multiple Choice

Which of the following are primary security divisions defined in the TCSEC (Orange Book) standard?

- A. Division D: Minimal Protection
- B. Division C: Discretionary Protection
- C. Division B: Mandatory Protection
- D. Division A: Verified Protection
- E. Division E: Open Source Protection

Correct Answer: A, B, C, D

Concept & Rationale: TCSEC defines four hierarchical divisions: Division D (Minimal), Division C (Discretionary: C1, C2), Division B (Mandatory: B1, B2, B3), and Division A (Verified: A1). There is no Division E.

Question 430**Topic:** APT Attack Stages**Type:** Multiple Choice

Which of the following stages are typically observed in a sophisticated Advanced Persistent Threat (APT) campaign?

- A. Reconnaissance and initial penetration (e.g., spear phishing)
- B. Establishing persistent backdoors and Command-and-Control (C2) communication
- C. Internal network discovery, lateral movement, and privilege escalation
- D. Data staging and stealthy exfiltration
- E. Immediate self-destruction of all target server power supplies on day one

Correct Answer: A, B, C, D

Concept & Rationale: An APT campaign progresses methodically through reconnaissance, initial infiltration, establishing command-and-control persistence, lateral propagation, privilege escalation, data collection, and covert exfiltration over weeks or months.

Question 431**Topic:** Zero Trust Core Principles**Type:** Multiple Choice

Which of the following are core architectural principles of the Zero Trust model?

- A. Explicit verification based on all available data points (identity, location, device health)
- B. Enforce least privilege access using just-in-time and just-enough access controls
- C. Assume breach and minimize blast radius through micro-segmentation
- D. Implicitly trust any device connected directly to an internal switch port

Correct Answer: A, B, C

Concept & Rationale: Zero Trust relies on three guiding tenets: Verify Explicitly, Use Least Privilege Access, and Assume Breach. Traffic from internal network ports is never implicitly trusted.

Question 432**Topic:** Future Security Technology Trends**Type:** Multiple Choice

Which of the following technologies reflect major trends shaping future enterprise network security architectures?

- A. Artificial Intelligence (AI) and machine learning for automated anomaly detection
- B. Cloud-native security and Security Access Service Edge (SASE)
- C. Software-Defined Perimeter (SDP) and Zero Trust micro-segmentation
- D. Returning exclusively to 1980s unencrypted cleartext terminal protocols

Correct Answer: A, B, C

Concept & Rationale: The future of network security centers on AI/ML threat analysis, cloud-delivered security frameworks (SASE/SSE), automated incident orchestration (SOAR), and Zero Trust/SDP architectures.

Question 433**Topic:** Information Asset Categories**Type:** Multiple Choice

In an enterprise risk assessment, which of the following are considered critical information assets requiring protection?

- A. Proprietary software applications and source code repositories
- B. Confidential customer records and financial transaction databases
- C. Physical servers, networking equipment, and security appliances
- D. Qualified cybersecurity personnel and domain administrators
- E. Obsolete promotional flyers displayed in the visitor lobby

Correct Answer: A, B, C, D

Concept & Rationale: Information assets encompass hardware infrastructure, software applications, electronic data, intellectual property, and key human personnel who operate and manage the infrastructure.

Question 434**Topic:** Risk Treatment Options**Type:** Multiple Choice

Which of the following are recognized risk treatment strategies in information security risk management?

- A. Risk Mitigation (Reduction)
- B. Risk Avoidance
- C. Risk Transfer (Sharing)
- D. Risk Acceptance (Retention)
- E. Risk Fabricating

Correct Answer: A, B, C, D

Concept & Rationale: The four standard risk treatment options under ISO 27005 and NIST frameworks are Risk Mitigation (applying controls), Risk Avoidance (stopping the risky activity), Risk Transfer (insurance/outsourcing), and Risk Acceptance (tolerating residual risk).

Question 435**Topic:** Social Engineering Vectors**Type:** Multiple Choice

Which of the following techniques are commonly classified under social engineering attacks?

- A. Spear phishing emails containing malicious attachments
- B. Vishing (voice phishing phone calls impersonating corporate officers)
- C. Baiting using malware-infected USB drives left in parking lots
- D. Overwriting router flash memory using laser drilling

Correct Answer: A, B, C

Concept & Rationale: Social engineering leverages cognitive deception against humans, encompassing phishing, spear phishing, vishing (voice), smishing (SMS), pretexting, and baiting with physical media.

Question 436**Topic:** Threat Actors Classification**Type:** Multiple Choice

Which of the following are common threat actor categories recognized in cybersecurity threat modeling?

- A. Organized cybercrime syndicates seeking financial gain
- B. Nation-state Advanced Persistent Threat (APT) groups
- C. Malicious insiders with authorized credentials
- D. Hacktivists motivated by political or ideological causes

Correct Answer: A, B, C, D

Concept & Rationale: Threat actors span cybercriminals (financial extortion), state-sponsored advanced threat actors (espionage/sabotage), insider threats (disgruntled employees), and hacktivists (ideological disruption).

Question 437

Topic: Defense in Depth Layers

Type: Multiple Choice

A comprehensive Defense-in-Depth architecture includes security controls across which of the following structural layers?

- A. Physical perimeter and facility security
- B. Network perimeter and boundary firewalls
- C. Host operating systems and endpoint detection and response (EDR)
- D. Data-level encryption and access auditing

Correct Answer: A, B, C, D

Concept & Rationale: Defense-in-Depth organizes multi-layered barriers spanning physical security, network perimeter defenses, endpoint/host hardening, application security, and data-centric cryptographic controls.

Question 438

Topic: Physical Security Threats

Type: Multiple Choice

Which of the following are considered physical and environmental security threats to enterprise data centers?

- A. Power failure and electrical surges
- B. Fire, flooding, and HVAC temperature extremes
- C. Unauthorized physical intrusion into server rooms
- D. Cross-Site Scripting (XSS) in a web form

Correct Answer: A, B, C

Concept & Rationale: Physical and environmental threats include environmental disasters (fire, flood, overheating), utility disruptions (blackouts, surges), and unauthorized physical entry. XSS is an application-layer logical vulnerability.

Question 439

Topic: Non-repudiation Guarantees

Type: Multiple Choice

What primary guarantees are provided when a sender digitally signs an electronic document using their private key?

- A. Proof of the sender's authentic identity (Data Origin Authentication)
- B. Proof that the document content was not altered since signature generation (Integrity)
- C. Inability of the sender to falsely deny having generated the document (Non-repudiation)
- D. Automatic encryption of the document so that the receiver cannot read it

Correct Answer: A, B, C

Concept & Rationale: A digital signature provides origin authentication, data integrity, and legal non-repudiation. It does not by itself encrypt the plaintext document unless an encryption operation is explicitly paired with it.

Question 440**Topic:** Security Policy Hierarchy**Type:** Multiple Choice

An enterprise information security governance structure typically includes which of the following documentation levels?

- A. Top-level Information Security Policies approved by executive leadership
- B. Topic-specific Security Standards and baselines
- C. Detailed Security Operating Procedures (SOPs) and Work Instructions
- D. Security Guidelines and best practices recommendations

Correct Answer: A, B, C, D

Concept & Rationale: Enterprise security policy hierarchy descends from high-level Policies (mandatory executive directives), to Standards (mandatory specific configurations), Procedures (step-by-step instructions), and Guidelines (advisory recommendations).

Question 441**Topic:** Common Security Compliance Drivers**Type:** Multiple Choice

Which of the following factors drive enterprise investments in network security compliance?

- A. Legal and regulatory mandates (e.g., national cybersecurity laws, data protection acts)
- B. Industry standard mandates (e.g., PCI-DSS for credit card processing)
- C. Mitigating severe financial liabilities from security breaches and ransomware
- D. Protecting corporate brand reputation and customer trust

Correct Answer: A, B, C, D

Concept & Rationale: Security compliance is driven by statutory regulations, industry standards, financial risk mitigation, business continuity requirements, and brand trust preservation.

Question 442**Topic:** Impact of Security Incidents**Type:** Multiple Choice

Severe cybersecurity breaches can inflict which of the following negative impacts on an enterprise?

- A. Direct financial loss from theft, ransom payments, and forensic remediation
- B. Regulatory fines and sanctions from government supervisory bodies
- C. Operational service interruption and supply chain paralysis
- D. Loss of intellectual property, trade secrets, and competitive advantage

Correct Answer: A, B, C, D

Concept & Rationale: Cyber breaches cause cascading damage including direct monetary losses, legal penalties, operational downtime, reputational damage, and forfeiture of intellectual property.

Question 443**Topic:** Data Security Lifecycle**Type:** Multiple Choice

Which of the following represent recognized stages of the data security lifecycle?

- A. Data Creation and Collection
- B. Data Storage and Transmission
- C. Data Processing and Sharing
- D. Data Destruction and Sanitization

Correct Answer: A, B, C, D

Concept & Rationale: The end-to-end data security lifecycle consists of Creation/Collection, Storage, Transmission, Processing/Use, Sharing, and Destruction/Disposal, requiring security controls at every phase.

Question 444

Topic: Threat Intelligence Types

Type: Multiple Choice

In modern cyber defense, threat intelligence is commonly classified into which of the following levels?

- A. Strategic Threat Intelligence (high-level risk trends for executives)
- B. Operational Threat Intelligence (details on threat actor TTPs)
- C. Tactical Threat Intelligence (Indicators of Compromise: IPs, hashes, domains)
- D. Fictional Threat Intelligence (creative storytelling for movie scripts)

Correct Answer: A, B, C

Concept & Rationale: Cyber threat intelligence is structured into Strategic (business impact and threat landscape), Operational (adversary tactics, techniques, and procedures - TTPs), and Tactical (technical IoCs like IP blacklists and file hashes).

Question 445

Topic: TCSEC Division C Classes

Type: Multiple Choice

Which of the following evaluation classes belong to TCSEC Division C (Discretionary Protection)?

- A. Class C1: Discretionary Security Protection
- B. Class C2: Controlled Access Protection
- C. Class C3: Complete Mandatory Encryption
- D. Class C4: Quantum Key Distribution

Correct Answer: A, B

Concept & Rationale: TCSEC Division C contains exactly two classes: Class C1 (Discretionary Security Protection) and Class C2 (Controlled Access Protection). There are no C3 or C4 classes.

Question 446

Topic: Controllability Safeguards

Type: Multiple Choice

Which technical mechanisms contribute directly to maintaining 'Controllability' over corporate networks?

- A. Centralized security logging, SIEM, and SOC auditing
- B. Network access control (NAC) enforcing endpoint compliance
- C. Firewall security policies regulating protocol and application flows
- D. Allowing all internal users unrestricted root access to production databases

Correct Answer: A, B, C

Concept & Rationale: Controllability is sustained through continuous logging/auditing, Network Access Control (NAC), granular firewall filtering, and behavioral monitoring. Granting unrestricted root access severely destroys controllability.

13 Chapter 2: Network Basics

Question 447**Topic:** OSI 7 Layers Identification**Type:** Multiple Choice

Which of the following are recognized layers in the ISO 7-layer OSI reference model?

- A. Physical Layer
- B. Data Link Layer
- C. Network Layer
- D. Transport Layer
- E. Cloud Layer

Correct Answer: A, B, C, D

Concept & Rationale: The 7 OSI layers in order are: Physical, Data Link, Network, Transport, Session, Presentation, and Application. 'Cloud Layer' does not exist in the OSI model.

Question 448**Topic:** TCP Header Flags**Type:** Multiple Choice

Which of the following are valid control flag bits defined in the standard TCP header?

- A. SYN (Synchronize)
- B. ACK (Acknowledgment)
- C. FIN (Finish)
- D. RST (Reset)
- E. EXP (Explore)

Correct Answer: A, B, C, D

Concept & Rationale: Standard 6 TCP control flags: URG (Urgent), ACK (Acknowledgment), PSH (Push), RST (Reset), SYN (Synchronize), and FIN (Finish). 'EXP' is not a TCP flag.

Question 449**Topic:** IPv4 Header Fields**Type:** Multiple Choice

Which of the following fields are present in a standard 20-byte IPv4 header?

- A. Time to Live (TTL)
- B. Protocol
- C. Header Checksum
- D. Source IP Address
- E. Flow Label

Correct Answer: A, B, C, D

Concept & Rationale: The IPv4 header includes Version, IHL, DSCP/ECN, Total Length, Identification, Flags, Fragment Offset, TTL, Protocol, Header Checksum, Source IP, and Destination IP. 'Flow Label' is unique to IPv6 headers.

Question 450

Topic: RFC 1918 Private Ranges

Type: Multiple Choice

Which of the following IPv4 address prefixes are reserved strictly for private network addressing under RFC 1918?

- A. 10.0.0.0/8
- B. 172.16.0.0/12
- C. 192.168.0.0/16
- D. 203.0.113.0/24

Correct Answer: A, B, C

Concept & Rationale: RFC 1918 defines three private blocks: 10.0.0.0/8 (10.0.0.0 - 10.255.255.255), 172.16.0.0/12 (172.16.0.0 - 172.31.255.255), and 192.168.0.0/16 (192.168.0.0 - 192.168.255.255).

Question 451

Topic: Ethernet Frame Fields

Type: Multiple Choice

Which of the following components are part of an Ethernet II data frame?

- A. Destination MAC Address
- B. Source MAC Address
- C. Type (EtherType)
- D. Frame Check Sequence (FCS)
- E. Hop Limit

Correct Answer: A, B, C, D

Concept & Rationale: An Ethernet II frame comprises: Preamble/SFD, Destination MAC (6B), Source MAC (6B), Type (2B), Payload Data (46-1500B), and FCS/CRC-32 (4B). 'Hop Limit' is an IPv6 network layer field.

Question 452

Topic: TCP Reliability Features

Type: Multiple Choice

Which mechanisms allow TCP to provide reliable end-to-end data delivery?

- A. Sequence numbers for in-order packet reassembly
- B. Cumulative positive acknowledgments (ACK)
- C. Retransmission timers for lost segments
- D. Sliding-window flow control to prevent buffer overrun

Correct Answer: A, B, C, D

Concept & Rationale: TCP achieves reliability via sequence numbering, explicit acknowledgments, timeout/retransmission algorithms, checksum error detection, and sliding window flow control.

Question 453

Topic: UDP Operational Features

Type: Multiple Choice

Which of the following statements accurately describe the User Datagram Protocol (UDP)?

- A. UDP is a connectionless transport protocol with low processing overhead
- B. UDP guarantees that packets arrive in the exact order they were sent
- C. UDP headers have a fixed size of 8 bytes
- D. UDP does not implement sliding-window flow control or congestion avoidance

Correct Answer: A, C, D

Concept & Rationale: UDP is connectionless, lightweight, has a fixed 8-byte header, and lacks sequencing, retransmission, flow control, and congestion control.

Question 454

Topic: DNS Resource Record Types

Type: Multiple Choice

Which of the following are valid DNS resource record types?

- A. A (IPv4 host address)
- B. AAAA (IPv6 host address)
- C. MX (Mail Exchange)
- D. CNAME (Canonical Name)
- E. MAC (Hardware Address)

Correct Answer: A, B, C, D

Concept & Rationale: Common DNS records: A (IPv4), AAAA (IPv6), CNAME (alias), MX (mail server), PTR (reverse lookup), NS (name server), and TXT. There is no 'MAC' record type in DNS.

Question 455

Topic: ICMP Error Messages

Type: Multiple Choice

Which of the following represent standard ICMP error or control message types?

- A. Type 0: Echo Reply
- B. Type 3: Destination Unreachable
- C. Type 8: Echo Request
- D. Type 11: Time Exceeded
- E. Type 50: Security Encapsulation

Correct Answer: A, B, C, D

Concept & Rationale: Key ICMP message types: Type 0 (Echo Reply), Type 3 (Destination Unreachable), Type 8 (Echo Request), Type 11 (Time Exceeded), and Type 5 (Redirect). IP Protocol 50 is ESP, not an ICMP type.

Question 456

Topic: HTTP Methods

Type: Multiple Choice

Which of the following are standard HTTP request methods defined in RFC specifications?

- A. GET
- B. POST
- C. PUT
- D. DELETE
- E. CONNECT

Correct Answer: A, B, C, D, E

Concept & Rationale: Standard HTTP methods include GET (retrieve data), POST (submit data), PUT (replace data), DELETE (remove resource), HEAD (headers only), OPTIONS, and CONNECT (proxy tunneling).

Question 457**Topic:** FTP Transmission Modes**Type:** Multiple Choice

Which of the following are the two primary data transfer modes utilized in File Transfer Protocol (FTP)?

- A. Active Mode (PORT mode)
- B. Passive Mode (PASV mode)
- C. Stealth Mode
- D. Tunnel Mode

Correct Answer: A, B

Concept & Rationale: FTP operates in two data connection modes: Active Mode (client issues PORT; server initiates data channel from port 20) and Passive Mode (client issues PASV; server opens dynamic port and client initiates data channel).

Question 458**Topic:** DHCP Messages**Type:** Multiple Choice

Which of the following messages are exchanged during the initial standard DHCP address acquisition process?

- A. DHCP Discover
- B. DHCP Offer
- C. DHCP Request
- D. DHCP ACK
- E. DHCP Encrypt

Correct Answer: A, B, C, D

Concept & Rationale: The standard 4-step DHCP address allocation process (DORA) consists of: DHCP Discover, DHCP Offer, DHCP Request, and DHCP ACK.

Question 459**Topic:** VLAN Characteristics**Type:** Multiple Choice

Which of the following are operational benefits of implementing Virtual Local Area Networks (VLANs)?

- A. Isolating broadcast domains to improve network performance
- B. Enhancing departmental security by restricting Layer 2 traffic between VLANs
- C. Simplifying network management and logical project grouping
- D. Automatically converting IPv4 packets into IPv6 format

Correct Answer: A, B, C

Concept & Rationale: VLANs segment broadcast domains, improve switch bandwidth utilization, enforce logical security boundaries between departments, and simplify moves/adds/changes.

Question 460**Topic:** ARP Table Attributes**Type:** Multiple Choice

Which of the following statements regarding the ARP table on hosts and switches are correct?

- A. Dynamic ARP entries have an aging timer and are flushed when idle
- B. Static ARP entries do not age out automatically and persist until manual removal or reboot
- C. An ARP table maps Layer 3 IP addresses to Layer 2 MAC addresses
- D. An ARP table is used by routers to decide the next-hop BGP autonomous system

Correct Answer: A, B, C

Concept & Rationale: ARP maps Layer 3 IP addresses to Layer 2 physical MAC addresses. Dynamic entries age out automatically, whereas static entries remain fixed. Routing decisions use routing tables, not ARP tables.

Question 461

Topic: TCP Connection States

Type: Multiple Choice

Which of the following are valid states in the TCP finite state machine?

- A. LISTEN
- B. SYN_SENT
- C. ESTABLISHED
- D. TIME_WAIT
- E. TRANSLATING

Correct Answer: A, B, C, D

Concept & Rationale: Standard TCP states: LISTEN, SYN_SENT, SYN_RECEIVED, ESTABLISHED, FIN_WAIT_1, FIN_WAIT_2, CLOSE_WAIT, CLOSING, LAST_ACK, TIME_WAIT, and CLOSED.

Question 462

Topic: Application Layer Protocols over TCP

Type: Multiple Choice

Which of the following application layer protocols typically rely on TCP as their transport layer protocol?

- A. HTTP / HTTPS (Web)
- B. FTP (File Transfer)
- C. SSH (Secure Shell)
- D. Telnet (Remote Terminal)
- E. TFTP (Trivial File Transfer)

Correct Answer: A, B, C, D

Concept & Rationale: HTTP (80), HTTPS (443), FTP (20/21), SSH (22), and Telnet (23) require reliable stream transport and use TCP. TFTP uses UDP port 69.

Question 463

Topic: Application Layer Protocols over UDP

Type: Multiple Choice

Which of the following network services predominantly utilize UDP as their underlying transport protocol?

- A. DNS (standard name resolution queries)
- B. DHCP (Dynamic Host Configuration)
- C. SNMP (Simple Network Management)
- D. TFTP (Trivial File Transfer)
- E. BGP (Border Gateway Protocol)

Correct Answer: A, B, C, D

Concept & Rationale: DNS queries (port 53), DHCP (ports 67/68), SNMP (ports 161/162), and TFTP (port 69) run over UDP. BGP utilizes TCP port 179.

Question 464

Topic: IPv4 Address Classes

Type: Multiple Choice

Which of the following statements regarding IPv4 address classes are correct?

- A. Class A addresses use a default /8 mask (1.0.0.0 - 126.255.255.255)
- B. Class B addresses use a default /16 mask (128.0.0.0 - 191.255.255.255)
- C. Class C addresses use a default /24 mask (192.0.0.0 - 223.255.255.255)
- D. Class D addresses (224.0.0.0 - 239.255.255.255) are reserved for multicast

Correct Answer: A, B, C, D

Concept & Rationale: Standard classful IPv4 divisions: Class A (1-126, /8), Class B (128-191, /16), Class C (192-223, /24), Class D (224-239, Multicast), and Class E (240-255, Experimental).

Question 465

Topic: ICMP Destination Unreachable Codes

Type: Multiple Choice

Under ICMP Type 3 (Destination Unreachable), which of the following are valid code values?

- A. Code 0: Network unreachable
- B. Code 1: Host unreachable
- C. Code 2: Protocol unreachable
- D. Code 3: Port unreachable
- E. Code 4: Fragmentation needed and DF set

Correct Answer: A, B, C, D, E

Concept & Rationale: Common ICMP Type 3 codes: Code 0 (Net Unreachable), Code 1 (Host Unreachable), Code 2 (Protocol Unreachable), Code 3 (Port Unreachable), Code 4 (Fragmentation Needed and DF set).

Question 466

Topic: TCP Flow Control Mechanisms

Type: Multiple Choice

Which mechanisms are employed by TCP to manage congestion and flow control?

- A. Advertised Receive Window (rwnd) for receiver flow control
- B. Slow Start and Congestion Avoidance algorithms
- C. Fast Retransmit triggered by three duplicate ACKs
- D. Fast Recovery algorithm
- E. Automatic MAC address rewriting

Correct Answer: A, B, C, D

Concept & Rationale: TCP flow control uses the advertised receive window (rwnd). Congestion control uses Congestion Window (cwnd) with Slow Start, Congestion Avoidance, Fast Retransmit, and Fast Recovery.

Question 467

Topic: Subnet Mask Properties

Type: Multiple Choice

Which of the following statements about IPv4 subnet masks are correct?

- A. A subnet mask is a 32-bit value consisting of contiguous 1s followed by contiguous 0s
- B. The 1-bits identify the network and subnet portion of the IP address
- C. The 0-bits identify the host portion of the IP address
- D. A /28 subnet mask corresponds to 255.255.255.240 in dotted-decimal notation

Correct Answer: A, B, C, D

Concept & Rationale: A subnet mask consists of continuous binary 1s (network bits) followed by continuous binary 0s (host bits). A /28 prefix has 28 ones: 255.255.255.240.

Question 468

Topic: Traceroute Mechanics

Type: Multiple Choice

Which of the following statements regarding the operation of the traceroute utility are true?

- A. It discovers router hops by sending probe packets with sequentially increasing TTL values
- B. Intermediate routers decrement TTL to 0 and reply with ICMP Type 11 Time Exceeded messages
- C. On Windows systems, 'tracert' primarily uses ICMP Echo Request probes
- D. On traditional Unix/Linux systems, 'traceroute' default probes use high-port UDP datagrams

Correct Answer: A, B, C, D

Concept & Rationale: Traceroute transmits probes with TTL=1, 2, 3... Intermediate routers reply with ICMP Type 11 (Time Exceeded). Windows tracert uses ICMP echo requests; Linux traceroute defaults to UDP high ports.

Question 469

Topic: ARP Spoofing Risks

Type: Multiple Choice

Which of the following security risks are caused by ARP spoofing / poisoning attacks on a local LAN?

- A. Man-in-the-Middle (MitM) eavesdropping of unencrypted traffic
- B. Denial of Service (DoS) by pointing gateway IP to a non-existent MAC address
- C. Session hijacking and unauthorized packet modification
- D. Hardware destruction of switch power supplies

Correct Answer: A, B, C

Concept & Rationale: ARP poisoning tricks victims into mapping target IPs (like the default gateway) to the attacker's MAC, enabling MitM eavesdropping, credential theft, session tampering, or blackholing (DoS).

Question 470

Topic: Proxy ARP Use Cases

Type: Multiple Choice

Under which conditions is Proxy ARP typically utilized?

- A. When hosts on the same logical subnet are separated by a router and lack default gateways
- B. In dial-up or remote access VPN scenarios where remote hosts share an intranet IP pool
- C. To secure database servers by encrypting SQL queries
- D. To translate IPv4 packets into ATM cells

Correct Answer: A, B

Concept & Rationale: Proxy ARP enables routers to respond to ARP requests on behalf of destination hosts located in different subnets or physical segments, common in legacy flat-network designs and remote dial-in setups.

Question 471

Topic: SSH Security Features

Type: Multiple Choice

Which security mechanisms are provided by Secure Shell (SSHv2)?

- A. Server authentication using public-key cryptography to prevent spoofing
- B. User authentication via password or client public-key certificates
- C. Confidentiality through symmetric session encryption (e.g., AES)
- D. Integrity protection using HMAC algorithms

Correct Answer: A, B, C, D

Concept & Rationale: SSHv2 delivers comprehensive security: host authentication (preventing MitM), user authentication (passwords/keys), symmetric payload encryption (AES/ChaCha20), and cryptographic integrity verification (HMAC).

Question 472

Topic: Telnet Insecurities

Type: Multiple Choice

Which of the following vulnerabilities are inherent to the Telnet protocol?

- A. Usernames and passwords are transmitted in cleartext
- B. Commands and session outputs are vulnerable to passive network sniffing
- C. Lack of cryptographic integrity checking permits packet injection and tampering
- D. Telnet packets cannot be routed across standard IP networks

Correct Answer: A, B, C

Concept & Rationale: Telnet (port 23) operates entirely in plaintext. Anyone with packet capture access can view credentials and commands, and tamper with sessions. Telnet routes over standard IP without issue.

Question 473

Topic: HTTP Status Code Categories

Type: Multiple Choice

Which of the following HTTP status code classifications are correct according to RFC standards?

- A. 1xx: Informational - Request received, continuing process
- B. 2xx: Success - The action was successfully received and accepted
- C. 3xx: Redirection - Further action must be taken to complete the request
- D. 4xx: Client Error - The request contains bad syntax or cannot be fulfilled
- E. 5xx: Server Error - The server failed to fulfill an apparently valid request

Correct Answer: A, B, C, D, E

Concept & Rationale: HTTP status codes are divided into: 1xx (Informational), 2xx (Success, e.g. 200 OK), 3xx (Redirection, e.g. 301/302), 4xx (Client Error, e.g. 403/404), and 5xx (Server Error, e.g. 500/502).

Question 474

Topic: HTTPS Security Architecture

Type: Multiple Choice

What components are utilized by HTTPS to secure HTTP communications?

- A. Transport Layer Security (TLS) protocol
- B. Digital certificates issued by trusted Certificate Authorities (CAs)
- C. Asymmetric encryption for initial key exchange and server authentication
- D. Symmetric encryption for high-speed session data transmission
- E. Unencrypted Telnet control sessions

Correct Answer: A, B, C, D

Concept & Rationale: HTTPS layers HTTP over TLS. It uses digital certificates and asymmetric ciphers to authenticate the server and negotiate keys, followed by symmetric ciphers for fast bulk encryption.

Question 475

Topic: DNS Resolution Methods

Type: Multiple Choice

Which resolution methods are used during DNS domain name resolution?

- A. Recursive Query: The queried DNS server must return the final IP or an error
- B. Iterative Query: The queried DNS server returns the best referral to another server
- C. Multicast Query: Querying all hosts across the global Internet simultaneously
- D. Loopback Query: Generating continuous DNS loops to test server memory

Correct Answer: A, B

Concept & Rationale: DNS resolution uses Recursive queries (typically client-to-resolver, where the resolver does all the work) and Iterative queries (resolver queries Root, TLD, and Authoritative servers successively).

Question 476

Topic: DHCP Lease Renewal

Type: Multiple Choice

Which of the following events occur during the DHCP client lease lifecycle?

- A. At 50% of lease time (T1), the client sends a unicast DHCP Request to the leasing server
- B. At 87.5% of lease time (T2), if T1 renewal failed, the client broadcasts a DHCP Request to any server
- C. If the lease expires without renewal, the client immediately stops using the IP address
- D. The client retains the IP address permanently even after lease expiration

Correct Answer: A, B, C

Concept & Rationale: DHCP clients attempt lease renewal at T1 (50% lease time) via unicast DHCP Request. If unacknowledged, at T2 (87.5% lease time) they broadcast DHCP Request. If expired, the IP is immediately released.

Question 477

Topic: Ethernet Frame Types

Type: Multiple Choice

Which of the following are valid frame encapsulation types utilized in Ethernet networking?

- A. Ethernet II (DIX Ethernet)
- B. IEEE 802.3 with 802.2 LLC
- C. IEEE 802.3 with SNAP
- D. Ethernet IV High-Speed

Correct Answer: A, B, C

Concept & Rationale: Ethernet frame formats in historical and current networking include Ethernet II (most common today), IEEE 802.3 LLC, and IEEE 802.3 SNAP. There is no 'Ethernet IV' specification.

Question 478**Topic:** IPv4 Header Flags Identification**Type:** Multiple Choice

Which of the following represent the 3 bits of the Flags field in an IPv4 packet header?

- A. Reserved bit (must be 0)
- B. Don't Fragment (DF) bit
- C. More Fragments (MF) bit
- D. Urgent Pointer (URG) bit

Correct Answer: A, B, C

Concept & Rationale: The 3 bits of the IPv4 Flags field are: Bit 0 (Reserved, must be 0), Bit 1 (DF - Don't Fragment), and Bit 2 (MF - More Fragments). URG is a TCP control flag, not an IP header flag.

Question 479**Topic:** Well-Known Port Numbers**Type:** Multiple Choice

Which of the following port assignments are correct for well-known Internet services?

- A. SSH: TCP port 22
- B. DNS: UDP/TCP port 53
- C. HTTP: TCP port 80
- D. HTTPS: TCP port 443
- E. FTP Control: TCP port 21

Correct Answer: A, B, C, D, E

Concept & Rationale: Standard well-known ports: SSH = 22, DNS = 53, HTTP = 80, HTTPS = 443, FTP Control = 21, and FTP Data = 20.

Question 480**Topic:** Ethernet Broadcast MAC**Type:** Multiple Choice

Which of the following MAC addresses represent Ethernet broadcast or multicast addresses?

- A. FF:FF:FF:FF:FF:FF (Layer 2 broadcast)
- B. 01:00:5E:00:00:01 (IPv4 multicast MAC mapping)
- C. 33:33:00:00:00:01 (IPv6 multicast MAC mapping)
- D. 00:00:00:00:00:00 (Standard default router unicast MAC)

Correct Answer: A, B, C

Concept & Rationale: FF:FF:FF:FF:FF:FF is the all-ones Layer 2 broadcast address. Addresses starting with 01:00:5E are reserved for IPv4 multicast. Addresses starting with 33:33 are reserved for IPv6 multicast. All-zeros is not a valid unicast host address.

14 Chapter 3: Common Network Security Threats and Threat Prevention

Question 481

Topic: Malware Broad Categories

Type: Multiple Choice

Which of the following are recognized classifications of malicious software (malware)?

- A. Computer Viruses
- B. Worms
- C. Trojan Horses
- D. Ransomware
- E. Standard Hypervisors

Correct Answer: A, B, C, D

Concept & Rationale: Major malware types include viruses, worms, Trojans, ransomware, rootkits, spyware, and botnets. Hypervisors are legitimate virtualization software layers.

Question 482

Topic: Virus vs Worm Differences

Type: Multiple Choice

Which of the following statements correctly distinguish a computer worm from a computer virus?

- A. A virus requires a host program or file to infect; a worm is an independent standalone program
- B. A virus typically requires human intervention (executing the host) to spread; a worm propagates autonomously over network connections
- C. A worm can exploit network service vulnerabilities directly to infect adjacent systems
- D. A virus never causes any damage to user files

Correct Answer: A, B, C

Concept & Rationale: Viruses require host files and user execution to spread; worms are autonomous standalone programs that exploit network vulnerabilities directly to self-propagate across systems. Both can cause severe file and system damage.

Question 483

Topic: Port Scanning Techniques

Type: Multiple Choice

Which of the following are common TCP/IP port scanning techniques utilized by penetration testers and threat actors?

- A. TCP Connect Scan (Full 3-way handshake)
- B. TCP SYN Scan (Half-open stealth scan)
- C. TCP FIN / NULL / XMAS Scan (Inverse RFC scanning)
- D. UDP Port Scan
- E. Optical Fiber Polarization Scan

Correct Answer: A, B, C, D

Concept & Rationale: Standard scanning methods include TCP Connect, TCP SYN, TCP FIN/NULL/XMAS, and UDP scanning. Optical polarization is a physical transmission property, not a port scanning method.

Question 484**Topic:** Layer 2 Sniffing Attacks**Type:** Multiple Choice

Which of the following techniques can an attacker use on a switched Ethernet LAN to intercept and sniff traffic destined for other hosts?

- A. ARP Cache Poisoning (ARP Spoofing)
- B. MAC Address Table Flooding (CAM table overflow)
- C. DHCP Server Rogue Spoofing
- D. BGP Route Leaking on Core ISP Routers

Correct Answer: A, B, C

Concept & Rationale: On local switched LANs, attackers bypass unicast switching isolation using ARP spoofing, MAC table flooding (forcing hub failover), and rogue DHCP servers. BGP route leaking occurs at wide-area inter-domain routing tiers.

Question 485**Topic:** Network Layer Spoofing Types**Type:** Multiple Choice

Which of the following represent spoofing attack vectors commonly executed across network communications?

- A. IP Address Spoofing
- B. MAC Address Spoofing
- C. DNS Cache Poisoning / Domain Spoofing
- D. DHCP Server Spoofing
- E. Processor Serial Number Overclocking

Correct Answer: A, B, C, D

Concept & Rationale: Network spoofing involves falsifying identity headers across layers: MAC spoofing (Layer 2), IP spoofing (Layer 3), DHCP spoofing (Layer 7), and DNS poisoning (Layer 7). Overclocking is a physical hardware tuning process.

Question 486**Topic:** Volumetric DDoS Attack Methods**Type:** Multiple Choice

Which of the following attack types are categorized as volumetric DoS/DDoS flooding attacks?

- A. UDP Flood
- B. ICMP Echo Flood (Ping Flood)
- C. TCP SYN Flood
- D. DNS Amplification Flood
- E. SQL Injection

Correct Answer: A, B, C, D

Concept & Rationale: Volumetric floods aim to saturate network link bandwidth or state tables using huge traffic volumes: UDP floods, ICMP floods, SYN floods, and DNS amplification. SQL injection is an application logic exploit.

Question 487

Topic: Malformed Packet DoS Attacks

Type: Multiple Choice

Which of the following attacks rely on sending malformed, oversized, or contradictory packet headers rather than high traffic volume?

- A. Ping of Death (oversized IP packets)
- B. Teardrop Attack (overlapping fragment offsets)
- C. Land Attack (identical source/destination IP and port)
- D. Smurf Amplification Attack

Correct Answer: A, B, C

Concept & Rationale: Ping of Death, Teardrop, and Land attacks are vulnerability-based malformed packet attacks that crash host networking stacks with minimal traffic volume. Smurf is a volumetric amplification flood.

Question 488

Topic: Application Layer (L7) Attacks

Type: Multiple Choice

Which of the following attacks operate primarily at Layer 7 (Application Layer) of the OSI model?

- A. Challenge Collapsar (CC) HTTP GET Flood
- B. Slowloris HTTP Connection Exhaustion
- C. SQL Injection (SQLi)
- D. Cross-Site Scripting (XSS)
- E. Ethernet Preamble Corrupting Attack

Correct Answer: A, B, C, D

Concept & Rationale: CC attacks, Slowloris, SQL Injection, and XSS target application logic and protocols (HTTP, SQL) at Layer 7. The Ethernet preamble operates at Layer 1/2.

Question 489

Topic: Amplification DDoS Mechanisms

Type: Multiple Choice

Which protocols are frequently exploited to launch distributed reflection and amplification DoS attacks?

- A. NTP (Network Time Protocol using 'monlist')
- B. DNS (Domain Name System querying 'ANY' records)
- C. SNMP (Simple Network Management Protocol queries)
- D. SSDP (Simple Service Discovery Protocol)
- E. SSH (Secure Shell Protocol)

Correct Answer: A, B, C, D

Concept & Rationale: Connectionless UDP services with large response-to-request ratios (NTP, DNS, SNMP, SSDP) are prime vectors for reflection amplification attacks. SSH runs over TCP, preventing spoofed reflection.

Question 490

Topic: ARP Poisoning Mitigation

Type: Multiple Choice

Which security mechanisms implemented on enterprise switches protect against ARP spoofing / poisoning attacks?

- A. Dynamic ARP Inspection (DAI)
- B. DHCP Snooping binding table integration
- C. Configuring static ARP entries on critical endpoints and gateways
- D. Disabling Ethernet CRC verification

Correct Answer: A, B, C

Concept & Rationale: DAI validates ARP packets against the DHCP Snooping database or static bindings, discarding unauthorized ARP responses. Static ARP mappings also prevent cache poisoning. Disabling CRC ruins data integrity.

Question 491

Topic: SYN Flood Countermeasures

Type: Multiple Choice

Which defensive techniques are effective in mitigating TCP SYN flood attacks on firewalls and enterprise servers?

- A. SYN Cookie technology
- B. TCP SYN Proxy / Embryonic connection inspection
- C. Rate limiting incoming SYN requests per second from external zones
- D. Disabling TCP keepalive timers entirely

Correct Answer: A, B, C

Concept & Rationale: SYN floods are mitigated by SYN Cookies (stateless verification), TCP SYN Proxy (firewall completes 3-way handshake before connecting to server), and SYN rate limiting. Disabling keepalives degrades session management.

Question 492

Topic: Anti-DDoS System Phases

Type: Multiple Choice

What are the core operational phases of an enterprise Anti-DDoS defense architecture?

- A. Traffic Detection (identifying anomaly spikes and flood patterns)
- B. Traffic Diversion (redirecting victim traffic to scrubbing centers)
- C. Traffic Scrubbing (filtering attack packets while retaining legitimate requests)
- D. Traffic Reinjection (forwarding cleaned traffic to original server)
- E. Traffic Deletion (deleting all enterprise databases)

Correct Answer: A, B, C, D

Concept & Rationale: Anti-DDoS scrubbing follows four distinct stages: 1. Detection (monitoring telemetry); 2. Diversion (rerouting via BGP/DNS); 3. Scrubbing (deep packet filtering); and 4. Reinjection (clean traffic delivery).

Question 493

Topic: Defense-in-Depth Components

Type: Multiple Choice

Which defensive layers should be incorporated into a comprehensive enterprise Defense-in-Depth strategy?

- A. Physical Security (access control, biometric badges, CCTV)
- B. Perimeter Security (Next-Generation Firewalls, Anti-DDoS, IPS)
- C. Network Security (VLAN segmentation, 802.1X NAC, encrypted tunnels)
- D. Endpoint Security (EDR, host firewalls, patch management)
- E. Data Security (encryption at rest/in transit, DLP, backup)

Correct Answer: A, B, C, D, E

Concept & Rationale: Defense-in-Depth mandates overlapping controls across Physical, Perimeter, Network, Endpoint, Application, and Data dimensions to ensure multi-layered resilience.

Question 494**Topic:** Social Engineering Varieties**Type:** Multiple Choice

Which of the following attack methods rely predominantly on social manipulation rather than software exploits?

- A. Phishing (fraudulent emails soliciting credentials)
- B. Vishing (voice telephone pretexting by fake technicians)
- C. Smishing (SMS text phishing)
- D. Watering Hole attack
- E. SYN Flood attack

Correct Answer: A, B, C, D

Concept & Rationale: Phishing, vishing, smishing, and watering hole attacks manipulate human psychology, trust, and habit to deliver malicious payloads. SYN flood is a network protocol resource exhaustion attack.

Question 495**Topic:** Botnet Utilization Scenarios**Type:** Multiple Choice

For which malicious activities are botnets commonly deployed by threat actors?

- A. Launching massive distributed denial-of-service (DDoS) attacks
- B. Sending billions of unsolicited spam and phishing emails
- C. Conducting large-scale cryptocurrency mining across zombie devices
- D. Coordinated credential stuffing and password brute-forcing
- E. Providing free high-speed bandwidth to non-profit organizations

Correct Answer: A, B, C, D

Concept & Rationale: Botnets provide distributed compute and bandwidth for DDoS floods, spam dissemination, illicit crypto mining, proxy anonymity networks, and automated brute-force attacks.

Question 496**Topic:** Vulnerability Assessment Tools**Type:** Multiple Choice

Which of the following tools and capabilities are standard components of vulnerability assessment and penetration testing?

- A. Network port scanners (e.g., Nmap)
- B. Automated vulnerability scanners (e.g., Nessus, OpenVAS)
- C. Web application vulnerability scanners (e.g., OWASP ZAP)
- D. Exploit frameworks (e.g., Metasploit)
- E. Physical soldering irons for switch chassis assembly

Correct Answer: A, B, C, D

Concept & Rationale: Vulnerability assessments leverage port discovery (Nmap), vulnerability scanners (Nessus/OpenVAS), web application scanners (ZAP), and exploit validation tools (Metasploit).

Question 497

Topic: Ransomware Infection Vectors

Type: Multiple Choice

Through which common entry vectors does ransomware initially compromise enterprise networks?

- A. Phishing emails carrying weaponized macro documents or malicious links
- B. Exposed Remote Desktop Protocol (RDP) ports with weak or compromised passwords
- C. Exploitation of unpatched software vulnerabilities (e.g., SMB flaws like EternalBlue)
- D. Drive-by downloads from compromised websites
- E. Standard certified fiber optic patch cables

Correct Answer: A, B, C, D

Concept & Rationale: Ransomware commonly infiltrates via email phishing, exposed remote desktop services, unpatched perimeter vulnerabilities, and malicious web drive-bys.

Question 498

Topic: Web Application Threats (OWASP Top 10)

Type: Multiple Choice

Which of the following security threats are included in the OWASP Top 10 vulnerabilities for web applications?

- A. Injection flaws (such as SQL Injection and Command Injection)
- B. Broken Authentication and Session Management
- C. Cross-Site Scripting (XSS)
- D. Security Misconfigurations and Outdated Components
- E. Optical Cable Attenuation

Correct Answer: A, B, C, D

Concept & Rationale: The OWASP Top 10 highlights critical application risks including Injection, Broken Authentication, XSS, Security Misconfigurations, and Insecure Design.

Question 499

Topic: Teardrop and Fragmentation Risks

Type: Multiple Choice

Why are fragmented IP packets historically utilized by attackers to bypass network defenses?

- A. Initial fragments may lack Layer 4 port headers, complicating stateful policy inspection
- B. Overlapping fragment offsets can exploit reassembly buffer bugs in target kernels
- C. Some primitive packet filters inspect only the first fragment and blindly permit subsequent fragments
- D. Fragmented packets automatically travel twice as fast across fiber links

Correct Answer: A, B, C

Concept & Rationale: Fragmented packets can split TCP/UDP headers across packets, evade legacy packet filters that inspect only Fragment 0, and trigger reassembly crashes via overlapping offsets (Teardrop).

Question 500

Topic: IP Address Spoofing Defenses

Type: Multiple Choice

Which network security techniques are utilized by internet service providers and routers to block spoofed IP traffic?

- A. Unicast Reverse Path Forwarding (uRPF)
- B. Ingress and egress access control list (ACL) packet filtering (BCP 38)
- C. IP Source Guard (IPSG) on access switches
- D. Disabling all IP routing protocols across the Internet

Correct Answer: A, B, C

Concept & Rationale: Spoofed source IPs are filtered using uRPF (checking if source IP is reachable via incoming interface), BCP 38 ingress filtering, and IP Source Guard on local switch ports.

Question 501

Topic: Zero-Day Mitigation Strategies

Type: Multiple Choice

Because signature-based antivirus cannot detect unknown zero-day attacks, which modern defenses are recommended?

- A. Heuristic and behavioral anomaly detection
- B. Sandboxing and dynamic malware analysis
- C. Endpoint Detection and Response (EDR) behavioral monitoring
- D. Strict network micro-segmentation and Zero Trust access policies
- E. Relying solely on paper log books

Correct Answer: A, B, C, D

Concept & Rationale: Zero-day threats lack known signatures. Defense requires behavioral heuristics, sandboxing execution environments, EDR anomaly telemetry, and Zero Trust micro-segmentation.

Question 502

Topic: Smurf Attack Amplifiers

Type: Multiple Choice

In a Smurf attack, what elements are required to successfully launch and amplify the flood?

- A. An attacker capable of crafting spoofed ICMP Echo Request packets
- B. An amplifying intermediary network that forwards directed broadcast packets to its local broadcast domain
- C. Multiple responsive hosts on the intermediary network that reply to the victim's spoofed IP
- D. A victim host whose network link becomes saturated by the replies
- E. Direct administrative access to the victim's BIOS

Correct Answer: A, B, C, D

Concept & Rationale: Smurf attacks require an attacker sending spoofed packets, an intermediary broadcast-forwarding network (amplifier), responsive hosts on that segment, and an overwhelmed victim.

Question 503

Topic: DNS Spoofing Impacts

Type: Multiple Choice

What adverse consequences occur when an attacker successfully executes DNS cache poisoning against a local resolver?

- A. Users requesting legitimate websites (e.g. online banking) are redirected to attacker-controlled phishing servers
- B. Corporate emails can be intercepted by pointing MX records to rogue mail servers
- C. Software update domains can be hijacked to distribute malware updates
- D. The client's physical RAM modules are instantly formatted

Correct Answer: A, B, C

Concept & Rationale: DNS poisoning corrupts IP resolution mappings, diverting web traffic to phishing clones, rerouting emails via rogue MX hosts, and facilitating drive-by malware delivery.

Question 504**Topic:** MAC Address Flooding Effects**Type:** Multiple Choice

What happens to a network switch when its CAM (Content Addressable Memory) table is exhausted during a MAC flood attack?

- A. The switch can no longer learn new legitimate MAC-to-port mappings
- B. The switch begins flooding incoming unicast frames out of all ports within the VLAN (acting like a hub)
- C. Network performance degrades drastically due to excessive broadcast traffic
- D. The switch turns off its power supply permanently

Correct Answer: A, B, C

Concept & Rationale: CAM exhaustion forces the switch into fail-open mode, broadcasting unicast frames across all ports, degrading bandwidth and exposing traffic to sniffing on any switch port.

Question 505**Topic:** CC Attack Defense Techniques**Type:** Multiple Choice

Which countermeasures are effective against Layer 7 Challenge Collapsar (CC) HTTP GET floods?

- A. Web Application Firewall (WAF) rate limiting and IP reputation filtering
- B. JavaScript challenge validation (verifying client is a genuine browser, not a script)
- C. CAPTCHA verification for suspicious high-frequency request patterns
- D. Disabling power to all external DNS root servers

Correct Answer: A, B, C

Concept & Rationale: CC attacks are mitigated by WAF rate limits, JavaScript computational challenges, CAPTCHA verification, and behavior-based bot management.

Question 506**Topic:** Drive-By Download Mechanism**Type:** Multiple Choice

Which conditions facilitate a successful 'Drive-By Download' infection?

- A. A victim visits a compromised or malicious website
- B. The malicious site hosts an exploit kit probing browser or plugin vulnerabilities
- C. The vulnerability is silently exploited without explicit user download consent
- D. The user must physically disassemble the computer monitor

Correct Answer: A, B, C

Concept & Rationale: Drive-by downloads silently exploit browser, PDF, or plugin flaws when a user merely visits a compromised website, installing malware without requiring user clicks or downloads.

Question 507**Topic:** Slowloris Attack Characteristics**Type:** Multiple Choice

Which operational features distinguish a Slowloris attack from traditional volumetric HTTP floods?

- A. It consumes very minimal upstream bandwidth from the attacker
- B. It holds server connections open by sending partial, incomplete HTTP request headers at regular intervals
- C. It targets thread-based web servers (such as Apache 1.x/2.x) with fixed worker limits
- D. It uses 100-gigabit UDP packet floods

Correct Answer: A, B, C

Concept & Rationale: Slowloris is a low-bandwidth, asymmetric Layer 7 attack. It slowly sends partial headers to exhaust server thread/connection pools, selectively devastating thread-based web servers like Apache.

Question 508

Topic: Defense Against Rogue DHCP

Type: Multiple Choice

Which feature on Huawei enterprise switches effectively eliminates rogue DHCP server attacks?

- A. DHCP Snooping with trusted and untrusted port designation
- B. Configuring the switch to drop DHCP Offer/ACK packets received on untrusted access ports
- C. Enabling 802.1Q trunking on all access ports
- D. Disabling all IP routing across the campus network

Correct Answer: A, B

Concept & Rationale: DHCP Snooping designates switch ports as 'trusted' (connected to legitimate DHCP servers) or 'untrusted' (connected to users). Any DHCP Offer/ACK received on an untrusted port is immediately dropped.

15 Chapter 4: Firewall Security Policies

Question 509

Topic: Predefined Security Zones

Type: Multiple Choice

Which of the following are predefined default security zones available out-of-the-box on Huawei USG firewalls?

- A. Local Zone (Priority 100)
- B. Trust Zone (Priority 85)
- C. DMZ Zone (Priority 50)
- D. Untrust Zone (Priority 5)
- E. Public Zone (Priority 200)

Correct Answer: A, B, C, D

Concept & Rationale: Huawei firewalls feature four factory-predefined security zones: Local (100), Trust (85), DMZ (50), and Untrust (5). There is no default 'Public' zone with priority 200.

Question 510

Topic: Security Policy Matching Conditions

Type: Multiple Choice

Which of the following parameters can be configured as matching conditions in a Huawei NGFW security policy rule?

- A. Source and Destination Security Zones
- B. Source and Destination IP Addresses or Address Groups
- C. Services (Protocols and Port numbers)
- D. Users or User Groups
- E. Applications identified by DPI
- F. Time Range / Schedule

Correct Answer: A, B, C, D, E, F

Concept & Rationale: Huawei NGFW security policies support comprehensive matching dimensions: Zones, IP addresses, Services/Ports, Users/Groups, Applications (L7), and Time schedules.

Question 511**Topic:** Firewall Evolution Generations**Type:** Multiple Choice

Which of the following are recognized generations in the historical development of firewall technology?

- A. First Generation: Packet Filtering Firewall
- B. Second Generation: Application Proxy Firewall
- C. Third Generation: Stateful Inspection Firewall
- D. Modern Generation: Next-Generation Firewall (NGFW)
- E. Wireless Radio Analog Firewall

Correct Answer: A, B, C, D

Concept & Rationale: Firewall technology evolved across: 1. Packet Filtering; 2. Application Proxy; 3. Stateful Inspection; and 4. Next-Generation Firewalls (NGFW).

Question 512**Topic:** Session Table Attributes**Type:** Multiple Choice

Which of the following pieces of information are recorded within an active Huawei firewall session entry?

- A. 5-tuple (Source/Dest IP, Source/Dest Port, Protocol)
- B. Current connection state (e.g., ESTABLISHED)
- C. Source and Destination security zone IDs
- D. Ingress and Egress interface names
- E. Remaining aging time before expiration

Correct Answer: A, B, C, D, E

Concept & Rationale: A session table entry tracks the 5-tuple, connection state, zone IDs, ingress/egress interfaces, application identity, NAT translation parameters, and aging timers.

Question 513**Topic:** ASPF Supported Protocols**Type:** Multiple Choice

Which of the following multi-channel or dynamic port protocols are commonly inspected by firewall ASPF engines?

- A. File Transfer Protocol (FTP)
- B. Session Initiation Protocol (SIP)
- C. H.323 (VoIP protocol suite)
- D. Real-Time Streaming Protocol (RTSP)
- E. Static Unencrypted Telnet

Correct Answer: A, B, C, D

Concept & Rationale: ASPF specifically inspects multi-channel protocols that negotiate secondary data ports inside control payloads: FTP, SIP, H.323, RTSP, and QQ. Static single-channel protocols like Telnet do not require ASPF.

Question 514**Topic:** NGFW Core Capabilities**Type:** Multiple Choice

Which of the following are core characteristics that define a Next-Generation Firewall (NGFW)?

- A. Application awareness independent of port numbers
- B. Integration of User identity into policy enforcement
- C. Unified threat prevention engine (IPS, AV, URL Filtering)
- D. High performance single-pass parallel inspection architecture
- E. Requirement to deploy external physical hubs on all ports

Correct Answer: A, B, C, D

Concept & Rationale: NGFWs feature application identification, user awareness, unified deep content inspection, and high-performance single-pass architecture.

Question 515**Topic:** Security Policy Actions**Type:** Multiple Choice

What are the two primary forwarding actions that can be configured on a firewall security policy rule?

- A. Permit (allow traffic to pass and inspect)
- B. Deny (discard and block matching traffic)
- C. Loopback (bounce packet between interfaces)
- D. Duplicate (send two copies to Internet)

Correct Answer: A, B

Concept & Rationale: The fundamental actions of a firewall security policy rule are 'Permit' (forward and apply security profiles) and 'Deny' (drop traffic).

Question 516**Topic:** Default Security Policy Characteristics**Type:** Multiple Choice

Which of the following statements regarding the predefined 'default' security policy on a Huawei firewall are true?

- A. It is permanently located at the very bottom of the rule list
- B. Its default action is set to 'Deny'
- C. It cannot be deleted or moved by administrators
- D. Its action can be modified from Deny to Permit if desired
- E. It matches only UDP traffic destined to port 53

Correct Answer: A, B, C, D

Concept & Rationale: The default rule is fixed at the bottom, defaults to Deny, cannot be deleted or reordered, and matches all remaining traffic regardless of protocol.

Question 517**Topic:** Traffic Direction Rules**Type:** Multiple Choice

Based on Huawei firewall zone priority rules, which of the following traffic flows are correctly classified as 'Outbound'?

- A. Trust (85) -> Untrust (5)
- B. Trust (85) -> DMZ (50)
- C. DMZ (50) -> Untrust (5)
- D. Local (100) -> Trust (85)
- E. Untrust (5) -> DMZ (50)

Correct Answer: A, B, C, D

Concept & Rationale: Outbound traffic flows from higher priority to lower priority: 85->5, 85->50, 50->5, and 100->85 are all Outbound. Untrust (5) to DMZ (50) is Inbound.

Question 518

Topic: Traffic Direction Inbound Examples

Type: Multiple Choice

Which of the following traffic paths represent 'Inbound' traffic flows on a Huawei firewall?

- A. Untrust (5) -> DMZ (50)
- B. Untrust (5) -> Trust (85)
- C. DMZ (50) -> Trust (85)
- D. Untrust (5) -> Local (100)
- E. Local (100) -> Untrust (5)

Correct Answer: A, B, C, D

Concept & Rationale: Inbound traffic flows from lower priority to higher priority: 5->50, 5->85, 50->85, and 5->100 are all Inbound. Local (100) to Untrust (5) is Outbound.

Question 519

Topic: Security Profiles on NGFW

Type: Multiple Choice

Which of the following security inspection profiles can be associated with a 'Permit' rule in a Huawei NGFW security policy?

- A. Intrusion Prevention System (IPS) Profile
- B. Antivirus (AV) Profile
- C. URL Filtering Profile
- D. File Filtering Profile
- E. Data Loss Prevention (DLP) / Content Filtering Profile

Correct Answer: A, B, C, D, E

Concept & Rationale: Huawei NGFW allows associating IPS, Antivirus, URL Filtering, File Filtering, Content/Data Filtering, and Mail Filtering profiles with permitted policy rules for deep inspection.

Question 520

Topic: Session Table Aging Time Reasons

Type: Multiple Choice

Why do different protocols have distinct session aging timers on firewalls?

- A. TCP handshake states (SYN_SENT) have short timers to prevent SYN flood resource starvation
- B. Established TCP connections have long timers because business transactions may have idle periods between requests
- C. UDP is connectionless, so moderate timers (e.g. 120s) ensure return packets pass without leaving permanent stale entries
- D. ICMP sessions are short-lived query/reply transactions requiring only brief aging times (e.g. 20s)

Correct Answer: A, B, C, D

Concept & Rationale: Timers reflect protocol semantics: TCP connection states use short timers during setup/teardown and long timers when established; connectionless UDP and ICMP use fixed expiration timers.

Question 521**Topic:** Server-Map Entry Generation Sources**Type:** Multiple Choice

On a Huawei firewall, Server-Map entries can be dynamically or statically generated by which of the following features?

- A. ASPF inspection of multi-channel protocols (e.g. FTP active mode)
- B. NAT Server (static destination IP/port mapping)
- C. NAT No-PAT (source address translation without port translation)
- D. Physical link speed auto-negotiation on Ethernet ports

Correct Answer: A, B, C

Concept & Rationale: Server-Map entries are generated by ASPF (dynamic secondary channels), NAT Server (static server mapping), and NAT No-PAT (mapping public IP to private IP). Physical auto-negotiation operates at Layer 1.

Question 522**Topic:** Stateful Firewall Advantages**Type:** Multiple Choice

Which of the following are major advantages of stateful inspection firewalls compared to stateless packet filters?

- A. Automatic tracking of connection state allows return traffic without opening broad static inbound ports
- B. Verification of sequence numbers and TCP flags protects against spoofed packets and out-of-sequence attacks
- C. Significantly higher throughput for established flows via session table fast-forwarding
- D. Complete elimination of the need for routing tables

Correct Answer: A, B, C

Concept & Rationale: Stateful inspection provides robust security (inspects state, sequence numbers, return traffic) and high performance (session fast path). Routing tables are still required for packet forwarding.

Question 523**Topic:** Security Policy Optimization Strategies**Type:** Multiple Choice

Which of the following practices are recommended when configuring firewall security policies?

- A. Place specific, high-frequency rules near the top of the policy list
- B. Group related IP addresses and ports into Address Sets and Service Objects for readability and maintainability
- C. Avoid configuring overly broad rules such as 'Permit Any Any Any'
- D. Periodically review policy hit counts to identify and decommission obsolete rules
- E. Set the default policy action to 'Permit' on perimeter firewalls

Correct Answer: A, B, C, D

Concept & Rationale: Best practices include top placement for frequent rules, object reuse, least privilege (avoiding permit any), and auditing hit counters. Setting the default policy to Permit breaks perimeter security.

Question 524**Topic:** Firewall Local Zone Functions**Type:** Multiple Choice

Which of the following traffic types originate from or terminate in the Local security zone?

- A. SSH or HTTPS administrative management sessions to the firewall itself
- B. OSPF or BGP dynamic routing protocol hello and update packets exchanged with neighbor routers
- C. IPsec VPN or SSL VPN tunnels terminated directly on the firewall
- D. SNMP queries polling firewall operational metrics
- E. Direct client browsing to external Internet web servers traversing through the firewall

Correct Answer: A, B, C, D

Concept & Rationale: The Local zone covers traffic terminating on or originating from the firewall: management (SSH/HTTPS), routing protocols (OSPF/BGP), VPN endpoints, and SNMP. Transit traffic traversing between interfaces does NOT enter the Local zone.

Question 525**Topic:** Time Range Types**Type:** Multiple Choice

In Huawei firewall configuration, what types of Time Ranges can be configured for security policy scheduling?

- A. Periodic Time Range (repeating on specific days of the week, e.g. Monday-Friday 08:00-18:00)
- B. Absolute Time Range (spanning a specific calendar date window, e.g. 2026-01-01 to 2026-01-15)
- C. Infinite Time Range that ignores the system clock completely
- D. Quantum Time Range that shifts backwards in time

Correct Answer: A, B

Concept & Rationale: Huawei VRP supports Periodic Time Ranges (recurring weekly schedules) and Absolute Time Ranges (specific calendar date/time intervals).

Question 526**Topic:** Address Object Types**Type:** Multiple Choice

Which of the following address representations can be configured within an Address Object on a Huawei firewall?

- A. A single host IPv4 address (e.g., 192.168.1.10/32)
- B. An IP address range (e.g., 192.168.1.50 to 192.168.1.100)
- C. A subnet prefix with subnet mask (e.g., 10.1.0.0/16)
- D. A Domain Name / FQDN (e.g., www.huawei.com)
- E. A physical hard drive partition serial number

Correct Answer: A, B, C, D

Concept & Rationale: Firewall address objects support single IPs, IP ranges, subnets, and FQDN domain names. Hard drive serial numbers are storage identifiers, not network address objects.

Question 527**Topic:** Service Object Predefined Services**Type:** Multiple Choice

Which of the following are predefined standard Service Objects available in Huawei USG firewalls?

- A. HTTP (TCP port 80)
- B. HTTPS (TCP port 443)
- C. DNS (UDP/TCP port 53)
- D. TELNET (TCP port 23)
- E. PING (ICMP Echo)

Correct Answer: A, B, C, D, E

Concept & Rationale: Huawei firewalls include standard predefined services for well-known protocols: HTTP, HTTPS, DNS, FTP, TELNET, SSH, SMTP, and PING/ICMP.

Question 528

Topic: Firewall Session Fast Path Steps

Type: Multiple Choice

During session table fast-path forwarding, which operations does the firewall perform for subsequent packets?

- A. Matches the 5-tuple against the active session table
- B. Refreshes the session aging timer
- C. Applies NAT translation if configured on the session
- D. Directly forwards the packet to the egress interface pipeline without re-evaluating security policy rules
- E. Prompts the user to re-enter their username

Correct Answer: A, B, C, D

Concept & Rationale: Fast-path matching checks the session table, refreshes the aging timer, executes NAT rewrite if applicable, and forwards packets directly, bypassing security policy rule evaluation.

Question 529

Topic: Asymmetric Routing Mitigation

Type: Multiple Choice

Which configuration techniques can resolve packet drops caused by asymmetric routing on stateful firewalls?

- A. Deploying Dual-system Hot Standby with session table synchronization (HRP)
- B. Adjusting routing metrics to ensure symmetric forward and return routing paths
- C. Disabling stateful inspection (or enabling loose state checking) for specific asymmetric flows
- D. Permanently disconnecting all WAN interfaces

Correct Answer: A, B, C

Concept & Rationale: Asymmetric drops are mitigated by route symmetry engineering, HRP hot-standby session synchronization between dual firewalls, or enabling loose stateful checking for affected flows.

Question 530

Topic: Session Table Exhaustion Consequences

Type: Multiple Choice

What are the direct consequences if a firewall's session table is completely exhausted by a DDoS flood?

- A. New legitimate user connection attempts are rejected and dropped
- B. Network services become inaccessible, causing a Denial of Service (DoS)
- C. Firewall CPU utilization increases significantly due to memory management overhead
- D. The firewall converts into a Layer 1 repeater

Correct Answer: A, B, C

Concept & Rationale: Session exhaustion prevents new TCP/UDP connections from forming, causing severe service outages and driving up CPU load as the kernel attempts to manage connection table limits.

Question 531

Topic: Intra-Zone vs Inter-Zone Security Differences

Type: Multiple Choice

Which of the following statements correctly contrast intra-zone and inter-zone traffic on Huawei firewalls?

- A. Intra-zone traffic travels between interfaces within the same security zone
- B. Inter-zone traffic travels between interfaces belonging to different security zones
- C. By default, intra-zone traffic is permitted, while inter-zone traffic is denied
- D. Inter-zone traffic requires explicit security policies to be permitted
- E. Intra-zone traffic can never be filtered or inspected

Correct Answer: A, B, C, D

Concept & Rationale: Intra-zone traffic occurs within a zone (permitted by default, but filterable if configured); inter-zone traffic traverses between distinct zones (denied by default, requiring explicit permit policies).

Question 532

Topic: CLI Commands for Security Policy

Type: Multiple Choice

Which of the following CLI commands are used in Huawei VRP to configure and inspect security policies?

- A. `security-policy` (enters the security policy configuration view)
- B. `rule name <name>` (creates a security policy rule)
- C. `action { permit | deny }` (specifies the policy action)
- D. `display security-policy rule all` (displays configured security policy rules)
- E. `format flash:` (deletes all system software)

Correct Answer: A, B, C, D

Concept & Rationale: In Huawei VRP, `security-policy`, `rule name`, `action permit/deny`, and `display security-policy rule all` are standard commands for managing security policies. `format flash:` erases storage.

Question 533

Topic: Security Policy Hit Count Utility

Type: Multiple Choice

How do policy hit count statistics assist security administrators?

- A. They confirm whether a newly created security rule is actively matching traffic
- B. They help detect shadow rules that are never matched because an earlier rule supersedes them
- C. They assist in capacity planning and performance auditing
- D. They automatically reboot the firewall at midnight

Correct Answer: A, B, C

Concept & Rationale: Hit count metrics verify rule activation, identify overshadowed/duplicate rules, assist in cleaning obsolete configurations, and inform traffic profiling.

Question 534

Topic: Custom Security Zones Use Cases

Type: Multiple Choice

For which network scenarios would an administrator create custom security zones beyond the four default zones?

- A. Creating a dedicated 'Guest_Wi-Fi' zone with priority 30 to isolate visitor traffic
- B. Creating a dedicated 'Management_OAM' zone with priority 95 for out-of-band network operations
- C. Creating an 'Extranet_Partners' zone with priority 60 for B2B VPN connections
- D. Creating a zone exclusively to increase the physical weight of the firewall chassis

Correct Answer: A, B, C

Concept & Rationale: Custom zones provide granular zoning for distinct business segments: Guest Wi-Fi (low trust), Partner Extranets (intermediate trust), and Out-of-Band Management (high trust).

Question 535

Topic: Application Layer Identification Benefits

Type: Multiple Choice

Why is application identification (L7 awareness) crucial in modern NGFWs compared to traditional L4 port filtering?

- A. Evasive applications (e.g. BitTorrent, Tor) dynamically hop ports to bypass static port filters
- B. Many diverse applications (e.g. webmail, video streaming, SaaS apps) share common ports like 80 and 443
- C. Application awareness allows granular control (e.g. permitting Facebook browsing while blocking Facebook Chat)
- D. It eliminates the need for physical Ethernet cables

Correct Answer: A, B, C

Concept & Rationale: Modern applications mask traffic over standard ports (80/443) or hop dynamic ports. L7 application control identifies true application signatures, enabling fine-grained behavioral policies (e.g., allow LinkedIn, block LinkedIn messaging).

Question 536

Topic: Session Table Fast-Path Bypass Conditions

Type: Multiple Choice

Which packets cannot use session table fast-path forwarding and MUST undergo policy/slow-path inspection?

- A. The first packet of a connection (e.g. TCP SYN) attempting to initiate a new session
- B. Packets that do not match any existing session table entry
- C. Packets whose transport layer headers are malformed or violate protocol state rules
- D. Established return packets that match a valid active session entry

Correct Answer: A, B, C

Concept & Rationale: Initial connection packets, packets without matching session entries, and state-violating packets are processed via the slow path. Packets matching active sessions use the fast path.

Question 537

Topic: Firewall Deployment Modes

Type: Multiple Choice

In which operational modes can a Huawei USG series firewall be deployed within an enterprise topology?

- A. Routing Mode (Layer 3 gateway with IP interfaces and routing)
- B. Transparent / Bridge Mode (Layer 2 bump-in-the-wire without changing existing IP subnetting)
- C. Hybrid Mode (some interfaces operate in Layer 3 while others operate in Layer 2)
- D. Satellite Wireless Relay Mode

Correct Answer: A, B, C

Concept & Rationale: Huawei firewalls support Routing Mode (Layer 3 routing/NAT), Transparent Mode (Layer 2 bridging, preserving IP schema), and Hybrid Mode (combining L2 and L3 interfaces).

Question 538**Topic:** Security Policy Logging Options**Type:** Multiple Choice

When configuring logging on a Huawei security policy rule, which logging options can be toggled?

- A. Session Start Logging (logs when a session is initially created)
- B. Session End Logging (logs when a session terminates, including duration and byte counts)
- C. Policy Hit Logging (logs rule execution events)
- D. Hardware Fan Speed Logging

Correct Answer: A, B, C

Concept & Rationale: Huawei firewalls support Session Start logging, Session End logging (capturing total duration and volume metrics), and Policy Hit logging. Fan speed is managed under system environment monitoring.

16 Chapter 5: Firewall NAT Technologies

Question 539**Topic:** Source NAT Flavors**Type:** Multiple Choice

Which of the following are recognized forms of Source NAT supported on Huawei firewalls?

- A. NAT No-PAT
- B. NAPT (Network Address Port Translation)
- C. Easy IP
- D. Smart NAT
- E. NAT Quad-Port

Correct Answer: A, B, C, D

Concept & Rationale: Huawei firewalls support four primary Source NAT modes: NAT No-PAT, NAPT, Easy IP, and Smart NAT. There is no 'NAT Quad-Port' specification.

Question 540**Topic:** NAPT Advantages**Type:** Multiple Choice

What are the primary operational advantages of NAPT compared to NAT No-PAT?

- A. Significantly higher public IP utilization efficiency
- B. Enabling thousands of internal hosts to share one or a few public IP addresses
- C. Lower public IP procurement and leasing costs from ISPs
- D. Complete elimination of transport layer port numbers

Correct Answer: A, B, C

Concept & Rationale: NAPT multiplexes connections over port numbers, allowing thousands of hosts to share minimal public IPs, drastically reducing IP costs. Transport layer ports are retained and translated, not eliminated.

Question 541**Topic:** NAT Policy Matching Conditions**Type:** Multiple Choice

Which of the following parameters can be configured as matching conditions in a Huawei NAT Policy rule?

- A. Source Security Zone
- B. Destination Security Zone
- C. Source IP Address / Subnet / Address Set
- D. Destination IP Address / Subnet / Address Set
- E. Service Object (Protocol and Port)
- F. Hard drive serial number

Correct Answer: A, B, C, D, E

Concept & Rationale: NAT policies match traffic based on: Source/Destination Zones, Source/Destination IPs, and Services (protocols/ports). Hardware serial numbers are not policy matching parameters.

Question 542**Topic:** NAT ALG Protocols**Type:** Multiple Choice

Which of the following application protocols typically require NAT ALG support on firewalls due to embedded IP/port information in payloads?

- A. FTP (File Transfer Protocol in active mode)
- B. SIP (Session Initiation Protocol for VoIP)
- C. RTSP (Real-Time Streaming Protocol)
- D. H.323 (Video conferencing protocol suite)
- E. Standard cleartext HTTP GET requests

Correct Answer: A, B, C, D

Concept & Rationale: Multi-channel protocols embedding IP addresses/ports in payloads require ALG: FTP, SIP, RTSP, H.323, and DNS. Standard HTTP GET requests do not embed Layer 3/4 socket parameters in payloads.

Question 543**Topic:** NAT Server Key Parameters**Type:** Multiple Choice

When configuring a static `nat server` rule on a Huawei firewall, which parameters are typically specified?

- A. Global (Public) IP Address
- B. Global (Public) Port Number
- C. Inside (Private) Server IP Address
- D. Inside (Private) Server Port Number
- E. Protocol (e.g., TCP or UDP)

Correct Answer: A, B, C, D, E

Concept & Rationale: A complete `nat server` definition specifies: Protocol (TCP/UDP), Global (public) IP and port, and Inside (private) IP and port.

Question 544

Topic: NAT Blackhole Route Characteristics

Type: Multiple Choice

Which of the following statements regarding NAT Blackhole Routes on Huawei firewalls are correct?

- A. A blackhole route points traffic destined for the NAT address pool to a NULL0 virtual interface
- B. It prevents routing loops between the firewall and the upstream router for idle/unassigned pool IPs
- C. It is required when the public address pool is on a different subnet than the firewall's egress interface
- D. It permanently disables all Internet access for internal users

Correct Answer: A, B, C

Concept & Rationale: A blackhole route (`ip route-static <pool-ip> 32 NULL0`) drops traffic destined to unused pool IPs, breaking routing loops between the firewall and ISP gateway. It does not disable Internet access.

Question 545

Topic: Server-Map Entry Characteristics

Type: Multiple Choice

Which of the following statements regarding Server-Map entries on Huawei firewalls are true?

- A. Static Server-Map entries are generated by NAT Server and remain active until deleted
- B. Dynamic Server-Map entries are generated by ASPF or NAT No-PAT and have expiration timers
- C. A Server-Map entry acts as an authorized temporary pinhole for subsequent traffic matching
- D. Server-Map entries replace the firewall's OSPF link-state database

Correct Answer: A, B, C

Concept & Rationale: Server-Map entries provide pre-allocated forwarding pinholes. NAT Server generates permanent static entries; ASPF and No-PAT generate temporary dynamic entries with aging timers.

Question 546

Topic: Easy IP Characteristics

Type: Multiple Choice

Which of the following statements accurately describe Easy IP?

- A. It is a specialized implementation of NAPT
- B. It uses the public IP address of the egress interface directly without creating an address group
- C. It is particularly suited for dynamic WAN links using PPPoE or DHCP
- D. It requires an enterprise to purchase a /24 public IPv4 address block

Correct Answer: A, B, C

Concept & Rationale: Easy IP multiplexes traffic over the egress interface's IP address directly, requiring no address pool, making it optimal for dynamic dial-up/DHCP WAN connections.

Question 547

Topic: Bidirectional NAT Scenarios

Type: Multiple Choice

In which of the following scenarios is Bidirectional NAT commonly deployed on enterprise firewalls?

- A. Intranet users accessing intranet servers using the server's public IP address (NAT Hairpinning)
- B. Preventing asymmetric routing when external users access internal servers through complex multi-homed topologies
- C. Allowing internal servers to communicate with isolated legacy subnets requiring overlapping IP translation
- D. Broadcasting high-definition television signals over Wi-Fi

Correct Answer: A, B, C

Concept & Rationale: Bidirectional NAT resolves NAT loopback (hairpinning), prevents asymmetric routing in multi-ISP server hosting, and translates overlapping private subnets.

Question 548

Topic: NAT Address Group Modes

Type: Multiple Choice

When defining an address group (`nat address-group`) in Huawei VRP, which operational modes can be assigned?

- A. PAT mode (default port address translation enabled)
- B. No-PAT mode (port address translation disabled, 1-to-1 IP translation)
- C. Unencrypted mode (disabling all security features)
- D. Transparent mode (operating as a bridge)

Correct Answer: A, B

Concept & Rationale: Address groups operate either in PAT mode (default, port multiplexing enabled) or No-PAT mode (port multiplexing disabled via the `no-pat` keyword).

Question 549

Topic: NAT IPsec Traversal Issues

Type: Multiple Choice

Why does standard NAT cause problems for traditional IPsec VPN tunnels without NAT-T?

- A. AH validates outer IP headers, causing integrity checks to fail when NAT modifies the IP address
- B. ESP packets lack Layer 4 TCP/UDP port headers, preventing standard NAT devices from multiplexing multiple tunnels over a single public IP
- C. IKE Phase 1 Main Mode identity validation can fail if pre-shared keys are bound to private IP identities
- D. IPsec packets are physically blocked by standard copper Ethernet cables

Correct Answer: A, B, C

Concept & Rationale: NAT breaks AH integrity (IP header hash mismatch), prevents NAT port multiplexing for portless ESP, and complicates IKE aggressive/main mode identity matching behind NAT.

Question 550

Topic: NAT-T Operational Mechanisms

Type: Multiple Choice

How does NAT-T (NAT Traversal) resolve IPsec NAT compatibility issues?

- A. It encapsulates IPsec ESP packets inside UDP datagrams using port 4500
- B. It automatically detects the presence of NAT devices during IKE Phase 1 negotiation
- C. It allows NAT devices to translate the outer UDP port 4500 header normally
- D. It disables encryption on the IPsec tunnel to reduce packet size

Correct Answer: A, B, C

Concept & Rationale: NAT-T detects NAT during IKE Phase 1 and encapsulates ESP into UDP port 4500, allowing NAT devices to translate the port header without corrupting the encrypted payload.

Question 551**Topic:** Benefits of Private IP Addressing**Type:** Multiple Choice

What benefits are achieved by using RFC 1918 private IPv4 addressing combined with NAT?

- A. Conservation of scarce, expensive public IPv4 addresses
- B. Internal network topology hiding from external reconnaissance
- C. Flexibility to design internal IP addressing schemas without coordinating with ISPs
- D. Guaranteed 100% immunity from all email phishing attacks

Correct Answer: A, B, C

Concept & Rationale: Private addressing conserves public IPs, obscures internal network topology from external port scanners, and gives administrators complete addressing freedom. It does not stop phishing.

Question 552**Topic:** Smart NAT Architecture**Type:** Multiple Choice

Which of the following components comprise the operational architecture of Smart NAT?

- A. A primary address pool used for 1-to-1 No-PAT translation
- B. A designated reserved public IP address within the pool used for NAPT translation when the primary pool is exhausted
- C. Automatic fallback to NAPT to prevent connection drops for subsequent users
- D. A mandatory requirement to reboot the firewall every hour

Correct Answer: A, B, C

Concept & Rationale: Smart NAT uses a dual-tier approach: No-PAT for initial connections, with automatic fallback to NAPT using a reserved pool IP when pool addresses are exhausted.

Question 553**Topic:** NAT Inbound Policy Order**Type:** Multiple Choice

When an external packet arrives destined to a NAT Server on a Huawei firewall, which sequence of inspection occurs?

- A. The firewall matches the packet against the Server-Map table to determine the internal private destination IP
- B. The firewall matches the Security Policy using the translated private destination IP
- C. If permitted by Security Policy, a session entry is created and the packet is routed to the server
- D. The firewall converts the packet into an ICMP Echo Request

Correct Answer: A, B, C

Concept & Rationale: Inbound NAT Server processing: 1. Server-Map lookup rewrites destination IP/port; 2. Security policy evaluates the translated private IP; 3. If allowed, a session entry is created and the packet is forwarded.

Question 554**Topic:** NAT Session Entry Information**Type:** Multiple Choice

In `display firewall session table verbose`, which fields indicate that NAT was applied to a connection?

- A. The original 5-tuple (Source IP, Destination IP, Protocol, Source Port, Destination Port)
- B. The translated 5-tuple indicated by translation arrows (->)
- C. Zone and interface transition records
- D. The serial number of the client computer monitor

Correct Answer: A, B, C

Concept & Rationale: The verbose session output details the pre-NAT 5-tuple, the post-NAT 5-tuple (indicated by ->), ingress/egress interfaces, zone IDs, and translation flags.

Question 555

Topic: Reasons to Exclude Traffic from NAT (No-NAT)

Type: Multiple Choice

For which of the following traffic types is a 'no-nat' policy rule typically configured?

- A. Site-to-Site IPsec VPN traffic between branch offices
- B. Internal management traffic between the Trust zone and Local zone
- C. Traffic between internal VLANs routed across the firewall
- D. General web browsing to external public Internet search engines

Correct Answer: A, B, C

Concept & Rationale: IPsec VPN traffic, firewall management flows, and inter-VLAN routing require original private IPs to be preserved and are exempted from NAT using 'no-nat' rules. Public Internet traffic requires NAT.

Question 556

Topic: NAT Multipool Deployment Factors

Type: Multiple Choice

Which criteria can be used in Huawei NAT policies to steer traffic to different NAT address groups?

- A. Source IP Subnet (e.g. Sales subnet vs R&D subnet)
- B. Source Security Zone (e.g. Guest Wi-Fi vs Corporate Trust)
- C. Destination IP Subnet or Service Port
- D. User or User Group identity authenticated via AAA
- E. Physical room temperature in the server room

Correct Answer: A, B, C, D

Concept & Rationale: Huawei NAT policies steer traffic to distinct address pools based on source/dest zones, IP subnets, services, and authenticated user/group identities.

Question 557

Topic: NAT Troubleshooting Commands

Type: Multiple Choice

Which of the following CLI commands are useful for troubleshooting NAT operations on Huawei USG firewalls?

- A. `display nat-policy all`
- B. `display nat address-group`
- C. `display firewall server-map`
- D. `display firewall session table verbose`
- E. `reset saved-configuration`

Correct Answer: A, B, C, D

Concept & Rationale: NAT diagnostics utilize `display nat-policy`, `display nat address-group`, `display firewall server-map`, and `display firewall session table verbose`. `reset saved-configuration` erases system configs.

Question 558**Topic:** NAT ALG FTP Commands Modified**Type:** Multiple Choice

In FTP active mode, which application-layer commands are inspected and rewritten by an FTP NAT ALG?

- A. PORT command (specifying client IP and listening data port)
- B. EPRT command (extended port command in IPv6/IPv4)
- C. PASV / EPSV response commands (specifying server data port)
- D. USER and PASS authentication commands

Correct Answer: A, B, C

Concept & Rationale: FTP ALG inspects and translates socket parameters in PORT, EPRT, PASV, and EPSV commands/replies. USER and PASS contain login credentials and are not rewritten by ALG.

Question 559**Topic:** Static 1-to-1 NAT Characteristics**Type:** Multiple Choice

Which of the following are true regarding Static 1-to-1 NAT?

- A. One private IP address is permanently mapped to one public IP address
- B. Port numbers are not translated
- C. Communication can be initiated bidirectionally (both inbound and outbound)
- D. It multiplexes 10,000 internal hosts onto one public IP

Correct Answer: A, B, C

Concept & Rationale: Static 1-to-1 NAT maps a single private IP to a single public IP permanently without port translation, enabling bidirectional session initiation. It does not perform port multiplexing.

Question 560**Topic:** Destination NAT Use Cases**Type:** Multiple Choice

Which of the following represent common use cases for Destination NAT?

- A. Publishing internal enterprise web, mail, and DNS servers to the Internet
- B. Server load balancing (distributing external requests across internal server farms)
- C. Port redirection (e.g., exposing an internal server on external port 8080 while internal port is 80)
- D. Translating client source IP addresses when browsing external websites

Correct Answer: A, B, C

Concept & Rationale: Destination NAT publishes internal servers, redirects ports, and load-balances incoming traffic across server clusters. Translating client source IPs is the role of Source NAT.

Question 561**Topic:** NAT Hairpinning Required Rules**Type:** Multiple Choice

To successfully implement NAT Hairpinning for intranet users accessing an intranet server via public IP, which two policies/rules are needed on the firewall?

- A. A Destination NAT / NAT Server rule mapping the public IP to the server's private IP
- B. A Source NAT rule translating the intranet client's IP to the firewall's interface IP for traffic destined to the server's private IP
- C. A rule that permanently blocks all ICMP echo requests
- D. A rule that converts Ethernet frames into Frame Relay

Correct Answer: A, B

Concept & Rationale: NAT hairpinning requires Destination NAT (translating the public server IP to private server IP) AND Source NAT (translating client private IP to firewall IP) so server replies return through the firewall.

Question 562

Topic: NAT Table Memory Management

Type: Multiple Choice

How does a Huawei firewall prevent NAT table resource exhaustion?

- A. Enforcing aging timers on session and server-map entries
- B. Setting maximum concurrent connection limits per source IP address
- C. Supporting NAPT port reuse algorithms
- D. Disabling all IP routing protocols during peak hours

Correct Answer: A, B, C

Concept & Rationale: Firewalls manage NAT memory through session aging timers, per-IP connection rate/session limits, and efficient port allocation/reuse. Routing protocols are not disabled.

Question 563

Topic: NAT Server Multi-Port Publishing

Type: Multiple Choice

Which configurations allow publishing multiple distinct internal servers using a SINGLE public IPv4 address?

- A. Mapping public port 80 to Web Server A (192.168.1.10:80)
- B. Mapping public port 443 to Secure Web Server B (192.168.1.20:443)
- C. Mapping public port 25 to Mail Server C (192.168.1.30:25)
- D. Mapping public port 80 to all 50 internal servers simultaneously without port distinction

Correct Answer: A, B, C

Concept & Rationale: Using port-based NAT Server (PAT), an administrator maps distinct public port numbers on a single public IP to different internal server private IPs and ports.

Question 564

Topic: Address Translation Security Side-Effects

Type: Multiple Choice

What positive security side-effects are introduced by deploying Source NAT?

- A. Internal private IP addressing structure is completely obscured from external networks
- B. External Internet hosts cannot directly initiate unsolicited connections to internal client PCs
- C. It helps protect internal hosts against direct IP-based vulnerability scanning
- D. It eliminates the need for host-level antivirus software

Correct Answer: A, B, C

Concept & Rationale: Source NAT hides internal IP addressing and prevents direct inbound external connection attempts to client workstations. Endpoint antivirus is still required for defense.

Question 565

Topic: NAT No-PAT Server-Map Type

Type: Multiple Choice

What type of Server-Map entry is generated by NAT No-PAT?

- A. A dynamic Server-Map entry recording the private-to-public IP binding
- B. It has a configurable aging timer that expires after host sessions end
- C. A permanent static routing table entry in the RIB
- D. A physical hardware interrupt on the motherboard

Correct Answer: A, B

Concept & Rationale: NAT No-PAT generates dynamic Server-Map entries linking private host IPs to allocated public IPs. These entries age out once all sessions associated with that host expire.

Question 566

Topic: Easy IP vs NAPT Pool Comparison

Type: Multiple Choice

What are the primary differences between Easy IP and standard NAPT using an address pool?

- A. Easy IP uses the egress interface IP directly; standard NAPT uses an address group pool
- B. Easy IP requires no address pool configuration commands
- C. Easy IP adapts automatically if the egress interface IP changes dynamically via DHCP/PPPoE
- D. Easy IP cannot translate TCP connections

Correct Answer: A, B, C

Concept & Rationale: Easy IP translates to the egress interface IP automatically without an address group, adapting seamlessly to dynamic IP changes. Both Easy IP and standard NAPT translate TCP and UDP flows.

Question 567

Topic: NAT Policy Actions Available

Type: Multiple Choice

Which of the following actions can be configured within a Huawei firewall NAT Policy rule?

- A. Source NAT (using an address group or Easy IP)
- B. No-NAT (exempting matching traffic from translation)
- C. Reboot (restarting the firewall upon match)
- D. Format (erasing system storage)

Correct Answer: A, B

Concept & Rationale: The standard actions in a NAT Policy rule are 'Source NAT' (specifying an address group or Easy IP) and 'No-NAT' (exempting traffic from translation).

Question 568

Topic: NAT Blackhole Route Creation Command

Type: Multiple Choice

Which Huawei VRP command syntax creates a 32-bit blackhole route for a public NAT pool IP?

- A. `ip route-static 203.0.113.5 255.255.255.255 NULL0`
- B. `ip route-static 203.0.113.5 32 NULL0`
- C. `nat blackhole create 203.0.113.5`
- D. `undo ip route-static 203.0.113.5`

Correct Answer: A, B

Concept & Rationale: In Huawei VRP, a blackhole route is created using standard static routing pointing to the NULL0 interface: `ip route-static <ip> 32 NULL0` or with mask `255.255.255.255 NULL0`.

Question 569

Topic: NAT Impact on End-to-End Principle

Type: Multiple Choice

Why is traditional NAT sometimes criticized in fundamental Internet architecture discussions?

- A. It violates the original end-to-end connectivity model of the Internet
- B. It complicates peer-to-peer (P2P) communications and VoIP call establishment
- C. It breaks protocols that carry IP addresses inside their application payloads unless ALGs are deployed
- D. It requires all routers on the Internet to be manufactured by the same vendor

Correct Answer: A, B, C

Concept & Rationale: NAT breaks the pure end-to-end principle where any two Internet nodes can directly address each other, complicating P2P, VoIP (SIP), and protocols with embedded IP addresses without ALGs.

Question 570

Topic: Multi-homed Multi-ISP NAT Design

Type: Multiple Choice

In an enterprise multi-homed to ISP1 and ISP2, how should NAT policies be structured?

- A. Configure separate NAT policies translating traffic egressing towards ISP1 to ISP1's public address pool
- B. Configure separate NAT policies translating traffic egressing towards ISP2 to ISP2's public address pool
- C. Translate all traffic to ISP1's public IP even when forwarding out through ISP2's interface
- D. Disable all routing protocols completely

Correct Answer: A, B

Concept & Rationale: In multi-ISP setups, egress traffic must be translated to the public address pool belonging to that specific ISP; otherwise, the ISP's ingress anti-spoofing filters (uRPF) will drop the packets.

17 Chapter 6: Firewall Hot Standby Technologies

Question 571

Topic: VRRP Core Entities

Type: Multiple Choice

Which of the following are primary operational entities defined in a VRRP deployment?

- A. VRRP Master Router
- B. VRRP Backup Router
- C. Virtual IP Address (VIP)
- D. Virtual MAC Address
- E. Virtual Satellite Receiver

Correct Answer: A, B, C, D

Concept & Rationale: VRRP defines Master and Backup router roles, associated with a shared Virtual IP address and Virtual MAC address. There is no 'Virtual Satellite Receiver'.

Question 572

Topic: Standard VRRP Router States

Type: Multiple Choice

Which of the following represent valid operational states in the standard VRRP finite state machine?

- A. Initialize
- B. Master
- C. Backup
- D. Listening

Correct Answer: A, B, C

Concept & Rationale: The standard VRRP state machine defines three states: Initialize (waiting for interface startup), Master (forwarding traffic), and Backup (monitoring Master).

Question 573**Topic:** Huawei Hot Standby Protocols**Type:** Multiple Choice

Which two proprietary protocols are implemented by Huawei to achieve comprehensive firewall hot standby clustering?

- A. VRRP Group Management Protocol (VGMP)
- B. Huawei Redundancy Protocol (HRP)
- C. Border Gateway Protocol (BGP)
- D. Spanning Tree Protocol (STP)

Correct Answer: A, B

Concept & Rationale: Huawei dual-system hot standby combines VGMP (managing VRRP groups unifiedly) and HRP (synchronizing configuration and state tables across heartbeat links).

Question 574**Topic:** Data Synchronized by HRP**Type:** Multiple Choice

Which of the following data and state tables are synchronized between clustered firewalls by HRP?

- A. Security Policy and NAT configuration commands
- B. Active Session Tables (connection states)
- C. Server-Map tables (dynamic and static pinholes)
- D. IPsec Security Associations (SAs)
- E. Local hardware BIOS firmware binaries

Correct Answer: A, B, C, D

Concept & Rationale: HRP synchronizes configuration rules (security/NAT policies), dynamic session tables, Server-Map entries, and IPsec SA states. BIOS firmware is hardware-specific and not synchronized over HRP.

Question 575**Topic:** VGMP Management Group States**Type:** Multiple Choice

Which of the following are valid operational states for a VGMP management group on a Huawei firewall?

- A. Active
- B. Standby
- C. Initialize
- D. Disabled

Correct Answer: A, B, C

Concept & Rationale: VGMP management groups operate in Active, Standby, or Initialize states.

Question 576**Topic:** Heartbeat Link Connection Methods**Type:** Multiple Choice

Which of the following physical connection methods are recommended for HRP heartbeat links between dual firewalls?

- A. Direct point-to-point connection using a dedicated Ethernet cable
- B. Aggregated link connection using a dedicated Eth-Trunk across multiple physical cables
- C. Connecting through intermediate Layer 2 switches over a dedicated VLAN
- D. Routing heartbeat packets across the public untrusted Internet without encryption

Correct Answer: A, B, C

Concept & Rationale: Heartbeat links can be direct physical cables, aggregated Eth-Trunk links, or dedicated isolated VLANs on intermediate switches. Routing cleartext heartbeats across the public Internet is unsafe and unsupported.

Question 577

Topic: Active/Standby Mode Features

Type: Multiple Choice

Which of the following characteristics describe Active/Standby (1+1 Redundancy) mode on Huawei firewalls?

- A. One firewall actively forwards all user traffic while the peer remains in standby mode
- B. The standby firewall does not forward user traffic under normal conditions
- C. Configuration commands on the active firewall are automatically replicated to the standby firewall
- D. Both firewalls forward 50% of the traffic simultaneously under normal conditions

Correct Answer: A, B, C

Concept & Rationale: In Active/Standby mode, only the active unit forwards user traffic; the standby unit maintains synchronized state tables. Distributing traffic 50/50 is the characteristic of Load Balancing mode.

Question 578

Topic: Load Balancing Mode Features

Type: Multiple Choice

Which of the following statements regarding Load-Balancing (Active/Active) hot standby mode are true?

- A. Both firewalls forward service traffic simultaneously during normal operation
- B. Typically accomplished by configuring two distinct VRRP groups with alternate Master assignments
- C. Requires Quick Session Backup to mitigate asymmetric routing packet drops
- D. If one firewall fails, the surviving firewall takes over 100% of the service traffic

Correct Answer: A, B, C, D

Concept & Rationale: In Active/Active mode, both firewalls actively forward traffic across different VRRP groups, use quick session backup to handle asymmetric paths, and provide mutual failover if one unit fails.

Question 579

Topic: Preemption Parameters

Type: Multiple Choice

Which parameters are associated with preemption configuration in firewall hot standby?

- A. Preemption Mode (Enabled or Disabled)
- B. Preemption Delay Timer (in seconds)
- C. Preemption Cable Thickness
- D. Preemption Fan Speed

Correct Answer: A, B

Concept & Rationale: Preemption settings consist of enabling/disabling preemption mode and configuring the preemption delay timer. Physical cable dimensions and fan speeds are unrelated.

Question 580**Topic:** Heartbeat Link Failure Risks**Type:** Multiple Choice

What severe risks arise if all heartbeat links between two active clustered firewalls are severed simultaneously?

- A. Split-Brain scenario where both firewalls assume the Active role
- B. IP address conflicts on the Virtual IP address
- C. MAC address flapping on connected switches due to dual Virtual MAC announcements
- D. Complete disruption of network traffic and intermittent session disconnection

Correct Answer: A, B, C, D

Concept & Rationale: Severing all heartbeat links causes a split-brain condition: both units become Active, generating duplicate VIPs/VMACs, MAC flapping, ARP conflicts, and session collapse.

Question 581**Topic:** HRP Heartbeat Statuses**Type:** Multiple Choice

When executing `display hrp state`, which of the following are valid heartbeat link interface statuses?

- A. running (heartbeat link is normal and communicating)
- B. ready (interface is up and ready to send heartbeats)
- C. down (physical link is disconnected or failed)
- D. invalid (misconfigured or unrouted interface)

Correct Answer: A, B, C, D

Concept & Rationale: HRP heartbeat interfaces report states: **running** (active communication), **ready** (standby heartbeat link ready), **down** (physical link failure), or **invalid** (configuration error).

Question 582**Topic:** HRP Configuration Synchronization Triggers**Type:** Multiple Choice

Through which mechanisms can HRP configuration synchronization take place?

- A. Real-time automatic synchronization when commands are executed on the active firewall
- B. Manual batch synchronization triggered by the administrator (`hrp sync config`)
- C. Automatic batch synchronization upon initial connection establishment
- D. Weekly scheduled reboot of both firewalls

Correct Answer: A, B, C

Concept & Rationale: HRP synchronizes configuration in real-time as commands are typed, upon initial cluster handshake, or upon manual execution of `hrp sync config`.

Question 583**Topic:** VRRP Priority Values Significance**Type:** Multiple Choice

In standard VRRP, what is the significance of the following priority values?

- A. Priority 255: IP Address Owner (physical IP matches Virtual IP)
- B. Priority 100: Default priority for standard participating routers
- C. Priority 0: Sent by Master router when relinquishing mastership gracefully
- D. Priority 1-254: Configurable range for standard master/backup election

Correct Answer: A, B, C, D

Concept & Rationale: VRRP defines priority 255 for the IP address owner, priority 0 for graceful relinquishment, default 100, and 1-254 for administrative tuning.

Question 584

Topic: VGMP Monitored Object Types

Type: Multiple Choice

Which network components can be tracked and monitored by VGMP on Huawei firewalls?

- A. Physical Ethernet interfaces
- B. Logical VLANIF interfaces
- C. Eth-Trunk aggregated link interfaces
- D. IP-Link connectivity probes checking upstream gateway reachability
- E. BFD (Bidirectional Forwarding Detection) sessions

Correct Answer: A, B, C, D, E

Concept & Rationale: VGMP can track physical interfaces, VLANIFs, Eth-Trunks, IP-Link health probes, and BFD sessions to detect link or upstream router failures.

Question 585

Topic: HRP Packet Contents

Type: Multiple Choice

What types of payload data are encapsulated within HRP UDP 18514 packets?

- A. Heartbeat keepalive hello messages
- B. VGMP group priority negotiation and state notification messages
- C. Configuration command synchronization strings
- D. Session table synchronization records
- E. High-definition video streaming data

Correct Answer: A, B, C, D

Concept & Rationale: HRP packets carry heartbeat hellos, VGMP state negotiations, synchronized CLI commands, session tables, Server-Map entries, and IPsec SA states.

Question 586

Topic: Dual-System Hot Standby Benefits

Type: Multiple Choice

What operational benefits does dual-system hot standby provide to enterprise networks?

- A. High service reliability and uninterrupted business continuity
- B. Seamless failover for ongoing voice and video transactions
- C. Protection against single point of failure (SPOF) on perimeter firewalls
- D. Elimination of the need for data backups on corporate file servers

Correct Answer: A, B, C

Concept & Rationale: Clustering eliminates SPOF, provides transparent failover, and protects business continuity. It is an operational redundancy technology and does not replace data backups.

Question 587

Topic: HRP Command Replication Exclusions

Type: Multiple Choice

Which types of commands are intentionally EXCLUDED from HRP automatic synchronization between firewalls?

- A. Interface IP addresses and physical parameters unique to each firewall
- B. HRP local interface configuration commands (`hrp interface`)
- C. Local device hostnames (`sysname`)
- D. Security policies and NAT policy rules

Correct Answer: A, B, C

Concept & Rationale: Device-unique settings (local interface IPs, sysnames, HRP interface declarations) must remain unique per box and are not synchronized. Security policies and NAT rules are synchronized.

Question 588

Topic: Asymmetric Routing Solutions on Firewalls

Type: Multiple Choice

Which methods allow stateful firewalls to successfully forward traffic in asymmetric routing topologies?

- A. Enabling HRP Quick Session Backup between the dual firewalls
- B. Configuring the firewall to disable stateful inspection for specific asymmetric protocols
- C. Engineering upstream and downstream routing protocols to maintain path symmetry
- D. Disconnecting the standby firewall permanently

Correct Answer: A, B, C

Concept & Rationale: Asymmetric traffic is handled by synchronizing sessions in real-time (quick session backup), tuning routing protocols for path symmetry, or relaxing stateful checks on asymmetric flows.

Question 589

Topic: HRP CLI Verification Commands

Type: Multiple Choice

Which commands are used to inspect and diagnose Huawei firewall hot standby operations?

- A. `display hrp state` (checks HRP state and VGMP priorities)
- B. `display hrp interface` (checks heartbeat link operational status)
- C. `display vrrp brief` (displays summary status of all VRRP groups)
- D. `display firewall session table` (verifies session presence)
- E. `reboot fast` (instantly restarts the firewall)

Correct Answer: A, B, C, D

Concept & Rationale: Hot standby diagnostics utilize `display hrp state`, `display hrp interface`, `display vrrp brief`, and `display firewall session table`. `reboot fast` is a disruptive restart command.

Question 590

Topic: Standby Unit Local Policy Locking

Type: Multiple Choice

What mechanisms ensure policy consistency on the standby firewall during HRP clustering?

- A. Locking direct configuration of security policies and NAT rules on the standby unit
- B. Displaying the HRP_S prompt prefix to alert administrators that the unit is in standby mode
- C. Overwriting standby configuration with active configuration during batch synchronization
- D. Physically disconnecting the standby console cable

Correct Answer: A, B, C

Concept & Rationale: HRP enforces consistency by locking configuration edits on the standby unit, changing the prompt to HRP_S, and propagating changes from the active unit.

Question 591**Topic:** Quick Session Backup Protocols Supported**Type:** Multiple Choice

Which protocols benefit significantly from Quick Session Backup in Active/Active asymmetric routing environments?

- A. TCP connection sessions (SYN/ACK handshakes)
- B. UDP datagram flows (DNS queries and responses)
- C. ICMP Echo query and reply sessions
- D. Analog AM radio broadcasts

Correct Answer: A, B, C

Concept & Rationale: Quick session backup synchronizes TCP, UDP, and ICMP session entries immediately upon creation so return packets arriving on the alternate firewall are forwarded without drops.

Question 592**Topic:** VRRP Virtual MAC Gratuitous ARP**Type:** Multiple Choice

When a VRRP backup firewall transitions to Master, why does it broadcast a Gratuitous ARP packet for the Virtual IP?

- A. To update the MAC address tables of connected Layer 2 switches, redirecting traffic to its own physical port
- B. To update the ARP caches of connected host endpoints with the Virtual MAC
- C. To force all connected PCs to shut down
- D. To test the maximum speed of the Ethernet switch fabric

Correct Answer: A, B

Concept & Rationale: The new Master broadcasts a Gratuitous ARP for the VIP with the VMAC so that intermediate switches immediately update their CAM tables, directing frames to the new Master's switch port.

Question 593**Topic:** VRRP Master Duties**Type:** Multiple Choice

Which of the following responsibilities are executed by the VRRP Master router?

- A. Responding to ARP Requests targeted at the Virtual IP address
- B. Forwarding IP packets destined to the Virtual IP or Virtual MAC address
- C. Periodically transmitting VRRP Advertisement packets to backup routers
- D. Assigning IP addresses to DHCP clients across the entire Internet

Correct Answer: A, B, C

Concept & Rationale: The Master responds to ARP for the VIP, forwards user traffic sent to the VIP/VMAC, and sends periodic heartbeat advertisements to backup routers.

Question 594**Topic:** HRP Network Topologies**Type:** Multiple Choice

In which networking topologies can Huawei firewall hot standby be deployed?

- A. Upstream and downstream connected to Layer 3 routers
- B. Upstream and downstream connected to Layer 2 switches
- C. Upstream connected to Layer 3 routers and downstream connected to Layer 2 switches
- D. Suspended without electrical power in space

Correct Answer: A, B, C

Concept & Rationale: Huawei firewalls support diverse hot standby topologies: L3 routing on both sides, L2 switching on both sides, or hybrid L3-to-L2 gateway deployments.

Question 595

Topic: VGMP Priority Inversion

Type: Multiple Choice

What causes a VGMP priority inversion leading to an automatic cluster switchover?

- A. Monitored interface link failure on the Active firewall reducing its priority below the Standby unit
- B. Monitored IP-Link or BFD session failure on the Active firewall
- C. Administrative manual priority adjustment or failover command
- D. Upgrading the RAM on an unrelated client computer

Correct Answer: A, B, C

Concept & Rationale: Priority inversion occurs when active firewall interface failures, BFD link drops, or administrator manual commands lower active VGMP priority below the standby firewall.

Question 596

Topic: Heartbeat Interface Best Practices

Type: Multiple Choice

Which of the following are recommended best practices for configuring HRP heartbeat interfaces?

- A. Use dedicated physical interfaces reserved exclusively for heartbeat traffic
- B. Bundle multiple physical links into an Eth-Trunk for link redundancy and increased bandwidth
- C. Configure an HRP authentication key (`hrp key`) to secure heartbeat communications
- D. Ensure MTU settings are identical on both ends of the heartbeat link
- E. Use a public Wi-Fi hotspot as the primary heartbeat link

Correct Answer: A, B, C, D

Concept & Rationale: Best practices include dedicated interfaces, Eth-Trunk aggregation, cryptographic authentication, and matching MTUs. Wi-Fi is completely unsuitable for heartbeat links.

Question 597

Topic: IP-Link Monitoring with VGMP

Type: Multiple Choice

What is the primary benefit of associating an IP-Link probe with VGMP on a firewall?

- A. It allows VGMP to monitor reachability to an upstream gateway across intermediate Layer 2 switches
- B. If the upstream gateway stops responding to IP-Link ICMP probes, VGMP priority is decremented to trigger a switchover
- C. It completely replaces the need for firewall security policies
- D. It increases the physical bandwidth of the ISP fiber

Correct Answer: A, B

Concept & Rationale: When firewalls connect to ISPs via intermediate switches, physical interface tracking cannot detect an ISP router failure. IP-Link sends ICMP probes to the ISP gateway; if probes fail, VGMP triggers failover.

Question 598**Topic:** Dual-System Active/Standby Failover Flow**Type:** Multiple Choice

When the active firewall fails in an Active/Standby deployment, what sequence of events occurs?

- A. The standby firewall detects missing advertisements / heartbeat loss
- B. The standby VGMP group transitions to Active, promoting all local VRRP groups to Master
- C. The new active firewall sends Gratuitous ARP packets to update switch MAC tables
- D. The new active firewall begins forwarding traffic using its synchronized session table

Correct Answer: A, B, C, D

Concept & Rationale: Upon failover: 1. Standby detects heartbeat loss; 2. Standby VGMP becomes Active; 3. Local VRRP groups become Master; 4. Gratuitous ARPs update switches; 5. Traffic is forwarded using pre-synchronized sessions.

Question 599**Topic:** HRP Track BFD Feature**Type:** Multiple Choice

Why is integrating BFD (Bidirectional Forwarding Detection) with VGMP beneficial compared to standard link tracking?

- A. BFD provides sub-second (millisecond) fault detection across Layer 2 networks
- B. BFD can detect indirect link failures across multi-hop switch networks
- C. BFD eliminates the need for IP addressing
- D. BFD converts all firewall sessions into UDP

Correct Answer: A, B

Concept & Rationale: BFD provides rapid millisecond-level failure detection and detects indirect link failures across transparent switches where physical carrier loss is not signaled to the firewall interface.

Question 600**Topic:** VRRP Virtual IP Configuration Rules**Type:** Multiple Choice

Which rules must be followed when configuring Virtual IP addresses in VRRP on Huawei firewalls?

- A. The Virtual IP address must belong to the same IP subnet as the interface's physical IP address
- B. All routers participating in the same VRRP group must be configured with the identical Virtual IP address
- C. The Virtual IP address cannot conflict with any existing physical host IP on the subnet
- D. The Virtual IP address must always be 127.0.0.1

Correct Answer: A, B, C

Concept & Rationale: VRRP Virtual IPs must reside on the same subnet as interface physical IPs, must match across all group members, and must not conflict with active host IPs. 127.0.0.1 is local loopback.

18 Chapter 7: Firewall IPS

Question 601**Topic:** IDS vs IPS Comparison**Type:** Multiple Choice

Which of the following statements correctly compare an IDS and an IPS?

- A. An IDS is typically deployed out-of-path via mirror ports, while an IPS is deployed in-line in the traffic path
- B. An IDS passively monitors traffic and generates alerts, while an IPS can actively drop malicious packets in real time
- C. An IDS has zero impact on network forwarding latency, whereas an IPS introduces minimal processing latency
- D. An IDS can actively modify live packet headers before they reach target hosts
- E. An IPS is deployed exclusively on wireless mice and keyboards

Correct Answer: A, B, C

Concept & Rationale: An IDS is passive and out-of-path with zero inline latency impact, generating alerts only. An IPS is inline, actively inspects and drops threats, introducing minor processing latency. An IDS cannot modify live packets.

Question 602**Topic:** IPS Detection Methodologies**Type:** Multiple Choice

Which of the following are primary detection methodologies employed by modern Intrusion Prevention Systems?

- A. Signature-Based Detection
- B. Anomaly-Based / Behavioral Detection
- C. Protocol Anomaly Detection
- D. Acoustic Room Resonance Detection

Correct Answer: A, B, C

Concept & Rationale: IPS engines combine signature detection (known exploits), anomaly detection (baseline deviations), and protocol anomaly detection (RFC non-compliance). Acoustic resonance is not a network detection method.

Question 603**Topic:** Huawei IPS Signature Classifications**Type:** Multiple Choice

On a Huawei USG series firewall, IPS signatures are categorized into which of the following groups?

- A. Predefined Signatures (vendor-supplied and updated via cloud intelligence)
- B. User-Defined Signatures (custom-authored by enterprise administrators)
- C. Hardware Optical Signatures
- D. Mechanical Relaying Signatures

Correct Answer: A, B

Concept & Rationale: Huawei IPS signatures comprise Predefined signatures (supplied and updated by Huawei) and User-Defined signatures (custom crafted for enterprise-specific rules).

Question 604**Topic:** Huawei IPS Actions Available**Type:** Multiple Choice

Which of the following actions can be configured when an IPS signature matches traffic on a Huawei firewall?

- A. Alert (generate a log and allow packet to pass)
- B. Block (drop the malicious packet and optionally reset the connection)
- C. Pass (permit the traffic without logging)
- D. Format (erase all firewall storage)

Correct Answer: A, B, C

Concept & Rationale: The standard IPS response actions on Huawei firewalls are Alert, Block (with optional TCP RST), and Pass.

Question 605**Topic:** Antivirus Scanning Methods**Type:** Multiple Choice

Which two primary scanning architectures are utilized in network antivirus engines?

- A. File-Based Antivirus Scanning (buffers and reassembles entire file in memory)
- B. Flow-Based / Stream-Based Antivirus Scanning (scans packet data streams on the fly)
- C. Manual Microscopic Chip Scanning
- D. Electromagnetic Radiation Scanning

Correct Answer: A, B

Concept & Rationale: The two core network antivirus approaches are File-based (full reassembly, high memory) and Flow-based (real-time stream scanning, low latency, high throughput).

Question 606**Topic:** Antivirus Supported Application Protocols**Type:** Multiple Choice

Huawei NGFW Antivirus engines can inspect which of the following application layer protocols for malware?

- A. HTTP / HTTPS (Web traffic)
- B. FTP (File Transfer Protocol)
- C. SMTP (Simple Mail Transfer Protocol)
- D. POP3 / IMAP (Mail retrieval protocols)
- E. SMB / CIFS (Windows file sharing)

Correct Answer: A, B, C, D, E

Concept & Rationale: Huawei firewall AV inspects HTTP/HTTPS, FTP, SMTP, POP3, IMAP, and SMB/CIFS protocols for viruses, trojans, worms, and ransomware.

Question 607**Topic:** URL Filtering Predefined Categories**Type:** Multiple Choice

Which of the following represent common predefined URL categories in Huawei cloud threat intelligence?

- A. Malicious Websites (Phishing, Malware distribution, C2 domains)
- B. Adult and Pornographic Content
- C. Gambling and Illegal Gaming
- D. Social Networking and Media Streaming
- E. Physical Hardware Circuit Schematics

Correct Answer: A, B, C, D

Concept & Rationale: Predefined categories group URLs into Malicious, Adult, Gambling, Social Media, Gaming, Financial, and Entertainment categories.

Question 608

Topic: URL Filtering Processing Elements

Type: Multiple Choice

When evaluating a user web request, in what order does Huawei URL Filtering evaluate matching elements?

- A. Blacklist (highest blocking priority)
- B. Whitelist (highest permitting priority)
- C. User-defined URL categories
- D. Predefined cloud URL categories

Correct Answer: A, B, C, D

Concept & Rationale: URL filtering precedence evaluates Whitelists and Blacklists first, followed by User-Defined categories, and finally Predefined cloud categories.

Question 609

Topic: File Filtering Control Capabilities

Type: Multiple Choice

Which of the following control capabilities are provided by Huawei NGFW File Filtering?

- A. Filtering files based on true file type (identifying magic bytes, e.g. EXE, PDF, ZIP)
- B. Filtering files based on declared file name and extension
- C. Applying directional control (Upload vs Download)
- D. Taking actions such as Alert or Block on matching file transfers

Correct Answer: A, B, C, D

Concept & Rationale: File filtering accurately identifies true file types via magic bytes, evaluates extensions, applies directional rules (upload/download), and enforces Alert or Block actions.

Question 610

Topic: Content Filtering Applications

Type: Multiple Choice

Content Filtering on Huawei firewalls can perform deep inspection on which of the following traffic types?

- A. Web page text content and user web form submissions (HTTP POST)
- B. Email body text and subject lines (SMTP/POP3/IMAP)
- C. Search engine query parameter text
- D. Physical fiber optic core refractive indexes

Correct Answer: A, B, C

Concept & Rationale: Content filtering scans HTTP web posts, search queries, and email bodies/subjects for confidential keywords or prohibited terms.

Question 611

Topic: Benefits of Flow-Based AV

Type: Multiple Choice

Why is Flow-Based AV inspection particularly suited for enterprise gateway firewalls?

- A. High packet processing throughput with minimal line-rate latency
- B. Low RAM footprint because complete multi-gigabyte files are not cached in memory
- C. Immediate inspection and drop of infected streams before complete file transmission
- D. Complete elimination of the need for an operating system on servers

Correct Answer: A, B, C

Concept & Rationale: Flow-based scanning provides high throughput, low memory usage, and immediate detection without waiting for complete file downloads.

Question 612

Topic: IPS Evasion Techniques

Type: Multiple Choice

Which of the following evasion techniques are historically attempted by attackers to bypass simple IPS inspection?

- A. IP Packet Fragmentation (splitting signatures across small fragments)
- B. TCP Segmentation (splitting exploit strings across multiple TCP segments)
- C. URL Encoding and Unicode Obfuscation (e.g., %20, %2F)
- D. Overwriting physical switch power transformers

Correct Answer: A, B, C

Concept & Rationale: Attackers attempt evasion via IP fragmentation, TCP segmentation, URL hex encoding, and polymorphic payload encryption. Modern NGFWs de-obfuscate and reassemble flows before scanning.

Question 613

Topic: Single-Pass Inspection Advantages

Type: Multiple Choice

What are the core operational benefits of Huawei's Unified Single-Pass Inspection architecture?

- A. Packets are decoded and parsed once, rather than repeated per security engine
- B. Signatures for IPS, Antivirus, and URL Filtering are evaluated in parallel simultaneously
- C. Drastically reduces processing latency and CPU utilization compared to serial multi-engine scanning
- D. Eliminates the requirement for security policies

Correct Answer: A, B, C

Concept & Rationale: Single-pass architecture decodes packets once and scans payloads in parallel across IPS, AV, and URL engines, maximizing throughput and minimizing latency.

Question 614

Topic: IPS Signature Severity Classifications

Type: Multiple Choice

Which of the following are valid severity levels defined for Huawei IPS signatures?

- A. High (critical severity, high risk of remote compromise)
- B. Medium (moderate severity, privilege escalation)
- C. Low (low severity, information gathering)
- D. Informational (benign protocol anomalies, reconnaissance)
- E. Galactic (cosmic solar radiation impact)

Correct Answer: A, B, C, D

Concept & Rationale: Huawei IPS signatures are categorized into High, Medium, Low, and Informational severity ratings.

Question 615**Topic:** Protocol Anomaly Inspection Checks**Type:** Multiple Choice

Which anomalies are detected by Protocol Anomaly Inspection engines?

- A. HTTP requests containing excessively long headers or illegal URI characters violating RFC 2616
- B. DNS query packets with invalid transaction IDs or malformed resource record lengths
- C. FTP commands containing non-ASCII control characters
- D. Unencrypted physical cables installed in office ceilings

Correct Answer: A, B, C

Concept & Rationale: Protocol anomaly engines verify RFC compliance, detecting illegal field lengths, malformed structures, and invalid command sequences in HTTP, DNS, FTP, and SMTP.

Question 616**Topic:** Antivirus Actions Available**Type:** Multiple Choice

Which actions can be configured in a Huawei Antivirus profile for infected traffic?

- A. Block (discard the packet/connection)
- B. Alert (generate a security log and allow the file to pass)
- C. Declare (allow the email message but attach a warning banner)
- D. Overclock (accelerate the client CPU frequency)

Correct Answer: A, B, C

Concept & Rationale: Antivirus response actions include Block, Alert, and Declare (for email protocols). 'Overclock' is hardware tuning.

Question 617**Topic:** URL Filtering Whitelist Benefits**Type:** Multiple Choice

In which situations is adding an internal or partner domain to the URL Whitelist recommended?

- A. To guarantee uninterrupted access to mission-critical business partner portals
- B. To prevent critical corporate web applications from being accidentally blocked by cloud category updates
- C. To accelerate browsing by bypassing deep category lookups for trusted internal portals
- D. To permit employees to download unrestricted torrents

Correct Answer: A, B, C

Concept & Rationale: Whitelisting ensures essential business portals and partner applications remain accessible and bypass categorization delays or accidental blocks.

Question 618**Topic:** Reasons for IPS False Positives**Type:** Multiple Choice

Which factors commonly contribute to false-positive detections in an enterprise IPS deployment?

- A. Poorly written custom enterprise software that violates RFC protocol standards
- B. Overly aggressive anomaly detection thresholds set without adequate baseline training
- C. Vulnerability scanner traffic performing authorized security audits
- D. Physical grounding of server racks

Correct Answer: A, B, C

Concept & Rationale: False positives stem from non-RFC compliant internal applications, uncalibrated anomaly baselines, and authorized penetration test scans.

Question 619**Topic:** Mitigating IPS False Positives**Type:** Multiple Choice

Which actions should an administrator take when a critical business application is blocked by an IPS false positive?

- A. Add an Exception rule in the IPS profile to change the signature action from Block to Alert or Pass
- B. Fine-tune the signature matching criteria if it is a user-defined signature
- C. Temporarily deactivate the specific signature while contacting vendor support for signature refinement
- D. Format all hard drives in the enterprise data center

Correct Answer: A, B, C

Concept & Rationale: False positives are resolved by creating signature Exceptions (changing action to Alert/Pass), tuning custom rules, or reporting false signatures to vendor threat research.

Question 620**Topic:** Mail Filtering Capabilities**Type:** Multiple Choice

Which defensive features are provided by Huawei firewall Mail Filtering?

- A. Spam filtering based on Real-Time Blackhole Lists (RBL)
- B. Sender IP reputation checking and sender address filtering
- C. Mail attachment filtering by file extension and true file type
- D. Mail content keyword scanning and filtering
- E. Automatically generating marketing emails to customers

Correct Answer: A, B, C, D

Concept & Rationale: Mail filtering provides RBL lookup, sender IP reputation, attachment type filtering, and body keyword analysis. It does not generate marketing emails.

Question 621**Topic:** SSL Decryption Necessity for Content Security**Type:** Multiple Choice

Why is SSL Decryption (SSL Proxy) becoming essential for effective IPS, Antivirus, and URL filtering?

- A. Over 80% of modern Internet web traffic is encrypted using HTTPS / TLS
- B. Without decryption, the firewall can only inspect the outer TCP/IP headers and SNI domain, unable to view the encrypted payload for viruses or exploit signatures
- C. Malware authors increasingly use HTTPS for C2 communication and malicious payload delivery
- D. SSL decryption makes fiber optic cables immune to physical bending

Correct Answer: A, B, C

Concept & Rationale: Because TLS encrypts packet payloads, inline security engines cannot inspect data for viruses or exploit signatures without SSL Decryption, leaving encrypted malware invisible.

Question 622**Topic:** True File Type vs Extension Matching**Type:** Multiple Choice

Why does Huawei NGFW File Filtering analyze magic numbers rather than just file extensions?

- A. Users can easily rename file extensions (e.g. `trojan.exe` to `photo.jpg`)
- B. Malware frequently disguises itself as innocuous office documents to bypass basic perimeter checks
- C. Magic numbers provide mathematically verifiable identification of binary file structures
- D. File extensions require 128-bit encryption keys to read

Correct Answer: A, B, C

Concept & Rationale: File extensions are easily forged by users or attackers. Magic numbers (file headers) provide reliable identification of binary file types regardless of file name.

Question 623

Topic: Content Filtering Data Loss Prevention (DLP) Use Cases

Type: Multiple Choice

For which data protection goals is Content Filtering deployed on corporate firewalls?

- A. Preventing the unauthorized leakage of intellectual property (source code, schematics)
- B. Detecting and blocking the transmission of sensitive personal data (credit card numbers, social security IDs)
- C. Enforcing acceptable use policies regarding prohibited or offensive language
- D. Accelerating the download speed of video files

Correct Answer: A, B, C

Concept & Rationale: Content filtering prevents data exfiltration (trade secrets, PII, financial records) and enforces corporate acceptable use standards in web and email transmissions.

Question 624

Topic: IPS Tuning Best Practices

Type: Multiple Choice

Which of the following are recommended best practices when initially rolling out IPS in an enterprise network?

- A. Deploy the IPS profile in 'Alert Only' mode initially for 1-2 weeks to observe baseline traffic and identify potential false positives
- B. Review alert logs daily and configure signature exceptions for legitimate internal business software
- C. Transition critical signatures to 'Block' mode after tuning is verified
- D. Immediately set all 10,000 signatures to Block without testing

Correct Answer: A, B, C

Concept & Rationale: Initial IPS deployments should run in Alert mode to identify false positives on business applications, configure exceptions, and transition signatures to Block mode incrementally.

Question 625

Topic: URL Filtering Deployment Modes

Type: Multiple Choice

Which lookup methods are supported by Huawei firewalls for URL category classification?

- A. Local URL Cache lookup (checking frequently accessed URLs stored in local memory)
- B. Cloud-based URL Category query (querying Huawei Security Intelligence Center for uncached domains)
- C. User-Defined Category matching
- D. Satellite Television Teletext query

Correct Answer: A, B, C

Concept & Rationale: URL classification utilizes local memory caches for speed, user-defined rules, and real-time queries to Huawei Cloud Security Intelligence for uncached sites.

Question 626

Topic: IPS Signature Attributes

Type: Multiple Choice

Which parameters define an individual IPS signature on a Huawei firewall?

- A. Unique Signature Identifier (Signature ID)
- B. Target OS / Application Protocol (e.g. HTTP, SMB, Windows, Linux)
- C. Severity Level (High, Medium, Low, Informational)
- D. Default Action (Block, Alert)
- E. Physical weight of the firewall chassis

Correct Answer: A, B, C, D

Concept & Rationale: Signatures are identified by Signature ID, protocol/OS classification, CVE reference, severity level, and default action.

Question 627

Topic: Antivirus Stream Scanning Protocols

Type: Multiple Choice

Flow-based antivirus scanning can be applied to which protocols on Huawei NGFWs?

- A. HTTP file downloads and web browsing
- B. FTP active and passive file transfers
- C. SMTP outbound email attachments
- D. SMB Windows file sharing transfers
- E. Analog AM radio voice broadcasts

Correct Answer: A, B, C, D

Concept & Rationale: Flow-based AV scans HTTP, FTP, SMTP, POP3, IMAP, and SMB. AM radio is an analog broadcast medium unrelated to digital IP networks.

Question 628

Topic: Network Security Profile Types

Type: Multiple Choice

Which of the following security inspection profiles are supported on Huawei USG series firewalls?

- A. IPS Profile
- B. Antivirus Profile
- C. URL Filtering Profile
- D. File Filtering Profile
- E. Content Filtering Profile
- F. Rocket Propulsion Profile

Correct Answer: A, B, C, D, E

Concept & Rationale: Huawei firewalls support IPS, Antivirus, URL Filtering, File Filtering, Content Filtering, and Mail Filtering profiles. 'Rocket Propulsion' is fictional.

Question 629

Topic: Hardware Fail-Open Bypass Mechanism

Type: Multiple Choice

What are the benefits of deploying an external optical or electrical Bypass Switch with an inline IPS?

- A. If the IPS firewall experiences a complete power failure, the bypass switch automatically connects the physical link directly, preserving network continuity
- B. It allows maintenance and firmware updates on the IPS without causing scheduled network downtime
- C. It permanently blocks all computer viruses automatically
- D. It converts copper cabling into single-mode fiber

Correct Answer: A, B

Concept & Rationale: Bypass switches provide hardware fail-open capability, bridging traffic across links during power failures or maintenance windows, ensuring zero service disruption.

Question 630

Topic: Threat Event Log Information

Type: Multiple Choice

When an IPS signature blocks an attack, which details are recorded in the resulting threat log?

- A. Attacking Source IP Address and Port
- B. Target Destination IP Address and Port
- C. Signature ID, Attack Name, and Severity Level
- D. Action taken (e.g. Block/Dropped)
- E. The color of the attacker's physical keyboard

Correct Answer: A, B, C, D

Concept & Rationale: IPS threat logs record 5-tuple socket details (source/dest IP and port), signature ID, attack name, CVE reference, severity, and action taken.

19 Chapter 8: Firewall User Management Technologies

Question 631

Topic: AAA Core Functions

Type: Multiple Choice

Which of the following functions constitute the AAA security model in network management?

- A. Authentication (verifying user identity)
- B. Authorization (granting resource access permissions)
- C. Accounting (tracking resource usage and session activity)
- D. Auditing (forensic review of system events)
- E. Attenuation (reducing electrical signal strength)

Correct Answer: A, B, C

Concept & Rationale: The AAA model consists of Authentication, Authorization, and Accounting. While auditing is an associated security function, the three defining pillars of AAA are Authentication, Authorization, and Accounting.

Question 632

Topic: User Types on Huawei Firewalls

Type: Multiple Choice

Which of the following are recognized user classifications managed by Huawei USG firewalls?

- A. Local Users (stored in firewall local database)
- B. Server Users (stored on RADIUS, HWTACACS, LDAP, or AD servers)
- C. Third-Party / Guest Users (authenticated via web portals or external tokens)
- D. Virtual Machine Hypervisor Users

Correct Answer: A, B, C

Concept & Rationale: Huawei firewalls classify users into Local Users, Server Users, and Third-Party/Guest Users based on their storage and authentication source.

Question 633**Topic:** RADIUS Operational Features**Type:** Multiple Choice

Which of the following statements accurately characterize the RADIUS protocol?

- A. It operates over UDP transport (ports 1812 and 1813)
- B. It couples Authentication and Authorization together in the **Access-Accept** message
- C. It encrypts only the User-Password attribute; usernames and other attributes are cleartext
- D. It strictly separates Authentication and Authorization into distinct TCP exchanges

Correct Answer: A, B, C

Concept & Rationale: RADIUS uses UDP (1812/1813), combines authentication with authorization, and encrypts only the password attribute using MD5. Separating auth/authz is a characteristic of HWTACACS/TACACS+, not RADIUS.

Question 634**Topic:** HWTACACS Operational Features**Type:** Multiple Choice

Which of the following statements accurately characterize Huawei's HWTACACS protocol?

- A. It operates over reliable TCP transport on port 49
- B. It strictly separates Authentication, Authorization, and Accounting into distinct exchanges
- C. It encrypts the entire packet body following the standard header
- D. It is ideally suited for device administrative management and per-command authorization

Correct Answer: A, B, C, D

Concept & Rationale: HWTACACS runs over TCP port 49, separates all three AAA phases, encrypts the entire packet body, and is optimized for administrative command authorization.

Question 635**Topic:** LDAP Architecture Characteristics**Type:** Multiple Choice

Which of the following statements regarding LDAP directory services are correct?

- A. LDAP organizes directory data in a hierarchical tree structure called a Directory Information Tree (DIT)
- B. Standard cleartext LDAP uses TCP port 389, while encrypted LDAPS uses TCP port 636
- C. Common LDAP naming components include DC (Domain Component), OU (Organizational Unit), and CN (Common Name)
- D. LDAP is used exclusively to translate IP addresses into MAC addresses

Correct Answer: A, B, C

Concept & Rationale: LDAP uses hierarchical DIT structures, communicates over TCP 389 (LDAP) and TCP 636 (LDAPS), and utilizes DC/OU/CN naming attributes. MAC address translation is handled by ARP, not LDAP.

Question 636**Topic:** User Identity Integration Advantages**Type:** Multiple Choice

What advantages are gained by integrating user identities into Next-Generation Firewall security policies?

- A. Security policies remain effective regardless of dynamic IP address changes caused by DHCP
- B. Administrators can assign permissions based on employee roles and organizational departments
- C. User activity auditing and forensic threat logs display actual usernames rather than anonymous IP addresses
- D. It completely eliminates the necessity for border firewalls

Correct Answer: A, B, C

Concept & Rationale: User-aware policies decouple access control from volatile IP addresses, align rules with corporate roles, and provide clear user-attributed audit trails for security operations.

Question 637

Topic: Single Sign-On (SSO) Methods

Type: Multiple Choice

Which SSO methods are supported by Huawei firewalls to automatically learn user-to-IP bindings without prompting users for credentials?

- A. Active Directory SSO (monitoring AD domain controller security event logs)
- B. RADIUS SSO (snooping RADIUS accounting packets from switches or wireless controllers)
- C. Portal SSO via integrated web portal agents
- D. Acoustic Speech Recognition SSO

Correct Answer: A, B, C

Concept & Rationale: Huawei NGFWs support AD SSO (monitoring event logs), RADIUS SSO (snooping accounting packets), and Portal SSO agents. Voice acoustic matching is not a network SSO protocol.

Question 638

Topic: Portal Authentication Components

Type: Multiple Choice

Which entities are typically involved in a complete Portal authentication system architecture?

- A. Client Web Browser (User equipment)
- B. Network Access Server / Gateway (Firewall or Switch)
- C. Portal Web Server (Hosting login pages and authentication interfaces)
- D. Authentication Server (RADIUS or LDAP backend database)

Correct Answer: A, B, C, D

Concept & Rationale: Portal authentication involves four interacting entities: the Client browser, the NAS/Gateway (firewall), the Portal Web Server, and the backend AAA Authentication Server.

Question 639

Topic: Local User Service Types in VRP

Type: Multiple Choice

Which service types can be assigned to a local user account in Huawei VRP AAA view?

- A. `http` (Web GUI management access)
- B. `ssh` (Secure Shell CLI management access)
- C. `telnet` (Telnet terminal access)
- D. `terminal` (Physical console port access)
- E. `ftp` (File transfer access)

Correct Answer: A, B, C, D, E

Concept & Rationale: Huawei VRP supports diverse service types for local users: HTTP/HTTPS, SSH, Telnet, Terminal (console), FTP, and PPP.

Question 640**Topic:** AD Domain Controller Event Logs for SSO**Type:** Multiple Choice

Which security events on a Microsoft Active Directory Domain Controller are typically monitored by AD SSO solutions?

- A. Event ID 4624 (An account was successfully logged on)
- B. Event ID 4634 (An account was logged off)
- C. Event ID 4768 (A Kerberos authentication ticket was requested)
- D. Event ID 1102 (The audit log was cleared)

Correct Answer: A, B, C

Concept & Rationale: AD SSO solutions monitor successful logon events (4624), logoff events (4634), and Kerberos ticket requests (4768) to dynamically maintain active IP-to-username mappings.

Question 641**Topic:** RADIUS Accounting Packet Types**Type:** Multiple Choice

Which message types are exchanged in the RADIUS accounting process?

- A. Accounting-Request (Start)
- B. Accounting-Request (Interim-Update)
- C. Accounting-Request (Stop)
- D. Accounting-Response
- E. Accounting-Denial

Correct Answer: A, B, C, D

Concept & Rationale: RADIUS accounting uses Accounting-Request messages with status types Start, Interim-Update, and Stop, all acknowledged by the server via Accounting-Response. There is no 'Accounting-Denial' packet.

Question 642**Topic:** HWTACACS Packet Types**Type:** Multiple Choice

Which of the following represent core message types defined in HWTACACS communication?

- A. Authentication Start / Continue / Reply
- B. Authorization Request / Response
- C. Accounting Request / Response
- D. Optical Wavelength Modulation Request

Correct Answer: A, B, C

Concept & Rationale: HWTACACS defines separate message structures for Authentication (Start/Continue/Reply), Authorization (Request/Response), and Accounting (Request/Response).

Question 643**Topic:** AAA Authentication Schemes in VRP**Type:** Multiple Choice

Which authentication methods can be specified within an Authentication Scheme on a Huawei firewall?

- A. Local authentication (using the local user database)
- B. RADIUS authentication (querying external RADIUS servers)
- C. HWTACACS authentication (querying external TACACS servers)
- D. LDAP authentication (querying external directory servers)
- E. None (bypassing authentication completely)

Correct Answer: A, B, C, D, E

Concept & Rationale: Huawei VRP authentication schemes support Local, RADIUS, HWTACACS, LDAP, and 'None' (allowing unauthenticated access).

Question 644

Topic: Active Directory Hierarchy Objects

Type: Multiple Choice

In Microsoft Active Directory, which organizational structures are mapped into Huawei firewall user hierarchies?

- A. Organizational Units (OUs)
- B. Security Groups and Distribution Groups
- C. User Accounts
- D. Physical Computer Objects

Correct Answer: A, B, C

Concept & Rationale: Firewalls import OUs, security groups, and individual user accounts from Active Directory to recreate organizational trees in firewall policy configurations.

Question 645

Topic: Guest Authentication Features

Type: Multiple Choice

Which capabilities are provided by modern Guest Management systems on Huawei NGFWs?

- A. Self-service guest portal registration
- B. SMS-based one-time passcode (OTP) verification
- C. Employee sponsor approval workflows for external visitors
- D. Time-limited access accounts that expire automatically after a predefined duration
- E. Unrestricted permanent administrative access to firewall configurations

Correct Answer: A, B, C, D

Concept & Rationale: Guest management supports self-registration, SMS OTPs, employee sponsor approvals, and automated account expiration. Unrestricted administrative access is never granted to guests.

Question 646

Topic: Online User Table Attributes

Type: Multiple Choice

When viewing online users (`display user-manage online-user`), which attributes are displayed for each active user?

- A. Username and User Group membership
- B. Mapped IPv4 or IPv6 address
- C. Authentication Mode (e.g. Local, RADIUS, SSO)
- D. Online duration and idle time elapsed
- E. Client computer physical weight

Correct Answer: A, B, C, D

Concept & Rationale: The online user table displays username, group, IP address, MAC address, authentication mode, connection duration, and idle timers.

Question 647**Topic:** Multi-Factor Authentication (MFA) Factors**Type:** Multiple Choice

Which of the following represent recognized independent authentication factor categories in MFA?

- A. Knowledge Factor: Something you know (e.g., password, PIN)
- B. Possession Factor: Something you have (e.g., hardware token, mobile phone for SMS OTP)
- C. Inherence Factor: Something you are (e.g., fingerprint, facial recognition)
- D. Locational Factor: Somewhere you are (e.g., GPS location, corporate subnet)
- E. Imaginary Factor: Something you dream

Correct Answer: A, B, C, D

Concept & Rationale: MFA leverages three primary factors: Knowledge (passwords), Possession (tokens/devices), and Inherence (biometrics), supplemented by context/location factors.

Question 648**Topic:** RADIUS Attributes in Access-Accept**Type:** Multiple Choice

Which authorization parameters can a RADIUS server return to a firewall NAS inside an **Access-Accept** packet?

- A. Assigned User Group / Role
- B. Authorized VLAN ID
- C. Filter-Id (referencing a local firewall ACL or policy)
- D. Session-Timeout and Idle-Timeout values
- E. Physical motherboard voltage settings

Correct Answer: A, B, C, D

Concept & Rationale: A RADIUS server returns authorization parameters including user group, assigned VLAN, Filter-Id (ACL), and session/idle timeouts.

Question 649**Topic:** HWTACACS Per-Command Authorization Flow**Type:** Multiple Choice

During HWTACACS per-command authorization, what steps take place when an administrator enters a command?

- A. The firewall intercepts the command string entered in the terminal
- B. The firewall transmits an Authorization Request containing the username, privilege level, and command string to the HWTACACS server
- C. The HWTACACS server checks its policy and returns an Authorization Response (PASS or FAIL)
- D. If authorized, the firewall executes the command; if denied, an error message is displayed

Correct Answer: A, B, C, D

Concept & Rationale: Per-command authorization sends each command string to the server; the server evaluates user permissions and returns PASS or FAIL before the command executes.

Question 650**Topic:** Authentication Domain Configuration Parameters**Type:** Multiple Choice

Which schemes and server templates are linked within an Authentication Domain on a Huawei firewall?

- A. Authentication Scheme
- B. Authorization Scheme
- C. Accounting Scheme
- D. RADIUS Server Template or HWTACACS Server Template
- E. Fiber Optic Transceiver Serial Number

Correct Answer: A, B, C, D

Concept & Rationale: An Authentication Domain links an Authentication Scheme, Authorization Scheme, Accounting Scheme, and associated RADIUS/HWTACACS/LDAP server templates.

Question 651**Topic:** Local User Account Security Settings**Type:** Multiple Choice

Which security constraints can be configured on local user accounts in Huawei VRP?

- A. Account expiration date and time
- B. Maximum allowed concurrent online sessions per account
- C. Account lockout threshold after consecutive failed login attempts
- D. Time-range restrictions specifying permitted login hours

Correct Answer: A, B, C, D

Concept & Rationale: Local user accounts support account expiration dates, concurrent session limits, brute-force lockout thresholds, and schedule-based login restrictions.

Question 652**Topic:** Password Complexity Policies in VRP**Type:** Multiple Choice

Which password policy enforcement settings are supported on Huawei firewalls to enforce strong passwords?

- A. Minimum password length requirement
- B. Mandatory inclusion of diverse character types (uppercase, lowercase, digits, special characters)
- C. Preventing password reuse from recent history
- D. Mandatory password expiration and aging intervals

Correct Answer: A, B, C, D

Concept & Rationale: VRP enforces password complexity: minimum length, character diversity requirements, history tracking to prevent reuse, and maximum password validity periods.

Question 653**Topic:** RADIUS vs HWTACACS Differences**Type:** Multiple Choice

Which of the following statements correctly highlight differences between RADIUS and HWTACACS?

- A. RADIUS uses UDP transport, whereas HWTACACS uses TCP transport
- B. RADIUS encrypts only the password, whereas HWTACACS encrypts the entire packet body
- C. RADIUS combines authentication and authorization, whereas HWTACACS separates them
- D. RADIUS is standard IETF RFC, whereas HWTACACS is Huawei's enhancement based on TACACS+

Correct Answer: A, B, C, D

Concept & Rationale: RADIUS uses UDP, encrypts only the password, and bundles auth/authz. HWTACACS uses TCP, encrypts the entire payload, and separates all three AAA phases.

Question 654**Topic:** User-Based Security Policy Elements**Type:** Multiple Choice

When writing a user-aware security policy rule, which user identity entities can be selected as matching sources?

- A. Individual specific user accounts
- B. User Groups (including parent and child groups)
- C. Security Groups imported from Active Directory
- D. Anonymous / Unregistered guest users
- E. Physical copper wiring categories

Correct Answer: A, B, C, D

Concept & Rationale: User-based policies can match specific user accounts, local user groups, imported Active Directory groups, and unregistered guest profiles.

Question 655**Topic:** Reasons for IP-to-User Mapping Expiration**Type:** Multiple Choice

Under which conditions will an active IP-to-user mapping be removed from the firewall's online user table?

- A. The user's idle timeout interval elapses without active network traffic
- B. The user explicitly logs out via the captive portal logout interface
- C. An Active Directory logoff event (Event ID 4634) is detected by AD SSO
- D. An administrator manually forces the user offline using CLI commands

Correct Answer: A, B, C, D

Concept & Rationale: Online user entries expire upon idle timeout, explicit portal logout, AD SSO logoff event detection, or administrative manual termination.

Question 656**Topic:** Portal Web Server Deployment Models**Type:** Multiple Choice

Which deployment architectures are supported for Portal Web Servers in Huawei firewall deployments?

- A. Built-In Portal Server (the firewall itself hosts the web portal login pages)
- B. External Portal Server (a dedicated external web server, e.g. Huawei Agile Controller / iMaster NCE, hosts the login portal)
- C. Satellite Relay Portal Server
- D. Analog Telegraph Portal Server

Correct Answer: A, B

Concept & Rationale: Huawei firewalls support Built-in Portal servers (hosted directly on the firewall for small networks) and External Portal servers (such as iMaster NCE / Agile Controller for large campuses).

Question 657**Topic:** Non-Interactive Device Authentication Methods**Type:** Multiple Choice

Which authentication methods are suitable for IoT endpoints, network printers, and IP security cameras?

- A. MAC Address Authentication (MAB)
- B. Pre-Shared Key (PSK) or Static IP binding with port security
- C. Certificate-Based 802.1X Authentication (using device certificates)
- D. Interactive Web Captive Portal where the camera types its password

Correct Answer: A, B, C

Concept & Rationale: Non-interactive devices use MAC Authentication Bypass (MAB), static IP/MAC bindings, or machine certificate-based 802.1X. They cannot navigate interactive web portals.

Question 658

Topic: Troubleshooting AAA Commands

Type: Multiple Choice

Which CLI commands assist administrators in troubleshooting AAA, RADIUS, and user management issues on Huawei firewalls?

- A. `display user-manage online-user` (view active user mappings)
- B. `display radius-server configuration` (verify RADIUS template settings)
- C. `display local-user` (check local user account status)
- D. `debugging radius packet` (inspect live RADIUS protocol message exchanges)
- E. `format sdcard:` (delete memory storage cards)

Correct Answer: A, B, C, D

Concept & Rationale: AAA diagnostics use `display user-manage online-user`, `display radius-server`, `display local-user`, and `debugging radius packet`. Formatting storage is destructive.

20 Chapter 9: Fundamentals of Encryption and Decryption Technologies

Question 659

Topic: Symmetric Algorithms Identification

Type: Multiple Choice

Which of the following cryptographic algorithms are categorized as Symmetric encryption algorithms?

- A. DES (Data Encryption Standard)
- B. 3DES (Triple DES)
- C. AES (Advanced Encryption Standard)
- D. RC4
- E. RSA (Rivest-Shamir-Adleman)

Correct Answer: A, B, C, D

Concept & Rationale: DES, 3DES, AES, and RC4 are symmetric ciphers (using the same key for encryption and decryption). RSA is an asymmetric public-key cipher.

Question 660

Topic: Asymmetric Algorithms Identification

Type: Multiple Choice

Which of the following algorithms belong to Asymmetric (Public-Key) cryptography?

- A. RSA
- B. ECC (Elliptic Curve Cryptography)
- C. Diffie-Hellman (DH Key Agreement)
- D. AES-256
- E. Blowfish

Correct Answer: A, B, C

Concept & Rationale: RSA, ECC, and Diffie-Hellman utilize asymmetric public/private key mathematics. AES and Blowfish are symmetric block ciphers.

Question 661**Topic:** One-Way Hash Algorithms Identification**Type:** Multiple Choice

Which of the following algorithms are cryptographic One-Way Hash functions?

- A. MD5
- B. SHA-1
- C. SHA-256
- D. SHA-512
- E. AES-128

Correct Answer: A, B, C, D

Concept & Rationale: MD5, SHA-1, SHA-256, and SHA-512 are one-way hash functions producing fixed-length digests. AES-128 is a symmetric block cipher.

Question 662**Topic:** Symmetric Cipher Modes of Operation**Type:** Multiple Choice

Which of the following are recognized modes of operation for symmetric block ciphers like AES?

- A. Electronic Codebook (ECB - insecure, leaks patterns)
- B. Cipher Block Chaining (CBC - uses Initialization Vector)
- C. Counter Mode (CTR - turns block cipher into stream cipher)
- D. Galois/Counter Mode (GCM - provides authenticated encryption with AEAD)
- E. Dynamic Quantum Routing Mode

Correct Answer: A, B, C, D

Concept & Rationale: Standard block cipher modes include ECB, CBC, CFB, OFB, CTR, and GCM (AEAD). 'Dynamic Quantum Routing' is fictional.

Question 663**Topic:** Hash Function Mathematical Properties**Type:** Multiple Choice

Which of the following are essential mathematical properties required of secure cryptographic hash functions?

- A. Pre-image Resistance (One-way property: infeasible to invert hash to find input)
- B. Second Pre-image Resistance (Weak collision resistance: given input, infeasible to find matching second input)
- C. Collision Resistance (Strong collision resistance: infeasible to find any two inputs with identical hash)
- D. Avalanche Effect (Minor input change produces radical digest change)
- E. Reversibility using a private key

Correct Answer: A, B, C, D

Concept & Rationale: Secure hash functions require pre-image resistance, second pre-image resistance, collision resistance, and the avalanche effect. Hash functions are strictly irreversible and cannot be reversed with any key.

Question 664**Topic:** Digital Signature Capabilities**Type:** Multiple Choice

Which security guarantees are mathematically provided by a digital signature?

- A. Data Origin Authentication (verifies the identity of the signer)
- B. Data Integrity (detects any unauthorized modification since signing)
- C. Non-repudiation (prevents the signer from denying the transaction)
- D. Automatic payload encryption ensuring confidentiality from all observers

Correct Answer: A, B, C

Concept & Rationale: Digital signatures provide authentication, integrity, and non-repudiation. They do NOT provide confidentiality unless explicit message encryption is also performed.

Question 665

Topic: Symmetric vs Asymmetric Comparison

Type: Multiple Choice

Which of the following statements correctly compare symmetric and asymmetric encryption?

- A. Symmetric encryption is significantly faster and uses less CPU power than asymmetric encryption
- B. Asymmetric encryption requires only $2N$ keys for N users, whereas symmetric requires $N(N-1)/2$ keys
- C. Asymmetric algorithms are commonly used for key exchange and digital signatures
- D. Symmetric algorithms are used for bulk data encryption in VPNs and TLS sessions
- E. Symmetric encryption can easily provide non-repudiation by itself

Correct Answer: A, B, C, D

Concept & Rationale: Symmetric is fast and used for bulk data ($N(N-1)/2$ keys); asymmetric is slower, scales at $2N$, and handles key exchange and signatures. Symmetric alone cannot provide non-repudiation.

Question 666

Topic: AES Transformation Rounds

Type: Multiple Choice

In the AES cipher algorithm, which operations are performed in standard transformation rounds?

- A. SubBytes (non-linear byte substitution using S-box)
- B. ShiftRows (transposition step shifting rows of the state array)
- C. MixColumns (linear mixing operation combining column bytes)
- D. AddRoundKey (XORing round subkey into the state array)
- E. FormatDrive (erasing physical storage sectors)

Correct Answer: A, B, C, D

Concept & Rationale: A standard AES round consists of SubBytes, ShiftRows, MixColumns, and AddRoundKey transformations. Drive formatting is unrelated.

Question 667

Topic: Diffie-Hellman Key Exchange Steps

Type: Multiple Choice

Which steps occur during a Diffie-Hellman key exchange between Alice and Bob?

- A. Both parties agree on public domain parameters (a large prime p and base generator g)
- B. Alice selects a secret private integer a and sends public value $A = g^a \bmod p$ to Bob
- C. Bob selects a secret private integer b and sends public value $B = g^b \bmod p$ to Alice
- D. Both parties compute the identical shared secret key $K = g^{ab} \bmod p$ independently
- E. Both parties transmit their secret private integers a and b across the network in cleartext

Correct Answer: A, B, C, D

Concept & Rationale: DH allows Alice and Bob to compute $g^{ab} \bmod p$ without transmitting private values a or b across the network. Transmitting private integers would defeat the entire security of the exchange.

Question 668

Topic: HMAC Construction Elements

Type: Multiple Choice

Which elements are required to compute a Hash-Based Message Authentication Code (HMAC)?

- A. A cryptographic hash function (e.g. SHA-256 or SHA-512)
- B. A shared secret cryptographic key
- C. The arbitrary-length message data payload
- D. Inner and outer padding constants (ipad and opad)
- E. A digital certificate signed by a root CA

Correct Answer: A, B, C, D

Concept & Rationale: HMAC requires a hash algorithm, a shared secret key, the message payload, and fixed padding constants (\$ipad=0x36\$, \$opad=0x5c\$). It does not require X.509 digital certificates.

Question 669

Topic: Cryptanalytic Attack Types

Type: Multiple Choice

Which of the following are recognized attack models used in cryptanalysis?

- A. Ciphertext-Only Attack (attacker possesses only intercepted ciphertexts)
- B. Known-Plaintext Attack (attacker possesses ciphertexts and matching plaintexts)
- C. Chosen-Plaintext Attack (attacker can choose plaintexts and obtain resulting ciphertexts)
- D. Brute-Force Attack (trying all possible keys sequentially)
- E. Physical Optical Cable Bending Attack

Correct Answer: A, B, C, D

Concept & Rationale: Standard cryptanalytic attack models include Ciphertext-Only, Known-Plaintext, Chosen-Plaintext, Chosen-Ciphertext, and Brute-Force key exhaustion.

Question 670

Topic: Block Cipher Padding Schemes

Type: Multiple Choice

Why is padding required in block ciphers like AES-CBC, and which padding schemes are standard?

- A. Plaintext messages are rarely an exact multiple of the block size (128 bits / 16 bytes)
- B. Padding appends structured bytes to fill the final block to the required length
- C. PKCS#7 (or PKCS#5) padding is widely used in standard cryptographic libraries
- D. Padding is used to convert binary data into audible sound waves

Correct Answer: A, B, C

Concept & Rationale: Block ciphers operate on fixed block sizes (16 bytes for AES). If plaintext is not an exact multiple, padding (such as PKCS#7) fills the remaining bytes.

Question 671

Topic: Initialization Vector (IV) Purpose

Type: Multiple Choice

What is the function of an Initialization Vector (IV) in block cipher modes like CBC?

- A. It ensures that identical plaintext blocks encrypt to completely different ciphertext blocks
- B. It prevents pattern analysis and dictionary attacks against encrypted communications
- C. It must be random or non-repeating (nonce) for each encryption session
- D. It is kept secret and never transmitted with the ciphertext

Correct Answer: A, B, C

Concept & Rationale: An IV introduces randomness into CBC mode, ensuring identical plaintexts produce distinct ciphertexts. The IV is not a secret; it is transmitted in the clear alongside the ciphertext.

Question 672

Topic: Digital Signature Verification Steps

Type: Multiple Choice

When a client verifies an RSA digital signature on a downloaded file, which operations occur?

- A. The client decrypts the digital signature using the signer's public key to extract the original digest (\$H_1\$)
- B. The client independently calculates the cryptographic hash of the downloaded file (\$H_2\$)
- C. The client compares \$H_1\$ and \$H_2\$; if they match, the signature is mathematically valid
- D. The client formats its operating system if the hashes match

Correct Answer: A, B, C

Concept & Rationale: Verification decrypts the signature with the sender's public key to retrieve \$H_1\$, computes hash \$H_2\$ over the file, and confirms \$H_1 == H_2\$.

Question 673

Topic: Security Weaknesses of Legacy Algorithms

Type: Multiple Choice

Why have algorithms like DES, MD5, and SHA-1 been officially deprecated by security standards?

- A. DES effective key length (56 bits) is vulnerable to complete brute-force exhaustion within hours
- B. MD5 is vulnerable to practical collision generation attacks created in seconds
- C. SHA-1 has demonstrated practical collision attacks (e.g. SHAttered attack)
- D. They cannot run on 64-bit microprocessors

Correct Answer: A, B, C

Concept & Rationale: DES is vulnerable to brute-force due to its short 56-bit key. MD5 and SHA-1 have broken collision resistance, making them unsafe for digital signatures or certificates.

Question 674

Topic: ECC Cryptographic Advantages

Type: Multiple Choice

Which benefits make Elliptic Curve Cryptography (ECC) superior for mobile and IoT devices?

- A. Much smaller key sizes compared to RSA for equivalent security (256-bit ECC vs 3072-bit RSA)
- B. Significantly lower computational power and battery consumption
- C. Reduced network transmission bandwidth for keys and digital certificates
- D. ECC eliminates the need for mathematical calculations entirely

Correct Answer: A, B, C

Concept & Rationale: ECC delivers high security with tiny keys, drastically cutting CPU cycles, battery drain, and certificate sizes on constrained mobile/IoT platforms.

Question 675

Topic: Cryptographic Key Management Lifecycle

Type: Multiple Choice

Which stages are recognized in the comprehensive cryptographic key management lifecycle?

- A. Key Generation (using cryptographically secure pseudo-random number generators)
- B. Key Distribution and Storage (secure transfer and hardware protection via HSMs)
- C. Key Usage and Rotation (periodic key renewal)
- D. Key Revocation and Destruction (secure sanitization of expired keys)

Correct Answer: A, B, C, D

Concept & Rationale: Key management spans generation, distribution, storage, rotation, revocation, and zeroization/destruction.

Question 676

Topic: Symmetric Key Agreement Protocols

Type: Multiple Choice

Which protocols or mechanisms are used to establish shared symmetric keys between communicating parties?

- A. Diffie-Hellman (DH) key exchange
- B. Elliptic Curve Diffie-Hellman (ECDH)
- C. RSA key transport (encrypting symmetric session key with recipient's public key)
- D. Pre-Shared Key (PSK) manual out-of-band configuration

Correct Answer: A, B, C, D

Concept & Rationale: Shared session keys are established via DH/ECDH key agreement, RSA public key encryption/transport, or manual pre-shared key (PSK) provisioning.

Question 677

Topic: Authenticated Encryption (AEAD)

Type: Multiple Choice

What is Authenticated Encryption with Associated Data (AEAD), such as AES-GCM?

- A. A cryptographic mode that provides confidentiality, data integrity, and authenticity simultaneously
- B. It eliminates the need to apply separate HMAC hashing operations over ciphertext
- C. It allows associated unencrypted data (e.g. packet headers) to be authenticated alongside encrypted payloads
- D. It converts all ciphertext into plain ASCII text for easy reading

Correct Answer: A, B, C

Concept & Rationale: AEAD (e.g. AES-GCM) integrates encryption and MAC generation in one pass, protecting confidentiality while authenticating both the ciphertext and unencrypted headers (associated data).

Question 678

Topic: Man-in-the-Middle on Diffie-Hellman

Type: Multiple Choice

In an unauthenticated Diffie-Hellman exchange, how does an attacker execute a Man-in-the-Middle attack?

- A. The attacker intercepts Alice's public value g^a and substitutes their own value g^e
- B. The attacker intercepts Bob's public value g^b and substitutes their own value g^e
- C. The attacker establishes shared secret $K_1 = g^{ae}$ with Alice and shared secret $K_2 = g^{be}$ with Bob
- D. The attacker decrypts, reads, modifies, and re-encrypts messages passing between Alice and Bob transparently

Correct Answer: A, B, C, D

Concept & Rationale: Without authentication, the attacker impersonates Bob to Alice and Alice to Bob, establishing separate keys (K_1 , K_2) with each party to intercept and tamper with all communications.

Question 679

Topic: Collision Resistance Categories

Type: Multiple Choice

In cryptographic literature, how is collision resistance categorized?

- A. Weak Collision Resistance (Second Pre-image Resistance: hard to find $M_2 \neq M_1$ such that $H(M_1) = H(M_2)$ for a given M_1)
- B. Strong Collision Resistance (hard to find ANY two messages M_1 , M_2 such that $H(M_1) = H(M_2)$)
- C. Zero Collision Resistance (collisions occur on every packet)
- D. Physical Collision Resistance (preventing cables from tangling)

Correct Answer: A, B

Concept & Rationale: Collision resistance is bifurcated into Weak (Second Pre-image Resistance for a given input) and Strong (finding any arbitrary collision pair).

Question 680

Topic: Hybrid Cryptography Benefits

Type: Multiple Choice

Why do protocols like SSL/TLS, IPsec, and SSH rely on hybrid cryptography rather than using only asymmetric encryption?

- A. Asymmetric encryption is too computationally slow to encrypt gigabytes of bulk data in real time
- B. Symmetric encryption alone cannot solve the secure key exchange problem across untrusted networks
- C. Combining both yields the speed of symmetric ciphers and the security/key management of asymmetric ciphers
- D. International law strictly forbids using symmetric encryption alone

Correct Answer: A, B, C

Concept & Rationale: Pure asymmetric encryption is too slow for bulk streaming; pure symmetric encryption lacks key exchange. Hybrid cryptography combines the strengths of both paradigms.

Question 681

Topic: Cryptographically Secure PRNG (CSPRNG)

Type: Multiple Choice

Why is a Cryptographically Secure Pseudo-Random Number Generator (CSPRNG) critical in security systems?

- A. Predictable random numbers allow attackers to guess encryption keys and nonces easily
- B. CSPRNGs pass statistical randomness tests and exhibit unpredictability (next-bit test resistance)
- C. They are used to generate high-entropy keys, initialization vectors, and salt values
- D. They accelerate physical network line speeds

Correct Answer: A, B, C

Concept & Rationale: Cryptographic keys, nonces, and IVs depend on true unpredictability. Weak random generators allow attackers to predict keys, breaking systems even when strong ciphers like AES are used.

Question 682**Topic:** Non-Repudiation Practical Applications**Type:** Multiple Choice

In which real-world digital applications is cryptographic Non-Repudiation essential?

- A. Online banking and financial wire transfers (preventing customers from falsely denying authorization)
- B. Legally binding electronic contracts and digital signatures (e.g. DocuSign)
- C. Government tax filing and regulatory compliance submissions
- D. Anonymous web browsing in public Internet cafes

Correct Answer: A, B, C

Concept & Rationale: Non-repudiation is indispensable for commercial contracts, banking transactions, and regulatory filings where parties must not be able to dispute originating transactions.

Question 683**Topic:** AES Key Sizes and Rounds Mapping**Type:** Multiple Choice

Which mappings between AES key lengths and transformation rounds are correct?

- A. AES-128 uses 10 transformation rounds
- B. AES-192 uses 12 transformation rounds
- C. AES-256 uses 14 transformation rounds
- D. AES-512 uses 30 transformation rounds

Correct Answer: A, B, C

Concept & Rationale: AES defines: 128-bit key = 10 rounds; 192-bit key = 12 rounds; 256-bit key = 14 rounds. There is no official AES-512 specification.

Question 684**Topic:** One-Way Hash Practical Uses**Type:** Multiple Choice

Which of the following are standard real-world uses of one-way hash functions in network security?

- A. Verifying file integrity after downloading software ISOs (e.g., comparing SHA-256 checksums)
- B. Storing user passwords securely in operating system databases using salted hashes
- C. Generating message digests for digital signatures
- D. Constructing Hash-Based Message Authentication Codes (HMAC) for packet integrity
- E. Recovering forgotten plaintext passwords by decrypting hash digests

Correct Answer: A, B, C, D

Concept & Rationale: Hashes are used for file integrity checksums, salted password storage, digital signatures, and HMAC. Hashes cannot be decrypted to recover original plaintext.

21 Chapter 10: PKI Certificate System

Question 685**Topic:** PKI Core Entities**Type:** Multiple Choice

Which of the following entities constitute fundamental components of a Public Key Infrastructure (PKI)?

- A. Certificate Authority (CA)
- B. Registration Authority (RA)
- C. Certificate Repository / Directory
- D. Certificate Revocation List (CRL) and OCSP Responder
- E. End Entity (Subscribers and Relying Parties)

Correct Answer: A, B, C, D, E

Concept & Rationale: A complete PKI comprises the CA (issuer), RA (identity verifier), Repository/Directory (storage), Revocation mechanisms (CRL/OCSP), and End Entities (certificate holders and relying parties).

Question 686

Topic: Standard X.509 v3 Header Fields

Type: Multiple Choice

Which of the following fields are defined in the standard X.509 v3 certificate structure?

- A. Version number
- B. Serial Number
- C. Signature Algorithm Identifier
- D. Issuer Distinguished Name
- E. Validity Period (Not Before, Not After)
- F. Subject Distinguished Name
- G. Subject Public Key Info

Correct Answer: A, B, C, D, E, F, G

Concept & Rationale: Standard X.509 fields include Version, Serial Number, Signature Algorithm, Issuer, Validity Period, Subject, Subject Public Key Info, and optional Extensions.

Question 687

Topic: Key X.509 v3 Extensions

Type: Multiple Choice

Which of the following are standardized X.509 v3 extension fields commonly used in modern digital certificates?

- A. Basic Constraints
- B. Key Usage
- C. Extended Key Usage (EKU)
- D. Subject Alternative Name (SAN)
- E. CRL Distribution Points (CDP)
- F. Authority Information Access (AIA)

Correct Answer: A, B, C, D, E, F

Concept & Rationale: Crucial v3 extensions include Basic Constraints (CA flag), Key Usage, EKU, SAN (multi-domain bindings), CDP (CRL URIs), and AIA (OCSP URIs).

Question 688

Topic: Revocation Checking Mechanisms

Type: Multiple Choice

Which two primary mechanisms are utilized in PKI to verify whether a digital certificate has been revoked prior to expiration?

- A. Certificate Revocation Lists (CRLs)
- B. Online Certificate Status Protocol (OCSP)
- C. BGP Route Withdrawals
- D. ARP Cache Flushing

Correct Answer: A, B

Concept & Rationale: PKI relies on two revocation verification systems: periodic, signed CRLs and real-time interactive OCSP query/response transactions.

Question 689

Topic: CRL Drawbacks

Type: Multiple Choice

What are the primary operational challenges and drawbacks associated with traditional CRLs?

- A. Time latency between publication intervals (a revoked certificate remains accepted until the next CRL is fetched)
- B. Increasing file size and bandwidth consumption as the list of revoked certificates expands
- C. High network overhead when millions of clients download large CRLs simultaneously
- D. CRLs cannot be verified mathematically

Correct Answer: A, B, C

Concept & Rationale: CRLs suffer from latency between update windows, scaling bandwidth bottlenecks as revocation lists expand, and high download overhead across client fleets. CRLs are cryptographically signed by the CA.

Question 690

Topic: OCSP Operational Advantages

Type: Multiple Choice

What operational benefits does OCSP provide compared to traditional CRLs?

- A. Real-time status verification at the exact moment of connection establishment
- B. Lightweight query and response packet sizes, conserving bandwidth
- C. Reduced client processing overhead compared to parsing massive CRL files
- D. Eliminating the need for Root CAs

Correct Answer: A, B, C

Concept & Rationale: OCSP provides instantaneous real-time status with tiny request/response packets, eliminating CRL download overhead. Root CAs are still required as trust anchors.

Question 691

Topic: Common Reasons for Certificate Revocation

Type: Multiple Choice

Under which circumstances should an enterprise administrator request certificate revocation?

- A. The private key corresponding to the certificate has been stolen or compromised
- B. An employee possessing an individual client certificate has left the organization
- C. The server's fully qualified domain name (FQDN) or IP has changed
- D. The issuing CA's own private key has been compromised

Correct Answer: A, B, C, D

Concept & Rationale: Revocation is mandatory upon private key loss/compromise, organizational role change, domain reassignment, or CA infrastructure compromise.

Question 692

Topic: Certificate Chain Path Validation Checks

Type: Multiple Choice

When a client verifies a multi-tier certificate chain, which checks must pass successfully for every certificate in the path?

- A. Cryptographic digital signature verification using the parent CA's public key
- B. Current system date falls within the certificate's Not Before and Not After validity window
- C. Revocation status check via CRL or OCSP confirms the certificate is not revoked
- D. Basic Constraints confirms that intermediate certificates are authorized CAs (cA=TRUE)
- E. The terminal Root CA is present in the client's local trusted root store

Correct Answer: A, B, C, D, E

Concept & Rationale: Full path validation verifies digital signatures, valid date ranges, non-revocation status, proper CA constraints, and linkage to a locally trusted root anchor.

Question 693

Topic: Key Usage Extension Attributes

Type: Multiple Choice

Which of the following specific cryptographic purposes can be designated in the Key Usage extension?

- A. Digital Signature (verifying software signatures and identity)
- B. Key Encipherment (encrypting symmetric session keys, e.g. RSA key exchange)
- C. Data Encipherment (direct payload encryption)
- D. Certificate Signing (**keyCertSign** - verifying other certificates)
- E. CRL Signing (**cRLSign** - verifying revocation lists)

Correct Answer: A, B, C, D, E

Concept & Rationale: Standard Key Usage bits include **digitalSignature**, **keyEncipherment**, **dataEncipherment**, **keyCertSign**, and **cRLSign**.

Question 694

Topic: Extended Key Usage (EKU) Standard Purposes

Type: Multiple Choice

Which of the following application purposes are defined in the Extended Key Usage (EKU) extension?

- A. TLS Web Server Authentication (OID 1.3.6.1.5.5.7.3.1)
- B. TLS Web Client Authentication (OID 1.3.6.1.5.5.7.3.2)
- C. Code Signing (OID 1.3.6.1.5.5.7.3.3)
- D. Email Protection / S/MIME (OID 1.3.6.1.5.5.7.3.4)
- E. Automated Teller Machine Currency Dispensing

Correct Answer: A, B, C, D

Concept & Rationale: EKU defines Server Auth, Client Auth, Code Signing, and Email Protection. ATM currency dispensing is an external physical application.

Question 695

Topic: Distinguished Name (DN) Common Attributes

Type: Multiple Choice

Which of the following naming attributes are commonly included in an X.500/X.509 Distinguished Name (DN)?

- A. CN: Common Name (e.g. **www.huawei.com**)
- B. O: Organization Name (e.g. **Huawei Technologies**)
- C. OU: Organizational Unit (e.g. **Security Dept**)
- D. C: Country Code (e.g. **CN**)
- E. L: Locality / City (e.g. **Shenzhen**)

Correct Answer: A, B, C, D, E

Concept & Rationale: Standard X.500 DN components include CN (Common Name), O (Organization), OU (Organizational Unit), C (Country), ST (State/Province), and L (Locality/City).

Question 696

Topic: PKI Hierarchical Architecture Components

Type: Multiple Choice

In a multi-tier hierarchical PKI deployment, which tiers are typically established?

- A. Offline Root CA (serves as the ultimate trust anchor, kept offline for security)
- B. Online Intermediate / Issuing CAs (issued by Root CA, handles daily certificate issuance)
- C. End Entities (web servers, firewalls, VPN gateways, user workstations)
- D. Quantum Key Distribution Satellite Network

Correct Answer: A, B, C

Concept & Rationale: Hierarchical PKIs employ an offline Root CA, online Intermediate/Issuing CAs, and End Entities (servers, gateways, users).

Question 697

Topic: CSR Contents

Type: Multiple Choice

Which items are packaged inside a standard Certificate Signing Request (CSR, PKCS#10)?

- A. The applicant's public key
- B. The applicant's Distinguished Name (DN) and subject attributes
- C. A digital signature generated by the applicant's private key to prove key possession
- D. The applicant's secret private key in cleartext

Correct Answer: A, B, C

Concept & Rationale: A CSR includes the public key, identity attributes, and a proof-of-possession signature. Private keys are NEVER included in a CSR!

Question 698

Topic: Common Certificate File Formats

Type: Multiple Choice

Which file extensions and encoding formats are standard in digital certificate management?

- A. .CRT / .CER (X.509 certificate in PEM or DER format)
- B. .KEY (Private key file)
- C. .CSR (Certificate Signing Request)
- D. .PFX / .P12 (PKCS#12 password-protected container holding certificate and private key)
- E. .EXE (Executable malware installer)

Correct Answer: A, B, C, D

Concept & Rationale: Standard certificate formats: .crt/.cer (certificates), .key (private keys), .csr (signing requests), and .pfx/.p12 (encrypted key+cert archives). .exe is an executable binary.

Question 699

Topic: OCSP Response Statuses

Type: Multiple Choice

When an OCSP Responder replies to a client certificate status query, which three definitive statuses can it return?

- A. Good (the certificate is valid and not revoked)
- B. Revoked (the certificate has been revoked)
- C. Unknown (the responder has no record of the certificate)
- D. Encrypted (the certificate is locked)

Correct Answer: A, B, C

Concept & Rationale: RFC 6960 mandates three status responses: **Good** (valid), **Revoked** (revoked), and **Unknown** (unrecognized serial number).

Question 700

Topic: OCSP Stapling Benefits

Type: Multiple Choice

What are the primary operational benefits of implementing OCSP Stapling on web servers?

- A. Eliminates client-side DNS lookups and latency to external CA OCSP responders
- B. Protects client browsing privacy by preventing the CA from tracking which sites users visit
- C. Reduces the query load on the CA's centralized OCSP infrastructure
- D. Completely removes the need for web servers to use digital certificates

Correct Answer: A, B, C

Concept & Rationale: OCSP stapling eliminates client latency, shields client IP privacy from the CA, and reduces load on CA servers. Digital certificates are still required.

Question 701

Topic: SAN Extension Supported Types

Type: Multiple Choice

Which identity types can be embedded within the Subject Alternative Name (SAN) extension?

- A. DNS Hostnames (e.g. `api.example.com`)
- B. IPv4 and IPv6 Addresses (e.g. `192.168.1.1`, `2001:db8::1`)
- C. Uniform Resource Identifiers (URIs)
- D. Email Addresses (RFC 822 names)
- E. Processor Hardware Clock Frequencies

Correct Answer: A, B, C, D

Concept & Rationale: SAN supports DNS names, IP addresses, URIs, and email addresses. Processor frequencies are hardware metrics.

Question 702

Topic: Hardware Security Module (HSM) Benefits

Type: Multiple Choice

Why do enterprise CAs utilize Hardware Security Modules (HSMs) to protect their private keys?

- A. Physical tamper-responsive hardware that zeroizes keys upon physical attack
- B. Private keys are generated and used inside cryptographic boundary and never leave in plaintext
- C. FIPS 140-2 / 140-3 security certification compliance
- D. HSMs convert copper cables into wireless antennas

Correct Answer: A, B, C

Concept & Rationale: HSMs provide tamper resistance, secure internal key generation/usage, and cryptographic compliance, preventing private key theft.

Question 703**Topic:** Trust Store Locations**Type:** Multiple Choice

Where are Root CA certificates typically stored on client operating systems and software?

- A. Windows Certificate Store (Trusted Root Certification Authorities)
- B. macOS Keychain Access (System Roots)
- C. Mozilla Firefox internal certificate database (NSS store)
- D. Linux `/etc/ssl/certs/` directory
- E. The monitor power cord

Correct Answer: A, B, C, D

Concept & Rationale: Trusted roots reside in OS stores (Windows Certificate Store, macOS Keychain, Linux `/etc/ssl/certs/`) and independent browser stores (Firefox NSS).

Question 704**Topic:** Public vs Private Enterprise PKI**Type:** Multiple Choice

Which statements correctly contrast Public CAs (e.g. DigiCert, Let's Encrypt) and Private Enterprise CAs (e.g. Microsoft AD CS)?

- A. Public CAs have root certificates pre-installed in global browsers and OSs by default
- B. Private Enterprise CAs require manual or GPO distribution of root certificates to internal endpoints
- C. Private CAs are ideal for internal VPN gateways, intranet servers, and employee 802.1X authentication
- D. Public CAs issue certificates free of charge for internal unroutable `.local` domains

Correct Answer: A, B, C

Concept & Rationale: Public CAs are globally trusted out-of-the-box for public websites. Private CAs require internal root distribution (via GPO) and are optimal for internal VPNs, servers, and 802.1X. Public CAs cannot issue certificates for internal `.local` domains.

Question 705**Topic:** Subject Alternative Name (SAN) Multi-Domain**Type:** Multiple Choice

In which scenarios is a SAN certificate preferable to multiple individual single-domain certificates?

- A. Securing multiple subdomains (e.g. `mail.corp.com`, `vpn.corp.com`, `portal.corp.com`) under one certificate
- B. Unified Communications environments (e.g. Microsoft Exchange) requiring diverse service FQDNs
- C. Simplifying certificate management, renewal, and deployment across load-balanced clusters
- D. Decreasing the physical weight of server chassis

Correct Answer: A, B, C

Concept & Rationale: SAN certificates consolidate multiple domains/services onto one certificate, simplifying deployment across Exchange servers, microservices, and multi-domain web clusters.

Question 706**Topic:** Certificate Lifecycle Stages**Type:** Multiple Choice

Which of the following are recognized stages in the end-to-end digital certificate lifecycle?

- A. Key Pair Generation and CSR Submission
- B. Identity Verification and Certificate Issuance
- C. Certificate Installation and Usage Monitoring
- D. Certificate Renewal or Revocation upon Expiration/Compromise

Correct Answer: A, B, C, D

Concept & Rationale: The certificate lifecycle spans generation/CSR, validation/issuance, deployment/monitoring, and renewal/revocation.

Question 707

Topic: Reasons for Self-Signed Certificate Warnings

Type: Multiple Choice

Why should self-signed certificates be avoided on public-facing corporate web servers?

- A. Visitors encounter alarming browser security warnings indicating the site is not trusted
- B. Users cannot verify whether the connection is reaching the genuine server or an MitM attacker
- C. It harms organizational brand reputation and deters customer engagement
- D. Self-signed certificates cannot encrypt data using AES

Correct Answer: A, B, C

Concept & Rationale: Self-signed certificates trigger browser untrusted warnings, leave users vulnerable to MitM attacks, and degrade brand trust. They can still technically perform AES encryption, but lack trust verification.

Question 708

Topic: Authority Information Access (AIA) Pointers

Type: Multiple Choice

Which critical URLs are discovered by client software via the AIA extension?

- A. The URL of the issuing CA certificate (allowing the client to fetch missing intermediate CAs)
- B. The URL of the issuing CA's OCSP responder service
- C. The URL of the client's home social media feed
- D. The URL to download free computer games

Correct Answer: A, B

Concept & Rationale: AIA specifies where to fetch missing intermediate CA certificates (`id-ad-caIssuers`) and the OCSP responder URL (`id-ad-ocsp`).

Question 709

Topic: Cross-Certification Use Cases

Type: Multiple Choice

When is cross-certification implemented between distinct PKI infrastructures?

- A. Corporate mergers and acquisitions between companies with existing internal PKIs
- B. Government inter-agency secure communications across different departmental CAs
- C. B2B secure supply chain electronic data exchange
- D. Connecting a microwave oven to the Internet

Correct Answer: A, B, C

Concept & Rationale: Cross-certification enables mutual trust between merging enterprises, inter-governmental agencies, and B2B federations without replacing existing Root CAs.

Question 710**Topic:** Certificate Renewal vs Re-Keying**Type:** Multiple Choice

How does Certificate Re-Keying differ from standard Certificate Renewal?

- A. Renewal extends the validity period using the existing public/private key pair
- B. Re-Keying generates a brand new cryptographic key pair while issuing an updated certificate
- C. Re-Keying is recommended if an existing key has been in use for an extended duration or if policy mandates key rotation
- D. Renewal permanently erases the server operating system

Correct Answer: A, B, C

Concept & Rationale: Renewal extends dates with the same key. Re-keying generates a fresh key pair, recommended periodically to limit exposure against cryptanalytic attacks.

22 Chapter 11: Encryption Technology Applications (IPsec & SSL VPN)

Question 711**Topic:** VPN Advantages**Type:** Multiple Choice

Compared with traditional leased lines, what are the major operational and technical advantages of deploying VPNs? (Select all that apply)

- A. Significantly lower operational deployment and maintenance costs
- B. High flexibility and scalability for adding new branch sites and mobile users
- C. Robust cryptographic protection including data confidentiality, integrity, and identity authentication
- D. Elimination of the need for all internal IP addresses and subnet masks

Correct Answer: A, B, C

Concept & Rationale: VPNs leverage low-cost public networks, reduce infrastructure expenses, support rapid expansion of branches and remote workers, and utilize robust cryptography (encryption, integrity, authentication). They do not eliminate IP addressing; internal IP subnets remain fundamental.

Question 712**Topic:** VPN Classification Criteria**Type:** Multiple Choice

By which criteria can VPN technologies be classified in enterprise networking? (Select all that apply)

- A. By network layer: Layer 2 VPN (e.g. L2TP, PPTP), Layer 3 VPN (e.g. GRE, IPsec), Application Layer VPN (e.g. SSL VPN)
- B. By business application model: Site-to-Site VPN and Client-to-Site (Remote Access) VPN
- C. By operational model: Customer-provisioned VPN and Provider-provisioned VPN
- D. By color of the firewall front bezel and LED status lights

Correct Answer: A, B, C

Concept & Rationale: VPNs are categorized by protocol layer (L2VPN, L3VPN, Application/L4-7 VPN), business deployment architecture (Site-to-Site, Client-to-Site/Remote Access), and service provisioning ownership (Customer-managed vs Carrier-managed).

Question 713**Topic:** Key VPN Security Technologies**Type:** Multiple Choice

Which core security technologies work together in a secure VPN framework like IPsec? (Select all that apply)

- A. Tunneling encapsulation technology
- B. User identity authentication technology
- C. Cryptographic data encryption technology
- D. Data integrity verification and anti-replay technology

Correct Answer: A, B, C, D

Concept & Rationale: A complete secure VPN architecture integrates tunneling (packet encapsulation), identity authentication (certificates, PSKs), confidentiality (symmetric encryption like AES), and data integrity verification (hash functions and anti-replay windowing).

Question 714**Topic:** IPsec Protocol Suite Architecture**Type:** Multiple Choice

Which protocols and components belong to the standardized IPsec architecture? (Select all that apply)

- A. Authentication Header (AH)
- B. Encapsulating Security Payload (ESP)
- C. Internet Key Exchange (IKE)
- D. Simple Network Management Protocol (SNMP)

Correct Answer: A, B, C

Concept & Rationale: The standardized IPsec framework comprises AH (protocol 51), ESP (protocol 50), and IKE (UDP 500/4500) for key management. SNMP is a network monitoring protocol, not an IPsec security protocol.

Question 715**Topic:** AH Header Fields**Type:** Multiple Choice

Which fields are present in the Authentication Header (AH) format? (Select all that apply)

- A. Next Header
- B. Payload Length
- C. Security Parameter Index (SPI)
- D. Sequence Number
- E. Integrity Check Value (ICV)

Correct Answer: A, B, C, D, E

Concept & Rationale: An AH header contains: Next Header (identifies the following protocol), Payload Length, Reserved, Security Parameter Index (SPI), Sequence Number (for anti-replay protection), and the Integrity Check Value (ICV).

Question 716**Topic:** ESP Packet Structure**Type:** Multiple Choice

Which components are part of an ESP encapsulated packet? (Select all that apply)

- A. ESP Header (containing SPI and Sequence Number)
- B. Encrypted Payload Data (e.g. transport segment or inner IP packet)
- C. ESP Trailer (containing Padding, Pad Length, and Next Header)
- D. ESP Authentication Data (Integrity Check Value - ICV)

Correct Answer: A, B, C, D

Concept & Rationale: An ESP packet consists of the ESP Header (SPI, Sequence Number), the encrypted Payload, the ESP Trailer (Padding, Pad Length, Next Header), and trailing ESP Authentication Data (ICV).

Question 717

Topic: AH vs ESP Comparison

Type: Multiple Choice

In comparing AH and ESP protocols, which statements are TRUE? (Select all that apply)

- A. AH does NOT support payload encryption, whereas ESP supports payload encryption
- B. AH authenticates the outer IP header (excluding mutable fields), while ESP does NOT authenticate the outer IP header
- C. AH is incompatible with NAT traversal, whereas ESP (with NAT-T) can traverse NAT gateways
- D. ESP can provide both confidentiality and integrity authentication simultaneously

Correct Answer: A, B, C, D

Concept & Rationale: All statements accurately compare AH and ESP: AH lacks encryption, protects outer IP headers, and breaks under NAT; ESP provides encryption, leaves outer IP headers unauthenticated, supports NAT-T, and can perform both encryption and integrity checking.

Question 718

Topic: IPsec Operating Modes

Type: Multiple Choice

Which two operating encapsulation modes are supported by IPsec? (Select all that apply)

- A. Transport Mode
- B. Tunnel Mode
- C. Promiscuous Mode
- D. Bridging Mode

Correct Answer: A, B

Concept & Rationale: IPsec operates in two encapsulation modes: Transport Mode (protects payload only, original IP header remains outer header) and Tunnel Mode (encapsulates entire original IP packet into a new outer IP header).

Question 719

Topic: IPsec Tunnel Mode Characteristics

Type: Multiple Choice

Which characteristics apply to IPsec Tunnel Mode? (Select all that apply)

- A. A new outer IP header is generated and added in front of the AH/ESP header
- B. The source and destination IP addresses in the outer header represent the IPsec peer gateway interfaces
- C. The internal private IP addresses of host endpoints are concealed across the public WAN
- D. It is the standard mode for Site-to-Site VPN connections between enterprise firewalls

Correct Answer: A, B, C, D

Concept & Rationale: In Tunnel Mode, gateways add a new outer IP header with their own public IPs as source/destination, encapsulating and encrypting the original private IP packet. This conceals internal topologies and facilitates Site-to-Site connectivity across untrusted networks.

Question 720**Topic:** IPsec Transport Mode Applications**Type:** Multiple Choice

In which scenarios is IPsec Transport Mode typically selected? (Select all that apply)

- A. Host-to-Host secure communication where both end systems terminate IPsec directly
- B. GRE over IPsec, where GRE already encapsulates private packets and IPsec provides encryption without needing another redundant IP header
- C. Site-to-Site VPN between two branch offices where gateways conceal internal private IP schemes
- D. Secure management access (e.g., SNMP or SSH) directly to a specific firewall interface

Correct Answer: A, B, D

Concept & Rationale: Transport Mode is ideal when end systems communicate directly (Host-to-Host), when securing management sessions directly to a gateway, or in GRE over IPsec (since GRE already adds an outer routing header, avoiding double outer headers). Site-to-Site subnet interconnects use Tunnel Mode.

Question 721**Topic:** Security Association (SA) Triplet**Type:** Multiple Choice

An incoming IPsec packet is matched to a specific Security Association (SA) in the SADB using which three parameters? (Select all that apply)

- A. Security Parameter Index (SPI)
- B. Destination IP address
- C. Security Protocol identifier (AH or ESP)
- D. Source MAC address of the switch

Correct Answer: A, B, C

Concept & Rationale: Under RFC standard IPsec, an SA is uniquely indexed in the Security Association Database (SADB) by the triplet: {SPI, Destination IP Address, Security Protocol (AH or ESP)}.

Question 722**Topic:** SA Establishment Methods**Type:** Multiple Choice

Through which methods can IPsec Security Associations be established on Huawei firewalls? (Select all that apply)

- A. Manual configuration (hardcoding keys, SPIs, and algorithms statically on both ends)
- B. IKE dynamic negotiation (using IKEv1 or IKEv2 to automatically negotiate parameters and refresh keys)
- C. Automatic assignment via DHCP Option 43
- D. Physical USB key insertion on boot

Correct Answer: A, B

Concept & Rationale: IPsec SAs can be established manually (manual mode, suitable for simple testing or static point-to-point links with no IKE) or dynamically via IKE (IKEv1/IKEv2, recommended for production networks due to automatic rekeying and scalability).

Question 723**Topic:** IKE Phase 1 Main Mode Steps**Type:** Multiple Choice

In IKEv1 Phase 1 Main Mode, what is accomplished across the 6 message exchanges? (Select all that apply)

- A. Messages 1 and 2 negotiate the IKE security proposal (encryption algorithm, hash algorithm, authentication method, DH group, SA lifetime)
- B. Messages 3 and 4 perform Diffie-Hellman public key exchange and exchange random nonces to generate keying material
- C. Messages 5 and 6 exchange encrypted peer identities and authentication signatures/hashes
- D. Messages 1 through 6 transmit all user data packets across the VPN

Correct Answer: A, B, C

Concept & Rationale: Main Mode executes in 3 distinct 2-message pairs: (1-2) Proposal negotiation; (3-4) DH exchange and nonce distribution; (5-6) Encrypted identity verification. User data is never transmitted in Phase 1; user data is transmitted after Phase 2 establishes IPsec SAs.

Question 724**Topic:** IKEv1 Authentication Methods**Type:** Multiple Choice

Which authentication methods are supported in IKEv1 Phase 1? (Select all that apply)

- A. Pre-Shared Key (PSK) authentication
- B. Digital Signature (RSA / X.509 Certificate) authentication
- C. Kerberos token authentication
- D. Cleartext PAP password over HTTP

Correct Answer: A, B

Concept & Rationale: IKEv1 Phase 1 primarily supports Pre-Shared Key (PSK) authentication and Digital Signature (PKI / X.509 certificates) authentication.

Question 725**Topic:** IKEv1 Main vs Aggressive Mode**Type:** Multiple Choice

Which statements correctly highlight the differences between IKEv1 Main Mode and Aggressive Mode? (Select all that apply)

- A. Main Mode uses 6 messages, whereas Aggressive Mode uses only 3 messages
- B. Main Mode encrypts peer identities (in messages 5 and 6), whereas Aggressive Mode transmits peer identities in cleartext (in messages 1 and 2)
- C. Aggressive Mode negotiates faster than Main Mode
- D. Aggressive Mode can be deployed with PSK when the initiator has a dynamic IP address and uses Name IDs

Correct Answer: A, B, C, D

Concept & Rationale: All four statements are correct. Aggressive Mode completes in 3 messages without identity encryption, trading confidentiality of identities for faster speed and compatibility with dynamic-IP initiators using PSK.

Question 726**Topic:** IKEv1 Phase 2 Quick Mode Functions**Type:** Multiple Choice

Which tasks are carried out during IKEv1 Phase 2 Quick Mode? (Select all that apply)

- A. Negotiating IPsec SA security proposals (encapsulation protocol, encryption, authentication, encapsulation mode)
- B. Exchanging traffic selectors (Proxy IDs / ACLs) defining which traffic is protected
- C. Optionally executing an additional Diffie-Hellman exchange if Perfect Forward Secrecy (PFS) is enabled
- D. Establishing the IKE SA control channel

Correct Answer: A, B, C

Concept & Rationale: Quick Mode negotiates IPsec SAs, exchanges proxy IDs (data flows), and derives fresh session keys (with optional PFS DH exchange). The IKE SA is established earlier during Phase 1, not Phase 2.

Question 727**Topic:** Diffie-Hellman (DH) Groups**Type:** Multiple Choice

Which statements regarding Diffie-Hellman (DH) key exchange in IPsec are TRUE? (Select all that apply)

- A. DH allows two parties to securely establish a shared secret over an insecure channel without transmitting the secret itself
- B. Higher DH group numbers (such as Group 14, 19, 20) provide larger key lengths and stronger security than older Group 1 or Group 2
- C. DH groups directly encrypt the user data packets flowing through the IPsec tunnel
- D. DH calculations rely on mathematically difficult discrete logarithm problems or elliptic curves

Correct Answer: A, B, D

Concept & Rationale: DH is a key agreement algorithm (not a symmetric bulk data encryption algorithm). It allows peers to derive shared secrets over untrusted links based on discrete logarithms or elliptic curves, with higher groups offering stronger resistance against cryptanalysis.

Question 728**Topic:** IKEv2 Improvements over IKEv1**Type:** Multiple Choice

What advantages and architectural improvements does IKEv2 provide over IKEv1? (Select all that apply)

- A. Significantly faster negotiation: initial negotiation completes in 4 messages instead of 9
- B. Native support for NAT Traversal (NAT-T) without requiring proprietary draft extensions
- C. Built-in support for EAP (Extensible Authentication Protocol) allowing diverse user authentication schemes
- D. Elimination of the complex separation into Main Mode, Aggressive Mode, and Quick Mode

Correct Answer: A, B, C, D

Concept & Rationale: IKEv2 consolidates multiple exchange modes into a streamlined 4-message initial exchange (IKE_SA_INIT and IKE_AUTH), natively integrates NAT-T and DPD, and natively supports EAP for enterprise identity integration.

Question 729

Topic: NAT Traversal (NAT-T) Mechanism

Type: Multiple Choice

Which statements regarding NAT Traversal (NAT-T) in IPsec are TRUE? (Select all that apply)

- A. NAT-T detects the presence of NAT devices by comparing hash values of IP addresses and ports in vendor-specific payloads
- B. When NAT is detected, traffic switches to UDP port 4500
- C. ESP packets are encapsulated inside a UDP header to allow port translation by PAT devices
- D. NAT-T allows AH protocol packets to successfully traverse NAT gateways without ICV errors

Correct Answer: A, B, C

Concept & Rationale: NAT-T encapsulates ESP in UDP port 4500 so PAT devices can track translation sessions via UDP ports. AH cannot traverse NAT even with NAT-T because AH protects the outer IP header itself, which NAT inescapably alters.

Question 730

Topic: IPsec Policy Configuration Elements

Type: Multiple Choice

When configuring an IPsec Policy (`ipsec policy`) on a Huawei USG firewall, which parameters must typically be referenced or configured? (Select all that apply)

- A. An ACL (Access Control List) defining the interesting traffic (data flow to protect)
- B. An IPsec Proposal defining security encapsulation, encryption, and authentication algorithms
- C. An IKE Peer specifying remote peer address, pre-shared key, and IKE version (in IKE-negotiated policies)
- D. The color depth of the firewall web interface

Correct Answer: A, B, C

Concept & Rationale: An IPsec policy binds together: (1) ACL identifying interesting traffic; (2) IPsec proposal specifying data plane crypto; and (3) IKE peer specifying control plane negotiation parameters.

Question 731

Topic: L2TP VPN Architecture Features

Type: Multiple Choice

Which statements regarding L2TP VPNs are TRUE? (Select all that apply)

- A. L2TP operates over UDP port 1701
- B. L2TP encapsulates PPP frames to transport Layer 2 protocols across IP networks
- C. L2TP provides strong built-in encryption and hashing by default without requiring any other protocol
- D. L2TP is commonly combined with IPsec (L2TP over IPsec) to provide robust data confidentiality and integrity

Correct Answer: A, B, D

Concept & Rationale: L2TP uses UDP 1701 and encapsulates PPP frames, but it lacks native data encryption. Therefore, it is paired with IPsec (L2TP over IPsec) to secure remote access dial-up connections.

Question 732

Topic: SSL VPN Service Types

Type: Multiple Choice

Which four major service modules are provided by the SSL VPN solution on Huawei USG firewalls? (Select all that apply)

- A. Web Proxy (Web Browsing)
- B. File Sharing
- C. Port Forwarding
- D. Network Extension

Correct Answer: A, B, C, D

Concept & Rationale: Huawei USG firewalls provide four core SSL VPN service categories: Web Proxy, File Sharing (SMB/NFS), Port Forwarding (TCP applications), and Network Extension (Layer 3 virtual adapter IP access).

Question 733

Topic: SSL VPN Web Proxy Characteristics

Type: Multiple Choice

Which characteristics describe the SSL VPN Web Proxy service? (Select all that apply)

- A. Requires no client software or browser plug-in installation
- B. Allows remote users to access internal HTTP and HTTPS web resources
- C. The virtual gateway rewrites internal links and handles proxy requests securely
- D. Allows raw UDP audio broadcasts to stream directly without proxying

Correct Answer: A, B, C

Concept & Rationale: Web Proxy is entirely clientless, running natively inside any standard browser to provide access to internal HTTP/HTTPS web applications. The gateway acts as a reverse proxy, rewriting URLs to keep internal servers hidden.

Question 734

Topic: SSL VPN Port Forwarding Characteristics

Type: Multiple Choice

Which statements describe the SSL VPN Port Forwarding service? (Select all that apply)

- A. It is designed for non-web, TCP-based client-server applications like Telnet, SSH, Remote Desktop (RDP), and VNC
- B. A lightweight local agent (ActiveX, Java, or standalone control) intercepts traffic destined for a local loopback port
- C. It natively supports dynamic multi-channel UDP streaming media protocols without special agents
- D. Traffic is multiplexed and encrypted over the existing SSL tunnel to the virtual gateway

Correct Answer: A, B, D

Concept & Rationale: Port Forwarding forwards static TCP client-server connections via local port listening over the SSL tunnel. It does not natively support dynamic UDP or raw IP protocols.

Question 735

Topic: SSL VPN Network Extension Features

Type: Multiple Choice

Which features characterize the SSL VPN Network Extension service? (Select all that apply)

- A. It installs a virtual network interface card (virtual NIC) on the client operating system
- B. The client PC is assigned an internal IP address from an IP address pool configured on the virtual gateway
- C. It provides full Layer 3 IP connectivity, enabling support for both TCP and UDP protocols
- D. It requires the client to replace its physical router with a Huawei hardware firewall

Correct Answer: A, B, C

Concept & Rationale: Network Extension delivers complete Layer 3 IP networking via a virtual NIC and private IP pool, supporting TCP, UDP, ICMP, and complex enterprise software. It runs entirely in software on the user's existing PC/laptop.

Question 736**Topic:** SSL VPN Network Extension Routing Modes**Type:** Multiple Choice

Which routing/tunneling modes can be configured for SSL VPN Network Extension on Huawei firewalls? (Select all that apply)

- A. Manual Mode (routes are manually defined by the administrator)
- B. Split Tunnel Mode (only traffic destined for enterprise intranet subnets passes through the SSL tunnel, while general Internet traffic routes directly via the local gateway)
- C. Full Tunnel Mode (all client traffic, including public Internet browsing, is forced through the SSL VPN tunnel to the enterprise gateway)
- D. Infinite Broadcast Mode

Correct Answer: A, B, C

Concept & Rationale: Network Extension supports Manual, Split Tunnel (efficient bandwidth usage: only enterprise traffic uses the tunnel), and Full Tunnel (strict security: all traffic routes through the enterprise firewall for inspection and logging).

Question 737**Topic:** SSL VPN User Authentication Methods**Type:** Multiple Choice

Which authentication methods can be used to verify remote users logging into an SSL VPN virtual gateway? (Select all that apply)

- A. Local authentication on the USG firewall
- B. RADIUS server authentication
- C. LDAP / Active Directory (AD) authentication
- D. Digital certificate (PKI / USB token) authentication

Correct Answer: A, B, C, D

Concept & Rationale: Huawei SSL VPN virtual gateways support flexible authentication mechanisms: local database, external AAA/RADIUS, enterprise LDAP/AD directories, and PKI digital certificates (including dual-factor certificate + password authentication).

Question 738**Topic:** GRE over IPsec Value**Type:** Multiple Choice

Why is GRE over IPsec frequently implemented in enterprise wide-area networks? (Select all that apply)

- A. GRE can encapsulate multicast packets and dynamic routing protocol hello/update packets (such as OSPF)
- B. Standard IPsec unicast tunnels cannot directly transport multicast or dynamic routing protocol traffic
- C. IPsec provides strong encryption and integrity protection for the GRE encapsulated packets
- D. GRE eliminates the need for any IPsec Security Associations

Correct Answer: A, B, C

Concept & Rationale: IPsec does not natively encrypt broadcast or multicast packets (used by dynamic routing protocols like OSPF). By encapsulating multicast in GRE first, and then encapsulating GRE inside an IPsec tunnel (GRE over IPsec), the network achieves secure dynamic routing across the WAN.

Question 739**Topic:** IPsec Anti-Replay Mechanism**Type:** Multiple Choice

How does the IPsec anti-replay mechanism protect against replay attacks? (Select all that apply)

- A. The sender assigns a monotonically increasing 32-bit or 64-bit Sequence Number to each AH/ESP packet
- B. The receiver maintains a sliding anti-replay window to track received sequence numbers
- C. Packets with duplicate sequence numbers or sequence numbers falling behind the left edge of the window are discarded
- D. Sequence numbers are reset to 0 every 10 seconds automatically

Correct Answer: A, B, C

Concept & Rationale: Anti-replay uses strictly increasing sequence numbers and a receiver sliding window. Replayed (duplicate) packets or expired packets falling outside the window are immediately dropped. Sequence numbers do not cycle or reset automatically without a complete SA rekey.

Question 740**Topic:** SSL VPN vs IPsec VPN Comparison**Type:** Multiple Choice

Which operational comparisons between SSL VPN and IPsec VPN are ACCURATE? (Select all that apply)

- A. SSL VPN is typically preferred for mobile remote access users due to ease of clientless/browser deployment
- B. IPsec VPN is typically preferred for Site-to-Site LAN interconnects between corporate offices due to high throughput and transparency to endpoints
- C. SSL VPN operates primarily across TCP port 443, easily traversing firewalls and NAT without special port forwarding
- D. IPsec VPN requires lower CPU utilization than cleartext HTTP

Correct Answer: A, B, C

Concept & Rationale: SSL VPN excels at remote worker access over standard HTTPS (port 443), effortlessly traversing NAT and guest firewalls. IPsec VPN excels at high-speed, transparent Site-to-Site LAN interconnection between branch routers/firewalls.

PART III

True / False Questions (Q741 – Q1050)

23 Chapter 1: Network Security Concepts and Specifications

Question 741

Topic: ISO 27002 Certification

Type: True/False

ISO/IEC 27002 can be used directly to certify an enterprise's information security management system (ISMS).

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. ISO/IEC 27001 is the normative specification used for ISMS certification. ISO/IEC 27002 is an advisory code of practice providing guidance on implementing security controls and cannot be certified against directly.

Question 742

Topic: Confidentiality and Plaintext

Type: True/False

If an attacker intercepts an encrypted ciphertext message across the Internet but cannot decrypt it, confidentiality has been successfully preserved.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Confidentiality ensures that unauthorized entities cannot access the plaintext meaning of the information. Intercepting encrypted ciphertext without the key preserves confidentiality.

Question 743

Topic: Availability and Hardware Redundancy

Type: True/False

Deploying redundant power supplies and clustered firewalls helps safeguard the Availability attribute of the CIA triad.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Hardware redundancy, uninterruptible power supplies (UPS), and dual-system firewall clustering ensure that services continue running reliably without disruption, directly protecting Availability.

Question 744**Topic:** Communication Security Era Focus**Type:** True/False

In the 1940s Communication Security era, information security primarily focused on software-defined wide area network (SD-WAN) encryption.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. In the 1940s, modern computer networks did not exist. Information security was restricted to physical security and basic cipher communications (such as manual stream ciphers for telegraph and radio).

Question 745**Topic:** Non-repudiation with Symmetric Keys**Type:** True/False

Symmetric key encryption alone provides non-repudiation because both communication parties share the exact same key.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Because both sender and receiver share the identical secret symmetric key, either party could have generated the message. Therefore, symmetric encryption cannot mathematically prove which party originated the data, failing to provide non-repudiation.

Question 746**Topic:** Classified Protection 2.0 Scope**Type:** True/False

Cybersecurity Classified Protection 2.0 applies only to traditional isolated PC workstations and excludes cloud computing, IoT, and industrial control systems.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Classified Protection 2.0 (MLPS 2.0) significantly expanded its scope beyond traditional networks to explicitly cover Cloud Computing, Mobile Internet, Internet of Things (IoT), Industrial Control Systems (ICS), and Big Data.

Question 747**Topic:** TCSEC Division D**Type:** True/False

In TCSEC (Orange Book), Division D represents systems that have been evaluated and verified to provide the highest cryptographic security.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. In TCSEC, Division D is labeled 'Minimal Protection' and represents systems that have failed security evaluation or provide no effective security controls. Division A is the highest verified tier.

Question 748**Topic:** Zero Trust Perimeter Assumption**Type:** True/False

The Zero Trust model assumes that internal corporate networks are inherently safe and free from threat actors.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. The core assumption of Zero Trust is 'Assume Breach'. It posits that threats already exist inside the perimeter and that no user, device, or packet should be trusted by default.

Question 749**Topic:** SDP Architecture Model**Type:** True/False

A Software-Defined Perimeter (SDP) makes server infrastructure completely invisible to unauthorized users until mutual identity authentication is completed.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. SDP enforces a 'Black Cloud' / invisible infrastructure model where gateway ports remain closed to the public Internet and open only after the centralized controller authenticates the connecting user and device.

Question 750**Topic:** Classified Protection Level 5**Type:** True/False

Level 5 in Classified Protection 2.0 is termed 'Special Control Protection' and is applied to systems critical to national security with the highest protection requirements.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Level 5 is the maximum classification under MLPS 2.0, reserved for systems vital to state sovereignty, national defense, and critical national security infrastructure.

Question 751**Topic:** Integrity and Hashing**Type:** True/False

A cryptographic hash function can guarantee confidentiality because the hash value cannot be reversed to derive the original plaintext.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. A cryptographic hash function guarantees Integrity (tamper detection), not confidentiality. While hashes are irreversible one-way functions, hashing is not an encryption mechanism because the original plaintext cannot be recovered from the digest.

Question 752**Topic:** APT Attack Stealth**Type:** True/False

APT attacks frequently utilize zero-day vulnerabilities and customized malware to remain undetected inside enterprise networks for months or years.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. A hallmark of Advanced Persistent Threats is stealthy persistence, leveraging zero-day exploits, living-off-the-land techniques, and custom backdoors to evade signature-based detection.

Question 753**Topic:** Cybersecurity Sovereignty Principle**Type:** True/False

Under the principle of cyberspace sovereignty, an enterprise operates completely outside the jurisdiction of domestic laws when handling digital data.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Cyberspace sovereignty establishes that state laws and regulatory authority extend directly over all cyber infrastructure, data processing, and digital operations conducted within national boundaries.

Question 754**Topic:** Risk Avoidance Definition**Type:** True/False

Disconnecting a vulnerable legacy server from the corporate network and decommissioning its service is an example of Risk Avoidance.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Risk Avoidance involves eliminating the risk by completely terminating or avoiding the activity, system, or process that gives rise to the risk.

Question 755**Topic:** Risk Transfer via Insurance**Type:** True/False

Purchasing cyber insurance completely eliminates all technical vulnerabilities from an organization's network infrastructure.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Cyber insurance is a financial Risk Transfer mechanism that offsets monetary liabilities and recovery costs; it does not repair technical vulnerabilities or prevent network attacks.

Question 756**Topic:** Security Awareness and Humans**Type:** True/False

Human error and credential phishing remain among the most frequent initial entry vectors for corporate cyber breaches.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Industry statistics consistently confirm that social engineering, phishing, and human errors account for the majority of initial security compromises, making ongoing security training essential.

Question 757**Topic:** ISO 27001 PDCA Applicability**Type:** True/False

The Plan-Do-Check-Act (PDCA) model in ISO 27001 means security policies are written once and never require subsequent audit or revision.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. The PDCA model requires continuous, iterative improvement: Plan (design ISMS), Do (implement controls), Check (monitor and review effectiveness), and Act (maintain and optimize continuously).

Question 758**Topic:** Physical Access Danger**Type:** True/False

An attacker who obtains direct physical access to an enterprise server chassis can easily bypass operating system authentication by booting from external media.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Physical possession allows attackers to boot alternative operating systems, extract unencrypted hard drives, clear firmware passwords, or attach hardware sniffers, completely bypassing OS-level logical controls.

Question 759**Topic:** Classified Protection Level 1 Certification**Type:** True/False

Information systems classified at Level 1 under Classified Protection 2.0 require mandatory annual third-party audits and supervision by national regulatory bodies.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Level 1 is 'User Autonomy Protection'. Organizations can autonomously design and maintain their systems without mandatory periodic government audits. Regulatory supervision begins at Level 3.

Question 760**Topic:** Social Engineering Defense**Type:** True/False

Technical firewalls and antivirus software alone are sufficient to protect an enterprise against all social engineering attacks.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Social engineering targets human psychology (authority, fear, curiosity). While technical filters block some phishing links, educating employees is critical to thwarting social manipulation.

Question 761**Topic:** Controllability and Auditing**Type:** True/False

A system where administrators have no ability to view user activity logs or enforce access policies complies fully with the Controllability principle.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Controllability requires the capability to supervise, monitor, and regulate information flows and user actions. Without logging or access enforcement, Controllability is entirely lost.

Question 762**Topic:** Residual Risk Tolerance**Type:** True/False

An organization can achieve zero residual risk across all business systems if sufficient security budget is allocated.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Zero risk is practically impossible in complex connected environments. Residual risk always remains due to unknown vulnerabilities, emerging threat vectors, and human factors; organizations must manage risk within acceptable thresholds.

Question 763**Topic:** TCSEC Class C1 DAC**Type:** True/False

In TCSEC Class C1, Discretionary Access Control allows object owners to determine which users can read or modify their files.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Discretionary Access Control (DAC) permits the owner or creator of a file/object to grant or restrict access permissions to other users at their own discretion.

Question 764**Topic:** Cyberspace Engineered Domain**Type:** True/False

Unlike land, sea, and air, cyberspace was entirely designed and constructed by human beings.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Cyberspace is the only operational domain created artificially through computer engineering, telecommunications, microprocessors, and software protocols.

Question 765**Topic:** Threat Intelligence Value**Type:** True/False

Subscribing to real-time threat intelligence feeds allows border firewalls to automatically block known command-and-control (C2) IP addresses and malicious domains.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Modern firewalls dynamically consume threat intelligence feeds to block traffic associated with known botnet controllers, phishing domains, and malicious IP addresses before attacks succeed.

Question 766**Topic:** Narrow vs Broad Network Security**Type:** True/False

In a narrow sense, network security focuses on network security devices and architectures (such as firewalls and VPNs) protecting enterprise networks.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. In a narrow sense, network security encompasses technical products and defensive solutions (firewalls, IDS/IPS, VPNs) ensuring the secure operation of enterprise data networks, as taught in HCIA-Security.

24 Chapter 2: Network Basics

Question 767**Topic:** Layer 2 Frame PDU**Type:** True/False

The Protocol Data Unit (PDU) at the Data Link layer of the OSI model is called a packet.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. The PDU at the Data Link layer is called a Frame. A Packet is the PDU at Layer 3 (Network layer).

Question 768**Topic:** Ethernet MAC Length**Type:** True/False

An Ethernet MAC address consists of 48 bits, typically displayed as 12 hexadecimal characters.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Ethernet MAC addresses are 48-bit (6-byte) physical hardware identifiers, typically written as six pairs of hexadecimal digits (e.g., 00:e0:fc:12:34:56).

Question 769**Topic:** IPv4 Header Options**Type:** True/False

The minimum length of an IPv4 header is 20 bytes, but it can expand up to 60 bytes if optional fields are included.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. With no options, IHL=5 (20 bytes). The 4-bit IHL field maximum value is 15 ($15 * 4 = 60$ bytes), allowing up to 40 bytes of optional parameters.

Question 770**Topic:** IPv4 Protocol Number 6**Type:** True/False

In the IPv4 header, a Protocol field value of 6 specifies that the encapsulated payload is UDP.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Protocol number 6 designates TCP. UDP is designated by Protocol number 17.

Question 771**Topic:** Loopback IP Routing**Type:** True/False

Packets addressed to 127.0.0.1 are transmitted out onto the physical local area network media before returning.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Loopback packets are handled entirely within the host's internal software networking stack and are never transmitted out of physical network interfaces.

Question 772**Topic:** Usable Hosts /24 Subnet**Type:** True/False

A standard Class C /24 subnet provides 256 usable IP addresses for assigning to host network interfaces.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. A /24 subnet contains 256 total addresses (2^8), but 2 addresses are reserved: the network address (.0) and directed broadcast address (.255). This leaves 254 usable host IP addresses.

Question 773

Topic: ARP Request Broadcast

Type: True/False

An initial ARP Request packet is sent as a Layer 2 unicast frame directed exclusively to the destination host's MAC address.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Because the sender does not yet know the destination MAC address, the ARP Request is broadcast to MAC FF:FF:FF:FF:FF:FF so all hosts on the segment receive and process it.

Question 774

Topic: Gratuitous ARP Conflict Check

Type: True/False

Gratuitous ARP is used by a device to verify that its newly configured IP address does not conflict with another device on the network.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. By broadcasting an ARP Request for its own IP address, a host detects IP address conflicts if another device replies, preventing duplicate IP assignments.

Question 775

Topic: ICMP Protocol Number

Type: True/False

ICMP messages are encapsulated directly inside IPv4 datagrams using Protocol number 1.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. ICMP is encapsulated directly within IP packets with the Protocol field set to 1.

Question 776

Topic: Ping Echo Reply Type

Type: True/False

An ICMP Echo Reply packet uses Type 8 and Code 0.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. An ICMP Echo Request uses Type 8, Code 0. An ICMP Echo Reply uses Type 0, Code 0.

Question 777**Topic:** Traceroute TTL Mechanism**Type:** True/False

Traceroute relies on intermediate routers decrementing the IP TTL to zero and returning ICMP Type 11 Time Exceeded messages.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Traceroute sends packets with incrementing TTL values. Each router that decrements TTL to 0 drops the packet and responds with an ICMP Type 11 message, identifying the hop.

Question 778**Topic:** TCP Reliable Delivery**Type:** True/False

TCP guarantees reliable, ordered, and error-checked delivery of a stream of octets between applications.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. TCP employs sequence numbers, acknowledgments, checksums, and retransmission mechanisms to provide reliable, ordered stream delivery.

Question 779**Topic:** TCP 3-Way Handshake First Step**Type:** True/False

The first segment sent during a TCP 3-way handshake is an ACK segment sent from server to client.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. The client initiates the 3-way handshake by transmitting a SYN segment (with its initial sequence number) to the server.

Question 780**Topic:** TCP TIME_WAIT Duration**Type:** True/False

The TCP TIME_WAIT state lasts for twice the Maximum Segment Lifetime (2 MSL) to ensure that delayed segments from the previous connection dissipate.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. 2 MSL allows late-arriving duplicate segments to expire in the network so they cannot interfere with a subsequent connection using the same socket pair.

Question 781**Topic:** TCP RST Graceful Close**Type:** True/False

A TCP RST (Reset) segment is used to negotiate a polite, graceful shutdown of a bidirectional session.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Graceful connection termination is performed using FIN segments. An RST segment immediately aborts an abnormal connection without waiting for outstanding data.

Question 782

Topic: UDP Checksum Mandatory IPv4

Type: True/False

In standard IPv4 datagrams, calculating and verifying the UDP checksum is strictly mandatory for all implementations.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. In IPv4, the UDP checksum field is optional (if not computed, it is filled with all zeros). In IPv6, however, computing the UDP checksum is mandatory.

Question 783

Topic: DNS Port TCP 53 Usage

Type: True/False

DNS servers use TCP port 53 exclusively for all standard name lookup queries from desktop web browsers.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Standard desktop DNS queries use UDP port 53 for speed. TCP port 53 is used for DNS zone transfers between servers and when query responses exceed 512 bytes.

Question 784

Topic: HTTPS Encryption Layer

Type: True/False

HTTPS operates by executing the HTTP protocol directly over a Transport Layer Security (TLS) encrypted session.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. HTTPS is not a separate application protocol; it is standard HTTP layered over an encrypted TLS/SSL transport channel (default TCP port 443).

Question 785

Topic: Active FTP Server Data Port

Type: True/False

In Active FTP mode, the FTP server initiates data connections to the client from TCP port 20.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. In Active FTP, the server uses TCP port 20 as the source port when connecting outbound to the client's negotiated high data port.

Question 786**Topic:** Passive FTP Client Initiation**Type:** True/False

In Passive FTP mode, the client initiates both the control connection and the data connection.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. In Passive FTP (PASV), the server opens an unprivileged high listening port and sends it to the client. The client then initiates the outbound data connection to that port.

Question 787**Topic:** Telnet Password Sniffing**Type:** True/False

Because Telnet transmits data in plaintext, an attacker capturing traffic on an intermediate switch can view administrative passwords in cleartext.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Telnet lacks encryption; usernames, passwords, and command keystrokes are transmitted as unencrypted ASCII characters, vulnerable to network sniffing.

Question 788**Topic:** DHCP Discover Broadcast**Type:** True/False

A newly booted DHCP client sends its initial DHCP Discover message as an IP broadcast to 255.255.255.255.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Because the client does not yet possess an IP address or know the server's IP, it broadcasts the DHCP Discover packet to 255.255.255.255 with source 0.0.0.0.

Question 789**Topic:** DHCP Server Default Port**Type:** True/False

A DHCP server listens for incoming client requests on UDP port 68.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. The DHCP server listens on UDP port 67. The DHCP client receives server messages on UDP port 68.

Question 790**Topic:** DHCP Relay Broadcast Forwarding**Type:** True/False

A router configured as a DHCP Relay agent forwards DHCP Discover packets as Layer 2 broadcasts across all its interfaces.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. A DHCP Relay converts the incoming broadcast Discover message into a Layer 3 unicast packet and forwards it directly to the designated DHCP server IP.

Question 791

Topic: VLAN 802.1Q Tag Location

Type: True/False

The IEEE 802.1Q tag is inserted between the Source MAC address and the EtherType/Length field in an Ethernet frame.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. An 802.1Q tag (4 bytes) is inserted immediately after the Source MAC address, with TPID 0x8100 indicating the presence of the VLAN tag.

Question 792

Topic: IPv4 DF Flag Dropping

Type: True/False

If a packet with the DF (Don't Fragment) bit set encounters a router link where MTU is smaller than packet size, the router fragments the packet anyway.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. If DF=1 and the packet exceeds the link MTU, the router must drop the packet and return an ICMP Type 3 Code 4 (Fragmentation Needed) error message.

Question 793

Topic: Private IP Internet Routing

Type: True/False

RFC 1918 private IP addresses are globally routed across public Internet service provider backbones without NAT.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. RFC 1918 private addresses are strictly non-routable on the public Internet. Internet routers filter and discard private IP ranges; NAT is required for Internet access.

Question 794

Topic: Default Gateway Role

Type: True/False

A host uses its configured default gateway only when transmitting packets destined to IP addresses located outside its local subnet.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. For hosts on the local subnet, the sender delivers packets directly using local ARP. For destinations on different subnets, packets are addressed to the default gateway's MAC address.

Question 795**Topic:** TCP Sliding Window Flow Control**Type:** True/False

TCP uses the sliding window mechanism primarily to protect the receiver's buffer from being overwhelmed by a fast sender.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. The receiver advertises its available buffer space (Receive Window, rwnd) in TCP acknowledgments, enabling flow control by restricting the sender's unacknowledged data volume.

Question 796**Topic:** Proxy ARP Disables Routing**Type:** True/False

Proxy ARP replaces the need for IP routing tables on enterprise core routers.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Proxy ARP only helps hosts resolve MAC addresses when they lack default gateways; routers still rely completely on IP routing tables to forward packets across interfaces.

Question 797**Topic:** TCP Sequence Numbers Counting**Type:** True/False

TCP sequence numbers count the number of segments transmitted rather than the number of data bytes.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. TCP sequence numbers are byte-oriented; each sequence number corresponds to a specific byte in the data stream, not the segment count.

Question 798**Topic:** Ethernet FCS Error Detection**Type:** True/False

The Frame Check Sequence (FCS) at the end of an Ethernet frame uses a 32-bit Cyclic Redundancy Check (CRC-32) to detect transmission errors.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. The 4-byte FCS field contains a CRC-32 checksum calculated across the frame. If the receiving NIC computes a mismatched CRC, the corrupted frame is dropped.

25 Chapter 3: Common Network Security Threats and Threat Prevention

Question 799**Topic:** Virus vs Worm Replication**Type:** True/False

Unlike a computer virus, a computer worm does not require a host file and can replicate autonomously across network connections.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Worms are standalone malicious programs that replicate across networks independently by exploiting vulnerabilities, whereas viruses attach to host files and require human execution.

Question 800**Topic:** Trojan Self-Replication**Type:** True/False

A Trojan horse is designed to replicate itself aggressively across all computers on a local area network like a worm.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Trojans do not self-replicate. They rely on social engineering, deception, or bundling with legitimate utilities to trick users into installing them.

Question 801**Topic:** Ransomware Key Recovery**Type:** True/False

If ransomware uses strong AES-256 and RSA-2048 encryption, victims can easily decrypt their files in seconds using simple mathematical tools without the private key.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Modern asymmetric and symmetric cryptography is computationally infeasible to break via brute-force; without the private key held by the attacker or an implementation flaw, decryption is impossible.

Question 802**Topic:** Rootkit Detection Ease**Type:** True/False

Because rootkits modify kernel-level data structures to hide their presence, standard Task Manager and basic antivirus tools can always detect them immediately.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Rootkits hook system APIs and kernel structures precisely to hide their processes, drivers, and open ports, making them invisible to standard operating system utilities and basic scanners.

Question 803**Topic:** Port Scanning Legality**Type:** True/False

Port scanning sends packets to target ports and is used both by network administrators for security audits and by attackers for vulnerability reconnaissance.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Port scanning is a dual-use technique. Administrators use tools like Nmap to audit open services and firewall rules, while adversaries use them to discover exploitable services.

Question 804**Topic:** TCP SYN Scan Completion**Type:** True/False

In a TCP SYN port scan, the scanning host completes the full 3-way handshake by sending a final ACK segment before logging out.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. A TCP SYN scan is a half-open scan. If a SYN-ACK is received, the scanner sends an RST segment to tear down the connection immediately, intentionally avoiding full handshake completion.

Question 805**Topic:** UDP Port Scan Response**Type:** True/False

When a UDP port scan probes an open UDP port, the target host is required by RFC standards to return an ICMP Echo Reply.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. ICMP Echo Replies are responses to ICMP Echo Requests. For an open UDP port, the target application either responds with an application-specific UDP response or produces no response (open|filtered).

Question 806**Topic:** Switch Hub Failover in MAC Flooding**Type:** True/False

When an attacker exhausts a switch's CAM table via MAC flooding, many switches default to broadcasting incoming unicast frames out all ports, allowing the attacker to sniff traffic.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. When the MAC table memory is full, the switch cannot learn new addresses. Incoming frames with unknown destination MACs are flooded out all ports in the VLAN (fail-open mode), enabling sniffing.

Question 807

Topic: ARP Protocol Authentication

Type: True/False

The standard Address Resolution Protocol (ARP) includes built-in cryptographic authentication to ensure ARP replies come from legitimate devices.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. ARP (RFC 826) was developed without security authentication. Hosts accept and update their cache with unsolicited ARP replies, leaving the protocol vulnerable to ARP spoofing and poisoning.

Question 808

Topic: Gratuitous ARP Poisoning

Type: True/False

Attackers can exploit Gratuitous ARP to silently poison the ARP caches of all hosts across a subnet simultaneously.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. By broadcasting a Gratuitous ARP packet claiming ownership of an IP address (such as the default gateway), an attacker overwrites the ARP tables of all listening hosts in the broadcast domain.

Question 809

Topic: DHCP Snooping Role

Type: True/False

DHCP Snooping prevents rogue DHCP servers by allowing DHCP reply messages (Offer/ACK) to enter the switch only through designated 'trusted' ports.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. DHCP Snooping classifies switch ports into trusted and untrusted. Only trusted ports can send DHCP server messages (Offer, ACK); untrusted ports are blocked from sending them, neutralizing rogue DHCP servers.

Question 810

Topic: SYN Flood Memory Exhaustion

Type: True/False

A TCP SYN flood attacks a server's bandwidth rather than its memory connection tables.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. While high-volume SYN floods consume bandwidth, their primary kill mechanism is exhausting the server's half-open connection backlog queue (memory allocated for TCP control blocks).

Question 811**Topic:** SYN Cookie Memory Allocation**Type:** True/False

When SYN Cookie defense is active, a server allocates full connection memory buffers immediately upon receiving the initial SYN packet.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. SYN Cookies prevent memory allocation during the SYN_RECEIVED state. State is encoded into the SYN-ACK sequence number, and memory is allocated only after the client returns a valid ACK.

Question 812**Topic:** Land Attack IP Match**Type:** True/False

In a Land attack, the source IP address and source port are forged to match the destination IP address and destination port of the victim.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. The defining feature of a Land attack is setting Source IP = Destination IP and Source Port = Destination Port, tricking the target into opening a connection with itself and freezing.

Question 813**Topic:** Smurf Attack UDP Protocol**Type:** True/False

A Smurf attack uses UDP port 7 packets to flood an amplifying network.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. A Smurf attack uses ICMP Echo Requests. The Fraggle attack is the counterpart that uses UDP datagrams (typically port 7).

Question 814**Topic:** Ping of Death Legality**Type:** True/False

The Ping of Death attack exploits the fact that the IPv4 specification permits packets to exceed 1 megabyte in size.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. The maximum legal size of an IPv4 datagram is 65,535 bytes. A Ping of Death creates fragmented packets whose total reassembled size illegally exceeds 65,535 bytes, crashing unpatched systems.

Question 815**Topic:** Teardrop Offset Overlap**Type:** True/False

The Teardrop attack crashes vulnerable systems by crafting packet fragments with overlapping and contradictory fragment offset values.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Teardrop manipulates the Fragment Offset and Length fields so that fragments overlap during reassembly, triggering buffer overflows or system crashes in unpatched kernels.

Question 816**Topic:** CC Attack Target Layer**Type:** True/False

A Challenge Collapsar (CC) attack targets Layer 2 MAC address tables on core enterprise switches.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. A CC attack is a Layer 7 (Application Layer) HTTP/HTTPS flood designed to overwhelm web server CPUs and database backends by repeatedly requesting complex web pages.

Question 817**Topic:** Slowloris Bandwidth Need**Type:** True/False

Slowloris requires massive gigabit-level bandwidth to crash enterprise web servers.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Slowloris is a low-bandwidth attack that sends incomplete HTTP headers very slowly, occupying server threads until the maximum connection limit is reached, requiring minimal attacker bandwidth.

Question 818**Topic:** NTP Monlist Amplification**Type:** True/False

NTP amplification attacks exploit the 'monlist' command to generate responses that are hundreds of times larger than the original request.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. The NTP 'monlist' command returns the addresses of the last 600 systems that communicated with the server, providing massive bandwidth amplification (over 500x) against a spoofed victim IP.

Question 819**Topic:** IP Spoofing for TCP Downloads**Type:** True/False

An attacker can successfully use a spoofed source IP address to download confidential files from a remote FTP server without any other access.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. TCP requires a bidirectional 3-way handshake. If the attacker spoofs the source IP, the server sends SYN-ACK to the spoofed IP, not the attacker. The attacker cannot complete the handshake or receive downloaded data.

Question 820**Topic:** Anti-DDoS Traffic Diversion**Type:** True/False

During a DDoS attack, traffic diversion redirects incoming traffic destined for the victim to a scrubbing center using mechanisms like BGP routing updates.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Anti-DDoS diversion announces more specific BGP routes or adjusts DNS to route traffic to specialized scrubbing centers for filtering before legitimate traffic is reinjected.

Question 821**Topic:** Logic Bomb Triggering**Type:** True/False

A logic bomb executes its payload immediately upon entering a computer system, regardless of dates or events.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. A logic bomb remains dormant until a specific trigger condition is met (such as a calendar date, account deletion, or specific event).

Question 822**Topic:** SQL Injection Impact**Type:** True/False

SQL injection attacks occur because web applications improperly concatenate untrusted user input directly into executable SQL statements.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. SQL injection is caused by lack of input validation and failure to use parameterized queries (prepared statements), allowing user inputs to alter SQL query logic.

Question 823**Topic:** XSS Execution Context**Type:** True/False

Cross-Site Scripting (XSS) attacks execute malicious code within the victim user's web browser rather than directly on the web server's operating system.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. In an XSS attack, the injected script executes inside the client's browser, enabling the attacker to steal cookies, hijack user sessions, or manipulate the webpage appearance.

Question 824**Topic:** Zero-Day Signature Protection**Type:** True/False

Traditional signature-based antivirus software provides immediate 100% protection against previously unknown zero-day exploits.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Signature-based antivirus relies on known hashes and patterns. Because zero-day exploits are previously unknown, signatures do not exist, making behavioral analysis and sandboxing necessary.

26 Chapter 4: Firewall Security Policies

Question 825**Topic:** Local Zone Priority Fixed**Type:** True/False

In Huawei firewalls, the priority of the predefined Local security zone is fixed at 100 and cannot be modified by the administrator.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. The Local zone priority is permanently fixed at 100, representing the firewall itself.

Question 826**Topic:** Untrust Zone Priority Value**Type:** True/False

The default priority of the Untrust security zone is 85.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. The Untrust zone priority is 5. The Trust zone priority is 85.

Question 827**Topic:** DMZ Zone Priority Value**Type:** True/False

The default priority of the DMZ security zone is 50.

- A. True
- B. False

Correct Answer: A (True)**Concept & Rationale:** True. The DMZ zone has a fixed default priority of 50.**Question 828****Topic:** Interface Zone Exclusivity**Type:** True/False

A single physical Ethernet interface on a Huawei firewall can be assigned to multiple security zones simultaneously.

- A. True
- B. False

Correct Answer: B (False)**Concept & Rationale:** False. An interface can belong to only one security zone at a time.**Question 829****Topic:** Inter-Zone Traffic Default Allow**Type:** True/False

By default, inter-zone traffic between different security zones is permitted without any security policy configuration.

- A. True
- B. False

Correct Answer: B (False)**Concept & Rationale:** False. Inter-zone traffic is denied by default; explicit security policy rules with the action 'Permit' must be configured to allow communication.**Question 830****Topic:** Intra-Zone Traffic Default Allow**Type:** True/False

Traffic between two interfaces assigned to the same security zone is permitted by default on Huawei firewalls.

- A. True
- B. False

Correct Answer: A (True)**Concept & Rationale:** True. Intra-zone traffic is permitted by default, though administrators can configure intra-zone policies to restrict it if required.**Question 831****Topic:** Outbound Direction Definition**Type:** True/False

Traffic flowing from the Trust zone (85) to the Untrust zone (5) is classified as Inbound traffic.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Traffic flowing from higher priority (85) to lower priority (5) is Outbound traffic.

Question 832

Topic: Default Policy Deletion

Type: True/False

Administrators can delete the predefined 'default' security policy rule to optimize firewall performance.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. The predefined default rule cannot be deleted or reordered; it is permanently situated at the bottom of the policy list.

Question 833

Topic: Security Policy Top-Down Matching

Type: True/False

Huawei firewalls match security policy rules sequentially from top to bottom, stopping evaluation as soon as the first matching rule is found.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Rule matching is top-down and terminates on the first match (first-match-wins principle).

Question 834

Topic: Session Table Fast-Forwarding

Type: True/False

Once a session is established on a stateful firewall, subsequent packets in that connection match the session table directly, bypassing security policy re-evaluation.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Fast-path forwarding utilizes the session table to forward packets without re-matching the entire security policy rulebase.

Question 835

Topic: Session Aging Timer Memory Reclaim

Type: True/False

The primary purpose of session aging timers is to prevent stale or inactive sessions from permanently exhausting firewall memory.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Aging timers automatically flush dead or idle sessions to maintain available connection capacity.

Question 836**Topic:** TCP Established vs SYN Timer**Type:** True/False

On Huawei firewalls, the default aging timer for a TCP connection in the ESTABLISHED state is much shorter than the timer for a TCP SYN packet.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. TCP SYN aging timers are short (e.g., 20 seconds) to resist SYN floods, whereas ESTABLISHED timers are long (e.g., 10,000 seconds / ~20 minutes) to sustain idle business sessions.

Question 837**Topic:** ASPF Multi-Channel Support**Type:** True/False

ASPF dynamically generates temporary Server-Map entries to allow dynamic secondary data channels for protocols like FTP active mode.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. ASPF inspects application-layer payloads and dynamically opens temporary Server-Map pinholes for secondary data connections.

Question 838**Topic:** Server-Map vs Session Table**Type:** True/False

A Server-Map entry is identical to a Session table entry and never expires.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. A Server-Map entry is a temporary pre-allocation pinhole. Once matching traffic arrives and establishes a standard session entry, the dynamic server-map entry expires.

Question 839**Topic:** First Generation Stateless Inspection**Type:** True/False

First-generation packet filtering firewalls track the connection state of every packet in a dynamic session table.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. First-generation packet filters are stateless; they inspect packets in isolation against 5-tuple ACLs without tracking connection states.

Question 840**Topic:** NGFW Port Independence**Type:** True/False

Next-Generation Firewalls can identify application types (e.g. BitTorrent, SSL) even when they communicate over non-standard or unusual port numbers.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. NGFWs utilize deep packet inspection (DPI) and protocol signature analysis to identify applications independent of transport port numbers.

Question 841**Topic:** Custom Security Zone Overlap**Type:** True/False

A custom security zone can be configured with the exact same priority value as an already existing security zone without restriction.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Priority values must be unique per security zone; two active security zones on the same firewall cannot share the identical priority value.

Question 842**Topic:** Security Policy Rule Order Significance**Type:** True/False

Placing an overly broad 'Permit Any Any' rule at the top of the security policy list renders all subsequent specific deny rules ineffective.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Because evaluation stops on the first match, placing a broad permit rule at the top matches all traffic immediately, preventing subsequent specific deny rules from ever being evaluated.

Question 843**Topic:** Local Zone Transit Traffic**Type:** True/False

Traffic traveling from an internal client in Trust (85) to an external web server in Untrust (5) passes through the Local zone (100).

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Transit traffic passes directly from Trust to Untrust. The Local zone is involved only when traffic originates from or terminates on the firewall itself.

Question 844**Topic:** Security Policy Schedule Control**Type:** True/False

Associating a Time Range with a security policy rule ensures that the rule is active and enforced only during specified time windows.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Schedules restrict policy rule activation to specified recurring days, hours, or absolute date ranges.

Question 845**Topic:** Address Object Set Maintenance**Type:** True/False

Modifying an Address Set object automatically updates all security policies referencing that object without needing to edit each policy individually.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Address Sets provide modular abstraction; modifying the object dynamically updates all referencing security policies.

Question 846**Topic:** Security Profile Binding**Type:** True/False

Security profiles (such as IPS and Antivirus) can be attached to rules whose action is configured as 'Deny'.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Security profiles perform deep packet inspection on allowed traffic and can only be bound to rules whose action is 'Permit'.

Question 847**Topic:** Stateful Firewall Asymmetric Drop**Type:** True/False

If return traffic enters a stateful firewall that has no existing session entry for that flow, the firewall drops the return packets by default.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. A stateful firewall expects return traffic to match an existing session. Unsolicited return packets violate stateful checks and are discarded.

Question 848**Topic:** Disabling Stateful Inspection Behavior**Type:** True/False

When stateful inspection is disabled on a firewall interface, administrators must write explicit security policy rules for both forward and return traffic flows.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Without session state tracking, the firewall behaves like a stateless packet filter, requiring explicit policy rules in both directions.

Question 849**Topic:** Session Table Capacity Exhaustion**Type:** True/False

When a firewall's session table reaches maximum hardware capacity, the firewall automatically shuts down all its physical power supplies.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. The firewall remains powered on, but it cannot allocate new session entries, causing new incoming connection requests to be dropped.

Question 850**Topic:** Display Session Table Command**Type:** True/False

The command `display firewall session table` is used in Huawei VRP to inspect active connection sessions on the firewall.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. `display firewall session table` is the standard VRP command for viewing active session entries.

Question 851**Topic:** Service Object Port Customization**Type:** True/False

Administrators can create custom Service Objects to define non-standard TCP or UDP port numbers used by proprietary enterprise applications.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Custom Service Objects allow administrators to define specific protocol types and port ranges for internal business software.

Question 852**Topic:** Hit Counter Policy Troubleshooting**Type:** True/False

Monitoring security policy hit counters helps administrators detect unused or obsolete rules that never match real traffic.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Zero hit counts over an extended period indicate that a rule may be shadowed, misconfigured, or obsolete, aiding rulebase cleanup.

Question 853**Topic:** Firewall Transparent Mode Subnetting**Type:** True/False

Deploying a Huawei firewall in Transparent Mode requires re-addressing all servers and reconfiguring the existing IP subnets.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Transparent Mode functions as a Layer 2 bridge ('bump in the wire'), filtering traffic without modifying existing IP addressing or subnet configurations.

Question 854**Topic:** Management Access via Interface Settings**Type:** True/False

Administrative access services (such as SSH, HTTPS, and Ping) on a firewall interface can be controlled directly through interface service configuration.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Huawei firewalls allow administrators to enable or disable specific management services (Ping, SSH, HTTPS) directly on individual interfaces via **service-manage** commands.

27 Chapter 5: Firewall NAT Technologies

Question 855**Topic:** NAT No-PAT Port Multiplexing**Type:** True/False

NAT No-PAT translates transport layer port numbers to allow multiple internal hosts to share a single public IP address.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. NAT No-PAT does NOT translate port numbers; it performs 1-to-1 IP translation without port multiplexing.

Question 856**Topic:** NAT Port Multiplexing**Type:** True/False

NAPT translates both IP addresses and transport layer port numbers, enabling thousands of hosts to share a single public IP address.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. NAPT (Network Address Port Translation) multiplexes connections over TCP/UDP ports, maximizing public IP utilization.

Question 857**Topic:** Easy IP Address Pool**Type:** True/False

Easy IP requires the administrator to manually configure a dedicated address group containing at least two public IP addresses.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Easy IP uses the public IP address configured directly on the firewall's egress interface, requiring no address group pool.

Question 858**Topic:** Smart NAT Fallback**Type:** True/False

Smart NAT operates in No-PAT mode initially and automatically falls back to NAPT using a reserved IP when public pool addresses are exhausted.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Smart NAT combines No-PAT and NAPT, using a designated reserved IP to perform NAPT for subsequent connections when pool IPs are depleted.

Question 859**Topic:** NAT Server Inbound Publishing**Type:** True/False

The NAT Server feature is used to publish internal intranet servers so that external Internet users can access them.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. NAT Server maps public IP addresses and ports to private server addresses and ports, enabling inbound Internet access to internal services.

Question 860

Topic: Static Server-Map Generation

Type: True/False

Configuring a `nat server` rule on a Huawei firewall automatically generates a static Server-Map table entry.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. `nat server` creates a permanent, static Server-Map entry that defines the translation between public and private socket parameters.

Question 861

Topic: Bidirectional NAT Definition

Type: True/False

Bidirectional NAT translates both the Source IP address and the Destination IP address of the same packet simultaneously.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Bidirectional NAT applies Source NAT and Destination NAT concurrently on the same packet flow.

Question 862

Topic: NAT Hairpinning Issue

Type: True/False

Without Source NAT, intranet clients accessing intranet servers via public IP addresses experience connection failures because server replies bypass the firewall.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. The server replies directly to the client's private IP across the local switch; the client drops the packet because it expects a reply from the public IP.

Question 863

Topic: NAT ALG Payload Inspection

Type: True/False

NAT ALG is required for multi-channel protocols like FTP active mode because standard NAT does not inspect or translate IP addresses embedded inside application payloads.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Standard NAT rewrites only L3/L4 headers. ALG inspects application payloads (e.g. PORT commands) and rewrites embedded IP/port information.

Question 864**Topic:** NAT Blackhole Route Function**Type:** True/False

A NAT blackhole route prevents routing loops between the firewall and upstream routers for unused IP addresses in a NAT address pool.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Pointing unused pool IPs to NULL0 terminates unassigned traffic at the firewall, preventing routing loops with the ISP gateway.

Question 865**Topic:** No-NAT Policy Use Case**Type:** True/False

A 'no-nat' policy rule is commonly used to exempt site-to-site IPsec VPN traffic from undergoing Internet Source NAT.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. VPN traffic between branch private subnets must preserve original private IP addresses and must not be translated by Internet Source NAT.

Question 866**Topic:** Inbound Security Policy Matching IP**Type:** True/False

When external traffic accesses a server published via NAT Server, the security policy must permit traffic using the server's private IP address.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Because destination translation occurs before security policy evaluation, the security policy rule must match the server's translated private IP address.

Question 867**Topic:** Outbound Security Policy Matching IP**Type:** True/False

When internal clients access the Internet via Source NAT, the security policy evaluates traffic using the translated public IP address.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. On outbound traffic, the security policy is evaluated against the original private source IP before Source NAT rewrites the packet header.

Question 868**Topic:** NAT Table Capacity Unlimited**Type:** True/False

A firewall's NAPT translation table has unlimited capacity and can support an infinite number of simultaneous connections.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. NAT table capacity is bounded by firewall memory and available 16-bit transport layer port numbers (~60,000 ports per public IP).

Question 869**Topic:** AH Incompatibility with NAT**Type:** True/False

The IPsec Authentication Header (AH) protocol operates seamlessly across standard NAT devices without any issues.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. AH integrity checks include the outer IP header. When NAT modifies the IP address, the AH checksum verification fails, causing the packet to be dropped.

Question 870**Topic:** NAT-T UDP Port 4500**Type:** True/False

NAT Traversal (NAT-T) encapsulates IPsec ESP packets inside UDP datagrams using port 4500 to traverse NAT devices.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. NAT-T encapsulates ESP into UDP port 4500, enabling standard NAPT devices to translate the port header without corrupting the IPsec payload.

Question 871**Topic:** Dynamic Server-Map Expiration**Type:** True/False

Dynamic Server-Map entries generated by ASPF or NAT No-PAT expire and are deleted automatically when their aging timer elapses.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Dynamic Server-Map entries are temporary pinholes with aging timers, unlike static Server-Map entries generated by NAT Server.

Question 872**Topic:** NAT Address Pool Subnet Requirement**Type:** True/False

A NAT address group must always reside on the exact same IP subnet as the firewall's egress interface.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Address pools can reside on different subnets, provided upstream routers route the pool prefix to the firewall and blackhole routes are configured.

Question 873**Topic:** Display Server-Map Command**Type:** True/False

The command `display firewall server-map` displays active static and dynamic Server-Map entries on a Huawei firewall.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. `display firewall server-map` is the standard VRP command to inspect active Server-Map entries.

Question 874**Topic:** Easy IP for Dynamic PPPoE**Type:** True/False

Easy IP is especially suitable for WAN connections where the public IP address is dynamically assigned via PPPoE or DHCP.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Easy IP dynamically tracks the IP address of the egress interface, eliminating the need to update address pools when WAN IPs change.

Question 875**Topic:** Multiple Servers on One Public IP**Type:** True/False

An enterprise can publish both a Web server (port 80) and a Mail server (port 25) on the same public IP address using port-based NAT Server.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. By mapping distinct public port numbers on the same public IP, multiple internal servers can be published simultaneously.

Question 876**Topic:** NAT Policy First Match Rule**Type:** True/False

Huawei NAT policy rules are evaluated from bottom to top, prioritizing the default rule.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. NAT policies are evaluated sequentially from top to bottom, stopping at the first matching rule.

Question 877

Topic: Static 1-to-1 NAT Port Mapping

Type: True/False

Static 1-to-1 NAT allows multiple internal hosts to share one public IP address by translating port numbers.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Static 1-to-1 NAT maps one private IP to one public IP without port translation; it does not multiplex multiple hosts.

Question 878

Topic: NAT No-PAT Host Tracking

Type: True/False

In NAT No-PAT, once a public IP is allocated to an internal host, other hosts cannot use that public IP until all sessions of the first host terminate.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. No-PAT allocates the entire public IP exclusively to one host at a time because port multiplexing is disabled.

Question 879

Topic: SIP Protocol and NAT

Type: True/False

SIP VoIP traffic requires NAT ALG on firewalls because SIP embeds private IP addresses and dynamic RTP media ports inside its message payload.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. SIP SDP payloads carry private IP and port parameters; without SIP ALG, voice/video RTP streams fail to establish across NAT.

Question 880

Topic: Twice NAT Source and Dest

Type: True/False

Twice NAT is another term for Bidirectional NAT, where both source and destination addresses are translated simultaneously.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. 'Twice NAT' and 'Bidirectional NAT' are synonymous terms in network security engineering.

Question 881**Topic:** NAT Prevents External Inbound**Type:** True/False

By default, Source NAT prevents external Internet hosts from initiating unsolicited connections directly to internal client PCs.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. External hosts cannot initiate connections to private internal IPs unless explicit inbound port mappings (NAT Server) or pinholes exist.

Question 882**Topic:** Blackhole Route Next-Hop Interface**Type:** True/False

A NAT blackhole route uses the NULL0 virtual interface as its next hop to silently discard matching packets.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Routes pointing to interface NULL0 discard packets immediately without generating ICMP error replies or forwarding loops.

Question 883**Topic:** NAT Overlapping Address Pools**Type:** True/False

Assigning overlapping IP address ranges to two distinct NAT address groups is recommended as best practice.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Overlapping pools cause address allocation conflicts, routing ambiguity, and unpredictable translation behavior.

Question 884**Topic:** Verbose Session Table NAT Indicator**Type:** True/False

In the output of `display firewall session table verbose`, the symbol -> indicates the post-NAT translated socket information.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Huawei firewalls use the arrow notation -> in verbose session displays to show original vs translated IP addresses and port numbers.

28 Chapter 6: Firewall Hot Standby Technologies

Question 885**Topic:** Five Nines Availability**Type:** True/False

'Five nines' availability represents 99.999% network uptime, equating to less than 6 minutes of unscheduled downtime annually.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. 99.999% availability translates to approximately 5.26 minutes of downtime per year, the gold standard for carrier-grade network availability.

Question 886**Topic:** VRRP Virtual MAC Byte 6**Type:** True/False

In the VRRP Virtual MAC address 00-00-5E-00-01-XX, the last byte XX represents the VRID in hexadecimal.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. The last octet of the VRRP virtual MAC address corresponds directly to the Virtual Router Identifier (VRID) in hexadecimal.

Question 887**Topic:** VRRP Priority 255 Assignment**Type:** True/False

An administrator can manually configure a priority value of 255 on a router that does not own the physical IP matching the Virtual IP.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Priority 255 is strictly reserved for the IP address owner. Administrators can configure priorities only between 1 and 254.

Question 888**Topic:** VRRP Multicast 224.0.0.18**Type:** True/False

VRRP Advertisement packets are sent to the IPv4 multicast address 224.0.0.18.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. VRRP uses the dedicated multicast address 224.0.0.18 (IP Protocol 112) for master advertisement broadcasts.

Question 889**Topic:** Standalone VRRP Independence Issue**Type:** True/False

Standard standalone VRRP groups on multi-interface firewalls automatically coordinate state changes across different interfaces without any additional protocols.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Standalone VRRP groups operate independently per interface. A failure on an uplink interface does not trigger a downlink VRRP state change, creating routing black holes.

Question 890**Topic:** VGMP Proprietary Protocol**Type:** True/False

VGMP is a Huawei proprietary protocol developed specifically to coordinate state synchronization across multiple VRRP groups on firewalls.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. VGMP is Huawei proprietary technology that unifies multi-interface VRRP group failovers on USG firewalls.

Question 891**Topic:** VGMP Default Priority 65000**Type:** True/False

The default initial priority of both the Active and Standby VGMP management groups on Huawei firewalls is 65000.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Both Active and Standby VGMP groups are initialized with a default priority value of 65000.

Question 892**Topic:** VGMP Unified State Transition**Type:** True/False

When a firewall's VGMP group switches from Active to Standby, all VRRP groups associated with it switch from Master to Backup simultaneously.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. VGMP forces all member VRRP groups to transition states simultaneously, preventing routing black holes.

Question 893**Topic:** HRP Heartbeat UDP 18514**Type:** True/False

HRP heartbeat packets and synchronization data are transmitted over UDP port 18514.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. HRP encapsulates its control messages and synchronization records in UDP datagrams using destination port 18514.

Question 894**Topic:** Session Synchronization Importance**Type:** True/False

Without real-time session synchronization by HRP, all active TCP connections are dropped when a firewall hot standby failover occurs.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Stateful firewalls require session entries to forward traffic. Without session replication, the new active firewall drops established connections, forcing clients to reconnect.

Question 895**Topic:** HRP Real-Time vs Batch**Type:** True/False

HRP Real-Time Backup synchronizes session entries immediately as they are created, whereas Batch Backup bulk-synchronizes tables upon initial peer connection or manual trigger.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Real-time backup replicates states dynamically per-session, while batch backup performs full synchronization on boot, recovery, or manual command.

Question 896**Topic:** Quick Session Backup in Active/Active**Type:** True/False

Quick Session Backup is designed for Active/Active load-balancing mode to prevent packet drops caused by asymmetric routing.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Quick session backup immediately replicates sessions so that return packets taking asymmetric paths on the peer firewall match active sessions and are forwarded.

Question 897**Topic:** Active/Standby Traffic Forwarding**Type:** True/False

In Active/Standby mode, both firewalls actively forward user service traffic under normal operating conditions.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. In Active/Standby mode, only the active unit forwards user traffic; the standby firewall remains idle, ready to take over upon failure.

Question 898

Topic: Active/Active Dual VRRP Groups

Type: True/False

In Load-Balancing mode, dual firewalls typically act as Master for alternate VRRP groups to distribute traffic across subnets.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. FW1 is Master for Group 1 (backing up Group 2), and FW2 is Master for Group 2 (backing up Group 1), balancing traffic loads.

Question 899

Topic: Dedicated Heartbeat Link Best Practice

Type: True/False

It is recommended to run HRP heartbeat communications over a dedicated point-to-point link or link-aggregated Eth-Trunk.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Dedicated point-to-point links isolate heartbeat traffic and prevent split-brain conditions caused by intermediate switch failures.

Question 900

Topic: HRP Enable Command Syntax

Type: True/False

The command `hrp enable` activates HRP hot standby functionality in Huawei VRP system view.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. `hrp enable` is the master command that initializes the HRP process on Huawei firewalls.

Question 901

Topic: Standby Configuration Lock

Type: True/False

Directly configuring security policies and NAT rules on the Standby firewall is permitted and recommended by Huawei.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Configuration edits are locked on the standby unit to prevent policy divergence; configurations must be made on the active unit and replicated via HRP.

Question 902

Topic: Preemption Delay Convergence

Type: True/False

A preemption delay allows routing protocols and physical links on a recovered primary firewall to stabilize before reclaiming active traffic forwarding.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Preemption delay prevents premature traffic switchback while OSPF, BGP, and interfaces are still converging.

Question 903

Topic: Split-Brain Dual Master State

Type: True/False

In a Split-Brain condition, both firewalls promote themselves to the Active state, causing IP and MAC conflicts on the virtual gateway addresses.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. When heartbeat connectivity is severed, both units assume the other has failed, promoting themselves to Active and creating severe IP/MAC conflicts.

Question 904

Topic: Display HRP State Command Output

Type: True/False

The command `display hrp state` provides information regarding VGMP group priorities, active/standby roles, and heartbeat link status.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. `display hrp state` is the primary diagnostic command for inspecting firewall clustering health and roles.

Question 905

Topic: IPsec SA Replication

Type: True/False

HRP synchronizes IPsec Security Associations (SAs) so that VPN tunnels do not need to renegotiate when a firewall failover occurs.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Replicating IPsec SAs allows the standby firewall to decrypt and encrypt ongoing VPN traffic immediately upon takeover.

Question 906**Topic:** Server-Map Replication**Type:** True/False

Server-Map table entries are not synchronized by HRP because they are purely local to each physical firewall.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Server-Map entries (for FTP data channels and NAT Server) are synchronized by HRP to preserve active services across failovers.

Question 907**Topic:** Interface IP Synchronization Exclusion**Type:** True/False

HRP automatically synchronizes interface IP addresses so that both firewalls have identical physical IP addresses on their interfaces.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Interface physical IP addresses must remain unique to each firewall and are intentionally excluded from HRP configuration synchronization.

Question 908**Topic:** IP-Link Remote Monitoring**Type:** True/False

IP-Link allows a firewall to monitor upstream gateway reachability through ICMP probes and trigger VGMP priority reduction if the gateway fails.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. IP-Link detects remote link failures across intermediate switches, enabling VGMP to initiate failover even when local interfaces remain physically UP.

Question 909**Topic:** HRP Authentication Key Security**Type:** True/False

Configuring an HRP key (`hrp key`) secures heartbeat communication by verifying packet authenticity between clustered firewalls.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. HRP authentication keys prevent unauthorized devices from injecting forged heartbeat packets or disrupting the cluster.

Question 910**Topic:** Asymmetric Routing Drop on Stateful Firewalls**Type:** True/False

A stateful firewall will drop return traffic packets if it has no matching session entry and stateful inspection is enabled.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Stateful firewalls require return packets to correspond to an existing session entry; unsolicited return packets are discarded as invalid state violations.

Question 911**Topic:** Gratuitous ARP on Failover**Type:** True/False

When a standby firewall becomes Master, it sends Gratuitous ARP packets to update MAC tables on connected Layer 2 switches.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Gratuitous ARPs notify connected switches to redirect frames destined for the Virtual MAC to the new Master's switch port.

Question 912**Topic:** BFD Sub-Second Detection**Type:** True/False

Integrating BFD with VGMP enables millisecond-level fault detection, significantly accelerating failover speed compared to standard keepalive timeouts.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. BFD provides rapid sub-second failure detection, triggering near-instantaneous VGMP priority adjustment and failover.

29 Chapter 7: Firewall IPS

Question 913**Topic:** IDS Inline Deployment**Type:** True/False

An Intrusion Detection System (IDS) is deployed in-line in the traffic forwarding path to actively block malicious packets.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. An IDS is deployed out-of-path via port mirroring or TAPs; it cannot actively drop packets in-line. An IPS is deployed in-line to actively block threats.

Question 914**Topic:** IPS Real-Time Dropping**Type:** True/False

Because an IPS sits in-line directly in the traffic path, it can inspect packets and drop malicious flows before they reach target servers.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Inline positioning enables an IPS to analyze packets and actively drop or reset malicious connections in real time.

Question 915**Topic:** Signature Zero-Day Detection**Type:** True/False

Signature-based intrusion detection can reliably detect novel zero-day attacks without requiring any signature updates.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Signature detection relies on known attack patterns; novel zero-day exploits lack pre-existing signatures and bypass signature inspection.

Question 916**Topic:** Anomaly Detection Zero-Day Advantage**Type:** True/False

Anomaly-based intrusion detection can detect unknown zero-day attacks by identifying statistical deviations from established normal network behavior baselines.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. By monitoring baseline traffic patterns and flagging unusual deviations, anomaly detection can catch novel attacks that lack signatures.

Question 917**Topic:** Anomaly False Positive Rate**Type:** True/False

A significant challenge of anomaly-based detection is that unusual but legitimate business traffic can be incorrectly flagged as an attack (false positive).

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Dynamic business environments generate legitimate traffic spikes and non-standard flows that anomaly detection models may misidentify as malicious.

Question 918**Topic:** Predefined Signatures Cloud Update**Type:** True/False

Predefined IPS signatures on Huawei firewalls are maintained and updated via Huawei Security Intelligence Center online feeds.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Huawei continually updates its predefined signature database to provide protection against newly discovered vulnerabilities and exploits.

Question 919**Topic:** User-Defined Custom Signatures**Type:** True/False

Administrators can write User-Defined IPS signatures using custom regular expressions to protect proprietary enterprise applications.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Huawei firewalls allow administrators to create custom user-defined signatures tailored to internal systems and specific threat patterns.

Question 920**Topic:** IPS Action Alert Behavior**Type:** True/False

When an IPS signature's action is set to 'Alert', the firewall drops the packet and resets the TCP connection.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. The 'Alert' action generates a security log entry but allows the packet to pass through to the destination without blocking.

Question 921**Topic:** Flow-Based AV Line Rate Throughput**Type:** True/False

Flow-based antivirus scans data streams in real time as packets transit the firewall without caching entire files in memory, delivering high throughput.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Flow-based AV evaluates packet streams on the fly, avoiding memory exhaustion and delivering low-latency, multi-gigabit inspection.

Question 922**Topic:** File-Based AV Full Reassembly**Type:** True/False

File-based antivirus scanning reconstructs the entire file in memory before scanning, which can cause significant latency on large file transfers.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Buffering complete multi-megabyte files in firewall RAM introduces substantial latency and can exhaust memory buffers under high concurrency.

Question 923**Topic:** Antivirus Protocol Coverage**Type:** True/False

Huawei firewall Antivirus can inspect file transfers across HTTP, FTP, SMTP, POP3, IMAP, and SMB protocols.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Huawei NGFW AV provides comprehensive coverage across web, file transfer, and mail protocols.

Question 924**Topic:** Antivirus Declare Action**Type:** True/False

The 'Declare' action in Huawei Antivirus allows an infected email to be delivered while inserting a warning notification to alert the recipient.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. 'Declare' permits email delivery but alerts the user by modifying the subject line or body with a warning notification.

Question 925**Topic:** URL Whitelist Precedence**Type:** True/False

On Huawei firewalls, a URL matching the configured Whitelist is permitted immediately, taking precedence over blacklists and category rules.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Whitelists have top evaluation priority in URL filtering, ensuring trusted business domains are never blocked.

Question 926**Topic:** URL Blacklist Precedence**Type:** True/False

A URL matching the configured URL Blacklist is immediately blocked, taking precedence over category-based filtering rules.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Blacklists have absolute blocking priority over standard category rules; matching requests are dropped immediately.

Question 927**Topic:** File Filtering True File Type**Type:** True/False

Huawei File Filtering identifies true file types by analyzing internal file header magic bytes rather than relying merely on file extension names.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. File filtering reads binary header magic numbers, preventing attackers from disguising executable binaries (.exe) as text or image files.

Question 928**Topic:** Content Filtering Keyword Matching**Type:** True/False

Content Filtering inspects application payloads (such as web form submissions and email text) to detect and block confidential keywords.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Content filtering performs deep text inspection to prevent sensitive data exfiltration (e.g. credit card numbers, intellectual property).

Question 929**Topic:** IPS Exception Signature Override**Type:** True/False

Configuring an Exception in an IPS profile allows an administrator to change the action of a specific signature (e.g. from Block to Alert) without disabling the entire profile.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Exceptions permit granular rule overrides for specific signatures to eliminate false positives on critical business systems.

Question 930**Topic:** Protocol Anomaly RFC Compliance**Type:** True/False

Protocol Anomaly Detection verifies that network traffic conforms to official RFC specifications, detecting malformed headers and illegal field lengths.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Protocol anomaly checking enforces strict RFC standard compliance, catching protocol fuzzing, header overflows, and malformed exploit vectors.

Question 931**Topic:** IPS Profile Security Policy Binding**Type:** True/False

An IPS profile is activated on a Huawei firewall by binding it to a Security Policy rule whose action is configured as 'Permit'.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Security profiles are applied to traffic permitted by security policy rules for deep Layer 7 threat inspection.

Question 932**Topic:** Daily AV Database Updates**Type:** True/False

Maintaining automated daily updates of the antivirus signature database is critical because thousands of new malware strains emerge every day.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Daily signature updates ensure the firewall can detect the latest ransomware, trojans, and polymorphic malware variants.

Question 933**Topic:** HTTPS Encryption Inspection Challenge**Type:** True/False

Without SSL Decryption, an IPS or Antivirus engine cannot inspect encrypted payload data inside HTTPS web connections.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. TLS encryption conceals payload contents; an SSL proxy / decryption policy is required to decrypt and inspect HTTPS payloads for threats.

Question 934**Topic:** False Positive Definition Check**Type:** True/False

A False Positive occurs when an IPS correctly detects and blocks an actual malware attack.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. A False Positive occurs when benign, legitimate traffic is incorrectly flagged and blocked as an attack.

Question 935**Topic:** False Negative Definition Check**Type:** True/False

A False Negative occurs when an IPS fails to detect a real attack and allows the malicious packet to pass through to the target.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. False negatives represent missed attacks that evade detection, passing through defenses unhindered.

Question 936**Topic:** Directional File Filtering**Type:** True/False

Huawei firewalls allow File Filtering rules to be applied specifically to Uploads (outbound) or Downloads (inbound).

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Directional controls enable separate policies for inbound malware prevention (downloads) and outbound data loss prevention (uploads).

Question 937**Topic:** Single-Pass Architecture Parallelism**Type:** True/False

Huawei's Single-Pass architecture evaluates packets in parallel across IPS, Antivirus, and URL filtering engines simultaneously in a single scan.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Single-pass inspection parses packet streams once and evaluates multiple threat engines in parallel, minimizing latency.

Question 938**Topic:** Hardware Bypass Fail-Open**Type:** True/False

An external optical bypass switch allows traffic to pass uninterrupted across a physical link if the inline IPS firewall suffers a complete power loss.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Hardware bypass switches provide fail-open reliability, bridging physical links during power failures to ensure business continuity.

Question 939**Topic:** Display Logbuffer Threat Viewing**Type:** True/False

The command `display logbuffer` can be used on a Huawei firewall to inspect recent security event logs and IPS signature alerts.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. `display logbuffer` displays operational logs, including real-time threat detection alerts and security policy hits.

Question 940**Topic:** IPS Tuning Alert-Only Phase**Type:** True/False

Best practice for deploying IPS in production networks involves running in Alert-only mode initially to detect false positives before switching to Block mode.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Running in Alert mode initially allows administrators to observe traffic, identify false positives, configure exceptions, and ensure business applications run smoothly before enforcing blocks.

30 Chapter 8: Firewall User Management Technologies

Question 941**Topic:** Authentication Definition**Type:** True/False

Authentication in the AAA framework verifies the identity claimed by an entity, answering the question 'Who are you?'.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Authentication establishes identity verification through credentials like passwords, tokens, or digital certificates.

Question 942**Topic:** Authorization Definition**Type:** True/False

Authorization is responsible for calculating network bandwidth usage and billing information for user accounts.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Calculating usage and billing is the role of Accounting. Authorization determines which services and permissions the user is permitted to access.

Question 943**Topic:** Local User Storage Location**Type:** True/False

Local user accounts are stored directly within the internal database of the Huawei firewall.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Local users reside on the local storage of the firewall, requiring no external authentication server.

Question 944**Topic:** RADIUS Transport UDP**Type:** True/False

The standard RADIUS protocol operates over TCP transport using destination port 49.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. RADIUS operates over UDP (ports 1812 and 1813). HWTACACS / TACACS+ operates over TCP port 49.

Question 945**Topic:** RADIUS Password Only Encryption**Type:** True/False

Standard RADIUS encrypts the entire packet including usernames and accounting attributes.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. RADIUS encrypts only the User-Password attribute using MD5; usernames and other attributes are transmitted in cleartext.

Question 946**Topic:** RADIUS Bundled Auth and Authz**Type:** True/False

RADIUS bundles Authentication and Authorization together in the single **Access-Accept** response packet.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. RADIUS delivers authorization attributes (VLAN, user group, ACL) alongside authentication acceptance in the **Access-Accept** message.

Question 947

Topic: HWTACACS Transport TCP 49

Type: True/False

HWTACACS utilizes TCP port 49 to provide reliable communication between the client NAS and the server.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. HWTACACS runs over reliable connection-oriented TCP transport on port 49.

Question 948

Topic: HWTACACS Full Body Encryption

Type: True/False

HWTACACS encrypts the entire body of the packet following the 12-byte header, protecting usernames and commands from network sniffing.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. HWTACACS encrypts all payload data, ensuring usernames, command strings, and authorization attributes are confidential.

Question 949

Topic: HWTACACS AAA Separation

Type: True/False

HWTACACS strictly separates Authentication, Authorization, and Accounting into distinct, independent exchanges.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. HWTACACS separates all three AAA phases, allowing independent server assignments and per-command authorization.

Question 950

Topic: LDAP Standard Ports

Type: True/False

Standard unencrypted LDAP uses TCP port 389, while encrypted LDAPS uses TCP port 636.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. LDAP operates over TCP port 389, and LDAPS (over TLS/SSL) uses TCP port 636.

Question 951**Topic:** Active Directory Integration via LDAP**Type:** True/False

Huawei firewalls can query Microsoft Active Directory domain controllers using the LDAP protocol to authenticate domain users.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Huawei firewalls use LDAP/LDAPS queries to validate domain user credentials and synchronize Active Directory user groups.

Question 952**Topic:** User-Based Policy IP Independence**Type:** True/False

User-based security policies allow access control rules to follow the user dynamically, regardless of changes to their assigned DHCP IP address.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. User-aware policies bind permissions to identity rather than volatile IP addresses, ensuring consistent access across mobile and roaming devices.

Question 953**Topic:** Portal Captive Redirection**Type:** True/False

Portal authentication intercepts unauthenticated HTTP requests and redirects users to a captive web login page.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Captive portal authentication intercepts initial HTTP/HTTPS traffic and redirects the browser to a login portal for credential verification.

Question 954**Topic:** AD SSO Event ID 4624**Type:** True/False

Active Directory SSO can monitor Event ID 4624 (Successful Logon) on domain controllers to transparently learn user-to-IP mappings.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Event ID 4624 records successful domain logons with username and workstation IP, which AD SSO monitors to create transparent user mappings.

Question 955**Topic:** RADIUS SSO Accounting Snooping**Type:** True/False

RADIUS SSO learns user IP mappings by snooping RADIUS Accounting-Request packets exchanged between network access devices and the RADIUS server.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. RADIUS SSO monitors accounting start/update packets to extract assigned IPs and usernames without requiring separate user authentication prompts.

Question 956**Topic:** Local User Password Plaintext Best Practice**Type:** True/False

Configuring passwords using `local-user password plain` is recommended as best practice for enterprise production networks.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Using `plain` stores passwords in readable cleartext in configuration files. Best practice mandates using `cipher` or irreversible cryptographic hashes.

Question 957**Topic:** User Group Hierarchical Inheritance**Type:** True/False

On Huawei NGFWs, child user groups inherit security policies and permissions assigned to their parent user groups.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Hierarchical group modeling allows child groups to inherit parent policies, simplifying multi-level departmental access management.

Question 958**Topic:** Guest Account Auto-Expiration**Type:** True/False

Guest user accounts can be configured to automatically expire and deactivate after a specific duration, such as 8 hours.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Automatic expiration ensures temporary visitor credentials do not remain valid indefinitely, closing security risks.

Question 959**Topic:** Policy Logical AND for IP and User**Type:** True/False

If a security policy rule specifies both a source IP address range and a user group, matching traffic must satisfy BOTH criteria simultaneously.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Policy conditions are evaluated using logical AND; matching packets must originate from the specified IP range AND belong to the specified user group.

Question 960**Topic:** Display Online User Command**Type:** True/False

The command `display user-manage online-user` displays active online users and their mapped IP addresses on a Huawei firewall.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. `display user-manage online-user` is the standard VRP command to view currently authenticated online users and their session bindings.

Question 961**Topic:** Authentication Domain Definition**Type:** True/False

An Authentication Domain in Huawei VRP links authentication schemes, authorization schemes, and server templates together.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Authentication Domains encapsulate complete AAA service pipelines for specific user communities.

Question 962**Topic:** Default Domain Usage**Type:** True/False

When a user logs in without typing a domain suffix (e.g., logging in simply as 'alice'), the firewall processes the login using the default domain.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Logins lacking an explicit @domain suffix are automatically routed to the designated default authentication domain.

Question 963**Topic:** Interim Accounting Purpose**Type:** True/False

Interim accounting updates are sent periodically by the NAS to verify ongoing session activity and report cumulative volume usage.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Interim accounting updates prevent orphaned sessions and provide periodic billing and bandwidth telemetry.

Question 964**Topic:** MFA Two-Factor Requirement**Type:** True/False

Multi-Factor Authentication (MFA) requires presenting two or more credentials belonging to completely independent authentication factor categories.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. True MFA mandates combining distinct categories (knowledge, possession, inherence), such as a password plus an SMS OTP or hardware token.

Question 965**Topic:** Online User Idle Timeout Aging**Type:** True/False

When an authenticated user remains idle with no active traffic for longer than the idle timeout, their entry is automatically removed from the online user table.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Idle timers flush inactive mappings to free connection resources and force re-authentication upon return.

Question 966**Topic:** HWTACACS Per-Command Authorization Capability**Type:** True/False

HWTACACS allows an enterprise to authorize or deny individual administrative CLI commands entered by an operator in real time.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Per-command authorization intercepts each typed command and queries the HWTACACS server before execution.

Question 967**Topic:** Account Lockout Brute Force Defense**Type:** True/False

Enabling account lockout policies on local user accounts protects the firewall against automated password brute-force guessing attacks.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Account lockout temporarily disables accounts after consecutive failed attempts, thwarting automated password guessing.

Question 968**Topic:** IoT Device Web Portal Authentication**Type:** True/False

Headless IoT endpoints such as network printers and CCTV cameras can easily navigate complex web portal captive login pages.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Headless devices lack web browsers and cannot complete portal logins; they require MAC Authentication Bypass (MAB) or certificate-based 802.1X.

31 Chapter 9: Fundamentals of Encryption and Decryption Technologies

Question 969**Topic:** Kerckhoffs's Principle Secrecy**Type:** True/False

Kerckhoffs's Principle states that a cryptosystem must be kept secret and proprietary to ensure maximum security.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Kerckhoffs's Principle asserts that a cryptosystem's security should rely solely on keeping the key secret, assuming the algorithm is public knowledge.

Question 970**Topic:** Symmetric Key Shared**Type:** True/False

In symmetric encryption, the sender and the receiver use the exact same secret key for both encryption and decryption.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Symmetric cryptography is defined by the use of an identical shared secret key ($K_e = K_d$) for both operations.

Question 971**Topic:** Symmetric Speed Advantage**Type:** True/False

Symmetric encryption algorithms are generally much faster and less computationally intensive than asymmetric encryption algorithms.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Symmetric algorithms rely on fast hardware-friendly bitwise operations, making them orders of magnitude faster than asymmetric algorithms.

Question 972**Topic:** DES 56-Bit Key Insecurity**Type:** True/False

The effective key length of DES is 56 bits, which is considered cryptographically insecure today due to brute-force vulnerability.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. A 56-bit key can be exhaustively brute-forced in hours with modern hardware, rendering single DES obsolete.

Question 973**Topic:** AES 128-Bit Block Size**Type:** True/False

The block size of the AES algorithm is fixed at 128 bits, regardless of whether a 128-bit, 192-bit, or 256-bit key is used.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Under FIPS 197, AES has a fixed block size of 128 bits across all supported key lengths (128, 192, 256 bits).

Question 974**Topic:** Asymmetric Key Pair Roles**Type:** True/False

In asymmetric cryptography, a message encrypted with an entity's Public Key can only be decrypted by the matching Private Key.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. The mathematical relationship ensures that data encrypted with the public key can be decrypted exclusively by the corresponding private key.

Question 975

Topic: Asymmetric Key Count Formula

Type: True/False

A network of 100 users utilizing asymmetric cryptography requires $100 * 99 / 2 = 4,950$ total keys across the system.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Asymmetric systems require $2N$ keys (one public and one private key per user), totaling $2 \times 100 = 200$ keys. $N(N-1)/2$ applies to symmetric ciphers.

Question 976

Topic: Diffie-Hellman Direct Encryption

Type: True/False

The Diffie-Hellman algorithm can be used directly to encrypt large database files and generate digital signatures.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Diffie-Hellman is strictly a key agreement protocol; it cannot directly encrypt data or produce digital signatures.

Question 977

Topic: Diffie-Hellman MitM Risk

Type: True/False

Unauthenticated Diffie-Hellman key exchange is vulnerable to Man-in-the-Middle (MitM) attacks.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Without authentication (via pre-shared keys or digital certificates), an attacker can intercept and establish separate keys with both endpoints.

Question 978

Topic: Hash Reversibility

Type: True/False

A cryptographic hash function can be easily inverted using a private key to recover the original plaintext message.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Hash functions are strictly one-way mathematical reductions; they do not have keys and cannot be inverted to recover original data.

Question 979**Topic:** Avalanche Effect Bit Change**Type:** True/False

The avalanche effect ensures that changing a single bit in the input message completely alters the resulting hash digest.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. The avalanche effect guarantees that small input changes produce radical, unpredictable changes across the entire output digest.

Question 980**Topic:** MD5 Collision Vulnerability**Type:** True/False

MD5 is still recommended for generating secure digital signatures because no collisions have ever been found in MD5.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. MD5 has been completely broken by practical collision attacks and is strictly deprecated for digital signatures and security certificates.

Question 981**Topic:** SHA-256 Digest Length**Type:** True/False

The SHA-256 hash algorithm produces a fixed-length output digest of 256 bits.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. SHA-256 (part of the SHA-2 family) consistently outputs a 256-bit (32-byte) digest.

Question 982**Topic:** HMAC Shared Key Authentication**Type:** True/False

An HMAC provides data integrity AND origin authentication because only parties possessing the shared secret key can generate a valid MAC.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. By combining a shared key with a hash function, HMAC confirms that data was not altered and was generated by a holder of the secret key.

Question 983**Topic:** Digital Signature Signing Key Check**Type:** True/False

A digital signature is created by encrypting the message hash using the RECIPIENT'S public key.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. A digital signature is generated by encrypting the hash with the SENDER'S private key, proving the sender's identity.

Question 984

Topic: Digital Signature Verification Key Check

Type: True/False

A recipient verifies a digital signature using the SENDER'S public key.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. The sender's public key decrypts the signature to extract the original digest for comparison against the newly computed hash.

Question 985

Topic: Digital Signature Confidentiality

Type: True/False

Digitally signing an email ensures that unauthorized eavesdroppers cannot read the plaintext content of the email.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. A digital signature provides authenticity and integrity, not confidentiality. Plaintext remains readable unless separate encryption is applied.

Question 986

Topic: Non-Repudiation Sender Denial

Type: True/False

Non-repudiation prevents the sender of a signed document from falsely denying that they created and transmitted the document.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Because only the sender possesses their unique private key, a valid digital signature provides indisputable proof of authorship.

Question 987

Topic: Hybrid Cryptosystem Performance

Type: True/False

Hybrid cryptosystems use asymmetric ciphers for secure key exchange and symmetric ciphers for high-speed bulk data encryption.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Hybrid architectures leverage asymmetric algorithms for key distribution and fast symmetric ciphers for line-rate data encryption.

Question 988**Topic:** Symmetric Cipher Non-Repudiation**Type:** True/False

Symmetric key encryption alone provides legal non-repudiation because the key is secret.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Because both sender and receiver share the identical symmetric key, either party could have created the ciphertext, failing non-repudiation.

Question 989**Topic:** ECC Key Length Efficiency**Type:** True/False

A 256-bit ECC key provides cryptographic strength roughly comparable to a 3072-bit RSA key.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Elliptic Curve Cryptography provides equivalent security with dramatically shorter key lengths than RSA.

Question 990**Topic:** Block Cipher ECB Mode Security**Type:** True/False

Electronic Codebook (ECB) mode is considered secure for encrypting complex images because it hides all visual patterns.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. ECB encrypts identical plaintext blocks into identical ciphertext blocks, preserving visual patterns and structural data, making it insecure.

Question 991**Topic:** CBC Mode IV Requirement**Type:** True/False

Cipher Block Chaining (CBC) mode requires an Initialization Vector (IV) to ensure identical plaintext blocks produce different ciphertext blocks.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. An IV randomizes the initial block, ensuring that identical plaintexts yield completely different ciphertexts.

Question 992**Topic:** RC4 Stream Cipher Deprecation**Type:** True/False

RC4 is officially deprecated across modern security standards due to discovered vulnerabilities and keystream biases.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. RC4 is prohibited by IETF RFCs and modern TLS specifications due to statistical biases and plaintext recovery attacks.

Question 993

Topic: Salted Hash Password Storage

Type: True/False

Adding a unique cryptographic 'salt' to passwords before hashing prevents attackers from using precomputed rainbow tables to crack passwords.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Salting introduces unique random strings per user, invalidating precomputed rainbow tables and forcing attackers to brute-force each password individually.

32 Chapter 10: PKI Certificate System

Question 994

Topic: PKI Public Key Binding

Type: True/False

A primary function of PKI is to securely bind an identity (Subject) to its public key using a digitally signed certificate.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. PKI establishes identity verification by linking public keys to verified entities through signed X.509 certificates.

Question 995

Topic: Private Key in Certificate

Type: True/False

An X.509 digital certificate contains both the subject's Public Key and their secret Private Key.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. A digital certificate contains ONLY the Public Key. The Private Key must remain strictly confidential and is never stored in a certificate.

Question 996

Topic: CA Signs with Private Key

Type: True/False

A Certificate Authority signs issued digital certificates using its own CA Private Key.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. The CA uses its private key to generate the digital signature on certificates, which clients verify using the CA's public key.

Question 997

Topic: Registration Authority Signing

Type: True/False

A Registration Authority (RA) is responsible for signing certificates with its own root private key.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. The RA verifies applicant identities and approves requests; the Certificate Authority (CA) signs and issues certificates.

Question 998

Topic: X.509 Serial Number Uniqueness

Type: True/False

Under the X.509 standard, a CA must assign a unique serial number to every certificate it issues.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. RFC 5280 requires that each certificate issued by a CA possess a unique positive serial number within that CA's domain.

Question 999

Topic: Certificate Lifespan Validity

Type: True/False

A certificate is considered valid only when the current system time falls between its **Not Before** and **Not After** timestamps.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Certificates are valid strictly within the designated validity period; before **Not Before** or after **Not After**, validation fails.

Question 1000

Topic: Basic Constraints CA Flag

Type: True/False

The Basic Constraints extension in an end-entity server certificate typically has **cA = TRUE**.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. End-entity certificates have **cA = FALSE** (not a CA). Only Root and Intermediate CAs have **cA = TRUE** allowing them to sign other certificates.

Question 1001

Topic: SAN Multi-Domain Support

Type: True/False

The Subject Alternative Name (SAN) extension allows a single certificate to protect multiple distinct domain names and IP addresses.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. SAN binds multiple hostnames, subdomains, and IP addresses to a single certificate.

Question 1002

Topic: CRL Periodic Publishing

Type: True/False

A Certificate Revocation List (CRL) is published periodically by the CA to list certificates that have been revoked before expiration.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. CRLs are signed lists published at regular intervals cataloging serial numbers of revoked certificates.

Question 1003

Topic: OCSP Real-Time Query

Type: True/False

OCSP provides real-time certificate status checks by sending a lightweight query to an OCSP responder for a specific certificate serial number.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. OCSP queries verify status on the fly with tiny packets, eliminating large CRL download overhead.

Question 1004

Topic: OCSP Stapling Server Role

Type: True/False

In OCSP Stapling, the web server queries the OCSP responder and attaches the signed OCSP response directly into the TLS handshake.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. OCSP stapling delivers a cached, signed OCSP response from the server during the handshake, improving client speed and privacy.

Question 1005

Topic: Root CA Self-Signed Anchor

Type: True/False

A Root CA certificate is self-signed, meaning its Issuer field is identical to its Subject field.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Root CAs are self-signed trust anchors where Issuer and Subject distinguished names match.

Question 1006**Topic:** Intermediate CA Offline Requirement**Type:** True/False

Best security practice mandates keeping Intermediate CAs offline in an air-gapped vault while the Root CA is online 24/7.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. The Root CA is kept offline for maximum security, while Intermediate CAs remain online to handle routine certificate issuance.

Question 1007**Topic:** Certificate Chain Verification Top-Down**Type:** True/False

Clients verify certificate chains by establishing mathematical trust links from the server certificate up to a trusted Root CA anchor.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Path validation verifies digital signatures sequentially up the chain to a pre-installed trusted root anchor.

Question 1008**Topic:** Private Key Compromise Revocation**Type:** True/False

If a server's private key is stolen, the administrator must immediately request certificate revocation from the CA.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Private key theft compromises data confidentiality and authentication; immediate revocation prevents impersonation.

Question 1009**Topic:** CSR Private Key Cleartext**Type:** True/False

A Certificate Signing Request (CSR) file sent to a commercial CA contains the applicant's unencrypted private key.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. A CSR contains the public key and subject details, signed by the private key as proof of possession. Private keys are NEVER transmitted in a CSR!

Question 1010**Topic:** PKCS#12 Encrypted Container**Type:** True/False

A PKCS#12 file (.pfx or .p12) can package a private key and its corresponding digital certificate inside a password-protected archive.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. PKCS#12 archives bundle certificates and private keys securely using symmetric password encryption.

Question 1011**Topic:** PEM ASCII Base64 Encoding**Type:** True/False

PEM format certificates are Base64-encoded ASCII text files framed by ---BEGIN CERTIFICATE--- headers.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. PEM is a standardized ASCII Base64 encoding format widely used across open systems.

Question 1012**Topic:** Key Usage Digital Signature**Type:** True/False

The Key Usage extension can restrict a public key to digital signatures only, prohibiting it from being used for key encipherment.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Key Usage enforces least privilege for cryptographic keys, separating signing capabilities from encryption capabilities.

Question 1013**Topic:** CDP Extension URI**Type:** True/False

The CRL Distribution Points (CDP) extension provides URIs where clients can download updated CRLs.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. The CDP extension guides client software to HTTP or LDAP locations where the issuing CA publishes CRLs.

Question 1014**Topic:** AIA Missing Intermediate Fetching**Type:** True/False

The AIA extension enables validating clients to automatically download missing intermediate CA certificates from specified URLs.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. AIA provides pointers to issuing CA certificates, allowing clients to reconstruct incomplete certificate chains.

Question 1015

Topic: Expired Certificate Warning

Type: True/False

Web browsers ignore certificate expiration dates if the website's domain name matches the certificate Subject CN.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Browsers enforce strict validity checks; an expired certificate triggers immediate security warning pages regardless of domain match.

Question 1016

Topic: Wildcard Certificate Subdomain Matching

Type: True/False

A wildcard certificate issued for *.example.com automatically protects multi-level subdomains like dev.mail.example.com.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Standard wildcard certificates protect only a single subdomain level (e.g. mail.example.com), not nested multi-level subdomains (dev.mail.example.com).

Question 1017

Topic: Cross-Certification Mutual Trust

Type: True/False

Cross-certification enables two separate PKI hierarchies to trust each other's certificates without creating a new shared Root CA.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Mutual cross-certification creates trust bridges between distinct organizations' existing PKI domains.

Question 1018

Topic: Hardware Security Module (HSM) Key Export

Type: True/False

A certified Hardware Security Module (HSM) allows anyone on the local network to export CA root private keys in cleartext.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. HSMs enforce physical tamper resistance and strictly prevent private keys from being extracted in cleartext.

33 Chapter 11: Encryption Technology Applications (IPsec & SSL VPN)

Question 1019

Topic: VPN Public Infrastructure

Type: True/False

A Virtual Private Network (VPN) builds a logical private network on top of a shared public network infrastructure.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. VPN leverages public shared transmission networks (such as the Internet) to establish logically isolated, private, and encrypted communication tunnels.

Question 1020

Topic: GRE Encryption Capability

Type: True/False

Standard Generic Routing Encapsulation (GRE) natively provides strong AES-256 encryption to protect payload data.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Standard GRE provides no native encryption or integrity protection whatsoever. All passenger data inside standard GRE tunnels is transmitted in cleartext.

Question 1021

Topic: GRE Multicast Support

Type: True/False

GRE tunnels support encapsulating multicast and broadcast packets, enabling dynamic routing protocols like OSPF to establish neighbor relationships across the tunnel.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Unlike raw IPsec tunnels, GRE can encapsulate broadcast, multicast, and non-IP protocols, making it suitable for running dynamic routing protocols over WAN links.

Question 1022

Topic: AH Header Encryption

Type: True/False

The Authentication Header (AH) protocol encrypts the packet payload so that unauthorized eavesdroppers cannot inspect the data.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. AH does not provide any encryption (confidentiality). Its function is strictly limited to data origin authentication, data integrity verification (via ICV), and anti-replay protection.

Question 1023**Topic:** AH and NAT Conflict**Type:** True/False

Deploying the AH protocol across a Network Address Translation (NAT) router will result in packet drop because NAT modifies the IP header, causing ICV integrity check failure at the receiver.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. AH computes its ICV over the immutable fields of the IP header. When NAT translates IP addresses, the header changes, causing the receiver's ICV verification to fail and drop the packet.

Question 1024**Topic:** ESP Header Encryption**Type:** True/False

The ESP protocol can encrypt user data and optionally authenticate both the payload and the outer IP header.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. ESP encrypts the payload and can authenticate the payload and ESP header, but ESP NEVER authenticates the outer IP header. Authenticating the outer IP header is an AH feature.

Question 1025**Topic:** IPsec Transport Mode Outer Header**Type:** True/False

In IPsec Transport Mode, the gateway generates and prepends a new outer IP header in front of the AH or ESP header.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Transport mode does NOT add a new IP header; it keeps the original IP header and inserts the AH/ESP header between the IP header and the transport payload.

Question 1026**Topic:** IPsec Tunnel Mode Scope**Type:** True/False

In IPsec Tunnel Mode, the entire original IP packet, including its original IP header and payload, is encapsulated and protected.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Tunnel mode encapsulates the complete original IP packet inside an AH/ESP header and prepends a brand-new outer IP header for routing across the intermediate transit network.

Question 1027**Topic:** IPsec SA Directionality**Type:** True/False

An IPsec Security Association (SA) is bidirectional, meaning a single SA handles both inbound and outbound traffic between two peers.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. IPsec SAs are strictly unidirectional (simplex). Bidirectional communication requires at least two distinct SAs: one inbound and one outbound.

Question 1028**Topic:** SPI Uniqueness**Type:** True/False

The Security Parameter Index (SPI) is a 32-bit identifier in the AH/ESP header that helps the receiver identify the appropriate inbound Security Association.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. The SPI, combined with the destination IP address and security protocol (AH/ESP), uniquely indexes the exact inbound SA in the receiver's Security Association Database (SADB).

Question 1029**Topic:** IKE Port Number**Type:** True/False

The Internet Key Exchange (IKE) protocol negotiates Security Associations over UDP port 500 by default.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. IKE uses UDP port 500 for standard message negotiations. (It switches to UDP port 4500 when NAT Traversal is engaged).

Question 1030**Topic:** IKEv1 Phase Count**Type:** True/False

IKEv1 negotiation is divided into two distinct phases: Phase 1 establishes the IKE SA, and Phase 2 establishes the IPsec SAs.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. IKEv1 strictly divides negotiation into Phase 1 (establishing a secure IKE SA control channel) and Phase 2 (negotiating the actual data-protecting IPsec SAs via Quick Mode).

Question 1031**Topic:** IKEv1 Main Mode Packet Total**Type:** True/False

IKEv1 Phase 1 Main Mode exchanges exactly four packets to complete negotiation.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. IKEv1 Phase 1 Main Mode strictly requires 6 packets (3 pairs of request/response messages) to negotiate proposals, perform DH exchange, and verify encrypted identities.

Question 1032**Topic:** IKEv1 Main Mode Identity Privacy**Type:** True/False

In IKEv1 Main Mode, peer identity information is protected by encryption during transmission.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. In Main Mode, identity information is exchanged in messages 5 and 6, which are encrypted using the session key derived during messages 3 and 4.

Question 1033**Topic:** IKEv1 Aggressive Mode Packet Total**Type:** True/False

IKEv1 Phase 1 Aggressive Mode completes its negotiation using only three packets.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Aggressive Mode completes Phase 1 in 3 messages: Message 1 (initiator to responder), Message 2 (responder to initiator), and Message 3 (initiator confirmation).

Question 1034**Topic:** IKEv1 Aggressive Mode Privacy**Type:** True/False

IKEv1 Aggressive Mode encrypts the peer identity information in the first message.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. In Aggressive Mode, peer identities are sent in cleartext in the first two messages because the shared secret has not yet been computed.

Question 1035**Topic:** IKEv1 Quick Mode Function**Type:** True/False

IKEv1 Phase 2 Quick Mode is used to negotiate IPsec SAs and user data encryption parameters under the protection of the Phase 1 IKE SA.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Quick Mode operates inside the encrypted Phase 1 tunnel to negotiate IPsec SAs, proxy IDs (ACLs), and session keys for user data protection.

Question 1036

Topic: Perfect Forward Secrecy Benefit

Type: True/False

Perfect Forward Secrecy (PFS) ensures that if an attacker compromises an IKE Phase 1 key in the future, past and future IPsec Phase 2 session keys cannot be decrypted.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. PFS forces an independent Diffie-Hellman exchange during Phase 2 Quick Mode, breaking the mathematical link between Phase 1 keys and Phase 2 data keys.

Question 1037

Topic: IKEv2 Packet Efficiency

Type: True/False

IKEv2 requires only 4 messages in its initial exchange to establish both the IKE SA and the initial IPsec Child SA.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. IKEv2 consolidates Phase 1 and Phase 2 into two 2-message exchanges: IKE_SA_INIT (negotiating IKE SA) and IKE_AUTH (authenticating identity and creating the first Child SA).

Question 1038

Topic: IKEv2 Main and Aggressive Modes

Type: True/False

IKEv2 retains the separate Main Mode and Aggressive Mode negotiation options from IKEv1.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. IKEv2 completely eliminated the confusing distinction between Main Mode and Aggressive Mode, replacing them with a unified initial exchange.

Question 1039

Topic: NAT-T UDP Port 4500

Type: True/False

When NAT Traversal (NAT-T) is active, ESP packets are encapsulated within UDP packets using destination port 4500.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. NAT-T wraps ESP packets in a UDP header using port 4500, enabling stateful PAT routers to translate and track the session using UDP port mappings.

Question 1040**Topic:** Dead Peer Detection Keepalives**Type:** True/False

Dead Peer Detection (DPD) sends keepalive probes to confirm the operational status of the remote IPsec gateway.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. DPD actively monitors the responsiveness of the peer gateway, cleaning up stale SAs and initiating failover if the remote peer stops responding.

Question 1041**Topic:** L2TP Native Encryption**Type:** True/False

L2TP protocol natively includes strong symmetric data encryption algorithms such as 3DES and AES.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. L2TP only provides Layer 2 frame tunneling and user authentication; it has no native encryption. Data confidentiality must be provided by pairing it with IPsec (L2TP over IPsec).

Question 1042**Topic:** SSL VPN Port Traversal**Type:** True/False

SSL VPN primarily operates over TCP port 443 (HTTPS), allowing it to easily pass through most corporate firewalls and NAT gateways without modifying port forwarding rules.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Because HTTPS (TCP 443) is almost universally permitted through enterprise firewalls and proxy servers, SSL VPN traffic traverses intermediate networks with minimal friction.

Question 1043**Topic:** SSL VPN Web Proxy Client Requirement**Type:** True/False

The SSL VPN Web Proxy service requires users to install a dedicated software client with administrator privileges on their local computers.

- A. True
- B. False

Correct Answer: B (False)

Concept & Rationale: False. Web Proxy is clientless; remote users access internal web servers entirely through standard web browsers without installing local software or needing administrator privileges.

Question 1044**Topic:** SSL VPN File Sharing Protocols**Type:** True/False

The SSL VPN File Sharing service enables users to access SMB/CIFS and NFS shares via a web browser interface.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. The USG firewall converts browser requests into internal SMB/CIFS or NFS file transactions, displaying files and folders directly in the user's web browser.

Question 1045**Topic:** SSL VPN Port Forwarding Scope**Type:** True/False

The SSL VPN Port Forwarding service is designed to forward static, TCP-based enterprise applications such as Telnet, SSH, and RDP.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Port Forwarding intercepts and forwards connections for preconfigured TCP client-server applications via local port listening.

Question 1046**Topic:** SSL VPN Network Extension IP Assignment**Type:** True/False

In SSL VPN Network Extension mode, the remote client receives a virtual IP address from a private address pool configured on the SSL VPN virtual gateway.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Network Extension operates at Layer 3, installing a virtual NIC and leasing an internal private IP address to the remote endpoint to enable full intranet routing.

Question 1047**Topic:** SSL VPN Split Tunneling Bandwidth**Type:** True/False

Split Tunnel mode in SSL VPN Network Extension sends only enterprise-bound intranet traffic through the VPN tunnel, conserving corporate gateway bandwidth.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Under Split Tunneling, only packets destined for corporate subnets traverse the SSL VPN tunnel; regular Internet traffic exits directly via the user's local ISP connection.

Question 1048**Topic:** SSL VPN Full Tunnel Security**Type:** True/False

Full Tunnel mode in SSL VPN Network Extension forces all user network traffic, including public Internet browsing, through the enterprise SSL VPN gateway.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Full Tunneling ensures all outbound traffic passes through corporate firewalls for unified security inspection, DLP auditing, and content filtering.

Question 1049**Topic:** SSL VPN Virtual Gateway Multi-Tenancy**Type:** True/False

A single Huawei USG physical firewall can be partitioned into multiple independent SSL VPN Virtual Gateways to serve distinct user groups or tenant organizations.

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. Huawei USG firewalls support virtual gateways, allowing multiple isolated virtual VPN instances on a single physical appliance with independent branding, user bases, and security policies.

Question 1050**Topic:** GRE over IPsec Multicast Routing**Type:** True/False

GRE over IPsec combines the routing flexibility of GRE (multicast and dynamic routing support) with the security features of IPsec (encryption and authentication).

- A. True
- B. False

Correct Answer: A (True)

Concept & Rationale: True. GRE over IPsec encapsulates multicast/dynamic routing traffic inside GRE, which is then encrypted by IPsec, achieving both routing capability and high-grade data protection.

PART IV

Complete Answer Key & Quick Reference

Master Examination Answer Key Matrices

Use these high-density reference matrices to rapidly cross-check your mock exam responses and verify test scores.

Part 1: Single Choice Answers (Q1 – Q420)

Q#	Ans	Q#	Ans	Q#	Ans	Q#	Ans	Q#	Ans
1	B	2	B	3	C	4	B	5	B
6	C	7	B	8	B	9	C	10	B
11	D	12	B	13	B	14	B	15	B
16	B	17	C	18	B	19	B	20	D
21	A	22	B	23	B	24	B	25	C
26	B	27	B	28	B	29	B	30	A
31	C	32	B	33	B	34	A	35	B
36	A	37	C	38	C	39	C	40	B
41	B	42	B	43	C	44	B	45	C
46	B	47	B	48	B	49	B	50	B
51	C	52	B	53	B	54	B	55	B
56	B	57	B	58	B	59	B	60	B
61	B	62	C	63	B	64	B	65	C
66	B	67	B	68	A	69	B	70	B
71	B	72	B	73	A	74	B	75	B
76	B	77	A	78	A	79	B	80	B
81	B	82	B	83	A	84	B	85	B
86	B	87	B	88	B	89	B	90	B
91	B	92	B	93	B	94	B	95	B
96	B	97	B	98	B	99	B	100	A
101	B	102	B	103	B	104	B	105	B
106	B	107	B	108	B	109	B	110	B
111	B	112	B	113	B	114	B	115	B
116	B	117	D	118	C	119	B	120	A
121	B	122	B	123	B	124	A	125	B
126	B	127	A	128	B	129	B	130	B
131	B	132	B	133	B	134	B	135	B
136	B	137	C	138	B	139	B	140	B
141	B	142	B	143	B	144	B	145	B
146	A	147	B	148	B	149	B	150	A
151	B	152	A	153	B	154	A	155	A
156	B	157	B	158	B	159	A	160	B
161	B	162	B	163	B	164	B	165	B
166	C	167	A	168	A	169	B	170	A
171	A	172	A	173	B	174	B	175	A
176	B	177	B	178	A	179	A	180	A
181	A	182	B	183	A	184	B	185	A
186	B	187	B	188	B	189	B	190	B
191	B	192	A	193	A	194	A	195	B
196	A	197	A	198	A	199	C	200	B
201	B	202	C	203	B	204	C	205	B

Q#	Ans	Q#	Ans	Q#	Ans	Q#	Ans	Q#	Ans
206	B	207	A	208	D	209	B	210	A
211	B	212	B	213	B	214	B	215	B
216	A	217	B	218	B	219	A	220	A
221	A	222	B	223	A	224	A	225	B
226	B	227	A	228	A	229	B	230	B
231	B	232	B	233	A	234	B	235	B
236	B	237	B	238	B	239	A	240	B
241	B	242	B	243	B	244	A	245	B
246	B	247	B	248	B	249	A	250	B
251	B	252	B	253	B	254	B	255	B
256	B	257	A	258	B	259	B	260	B
261	A	262	A	263	B	264	B	265	B
266	B	267	A	268	B	269	A	270	A
271	A	272	A	273	B	274	B	275	B
276	B	277	C	278	A	279	B	280	B
281	B	282	B	283	B	284	A	285	B
286	B	287	A	288	B	289	B	290	B
291	B	292	B	293	B	294	A	295	B
296	A	297	A	298	B	299	B	300	A
301	A	302	B	303	B	304	B	305	B
306	B	307	B	308	A	309	B	310	A
311	B	312	A	313	B	314	B	315	B
316	C	317	B	318	B	319	B	320	C
321	C	322	B	323	B	324	B	325	D
326	B	327	B	328	B	329	B	330	A
331	B	332	B	333	C	334	B	335	B
336	B	337	B	338	C	339	B	340	B
341	B	342	B	343	B	344	B	345	B
346	B	347	B	348	B	349	B	350	B
351	B	352	C	353	B	354	B	355	B
356	B	357	B	358	A	359	B	360	D
361	B	362	B	363	B	364	A	365	B
366	B	367	A	368	D	369	B	370	B
371	A	372	B	373	B	374	A	375	B
376	B	377	B	378	B	379	B	380	A
381	B	382	B	383	B	384	B	385	C
386	B	387	B	388	B	389	B	390	B
391	B	392	B	393	B	394	B	395	B
396	B	397	B	398	B	399	B	400	B
401	B	402	D	403	C	404	A	405	B
406	B	407	C	408	B	409	B	410	C
411	B	412	B	413	B	414	B	415	B
416	B	417	A	418	B	419	D	420	B

Part 2: Multiple Choice Answers (Q421 – Q740)

Q#	Ans	Q#	Ans	Q#	Ans	Q#	Ans	Q#	Ans
421	ABC	422	AB	423	ABC	424	ABC	425	ABD
426	ABCDE	427	ABCD	428	ABCDE	429	ABCD	430	ABCD
431	ABC	432	ABC	433	ABCD	434	ABCD	435	ABC
436	ABCD	437	ABCD	438	ABC	439	ABC	440	ABCD
441	ABCD	442	ABCD	443	ABCD	444	ABC	445	AB
446	ABC	447	ABCD	448	ABCD	449	ABCD	450	ABC
451	ABCD	452	ABCD	453	ACD	454	ABCD	455	ABCD
456	ABCDE	457	AB	458	ABCD	459	ABC	460	ABC
461	ABCD	462	ABCD	463	ABCD	464	ABCD	465	ABCDE
466	ABCD	467	ABCD	468	ABCD	469	ABC	470	AB
471	ABCD	472	ABC	473	ABCDE	474	ABCD	475	AB
476	ABC	477	ABC	478	ABC	479	ABCDE	480	ABC
481	ABCD	482	ABC	483	ABCD	484	ABC	485	ABCD
486	ABCD	487	ABC	488	ABCD	489	ABCD	490	ABC
491	ABC	492	ABCD	493	ABCDE	494	ABCD	495	ABCD
496	ABCD	497	ABCD	498	ABCD	499	ABC	500	ABC
501	ABCD	502	ABCD	503	ABC	504	ABC	505	ABC
506	ABC	507	ABC	508	AB	509	ABCD	510	ABCDEF
511	ABCD	512	ABCDE	513	ABCD	514	ABCD	515	AB
516	ABCD	517	ABCD	518	ABCD	519	ABCDE	520	ABCD
521	ABC	522	ABC	523	ABCD	524	ABCD	525	AB
526	ABCD	527	ABCDE	528	ABCD	529	ABC	530	ABC
531	ABCD	532	ABCD	533	ABC	534	ABC	535	ABC
536	ABC	537	ABC	538	ABC	539	ABCD	540	ABC
541	ABCDE	542	ABCD	543	ABCDE	544	ABC	545	ABC
546	ABC	547	ABC	548	AB	549	ABC	550	ABC
551	ABC	552	ABC	553	ABC	554	ABC	555	ABC
556	ABCD	557	ABCD	558	ABC	559	ABC	560	ABC
561	AB	562	ABC	563	ABC	564	ABC	565	AB
566	ABC	567	AB	568	AB	569	ABC	570	AB
571	ABCD	572	ABC	573	AB	574	ABCD	575	ABC
576	ABC	577	ABC	578	ABCD	579	AB	580	ABCD
581	ABCD	582	ABC	583	ABCD	584	ABCDE	585	ABCD
586	ABC	587	ABC	588	ABC	589	ABCD	590	ABC
591	ABC	592	AB	593	ABC	594	ABC	595	ABC
596	ABCD	597	AB	598	ABCD	599	AB	600	ABC
601	ABC	602	ABC	603	AB	604	ABC	605	AB
606	ABCDE	607	ABCD	608	ABCD	609	ABCD	610	ABC
611	ABC	612	ABC	613	ABC	614	ABCD	615	ABC
616	ABC	617	ABC	618	ABC	619	ABC	620	ABCD
621	ABC	622	ABC	623	ABC	624	ABC	625	ABC
626	ABCD	627	ABCD	628	ABCDE	629	AB	630	ABCD
631	ABC	632	ABC	633	ABC	634	ABCD	635	ABC
636	ABC	637	ABC	638	ABCD	639	ABCDE	640	ABC
641	ABCD	642	ABC	643	ABCDE	644	ABC	645	ABCD
646	ABCD	647	ABCD	648	ABCD	649	ABCD	650	ABCD
651	ABCD	652	ABCD	653	ABCD	654	ABCD	655	ABCD
656	AB	657	ABC	658	ABCD	659	ABCD	660	ABC
661	ABCD	662	ABCD	663	ABCD	664	ABC	665	ABCD
666	ABCD	667	ABCD	668	ABCD	669	ABCD	670	ABC
671	ABC	672	ABC	673	ABC	674	ABC	675	ABCD
676	ABCD	677	ABC	678	ABCD	679	AB	680	ABC
681	ABC	682	ABC	683	ABC	684	ABCD	685	ABCDE
686	ABCDEFG	687	ABCDE	688	AB	689	ABC	690	ABC
691	ABCD	692	ABCDE	693	ABCDE	694	ABCD	695	ABCDE
696	ABC	697	ABC	698	ABCD	699	ABC	700	ABC
701	ABCD	702	ABC	703	ABCD	704	ABC	705	ABC
706	ABCD	707	ABC	708	AB	709	ABC	710	ABC
711	ABC	712	ABC	713	ABCD	714	ABC	715	ABCDE
716	ABCD	717	ABCD	718	AB	719	ABCD	720	ABD

Q#	Ans	Q#	Ans	Q#	Ans	Q#	Ans	Q#	Ans
721	ABC	722	AB	723	ABC	724	AB	725	ABCD
726	ABC	727	ABD	728	ABCD	729	ABC	730	ABC
731	ABD	732	ABCD	733	ABC	734	ABD	735	ABC
736	ABC	737	ABCD	738	ABC	739	ABC	740	ABC

Part 3: True / False Answers (Q741 – Q1050)

Q#	Ans	Q#	Ans	Q#	Ans	Q#	Ans	Q#	Ans
741	False	742	True	743	True	744	False	745	False
746	False	747	False	748	False	749	True	750	True
751	False	752	True	753	False	754	True	755	False
756	True	757	False	758	True	759	False	760	False
761	False	762	False	763	True	764	True	765	True
766	True	767	False	768	True	769	True	770	False
771	False	772	False	773	False	774	True	775	True
776	False	777	True	778	True	779	False	780	True
781	False	782	False	783	False	784	True	785	True
786	True	787	True	788	True	789	False	790	False
791	True	792	False	793	False	794	True	795	True
796	False	797	False	798	True	799	True	800	False
801	False	802	False	803	True	804	False	805	False
806	True	807	False	808	True	809	True	810	False
811	False	812	True	813	False	814	False	815	True
816	False	817	False	818	True	819	False	820	True
821	False	822	True	823	True	824	False	825	True
826	False	827	True	828	False	829	False	830	True
831	False	832	False	833	True	834	True	835	True
836	False	837	True	838	False	839	False	840	True
841	False	842	True	843	False	844	True	845	True
846	False	847	True	848	True	849	False	850	True
851	True	852	True	853	False	854	True	855	False
856	True	857	False	858	True	859	True	860	True
861	True	862	True	863	True	864	True	865	True
866	True	867	False	868	False	869	False	870	True
871	True	872	False	873	True	874	True	875	True
876	False	877	False	878	True	879	True	880	True
881	True	882	True	883	False	884	True	885	True
886	True	887	False	888	True	889	False	890	True
891	True	892	True	893	True	894	True	895	True
896	True	897	False	898	True	899	True	900	True
901	False	902	True	903	True	904	True	905	True
906	False	907	False	908	True	909	True	910	True
911	True	912	True	913	False	914	True	915	False
916	True	917	True	918	True	919	True	920	False
921	True	922	True	923	True	924	True	925	True
926	True	927	True	928	True	929	True	930	True
931	True	932	True	933	True	934	False	935	True
936	True	937	True	938	True	939	True	940	True
941	True	942	False	943	True	944	False	945	False
946	True	947	True	948	True	949	True	950	True
951	True	952	True	953	True	954	True	955	True
956	False	957	True	958	True	959	True	960	True
961	True	962	True	963	True	964	True	965	True
966	True	967	True	968	False	969	False	970	True
971	True	972	True	973	True	974	True	975	False
976	False	977	True	978	False	979	True	980	False
981	True	982	True	983	False	984	True	985	False
986	True	987	True	988	False	989	True	990	False
991	True	992	True	993	True	994	True	995	False
996	True	997	False	998	True	999	True	1000	False
1001	True	1002	True	1003	True	1004	True	1005	True
1006	False	1007	True	1008	True	1009	False	1010	True
1011	True	1012	True	1013	True	1014	True	1015	False
1016	False	1017	True	1018	False	1019	True	1020	False
1021	True	1022	False	1023	True	1024	False	1025	False
1026	True	1027	False	1028	True	1029	True	1030	True
1031	False	1032	True	1033	True	1034	False	1035	True
1036	True	1037	True	1038	False	1039	True	1040	True

Q#	Ans	Q#	Ans	Q#	Ans	Q#	Ans	Q#	Ans
1041	False	1042	True	1043	False	1044	True	1045	True
1046	True	1047	True	1048	True	1049	True	1050	True